

ECCouncil

312-50v13

Certified Ethical Hacker Exam (CEHv13)

[Total Questions: 542]

Category Breakdown

Category	Number of Questions
Information Security and Ethical Hacking Overview	27
Reconnaissance Techniques	62
System Hacking Phases	28
Network and Perimeter Hacking	106
Security Operations and Incident Response	43
Web Application Hacking	89
Wireless Network Hacking	24
Cloud Computing	25
Malware Threats	32
Mobile Platform and IoT Hacking	20
Mobile Platform and IoT Hacking	9
Cryptography	29
Social Engineering	28
Mobile Platform, IoT, and OT Hacking	18
Mobile Platform, IoT, and OT Hacking	1
TOTAL	542

Question #:1 - [Information Security and Ethical Hacking Overview]

An ethical hacker is conducting a penetration test on a company's network with full knowledge and permission from the organization. What is this type of hacking called?

- A. Blue Hat Hacking
- B. Grey Hat Hacking
- C. Black Hat Hacking
- D. White Hat Hacking

Answer: D

Explanation

White-hat hackers perform security assessments with authorization. CEH defines ethical hacking as legal, structured testing of network defenses with the goal of improving security rather than causing harm.

Question #:2 - [Reconnaissance Techniques]

A cybersecurity analyst wants to monitor competitors' web content updates. What key element is missing from the plan?

- A. Hacking competitor databases

- B. Google Alerts for content monitoring
- C. Engaging in blog discussions
- D. Using a VPN

Answer: B

Explanation

In CEH v13 Reconnaissance Techniques, passive monitoring of competitors' online presence is a legitimate and effective intelligence-gathering activity. One of the most efficient tools for this purpose is Google Alerts.

Google Alerts allow analysts to receive automated notifications when new content containing specific keywords—such as company names, products, or executives—is indexed online. This enables continuous, passive surveillance without repeatedly visiting websites manually.

Option B directly addresses the analyst's goal of staying updated efficiently.

Option A is illegal and unethical.

Option C involves direct interaction, which may reveal the analyst's presence.

Option D provides anonymity but does not actively monitor changes.

CEH v13 strongly encourages automation in reconnaissance to reduce noise, effort, and detection risk. Therefore, Option B is the correct and CEH-aligned answer.

Question #:3 - [System Hacking Phases]

In the rainy streets of Portland, Oregon, ethical hacker Ethan Brooks delves into the security layers of ShopSwift, a US-based e-commerce platform reeling from a recent data breach. Tasked with uncovering the method behind unauthorized account takeovers, Ethan examines login patterns across the platform's user base. His investigation reveals a surge of automated login activity across multiple accounts, with a suspiciously high success rate. Determined to trace the root cause, Ethan compiles a detailed log to assist ShopSwift's security team in restoring trust.

Which attack method is Ethan most likely uncovering in ShopSwift's authentication system?

- A. Password Spraying
- B. Brute Force Attack
- C. Credential Stuffing
- D. Phishing Attacks

Answer: C

Explanation

Credential stuffing is the best match because the scenario highlights automated login attempts across many accounts with an unusually high success rate, occurring in the aftermath of a breach. In CEH-aligned system hacking concepts, credential stuffing is the automated testing of known username and password pairs—typically harvested from prior breaches—against a different service. Because many users reuse passwords across sites, attackers often achieve a higher-than-normal success rate compared to guessing-based attacks. This “high success rate” across numerous accounts is a key indicator that the attacker is not randomly guessing, but replaying valid credentials at scale using bots or automation frameworks.

Password spraying differs in that the attacker tries a small set of common passwords (or one password) across many accounts to avoid lockouts. Spraying generally yields a lower success rate and is driven by guessing rather than replaying known credential pairs. A brute force attack is even noisier and typically involves repeated guessing for a single account or small set of accounts; it is both slower and far less likely to produce a high success rate across many users in a short period. Phishing attacks can lead to account takeovers, but the pattern described would more often show targeted victims and varied sources rather than broad, automated, multi-account authentication bursts with consistently successful logins.

CEH defensive guidance emphasizes layered controls: enforce MFA, monitor for abnormal login velocity and credential reuse indicators, deploy bot detection and rate limiting, use breached-password checks, implement adaptive authentication, and tune lockout and detection policies to disrupt automated credential replay without enabling denial-of-service against legitimate users.

Question #:4 - [Network and Perimeter Hacking]

In an enterprise environment, the network security team detects unusual behavior suggesting advanced sniffing techniques exploiting legacy protocols to intercept sensitive communications. Which of the following sniffing-related techniques presents the greatest challenge to detect and neutralize, potentially compromising confidential enterprise data?

- A. Steganographic payload embedding within SMTP email headers
- B. Encrypted data extraction via HTTP header field overflows
- C. Covert data interception via X2S packet fragmentation
- D. Covert channel establishment through Modbus protocol manipulation

Answer: D

Explanation

According to the CEH Sniffing and Network Protocol Attacks module, covert channels represent one of the most sophisticated and difficult-to-detect data interception techniques. These channels hide malicious communication within legitimate protocol behavior, making them extremely challenging for traditional IDS /IPS and packet inspection tools to identify.

Industrial and legacy protocols such as Modbus, widely used in OT and legacy enterprise environments, lack encryption and authentication by design. CEH documentation highlights that attackers can manipulate unused or poorly validated Modbus fields to covertly transmit or intercept data while appearing as normal control traffic.

Option D is correct because covert channels over trusted legacy protocols blend seamlessly with legitimate traffic and bypass many security controls.

Option A is not a sniffing technique but a data-hiding method.

Option B describes exploitation, not sniffing.

Option C is a theoretical evasion method but is more detectable through reassembly.

CEH emphasizes covert channels as one of the most formidable sniffing challenges.

Question #:5 - [Security Operations and Incident Response]

On July 9, 2025, during a security penetration test at MedSecure Health in Phoenix, Arizona, the ethical hacking team evaluates the resilience of the company's patient portal system. Ethical hacker Aisha Khan initiates a controlled test that generates sustained traffic pressure against the web application servers. As system responsiveness declines, the IT operations team reallocates backend resources, suspending lower-priority modules such as system alerts and notification services, allowing high-priority functions like prescription refills and patient check-ins to remain accessible. Aisha's controlled simulation is designed to assess the IT team's ability to maintain critical functionality under partial resource exhaustion.

What DoS DDoS countermeasure strategies is Aisha's exercise primarily simulating?

- A. Degrading Services
- B. Shutting Down Services
- C. Absorbing the Attack
- D. Rate Limiting
- E. AThe behavior described aligns with the countermeasure strategy commonly referred to in CEH-aligned DoS resilience planning as service degradation or graceful degradation. Under sustained traffic pressure, the goal is not necessarily to keep every feature available, but to preserve mission-critical functions by intentionally reducing nonessential workload. In the scenario, the operations team "reallocates backend resources" and "suspends lower-priority modules" such as alerts and notifications so that essential healthcare workflows like prescription refills and patient check-ins remain operational. That is the definition of degrading services: selectively limiting functionality to maintain availability of the most important business processes during partial resource exhaustion. This differs from shutting down services, which implies taking the application or major components offline to stop damage or recover stability, typically reducing availability entirely or more broadly than what's described. It also differs from absorbing the attack, which focuses on scaling, load balancing, scrubbing, or using CDNs and DDoS protection to handle and dilute the incoming volume while keeping normal functionality as intact as possible. Rate limiting is a specific control to cap requests per client or per time window; it

may be used, but the prompt emphasizes feature prioritization and intentional suspension of lower-value modules, not throttling request rates. CEH best practices highlight that graceful degradation requires #####-defined service tiers, dependency awareness, and runbooks so teams can shed load safely without breaking core authentication, data integrity, or critical user journeys.

Answer: A B C D E

Question #:6 - [Web Application Hacking]

A Certified Ethical Hacker (CEH) is auditing a company's web server that employs virtual hosting. The server hosts multiple domains and uses a web proxy to maintain anonymity and prevent IP blocking. The CEH discovers that the server's document directory (containing critical HTML files) is named "certrcx" and stored in /admin/web. The server root (containing configuration, error, executable, and log files) is also identified. The CEH also notes that the server uses a virtual document tree for additional storage. Which action would most likely increase the security of the web server?

- A. Moving the document root directory to a different disk
- B. Regularly updating and patching the server software
- C. Changing the server's IP address regularly
- D. Implementing an open-source web server architecture such as LAMP

Answer: B

Explanation

CEH guidance for web server hardening prioritizes controls that reduce exploitable conditions across the broadest set of threats. While obscuring paths (for example, unusual directory names like "certrcx" or storing content under "/admin/web") may slightly slow down casual discovery, CEH emphasizes that security through obscurity is not a reliable control. If an attacker can identify the server root, document root, and virtual directory structure (through misconfigurations, directory listing, error leakage, backup exposure, or known-path enumeration), then the real risk becomes unpatched vulnerabilities in the web server, modules, libraries, and underlying OS.

Regularly updating and patching the server software is the most direct, high-impact countermeasure because it closes known vulnerabilities attackers routinely exploit (RCE, privilege escalation, auth bypass, path traversal, request smuggling, etc.). CEH materials also stress that virtual hosting expands the attack surface (multiple sites, shared services, shared misconfigurations), making systematic patching and configuration management even more important.

Option A (moving the document root to a different disk) may help with organization and, in some cases, recovery planning, but it does not inherently reduce vulnerabilities. Option C (changing IPs) is not a security control; it may complicate blocking lists but doesn't fix the underlying weakness. Option D (using LAMP) is an architectural choice, not a security measure by itself—an open-source stack can still be insecure if misconfigured or unpatched.

Therefore, CEH-aligned best practice is regular patching and updates.

Question #:7 - [Network and Perimeter Hacking]

During a penetration test at a telecom provider in Denver, Colorado, Maria, a senior ethical hacker, notices that her scans are immediately flagged by intrusion detection systems. She modifies her technique, and as a result, the IDS devices are unable to reassemble the packets correctly, allowing her probes to slip through without detection. Which scanning evasion technique is Maria applying in this case?

- A. Packet Fragmentation
- B. Source Routing
- C. Decoy Scanning
- D. IP Spoofing

Answer: A

Explanation

The described evasion relies on preventing the IDS from correctly reassembling packets, which points directly to packet fragmentation. In fragmentation-based evasion, the attacker breaks the probe payload into multiple IP fragments. Some IDS sensors—especially if misconfigured, overloaded, or using limited reassembly logic—may fail to fully reconstruct the original packet stream, causing the malicious or suspicious content to evade signature matching and detection. Meanwhile, the target host (or a downstream device) may correctly reassemble the fragments and process the probe normally. This mismatch between what the IDS “sees” and what the target ultimately receives is the core concept behind fragmentation evasion.

The scenario explicitly says “IDS devices are unable to reassemble the packets correctly,” which is essentially the textbook rationale for fragmentation as an IDS evasion method. Attackers may vary fragment size, overlap fragments, or manipulate offsets to stress or confuse reassembly engines. Even when modern IDS systems support reassembly, fragmentation can still be used to reduce detection reliability if sensors are under resource pressure or if traffic normalization is not enforced.

Why the other options don't match:

Source routing (B) attempts to influence the path packets take through the network; it does not inherently prevent IDS reassembly.

Decoy scanning (C) floods the target/IDS with scans from multiple spoofed addresses to obscure the true scanner source. This is about attribution noise, not packet reassembly failure.

IP spoofing (D) for scanning can disguise origin, but it does not inherently cause IDS reassembly problems.

Therefore, Maria is applying A. Packet Fragmentation.

Question #:8 - [Network and Perimeter Hacking]

A penetration tester is tasked with scanning a network protected by an IDS and firewall that actively blocks connection attempts on non-standard ports. The tester needs to gather information on the target system without triggering alarms. Which technique should the tester use to evade detection?

- A. Use a low-and-slow scan to reduce detection by the IDS
- B. Conduct a full TCP Connect scan to confirm open ports
- C. Perform a SYN flood attack to overwhelm the firewall
- D. Execute a TCP ACK scan to map firewall rules and bypass the IDS

Answer: A

Explanation

A low-and-slow scanning technique spreads probe attempts over long intervals, reducing the chance of triggering IDS signatures that rely on detecting rapid or high-volume scans. CEH highlights timing-based evasion as an effective method for reconnaissance against networks with strict perimeter controls.

Question #:9 - [Web Application Hacking]

You discover a Web API integrated with webhooks and an existing administrative web shell. Your objective is to compromise the system while leaving minimal traces. Which technique is most effective?

- A. SSRF to perform unauthorized API calls
- B. IDOR exploitation
- C. Upload malicious scripts via the web shell
- D. Manipulate the webhook for unintended data transfer

Answer: A

Explanation

Server-Side Request Forgery (SSRF) is emphasized in CEH v13 Web Application Hacking as a stealthy and powerful attack. SSRF allows attackers to make requests from the trusted server itself, bypassing firewalls, authentication, and logging controls.

Compared to web shells or webhook abuse, SSRF leaves fewer forensic artifacts and enables internal API access, metadata exposure, and lateral movement.

Question #:10 - [Web Application Hacking]

You are an ethical hacker at CyberShield Analytics, hired by Coastal Education Services, a tutoring platform in Miami, Florida, to test the security of their student portal. While probing the portal's course enrollment page, you input a crafted value into the course ID field, appending a condition that checks if the first character of the database name is a specific value. The application does not display error messages or additional data, but the page takes significantly longer to load when the condition evaluates to true, indicating a deliberate delay.

Based on the observed behavior, which SQL injection technique are you employing?

- A. Boolean exploitation
- B. Time-based blind SQL injection
- C. UNION SQL injection
- D. Error-based SQL injection

Answer: B

Explanation

The behavior described is a textbook indicator of time-based blind SQL injection. In CEH methodology for web application hacking, blind SQL injection is used when the application does not return database errors, query results, or verbose messages to the attacker. Instead of extracting data directly through displayed output, the attacker infers true or false outcomes by observing indirect side effects.

Here, the crafted input appends a conditional test about the database name's first character. When the condition is true, the page response becomes "significantly longer," which implies the injected payload triggers a database delay function or a time-consuming operation. This deliberate time difference becomes the communication channel: a longer response indicates "true," while a normal response indicates "false." By repeating such tests character-by-character, an attacker can enumerate sensitive values like database names, table names, and sometimes credentials—despite the application showing no errors or returned data.

This differs from Boolean-based blind SQL injection, where the inference is made through visible page content changes (for example, one response page looks different or contains different text when the condition is true). It also differs from UNION-based SQL injection, which relies on combining queries to return data in the application's response, and error-based SQL injection, which depends on database error messages leaking information. Because the only observable signal here is response time, CEH classifies it specifically as time-based blind SQL injection. Defensive controls include parameterized queries, input validation, least-privilege database accounts, and WAF rules to detect time-delay functions and abnormal query patterns.

Question #:11 - [Wireless Network Hacking]

In Miami, Florida, Sarah Thompson, a security analyst at Apex Cyber Defense, is tasked with monitoring the wireless infrastructure at Coastal Healthcare, a busy urban hospital. One morning, nurse Emily Carter reports that her tablet used for accessing patient records is unexpectedly connecting to an access point broadcasting a name and signal similar to the hospital's secure Wi-Fi. Upon investigation, Sarah's log analysis reveals an unauthorized device on the network capturing sensitive traffic from connected systems. Suspecting a breach, she identifies that the attacker has deployed an access point to mimic the hospital's legitimate network.

Based on this behavior, which wireless threat is the attacker executing?

- A. Misconfigured AP
- B. Rogue AP
- C. Evil Twin AP

D. Honeypot AP

Answer: C

Explanation

An Evil Twin access point is a malicious wireless access point that impersonates a legitimate Wi-Fi network by copying its SSID and often mimicking other observable characteristics such as security settings and signal behavior. In CEH-aligned wireless attack coverage, the goal is to trick users into connecting to the attacker-controlled AP instead of the real one. Once a victim device associates, the attacker can perform man in the middle interception, capture credentials, observe sensitive traffic, and potentially downgrade protections if the victim is not properly validating the network.

This scenario strongly matches an Evil Twin because the tablet connects to an access point “broadcasting a name and signal similar to the hospital’s secure Wi-Fi,” and Sarah finds an unauthorized device capturing sensitive traffic from connected systems. That combination indicates active impersonation and client deception, not merely an accidental device. A rogue AP is typically an unauthorized access point connected to the internal network, often deployed by employees for convenience, and may not be designed to impersonate the official SSID to lure clients. A misconfigured AP refers to an access point with weak settings or improper security controls, not an attacker-created clone. A honeypot AP is a deliberate decoy set up by defenders to attract attackers, which is the opposite of what is described.

Mitigations emphasized in CEH best practices include using WPA2 Enterprise or WPA3 Enterprise with certificate validation, enabling protected management frames where supported, deploying wireless intrusion detection and prevention to identify spoofed SSIDs and BSSID anomalies, disabling auto-join where possible, and training users to report suspicious network prompts or unexpected reconnect behavior.

Question #:12 - [Cloud Computing]

John, a penetration tester at a Los Angeles-based online gaming company, is analyzing the company's cloud infrastructure after a recent security breach caused unexpected downtime and delayed alerts. His investigation reveals that the attackers remained undetected, due to the absence of mechanisms that track function-level activity and capture anomalous events. The backend architecture for matchmaking and in-game purchases is serverless, increasing the importance of robust security measures.

So, which cloud computing threat should John prioritize to prevent similar breaches?

- A. Insufficient logging and monitoring
- B. Privilege escalation
- C. Loss of governance
- D. Side-channel attacks

Answer: A

Explanation

Insufficient logging and monitoring is the most direct threat highlighted by the scenario. In CEH-aligned cloud security concepts, visibility is foundational: without adequate telemetry, security teams cannot detect, investigate, or respond to malicious activity in time. The question explicitly states attackers “remained undetected” because the organization lacked mechanisms to track function-level activity and capture anomalous events. In a serverless architecture, this visibility gap can be especially damaging because there are no traditional servers for defenders to log into, and many security signals must be collected from cloud-native sources such as function invocation logs, API gateway logs, identity events, and centralized monitoring pipelines.

While privilege escalation is a common cloud threat, the question’s root cause is not described as excessive permissions or role abuse; it is the lack of detection capability. Loss of governance refers to weak policies, mismanaged accounts, and lack of control over cloud resources, which may contribute indirectly but is not the immediate failure described. Side-channel attacks are specialized and do not match the evidence of missed alerts and absent operational telemetry.

CEH guidance emphasizes implementing centralized logging, continuous monitoring, alerting, and anomaly detection as core controls. For serverless, this includes capturing detailed function execution logs, tracing, identity and access events, and integrating them into a SIEM/SOAR workflow. Effective monitoring enables rapid detection of abnormal invocation patterns, suspicious API calls, unusual data access, and persistence attempts—reducing dwell time and preventing small compromises from becoming major outages.

Question #:13 - [Malware Threats]

At a cybersecurity consultancy firm in Boston, senior analyst Amanda Liu is called in to assess a malware outbreak affecting a regional healthcare provider. Despite using updated antivirus tools, the security team notices inconsistent detection across infected endpoints. Amanda discovers that while the malicious behavior is consistent, system file tampering and suspicious outbound traffic, each malware sample has a slightly different code structure and fails traditional hash-based comparison. Static analysis reveals that the underlying logic remains unchanged, but the code patterns vary unpredictably across infections. What type of virus is most likely responsible for this behavior?

- A. Cavity virus
- B. Macro virus
- C. Polymorphic virus
- D. Stealth virus

Answer: C

Explanation

A polymorphic virus is specifically designed to change its code appearance while keeping the same underlying functionality, which aligns exactly with the scenario. In CEH terms, polymorphism allows malware to mutate its decryptor routine, instruction ordering, register usage, junk code insertion, and other syntactic elements every time it propagates or executes. This causes each instance to look different at the binary level, producing different hashes and signatures, even though the malicious payload and behavior remain the same. That is why the security team sees inconsistent antivirus detection and why “traditional hash-based comparison” fails. The key indicator is that static analysis shows the “underlying logic remains

unchanged,” but “code patterns vary unpredictably,” which is the hallmark of polymorphism: behavior stays consistent, signature changes.

The other options do not fit as well. A cavity virus typically hides by inserting itself into unused spaces within legitimate executable files to avoid changing the overall file size, but it does not inherently generate unpredictable code variants per infection. A macro virus primarily targets macro-enabled documents and spreads through document templates and user actions, which is not suggested here. A stealth virus focuses on evading detection by intercepting system calls and hiding its presence, such as returning “clean” file reads, but it does not necessarily produce many structurally different binaries that break hash matching. Therefore, the most likely cause of the described outbreak is a polymorphic virus.

Question #:14 - [Malware Threats]

You detect the presence of a kernel-level rootkit embedded deeply within an operating system. Given the critical nature of the infection, which remediation strategy should be followed to effectively remove the rootkit while minimizing long-term risk?

- A. Use specialized rootkit detection tools followed by tailored removal procedures
- B. Deploy high-interaction honeypots to observe attacker behavior
- C. Perform a complete system format and reinstall the operating system from a trusted source
- D. Immediately power down the system and disconnect it from the network

Answer: C

Explanation

The CEH Malware and Rootkit Analysis module emphasizes that kernel-level rootkits compromise the most trusted components of the operating system. Once a kernel is compromised, no tool running on that system can be fully trusted.

CEH explicitly states that the only reliable remediation for kernel-mode rootkits is:

Full system wipe

Reinstallation from a known, trusted source

Restoration of verified clean data

Option C is correct and represents CEH best practice.

Option A may work for user-mode rootkits but is unreliable for kernel-level infections.

Option B is a research tactic, not remediation.

Option D is containment, not eradication.

Question #:15 - [System Hacking Phases]

After installing a backdoor on a web server, what action best ensures it remains undetected?

- A. Embed it in a frequently updated web file
- B. Increase the backdoor code size
- C. Install it on a non-web file referenced in a URL
- D. Place it in a file type excluded from resource maps

Answer: D

Explanation

In CEH v13 Maintaining Access, stealth and persistence are key goals after compromise. Placing a backdoor in a file type excluded from resource maps (such as image metadata, configuration files, or uncommon extensions) reduces the likelihood of discovery by automated scanners and integrity checks.

Option D is correct because many security tools focus on executable or commonly accessed web files. Files excluded from resource maps are less likely to be scanned or monitored.

Option A increases detection risk due to frequent changes. Option B increases signature visibility. Option C still exposes the file to access logs and monitoring.

CEH v13 highlights that attackers often hide backdoors in non-obvious locations to avoid detection. Therefore, Option D is correct.

Question #:16 - [Mobile Platform and IoT Hacking]

Which advanced mobile attack is hardest to detect and mitigate?

- A. Mobile MitM
- B. Jailbreaking/Rooting
- C. Mobile Remote Access Trojan (RAT)
- D. Clickjacking

Answer: C

Explanation

Mobile Remote Access Trojans (RATs) are highlighted in CEH v13 Mobile Platform Hacking as one of the most dangerous threats. Once installed, a mobile RAT provides attackers persistent, covert access to devices, allowing screen capture, keystroke logging, microphone activation, and data exfiltration.

Unlike MitM or clickjacking, RATs operate post-compromise, often disguised as legitimate apps. Jailbreaking is detectable via integrity checks, but RATs can remain hidden even on non-rooted devices.

CEH v13 emphasizes that RATs bypass traditional defenses, including antivirus and MDM, making them extremely difficult to detect. Hence, Option C is correct.

Question #:17 - [Mobile Platform and IoT Hacking]

Maya Patel from SecureHorizon Consulting is investigating a breach at Dallas General Hospital in Texas after a nurse misplaced a smartphone containing patient management software. Although the device remained active on the network, administrators had no way to identify its physical whereabouts, delaying incident response and allowing sensitive medical records to be exposed for hours. Which mobile security guideline would have most directly reduced the impact of this incident?

- A. Use anti-virus and data loss prevention (DLP) solutions
- B. Utilize a secure VPN connection while accessing public Wi-Fi networks
- C. Install device tracking software that allows the device to be located remotely
- D. Register devices with a remote locate and wipe facility

Answer: D

Explanation

The most direct guideline is D. Register devices with a remote locate and wipe facility because the incident's core impact came from two factors: loss of physical control of the device and continued exposure of sensitive records while the device remained active. A remote locate-and-wipe capability (commonly delivered through Mobile Device Management (MDM) / Enterprise Mobility Management (EMM) platforms) addresses both problems immediately: it enables administrators to identify the device's last known location (or trigger location reporting) and, critically, to remotely lock or wipe the device to prevent ongoing unauthorized access to patient data.

In healthcare environments handling regulated data, the priority during a lost-device event is rapid containment. Even if device tracking alone can help find the phone, it does not guarantee that sensitive information stops being accessed during the search. Remote wipe (often paired with remote lock, enforced encryption, and policy-based access control) reduces exposure time by allowing responders to remove protected data and invalidate application access. This is particularly important when the device is still connected to the network, because an attacker (or unauthorized holder) could continue using cached sessions, stored tokens, or locally available records until access is cut off.

Why the other options are less direct: A (anti-virus/DLP) may help detect malware or control data movement, but it does not solve the immediate lost-device containment requirement. B (VPN on public Wi-Fi) is unrelated because the problem is physical loss and inability to control the endpoint. C (install tracking software) helps locate the device, but the scenario highlights that sensitive records were exposed for hours; the most direct impact reduction is achieved when the organization can both locate and wipe/lock the device through an enrolled, centrally managed capability.

Therefore, enrolling devices in a remote locate and wipe facility would have most directly reduced the breach impact.

Question #:18 - [Network and Perimeter Hacking]

In the bustling tech hub of Silicon Valley, cybersecurity investigator Elena Martinez found herself deep into a late-night investigation at Horizon Tech Solutions on July 7, 2025. The company had reported sporadic network disruptions affecting their research team's access to critical project files. Elena, working under the cover of a maintenance window from midnight to 3 AM PDT, began monitoring the internal network, focusing on a subnet reserved for the R&D department. She noticed a pattern of failed connection attempts logged just before each disruption, with multiple hosts reporting temporary IP address conflicts. Suspecting foul play, Elena deployed a discreet test to simulate an internal threat scenario. Shortly afterward, several workstations began showing unfamiliar gateway settings and redirected users to misleading login portals during routine access attempts. Despite these anomalies, no security alerts were triggered.

What type of attack technique did Elena most likely simulate?

- A. DHCP Starvation Attack
- B. Packet Sniffing
- C. MAC Flooding
- D. Rogue DHCP Server Attack

Answer: D

Explanation

A Rogue DHCP Server attack best fits the symptoms because it directly explains unexpected gateway changes, IP conflicts, and traffic redirection to deceptive portals. In CEH network attack coverage, DHCP is a foundational service that automatically provides clients with IP configuration such as IP address, subnet mask, default gateway, and DNS servers. If an attacker introduces a rogue DHCP server on the same broadcast domain, clients may accept leases from the rogue server—especially if it responds faster than the legitimate DHCP infrastructure. Once that happens, the attacker can push a malicious default gateway or DNS server to victims. This allows redirection of traffic, man-in-the-middle positioning, and phishing-style interception, which matches the “unfamiliar gateway settings” and “misleading login portals” described.

The mention of “temporary IP address conflicts” also aligns: a rogue server can hand out addresses that overlap with legitimate allocations, causing intermittent connectivity issues and failed connection attempts. While a DHCP starvation attack can create disruption by exhausting the DHCP pool, the key difference is outcome: starvation primarily denies service until a rogue server takes over. Here, the defining observable behavior is not just outage—it is misconfiguration and redirection, which points to the presence of a rogue DHCP server actively issuing malicious leases.

Packet sniffing alone would not change gateway settings, and MAC flooding is aimed at forcing switches to behave like hubs, not issuing IP configuration. Defensive controls include DHCP snooping, port security, network segmentation, and monitoring for unauthorized DHCP offers and anomalous lease patterns.

Question #:19 - [Web Application Hacking]

At TechTrend Innovations in Silicon Valley, network administrator Jake Henderson reviews the configuration of their web infrastructure. While inspecting the web server setup, he identifies the directory that stores the publicly accessible website content such as HTML files, images, and client-side scripts. Jake highlights this area as a frequent target for attackers, since improper permissions could expose sensitive files to unauthorized users.

Which web server component is Jake analyzing in this scenario?

- A. Application Server
- B. Document Root
- C. HTTP Server (Core)
- D. Virtual Document Tree

Answer: B**Explanation**

The directory that contains the publicly accessible web content—including HTML pages, images, JavaScript, CSS, and other client-side assets—is known as the Document Root. This is the base filesystem path that a web server maps to the “/” location of a website. When a user requests a resource (for example, <https://site.com/index.html>), the web server typically resolves that URL path to a file under the configured document root and then serves it to the client (subject to access controls and server configuration).

The scenario’s details match this precisely: Jake identifies “the directory that stores the publicly accessible website content,” and notes that it is a frequent attacker target due to risks from improper permissions. Document root security is critical because overly permissive read or browse access can expose files that were never intended to be public—such as backups, configuration files, temporary files, source code archives, or sensitive data accidentally placed in web-accessible paths. Misconfigurations can also enable directory listing, allowing attackers to enumerate and retrieve files directly. Attackers often probe for common filenames (e.g., old .zip backups, .bak files, exposed .env files, or test pages) precisely because document root is where such mistakes become externally reachable.

Why the other options are less accurate:

An Application Server (A) runs server-side application logic (e.g., Java/.NET app containers) and is not specifically the directory of static public web content.

The HTTP Server (Core) (C) refers to the web server software/service handling HTTP requests, not the content directory itself.

A Virtual Document Tree (D) describes the logical structure mapping URLs to resources (sometimes via aliases and virtual hosts), but the question asks for the directory that stores the publicly accessible content—this is the document root.

Therefore, Jake is analyzing B. Document Root.

Question #:20 - [Cloud Computing]

Michael, an ethical hacker at a San Francisco-based fintech startup, is conducting a security assessment of the company's cloud-based payment processing platform, which uses Kubernetes, an open-source system for automating the deployment, scaling, and management of containerized applications. During his review, Michael identified a feature that automatically replaces and reschedules containers from failed nodes to ensure high availability of services a critical requirement for uninterrupted payment operations. Based on his study of cloud container technology principles, which Kubernetes feature should Michael highlight as responsible for this capability?

- A. Container vulnerabilities
- B. Kube-controller-manager
- C. Container orchestration
- D. Self-healing

Answer: D**Explanation**

The capability described is Kubernetes self-healing, a core behavior emphasized in CEH cloud and container security coverage when discussing resilience, availability, and fault tolerance in containerized environments. Self-healing means Kubernetes continuously monitors the desired state of workloads and automatically acts when the current state deviates due to failures. If a node crashes, a container exits unexpectedly, or a pod becomes unhealthy, Kubernetes responds by restarting containers, recreating pods, and rescheduling workloads onto healthy nodes to maintain service continuity. This directly matches the scenario where containers are “automatically replaced and rescheduled” from failed nodes to keep payment services highly available.

While several Kubernetes components participate in achieving this outcome, the feature name most aligned with the described behavior is self-healing. Kubernetes uses controllers and the scheduler to implement it: deployments and replica sets ensure the correct number of pod replicas exist; liveness and readiness probes detect unhealthy containers; and when nodes become NotReady, pods are evicted and recreated elsewhere. This is exactly how Kubernetes supports uninterrupted operations for critical applications such as payment processing platforms.

Option B, kube-controller-manager, is a control-plane component that runs multiple controllers, and it contributes to enforcing desired state, but the question asks for the feature capability rather than the specific internal process that provides it. Option C, container orchestration, is broader and includes deployment, scaling, and management, but it is less precise than self-healing for the specific behavior of automatic replacement and rescheduling after failures. Option A is unrelated to availability behavior.

Question #:21 - [Network and Perimeter Hacking]

While analyzing suspicious network activity, you observe a slow, stealthy scanning technique that is difficult to trace back to the attacker. Which scenario best describes the scanning technique being used?

- A. The attacker sends FIN packets to infer port states based on responses
- B. The attacker uses a “zombie” machine to perform scans, hiding their true identity
- C. The attacker performs full TCP connect scans on all ports
- D. The attacker sends packets with all TCP flags set

Answer: B

Explanation

According to the CEH Network Scanning module, Idle Scanning (Zombie Scanning) is one of the most stealthy reconnaissance techniques. In this method, the attacker uses an idle third-party host (zombie) to probe the target indirectly.

Because all scan packets appear to originate from the zombie system, the true attacker remains hidden. CEH highlights that idle scans:

Are extremely stealthy

Generate minimal traffic from the attacker

Make attribution very difficult

Option B is correct.

Option A (FIN scan) is stealthy but still traceable.

Option C is noisy and easily detected.

Option D describes a Xmas scan, which is detectable.

CEH classifies idle scanning as one of the hardest scanning techniques to trace.

Question #:22 - [Security Operations and Incident Response]

During a red team exercise at Apex Logistics in Denver, ethical hacker Rachel launches controlled packet injection attacks to simulate session hijacking attempts. The client's IT team wants a way to automatically detect such abnormal behaviors across the network in real time, instead of relying on manual analysis. They decide to deploy a monitoring system capable of flagging suspicious session activity based on predefined rules and traffic signatures.

Which detection method best fits the IT team's requirement?

- A. Check for predictable session tokens
- B. Perform manual packet analysis using sniffing tools
- C. Monitor for ACK storms

D. Use an Intrusion Detection System (IDS)

Answer: D

Explanation

The IT team's requirement is automatic, real-time detection of abnormal session activity using predefined rules and traffic signatures. That description aligns most directly with an Intrusion Detection System (IDS), particularly a network IDS (NIDS) that monitors traffic, compares it to known patterns (signatures) and/or behavioral rules, and generates alerts when suspicious activity is detected. Session hijacking attempts often produce recognizable anomalies—unexpected packet sequences, suspicious flags, unusual injection patterns, resets, or protocol misuse—that IDS rules can be designed to detect across many hosts and segments without requiring an analyst to manually inspect each capture.

The scenario explicitly contrasts this desired capability with “manual analysis,” which rules out option B. Tools like packet sniffers are valuable for investigation and confirmation, but they do not provide organization-wide automated alerting by themselves. An IDS is built for continuous monitoring and alert generation, making it appropriate for detecting red-team-simulated packet injection and session manipulation attempts.

Why the other options are less suitable:

Checking for predictable session tokens (A) is an application-layer defensive review (and a good hardening practice), but it does not automatically detect packet injection behaviors occurring on the network in real time.

Monitoring for ACK storms (C) can be one specific indicator in some TCP manipulation or desynchronization scenarios, but it is too narrow and does not represent a general detection system. The requirement is broader: a monitoring system that flags suspicious session activity using rules and signatures—an IDS fits that role.

Manual packet analysis (B) is explicitly what they want to avoid.

Therefore, the correct answer is D. Use an Intrusion Detection System (IDS).

Question #:23 - [Reconnaissance Techniques]

During a penetration test at a retail company in Seattle, Washington, an ethical hacker needs to disguise her scans so they appear to originate from a specific hardware vendor. The organization uses MAC-based logging, and by assigning a vendor-associated identifier, she can make her traffic blend in with legitimate devices on the network. Which Nmap command should she use to achieve this?

- A. `nmap -sT -Pn --spoof-mac 00:11:22 10.10.1.11`
- B. `nmap -sT -Pn --spoof-mac Dell 10.10.1.11`
- C. `nmap -sT -Pn --spoof-mac 0 10.10.1.11`
- D. `nmap -sT -Pn --spoof-mac 00:01:02:25:56:AE 10.10.1.11`

Answer: B

Explanation

The correct option is B because it uses vendor-based MAC spoofing, which is the most direct way to make traffic appear to come from a device manufactured by a specific, recognizable vendor (in this case, “Dell”). In MAC addressing, the first portion of the MAC address is the OUI (Organizationally Unique Identifier), which identifies the vendor/manufacture. Many security and asset tools perform lightweight device profiling by correlating observed OUIs with known vendors, and MAC-based logs may record or flag devices based on whether their OUIs match expected corporate endpoints.

Nmap supports MAC spoofing in a way that allows specifying a vendor name so the resulting MAC address is generated with an OUI associated with that vendor. This matches the requirement in the scenario: the tester wants the scan traffic to “blend in with legitimate devices” by adopting a vendor-associated identifier rather than using a random or obviously unusual MAC prefix.

Why the other options are less appropriate:

A provides only a partial prefix-like value (not a full MAC), and it does not explicitly map to a vendor name, making it less aligned with “specific hardware vendor” blending.

C uses 0 (zero), which is commonly associated with generating a random MAC rather than selecting a specific vendor identity; randomization does not guarantee blending with a chosen vendor’s footprint.

D supplies a full explicit MAC address; while this can spoof a MAC, it does not inherently express the intent to “appear as a specific vendor” unless you already know that exact MAC’s OUI belongs to the desired vendor. The question emphasizes selecting a vendor-associated identifier directly, which is exactly what option B does.

So, the best match for vendor-based disguise is B.

Question #:24 - [Cryptography]

Noah, a security analyst at a Seattle-based healthcare provider, is responding to a real-time data breach where attackers accessed patient records stored on a compromised server. During incident response, he must quickly secure sensitive files located on the system’s primary storage to prevent further exfiltration. The data resides in a mounted partition that needs full-volume encryption, but standard file encryption isn’t sufficient. Noah selects a solution that supports encrypted containers, strong key lengths like 256-bit AES, and can conceal secure volumes within standard ones to reduce detection. His goal is to ensure confidentiality while forensic operations continue without disrupting system functionality.

Which disk encryption tool should Noah deploy to meet these objectives?

- A. BitLocker Drive Encryption
- B. FileVault
- C. Rohos Disk Encryption
- D. VeraCrypt

Answer: D**Explanation**

The best match is VeraCrypt because the scenario explicitly requires three capabilities commonly associated with it in CEH cryptography and data protection coverage: encrypted containers, strong modern ciphers such as AES with 256-bit keys, and the ability to hide a protected volume inside another volume to reduce detectability. VeraCrypt is a successor to TrueCrypt and is widely referenced in ethical hacking curricula as a practical disk encryption utility that can create encrypted file containers and encrypt entire partitions or drives. It supports multiple algorithms and combinations, including AES-256, and can mount encrypted containers as virtual drives so applications can access data normally while it remains encrypted at rest.

The key distinguishing requirement is concealment of secure storage using hidden volumes. VeraCrypt supports plausible deniability by allowing a hidden volume to exist inside an outer encrypted volume. If compelled to reveal a password, a user can disclose the outer volume password while the hidden volume remains undetectable without its separate credentials. The prompt's phrase "conceal secure volumes within standard ones" maps directly to this VeraCrypt feature and is not a standard capability of BitLocker or FileVault.

BitLocker and FileVault provide strong full-disk encryption, but they do not provide hidden volumes for plausible deniability. Rohos can create encrypted containers, but hidden-volume style plausible deniability is most strongly and commonly associated with VeraCrypt in CEH-oriented discussions. Therefore, VeraCrypt is the most appropriate tool for Noah's stated objectives.

Question #:25 - [System Hacking Phases]

After responding to an alert involving unauthorized access to payroll data, forensic analyst Jason Miller traces the breach to a Windows workstation previously used by a temporary staff member in Chicago. While analyzing the event timeline, Jason identifies a non-elevated process that launched a signed Microsoft binary — one of several auto-elevate executables such as fodhelper.exe, eventvwr.exe, or sdclt.exe — which resulted in execution of unauthorized code without prompting the user. Registry analysis reveals manipulation of shell-related keys under the current user hive, redirecting the trusted binary to invoke a malicious payload.

Which technique most likely enabled the privilege escalation?

- A. Kernel Exploitation
- B. Scheduled Task
- C. UAC Bypass
- D. DLL Hijacking

Answer: C**Explanation**

The evidence points to a User Account Control bypass. In CEH coverage of Windows privilege escalation, UAC is a protection mechanism intended to prevent silent elevation of privileges, typically prompting the user when an action requires administrative rights. However, certain Windows binaries are "auto-elevate" (often

trusted, signed Microsoft executables) and can run with elevated privileges under specific conditions without showing a UAC prompt. Attackers abuse this behavior by manipulating user-writable registry locations—commonly under the current user hive—to influence how these trusted binaries launch other components.

The scenario describes exactly that pattern: a non-elevated process starts an auto-elevate executable such as fodhelper.exe, eventvwr.exe, or sdclt.exe, and the system executes unauthorized code with no prompt. The key forensic clue is “manipulation of shell-related keys under the current user hive,” which is a hallmark of UAC bypass techniques that hijack file association or shell open commands so the trusted binary invokes an attacker-controlled payload instead of the intended system action. Because the modification occurs in HKCU, it can often be performed without administrator privileges, making it attractive for stealthy elevation.

The other options do not match as well. Kernel exploitation involves abusing OS kernel vulnerabilities and would not hinge on shell registry hijacks. Scheduled tasks typically leave task artifacts and are a persistence /execution method rather than this specific auto-elevate redirection behavior. DLL hijacking focuses on search-order abuse for loading malicious DLLs, not shell key redirection tied to UAC auto-elevation.

Question #:26 - [System Hacking Phases]

During a scheduled security review in a high-tech lab in Austin, Texas, penetration tester Lucas Bennett was assessing a state government’s new payroll system hosted in a private cloud. One humid afternoon, while fuzz testing the input validation logic of the TaxCalcEngine.dll module, he triggered a buffer overflow by submitting malformed taxpayer ID strings. The crash led to unintended disclosure of payroll data due to unchecked data boundaries. Lucas traced the issue to a coding oversight in a core processing module. Applying a structured analysis approach, which category best describes the vulnerability he discovered?

- A. Application Flaws
- B. Poor Patch Management
- C. Misconfigurations Weak Configurations
- D. Design Flaws

Answer: A

Explanation

Application Flaws is the best classification because the root cause is a coding error in the application’s input handling that results in a buffer overflow. In CEH-aligned vulnerability categorization, application flaws include implementation mistakes such as improper bounds checking, unsafe string handling, and inadequate input validation. The scenario explicitly states Lucas used fuzz testing against input validation logic and triggered a buffer overflow using malformed taxpayer ID strings, then observed unintended disclosure of payroll data due to unchecked data boundaries. Those details point to defective code behavior at runtime, not an administrative or configuration issue.

Poor Patch Management typically refers to failing to apply vendor patches or updates, leaving known vulnerabilities exploitable. The prompt does not indicate the issue was a previously known, patched defect that remained unpatched; instead, it describes a newly discovered weakness traced to an internal module and a “coding oversight.” Misconfigurations or weak configurations involve insecure settings such as overly permissive access controls, exposed services, default credentials, or insecure cloud storage policies. None of

those are the trigger here; the trigger is malformed input causing memory corruption. Design Flaws relate to weaknesses in the system's architecture or security model, such as missing authorization logic, flawed trust boundaries, or insecure workflows. While poor design can contribute to impact, the specific vulnerability mechanism described is an implementation-level memory handling failure.

Therefore, the correct classification is Application Flaws, because the vulnerability is fundamentally an input-processing and bounds-checking defect in the application code that results in a buffer overflow and data exposure.

Question #:27 - [Web Application Hacking]

In the bustling financial hub of Charlotte, North Carolina, ethical hacker Raj Patel is contracted by TrustBank, a regional US bank, to evaluate their online loan application portal. On April 22, 2025, Raj tests a feature allowing customers to upload structured financial documents for loan processing. By submitting a specially crafted document, he triggers a response that exposes internal server file paths and sensitive configuration data, including database connection strings. The issue arises from the portal's handling of external references in document parsing, not from response manipulation, authentication weaknesses, or undetected attack attempts. Raj compiles a detailed report to assist TrustBank's security team in mitigating the vulnerability.

Which type of vulnerability is Raj most likely exploiting in TrustBank's online loan application portal?

- A. Identification and Authentication Failures
- B. HTTP Response Splitting
- C. XML External Entity (XXE) Injection
- D. Security Logging and Monitoring Failures

Answer: C

Explanation

The vulnerability described is characteristic of XML External Entity (XXE) Injection. In CEH web application security coverage, XXE occurs when an application parses XML input without properly disabling external entity resolution. If the XML parser is configured insecurely, an attacker can define a malicious external entity that references local files or internal system resources. When the parser processes the XML document, it resolves the external entity and may return the contents of sensitive files in the server's response.

The scenario clearly states that the issue arises from "handling of external references in document parsing" and results in exposure of internal file paths and database connection strings. This aligns directly with XXE behavior, where attackers leverage external entity declarations to retrieve local files such as configuration files, environment settings, or system credentials. In some cases, XXE can also enable server-side request forgery by forcing the server to make internal network requests.

The other options do not match the described behavior. Identification and authentication failures relate to improper access controls, not document parsing. HTTP response splitting involves manipulating headers to inject malicious responses. Security logging and monitoring failures refer to detection gaps, not data exposure.

through parsing. CEH-recommended mitigation strategies include disabling DTD processing, turning off external entity resolution in XML parsers, validating input formats, implementing least privilege on file access, and using secure parsing libraries that prevent XXE exploitation.

Question #:28 - [System Hacking Phases]

In sunny San Diego, California, security consultant Maya Ortiz is engaged by PacificGrid, a regional utilities provider, to analyze suspicious access patterns on their employee portal. While reviewing authentication logs, Maya notices many accounts each receive only a few login attempts before the attacker moves on to other targets; the attempts reuse a very small set of likely credentials across a large number of accounts and are spread out over several days and IP ranges to avoid triggering automated lockouts. Several low-privilege accounts were successfully accessed before the pattern was detected. Maya prepares a forensic timeline to help PacificGrid contain the incident.

Which attack technique is being used?

- A. Session Hijacking
- B. Password Spraying
- C. Cross-Site Request Forgery (CSRF)
- D. Brute Force Attack

Answer: B

Explanation

The correct answer is B. Password Spraying because the pattern described is the defining behavior of a spraying attack: the attacker tries a small set of common or likely passwords (for example, seasonal passwords, default patterns, or organization-themed guesses) across many different user accounts, using only a few attempts per account to avoid account lockout thresholds. The scenario explicitly states that “many accounts each receive only a few login attempts,” the attacker “reuses a very small set of likely credentials across a large number of accounts,” and the activity is “spread out over several days and IP ranges to avoid triggering automated lockouts.” These are the exact operational traits that distinguish password spraying from traditional brute force.

In CEH-aligned credential attack concepts, brute force is typically characterized by repeated attempts against a single account (or a small set of accounts), often cycling through many password candidates until the correct one is found. That approach is noisy and quickly triggers lockouts and detection. Password spraying flips the strategy: it keeps the per-account attempt count low and distributes attempts widely and slowly, which reduces alerting and lockout events. This is why the attacker was able to successfully access “several low-privilege accounts” before the pattern was noticed—spraying often compromises accounts with weak or reused passwords while staying below detection thresholds.

Why the other options are incorrect: Session hijacking involves stealing or replaying session tokens/cookies after authentication, not repeated login attempts across accounts. CSRF forces a logged-in user’s browser to perform unintended actions; it does not produce distributed authentication failures in logs. Brute force is related, but the avoidance of lockouts through minimal attempts per account and broad targeting is the signature of password spraying.

Therefore, the observed behavior most clearly indicates a password spraying attack.

Question #:29 - [Reconnaissance Techniques]

You are working as a threat intelligence analyst for a fintech startup that recently discovered a spike in credential stuffing attempts against its admin panel. The security team believes this may be due to leaked internal files circulating on underground forums. You are tasked with investigating potential exposure on the dark web without directly interacting with any service or forum. You decide to use advanced search filters to identify documents hosted on hidden services that may contain sensitive access details. The team suspects these documents might include account-related keywords in their titles.

Which of the following search queries would best support this investigation?

- A. filetype:pdf intitle:"admin access" site:onion
- B. filetype:docx intitle:"login credentials"
- C. filetype:pdf intitle:"secure login" site:onion
- D. filetype:docx intitle:"user accounts" site:onion

Answer: A

Explanation

This task describes passive reconnaissance using advanced search operators, a technique covered in CEH as search engine reconnaissance or Google dorking. The objective is to find potentially exposed documents on hidden services while avoiding direct interaction with forums or services. The most important element in the query is restricting results to hidden service domains using the site:onion operator. Any option that does not include site:onion is less suitable because it will return results from the public web rather than from .onion resources.

Option A is the strongest fit because it combines three high-value filters: filetype:pdf to focus on document artifacts that are commonly leaked or shared, intitle:"admin access" to target titles suggesting privileged access or administrative information, and site:onion to restrict the scope to hidden services. In CEH reporting and threat intelligence workflows, targeting high-signal keywords such as admin access, credentials, password list, or vpn access in document metadata is a practical way to identify likely leak sources without active engagement.

Option B lacks site:onion, so it fails the hidden-service requirement. Option C includes site:onion but the phrase secure login is more generic and may return many benign pages, reducing precision. Option D includes site:onion and filetype targeting, but user accounts is broader and less indicative of immediate access data than admin access. Therefore, A best supports efficient passive discovery of high-risk documents relevant to credential exposure on hidden services.

Question #:30 - [Security Operations and Incident Response]

Dr. Evelyn Reed, a cybersecurity expert, was called in to investigate a series of unusual activities at "Global Innovations Inc." The first red flag was a surge in spear-phishing emails targeting senior management, disguised as urgent internal memos. Soon after, the company's web server showed unexpected outbound traffic to unfamiliar IP addresses. A network audit revealed that multiple underutilized printers and routers had unauthorized firmware installed. Further review uncovered inconsistencies in file access logs linked to the R&D department, including unusually large data transfers occurring during non-business hours. Dr. Reed also noted the attackers appeared to have intimate knowledge of the organization's internal data structure.

Which phase of the Advanced Persistent Threat (APT) lifecycle is Global Innovations Inc. most likely experiencing, given the combination of these incidents?

- A. Initial Intrusion
- B. Expansion
- C. Search and Exfiltration
- D. Persistence

Answer: C

Explanation

The indicators described align most strongly with the Search and Exfiltration phase of the APT lifecycle. In CEH-aligned APT models, attackers typically progress from initial access to establishing footholds, expanding access through internal reconnaissance and lateral movement, then locating valuable data and exfiltrating it. While spear-phishing is a common Initial Intrusion technique, the scenario explicitly includes multiple signals that the attackers are already deep inside the environment and actively handling sensitive information.

The key evidence is the “unusually large data transfers during non-business hours” tied to the R&D department and “unexpected outbound traffic to unfamiliar IP addresses.” Those are classic signs of staging and exfiltration, where collected data is aggregated internally and then sent out to attacker-controlled infrastructure, often at times chosen to reduce detection. The observation that attackers have “intimate knowledge of the organization’s internal data structure” further supports that they have already performed internal discovery and are now targeting specific high-value repositories.

Unauthorized firmware on printers and routers suggests the attackers may have created durable internal collection points or covert channels, but that activity supports and enables the data-theft mission rather than being the primary phase indicated by the full pattern of events. Therefore, the combination of targeted access to R&D resources, anomalous outbound connections, and large off-hours transfers most closely matches the Search and Exfiltration phase in CEH APT lifecycle coverage.

Question #:31 - [System Hacking Phases]

During an internal red team engagement at a financial services firm, an ethical hacker named Anika tests persistence mechanisms after successfully gaining access to a junior employee’s workstation. As part of her assessment, she deploys a lightweight binary into a low-visibility system folder. To maintain long-term access, she configures it to launch automatically on every system reboot without requiring user interaction.

Which of the following techniques has most likely been used to ensure the persistence of the attacker's payload?

- A. Installing a keylogger
- B. Creating scheduled tasks
- C. Modifying file attributes
- D. Injecting into the startup folder

Answer: B

Explanation

Creating scheduled tasks is the most likely persistence technique because it can be configured to execute automatically at system startup or on reboot without requiring a user to log in or manually launch anything. In CEH-aligned post-exploitation and persistence concepts, attackers commonly use operating system native mechanisms that blend into normal administrative activity. A scheduled task fits this goal well because it can be named to look legitimate, set to run under a specific account, and triggered by events such as system boot, user logon, or a timed schedule. The scenario explicitly states the payload launches on every reboot without user interaction, which aligns with a boot-triggered scheduled task.

Injecting into the startup folder usually triggers execution when a user logs on, not strictly on system reboot, and it depends on an interactive user session. That contradicts the requirement of no user interaction. Modifying file attributes, such as setting hidden or system attributes, improves stealth and makes a file less noticeable, but it does not create an automatic execution mechanism by itself. Installing a keylogger is a capability for capturing keystrokes, not a persistence method, and it does not inherently guarantee execution after reboot unless paired with an auto-start mechanism.

Therefore, the action that directly ensures the binary runs after each reboot in a controlled and reliable way is creating scheduled tasks, which is a classic persistence method emphasized in ethical hacking workflows for demonstrating real-world attacker behavior and improving defensive detection and hardening.

Question #:32 - [Cryptography]

Which encryption method supports secure key distribution?

- A. Disk encryption
- B. Symmetric encryption
- C. Hash functions
- D. Asymmetric encryption

Answer: D

Explanation

Asymmetric encryption, as defined in CEH v13 Cryptography, uses a public-private key pair, solving the key distribution problem inherent in symmetric encryption.

Public keys can be freely shared, enabling secure communication initiation without prior shared secrets. Disk encryption and hashes do not address key exchange.

Therefore, Option D is correct.

Question #:33 - [Malware Threats]

During a stealth penetration test at a defense research facility, ethical hacker Daniel installs a payload that survives even after multiple operating system reinstalls. The implant resides deep inside the system hardware and executes before the OS is loaded, ensuring that forensic scans and antivirus tools at the OS level cannot detect or remove it. Administrators notice unusual activity on network cards and storage devices, but repeated scans show no malware traces within the file system.

Which type of rootkit most likely enabled this level of persistence?

- A. Boot-Loader-Level Rootkit
- B. Hypervisor-Level Rootkit
- C. Kernel-Level Rootkit
- D. Hardware/Firmware Rootkit

Answer: D

Explanation

The correct answer is D. Hardware/Firmware Rootkit because the scenario describes persistence that remains even after multiple OS reinstalls and executes before the operating system loads, while evading OS-level antivirus and forensic scans. In CEH-aligned malware/rootkit concepts, hardware/firmware rootkits embed malicious code into firmware components such as BIOS/UEFI, device firmware (for example, NIC firmware, storage controller firmware, HDD/SSD firmware), or other embedded hardware layers. Because firmware is separate from the operating system's file system, reinstalling the OS typically does not remove the implant.

The clue "resides deep inside the system hardware" and "executes before the OS is loaded" aligns with firmware-level execution in the boot chain. Firmware rootkits can run during early startup, initialize malicious hooks, and then hand off control to the OS in a way that hides their presence. This makes them extremely difficult to detect using conventional host-based tools, because those tools operate after the OS is running and generally cannot easily inspect or validate firmware integrity. The mention of "unusual activity on network cards and storage devices" is also a strong indicator: compromised NIC or storage firmware can manipulate traffic, exfiltrate data, or alter reads/writes while remaining invisible to file-based scanning.

Why the other options are less accurate: a boot-loader-level rootkit typically infects the bootloader on disk; while it runs early, it may be removed by disk reimaging or certain reinstall workflows. A kernel-level rootkit

resides within the OS kernel and is generally removed by reinstalling the OS. A hypervisor-level rootkit (virtualization-based) can be stealthy, but it still generally depends on software layers that may not survive repeated OS reinstalls unless paired with firmware persistence.

Therefore, the persistence across reinstalls and pre-OS execution most clearly indicate a hardware/firmware rootkit.

Question #:34 - [Security Operations and Incident Response]

A known vulnerability exists on a production server, but patching is delayed due to operational constraints. What immediate action can reduce risk without disrupting operations?

- A. Conduct a full penetration test
- B. Shut down the server
- C. Monitor traffic continuously
- D. Implement Virtual Patching

Answer: D

Explanation

Virtual Patching is a risk-mitigation technique emphasized in CEH v13 Security Operations. It involves deploying compensating controls—such as WAF rules, IPS signatures, or firewall policies—to block exploitation attempts without modifying the vulnerable system.

CEH v13 highlights virtual patching as especially useful when:

Downtime is unacceptable

Vendor patches are delayed

Legacy systems are in use

Monitoring alone does not prevent exploitation, and shutting down systems is often impractical. Virtual patching provides immediate protection while maintaining availability.

Question #:35 - [Social Engineering]

Which scenario best represents a social engineering attack?

- A. Fake IT call requesting credentials
- B. Packet sniffing by an IT executive
- C. Malware introduced during OS update

D. Unlocked workstation accessed by stranger

Answer: A

Explanation

According to CEH v13 Social Engineering, social engineering attacks manipulate human trust rather than technical vulnerabilities. Option A describes a classic pretexting attack, where the attacker impersonates IT staff and fabricates a false issue to trick a victim into revealing credentials.

This scenario aligns perfectly with CEH definitions because:

The attacker relies on authority impersonation

The victim is socially manipulated

No technical exploitation is required

Option B is a legitimate security activity.

Option C is accidental malware introduction, not social engineering.

Option D is physical negligence exploitation, not direct social engineering interaction.

CEH v13 stresses that pretexting attacks are extremely effective against new employees who lack familiarity with procedures. Therefore, Option A is correct.

Question #:36 - [Reconnaissance Techniques]

An attacker performs DNS cache snooping using dig +norecurse. The DNS server returns NOERROR but no answer. What does this indicate?

- A. The domain has expired
- B. The record was cached and returned
- C. The DNS server failed
- D. No recent client from that network accessed the domain

Answer: D

Explanation

In CEH v13 DNS Enumeration, DNS cache snooping determines whether a DNS resolver has a record cached. When +norecurse is used and the response is NOERROR with no answer, it means the server is authoritative but does not have the record cached.

CEH v13 explains that this suggests no internal client has recently queried the domain, making option D correct.

Question #:37 - [Network and Perimeter Hacking]

Packet fragmentation is used as an evasion technique. Which IDS configuration best counters this?

- A. Recognizing regular fragmented packet intervals
- B. Anomaly-based IDS detecting irregular traffic patterns
- C. Rejecting all fragmented packets
- D. Signature-based IDS detecting fragmented packet signatures

Answer: B**Explanation**

Packet fragmentation is a well-documented IDS evasion technique in CEH v13 Network and Perimeter Hacking. Attackers fragment packets to evade detection by overwhelming or confusing intrusion detection systems, especially those that rely on simple pattern matching.

CEH v13 explains that anomaly-based IDS systems are particularly effective against evasion techniques like packet fragmentation because they analyze deviations from normal network behavior, rather than relying on static signatures. Fragmented packets often create unusual traffic patterns, abnormal packet sizes, or irregular reassembly behavior, which anomaly-based systems are designed to detect.

Signature-based IDS solutions struggle against fragmentation because attackers can split malicious payloads across multiple packets in ways that bypass predefined signatures. Rejecting all fragmented packets (Option C) is impractical and could disrupt legitimate network communication, as fragmentation is a normal part of TCP/IP networking.

Recognizing regular intervals (Option A) is unreliable, as attackers can randomize packet timing. CEH v13 clearly recommends anomaly-based detection to counter advanced evasion techniques.

Thus, Option B is the most effective and CEH-aligned IDS configuration.

Question #:38 - [Network and Perimeter Hacking]

During a quarterly security audit at a financial services company in Charlotte, North Carolina, you are tasked with reviewing exposed services on legacy servers inherited from a third-party vendor. While scanning, you discover that TCP port 1434 is open on a database node that is not listed in the company's active inventory. The IT team has no records explaining why this service is running, and you are asked to determine whether the exposure of this port could indicate an unnecessary database-related risk. Based on standardized port assignments, which service is most likely running on this port and requires further review?

- A. ms-sql-m
- B. sqlsrv

- C. sql*net
- D. ms-sql-s

Answer: A**Explanation**

The correct answer is A. ms-sql-m because TCP/1434 is commonly associated with Microsoft SQL Server Monitor / SQL Server Browser-related services, which are used to help clients discover SQL Server instances and their connection details. In standardized service naming, ms-sql-m corresponds to Microsoft SQL “monitor” functionality tied to instance discovery and related metadata exposure. When this port is reachable from networks where it is not needed, it can increase attack surface by exposing information that helps attackers identify database instances, target the correct ports, and focus exploitation attempts.

In the context of a legacy server that is “not listed in the company’s active inventory,” an open 1434 is a red flag because it suggests an unnecessary or unmanaged database discovery component may be running. Attackers often use exposed database-related ports for reconnaissance (identifying instance names, versions, and listening endpoints) and then pivot to authentication attacks or exploitation of known weaknesses. Even when the core SQL service port is controlled, discovery services can still leak useful environment details that lower the cost of an attack.

Why the other options are incorrect:

ms-sql-s typically refers to the primary Microsoft SQL Server service, most commonly associated with TCP /1433 (the default SQL Server port), not 1434.

sql*net is associated with Oracle SQL*Net/Net8 traffic, typically using Oracle listener ports such as 1521, not 1434.

sqlsrv is not the standardized assignment for 1434 in the way ms-sql-m/ms-sql-s are used for Microsoft SQL-related services.

Therefore, based on standardized port associations and the database discovery/monitoring role of this service, the exposure most likely indicates ms-sql-m on TCP/1434, and it warrants further review and potential restriction if not required.

Question #:39 - [Network and Perimeter Hacking]

During an internal security assessment of a medium-sized enterprise network, a security analyst notices an unusual spike in ARP traffic. Closer inspection reveals that one particular MAC address is associated with multiple IP addresses across different subnets. The ARP packets were unsolicited replies rather than requests, and several employees from different departments have reported intermittent connection drops, failed logins, and broken intranet sessions. The analyst suspects an intentional interference on the local network segment. What is the most likely cause of this abnormal behavior?

- A. ARP poisoning causing routing inconsistencies
- B. DHCP snooping improperly configured

- C. Legitimate ARP table refresh on all clients
- D. Port security restricting all outbound MAC responses

Answer: A

Explanation

CEH v13 explains that ARP poisoning (also known as ARP spoofing) occurs when an attacker sends forged ARP replies across the network to associate their MAC address with multiple IP addresses, tricking hosts into sending traffic through the attacker's machine. This results in routing inconsistencies, intermittent connectivity, failed logins, and degraded intranet performance—exactly the symptoms described. ARP poisoning typically involves unsolicited ARP replies, which overwrite legitimate ARP cache entries. CEH emphasizes that ARP-based attacks are common on LANs because ARP lacks authentication, allowing attackers to impersonate gateways or key hosts. DHCP snooping misconfigurations (Option B) affect IP allocation, not ARP mappings. Legitimate ARP refreshes (Option C) are request-based and do not involve flooding unsolicited replies. Port security restrictions (Option D) block MAC anomalies, not create them. Therefore, ARP poisoning is the correct root cause.

Question #:40 - [Mobile Platform and IoT Hacking]

Javier Ruiz from CyberFortress Solutions is tasked with auditing the mobile security practices of Apex Financial Services, a financial firm in Houston, Texas. During a covert penetration test, Javier targets employees' personal smartphones used to access corporate financial systems. He exploits a vulnerability by installing a malicious app that bypasses access controls, granting him unauthorized entry to sensitive financial data because the devices lack a specific security measure to restrict app access. Based on this vulnerability, which BYOD security guideline is most likely missing in Apex Financial Services' policy?

- A. Review permissions requested by apps before installing them
- B. Set passwords for apps to restrict others from accessing them
- C. Enforce automatic device locking or implement biometric authentication
- D. Use encryption mechanisms to store data

Answer: A

Explanation

The most likely missing BYOD guideline is reviewing application permissions before installation. In CEH mobile security guidance, a major risk in BYOD environments is the introduction of untrusted or malicious applications that abuse the mobile permission model to access corporate data, intercept authentication tokens, read storage, capture keystrokes via accessibility services, or communicate externally. When users install apps without scrutinizing requested permissions, they may unknowingly grant excessive privileges that enable data theft or access-control bypass, especially if the app leverages OS weaknesses or misconfigurations.

The scenario states Javier “installs a malicious app that bypasses access controls” and gains access to sensitive financial data because devices “lack a specific security measure to restrict app access.” This maps directly to a policy gap around controlling and validating apps and their permission requests. CEH emphasizes that

organizations should reduce attack surface by limiting app privileges, avoiding sideloading from untrusted sources, and enforcing least privilege through user awareness and enterprise controls such as MDM application allowlisting and permission governance. Reviewing permissions is the user-facing guideline that prevents employees from granting dangerous access (for example, SMS, storage, contacts, accessibility, device admin, or VPN configuration permissions) that can enable credential theft or unauthorized data access.

Option B adds an extra layer for local access but does not stop a malicious app with granted permissions from accessing corporate data. Option C helps if a device is physically stolen, but it does not prevent malicious apps already running under the user context. Option D protects data at rest, yet a malicious app can still exfiltrate data once it is decrypted and accessed by the user session. Therefore, permission review is the most directly relevant missing BYOD guideline.

Question #:41 - [Security Operations and Incident Response]

During a penetration test at Cascade Biotech in Portland, Oregon, ethical hacker Olivia Harper installs a monitoring agent on a single test workstation inside the research subnet. The system records local events such as file access, configuration changes, and unauthorized process execution. Olivia explains to the security team that attackers often attempt to disable or evade this type of monitoring to avoid being detected at the host level.

Which security system is Olivia most likely demonstrating?

- A. Network-Based Firewall
- B. Host-Based Firewall
- C. Network-Based Intrusion Detection System
- D. Host-Based Intrusion Detection System

Answer: D

Explanation

The scenario describes a host-level monitoring agent installed on a single workstation that records local system events such as file access, configuration changes, and unauthorized process execution. These are classic indicators of Host-Based Intrusion Detection System (HIDS) functionality. A HIDS runs on an endpoint (server or workstation) and monitors activity on that host, including operating system logs, file integrity, registry/config changes, system calls, application logs, and process behavior. Because it has direct visibility into what is happening locally, it can detect suspicious activity that may not be obvious from network traffic alone.

The clue that “attackers often attempt to disable or evade this type of monitoring to avoid being detected at the host level” also aligns strongly with HIDS. Adversaries commonly try to stop endpoint agents, tamper with logs, or evade detection by living-off-the-land techniques precisely because host-based sensors can catch actions like privilege escalation attempts, persistence mechanisms, malicious process launches, or unauthorized modifications to critical files and configurations.

Why the other options are not the best match:

A Network-Based Firewall (A) is a perimeter or network control that filters traffic based on rules (IPs, ports, protocols). It does not typically record detailed local file/process/configuration events on a single workstation.

A Host-Based Firewall (B) resides on the endpoint but primarily controls inbound/outbound network connections at that host. While it can log connection attempts, it is not chiefly designed to track file access, configuration integrity, or process execution.

A Network-Based IDS (C) analyzes traffic on the network segment (via taps/SPAN) to identify suspicious patterns. It does not require installing an agent on a single workstation and lacks direct visibility into local file and process events.

Therefore, the security system Olivia is demonstrating is D. Host-Based Intrusion Detection System.

Question #:42 - [Cloud Computing]

Customer data in a cloud environment was exposed due to an unknown vulnerability. What is the most likely cause?

- A. Misconfigured security groups
- B. Brute force attack
- C. DoS attack
- D. Side-channel attack

Answer: A

Explanation

CEH v13 identifies misconfigured cloud security groups as the leading cause of cloud data exposure. Open ports, public storage buckets, and overly permissive firewall rules frequently expose sensitive data.

Brute force and DoS do not directly expose stored data, and side-channel attacks are rare and advanced.

Question #:43 - [Web Application Hacking]

In the heart of Silicon Valley, California, network administrator Jake Henderson oversees the web infrastructure for TechTrend Innovations, a startup specializing in cloud solutions. During a routine architecture review, Jake evaluates the setup of their web server, which handles high-traffic API requests. He notes that the server's primary module processes incoming requests and works with additional modules to manage encryption, URL rewriting, and authentication. Curious about the server's design, Jake consults the documentation to ensure optimal performance and security.

Which web server component is Jake analyzing as part of TechTrend Innovations' architecture?

- A. Virtual Document Tree

- B. Application Server
- C. Document Root
- D. HTTP Server Core

Answer: D

Explanation

The correct answer is HTTP Server Core because the scenario describes the primary module of a web server that processes incoming requests and coordinates with additional modules responsible for encryption, URL rewriting, and authentication. In CEH-aligned web server architecture concepts, the core HTTP engine is responsible for handling client requests, managing connections, parsing HTTP headers, and passing requests to the appropriate modules for further processing.

Modern web servers such as Apache HTTP Server or Nginx operate using a modular architecture. The core component manages the fundamental HTTP protocol operations, while optional or loadable modules extend functionality. For example, SSL or TLS modules handle encryption, rewrite modules manage URL manipulation, and authentication modules enforce access controls. The description in the question clearly aligns with this architecture, where a central processing unit works in conjunction with supporting modules.

The other options do not fit. The Document Root refers only to the directory location from which web content is served. A Virtual Document Tree relates to how URLs are logically mapped to file paths. An Application Server is a separate server component that processes business logic, often interacting with backend systems, rather than directly managing HTTP request parsing at the core level.

Therefore, Jake is analyzing the HTTP Server Core, which is responsible for handling incoming requests and integrating modular security and performance features within the web server environment.

Question #:44 - [Security Operations and Incident Response]

Joe, a cybersecurity analyst at Norwest Freight Services, has been assigned to run a vulnerability scan across the organization's infrastructure. He is specifically tasked with detecting weaknesses such as missing patches, unnecessary services, weak encryption, and authentication flaws across multiple servers. His scan identifies open ports and active services throughout the environment, providing a clear map of potential entry points for attackers.

Which type of vulnerability scanning best matches Joe's assignment?

- A. Network-based Scanning
- B. External Scanning
- C. Application Scanning
- D. Host-based Scanning

Answer: A

Explanation

Joe's assignment is best described as network-based vulnerability scanning because the scan is mapping open ports and active services across multiple servers and identifying weaknesses visible through network exposure, such as unnecessary services, weak encryption configurations on network services, and authentication-related flaws reachable over the network. Network-based scanning focuses on discovering and evaluating network-accessible entry points by probing hosts and services, enumerating versions /configurations, and correlating findings to known weaknesses.

The scenario highlights that the scan "identifies open ports and active services throughout the environment," producing "a clear map of potential entry points." That is the core outcome of network-based scanning: a view of the organization's externally or internally reachable services, where each listening port represents a possible attack path. From there, scanners can detect issues like outdated service versions (implying missing patches), insecure protocols (e.g., weak TLS ciphers), default credentials, and exposed administrative interfaces.

Why the other options are less accurate:

External scanning (B) refers to a scan performed from outside the organization's perimeter. The scenario says he is scanning across organizational infrastructure and focuses on multiple servers; it doesn't specify "from the Internet," so "external" is not the best classification.

Application scanning (C) targets web applications or specific application-layer logic (e.g., SQLi, XSS, auth bypass). Joe's focus is broader infrastructure exposure and service/port mapping.

Host-based scanning (D) typically involves local, credentialed inspection on the host (patch inventory, local config files, registry) rather than primarily mapping ports/services across many systems. While host-based scanning is valuable, the described output is network entry-point mapping.

Therefore, the scan type that best matches Joe's task is A. Network-based Scanning.

Question #:45 - [Malware Threats]

A malware analyst is tasked with evaluating a suspicious PDF file suspected of launching attacks through embedded JavaScript. Initial scans using pdfid show the presence of /JavaScript and /OpenAction keywords. What should the analyst do next to understand the potential impact?

- A. Upload the file to VirusTotal and rely on engine consensus
- B. Disassemble the PDF using PE Explorer
- C. Extract and analyze stream objects using PDFStreamDumper
- D. Compute file hashes using HashMyFiles for signature matching

Answer: C

Explanation

This question relates to Malware Analysis, specifically PDF-based malware, as covered in the CEH v13 Malware Threats module. The presence of /JavaScript and /OpenAction keywords identified by pdfid strongly indicates potentially malicious behavior triggered when the PDF is opened.

CEH v13 recommends static analysis of PDF stream objects as the next step to understand embedded malicious logic. Tools such as PDFStreamDumper allow analysts to extract, decompress, and inspect object streams within a PDF file, revealing obfuscated JavaScript code or exploit payloads.

The /OpenAction keyword indicates that the embedded JavaScript executes automatically when the document is opened, a common technique used in PDF-based attacks to exploit reader vulnerabilities or download secondary payloads.

Other options are insufficient:

VirusTotal provides detection results but not behavioral insight.

PE Explorer is irrelevant because PDFs are not Portable Executable files.

Hashing only helps identify known malware, not analyze behavior.

CEH v13 emphasizes manual inspection of embedded scripts to determine intent, making PDFStreamDumper the correct next step.

Question #:46 - [Malware Threats]

Malware uses Background Intelligent Transfer Service (BITS) to evade detection. Why is BITS attractive to attackers?

- A. It uses IP fragmentation
- B. It encrypts DNS packets
- C. It looks like normal Windows Update traffic
- D. It works only through HTTP tunneling

Answer: C

Explanation

In CEH v13 Malware Threats, BITS is highlighted as a legitimate Windows service frequently abused by attackers for stealthy command-and-control (C2) communication and data exfiltration. BITS is designed to transfer files in the background using idle bandwidth, primarily for Windows Updates and Microsoft services.

Attackers exploit BITS because its traffic closely resembles legitimate Windows update traffic, which is almost always allowed through firewalls, proxies, and endpoint security controls. This makes malicious traffic blend seamlessly into normal network activity, significantly reducing the likelihood of detection.

Option C correctly captures this behavior. BITS does not rely on IP fragmentation (Option A), DNS encryption (Option B), or exclusive HTTP tunneling (Option D). Instead, it leverages trusted system behavior and signed binaries, allowing malware to “live off the land.”

CEH v13 stresses that abuse of trusted services like BITS is a hallmark of advanced persistent threats (APTs) and fileless malware. Detecting such abuse typically requires behavioral monitoring rather than signature-based detection.

Thus, Option C is correct.

Question #:47 - [Network and Perimeter Hacking]

You perform a network scan using ICMP Echo Requests and observe that certain IP addresses do not return Echo Replies, while other network services remain functional. How should this situation be interpreted?

- A. The scanned IPs are unused and available for expansion
- B. The lack of replies indicates a major breach
- C. A firewall or security control is blocking ICMP Echo Requests
- D. The non-responsive IPs indicate severe congestion

Answer: C

Explanation

According to CEH v13 Network Scanning and Enumeration, ICMP Echo Requests (ping) are commonly filtered by firewalls and intrusion prevention systems to reduce network reconnaissance exposure. When ICMP Echo Replies are not returned but other services remain operational, the most likely explanation is ICMP filtering rather than host unavailability or compromise.

CEH v13 explicitly states that many organizations configure firewalls to block ICMP Echo Requests while allowing other ICMP types or higher-layer protocols. This practice helps prevent attackers from easily mapping live hosts during the reconnaissance phase.

The other options are incorrect because:

Unused IPs would not necessarily have active services.

A breach would typically present additional symptoms.

Network congestion would affect multiple protocols, not just ICMP.

Thus, blocked ICMP is the correct interpretation.

Question #:48

Hacking]

In Dallas, Texas, ethical hacker Ethan Brooks is hired by Lone Star Credit Union to assess the security of their online banking portal, which processes customer transactions. During his penetration test, Ethan probes the web server hosting the portal, experimenting with crafted URL requests. He notices that by altering the URL parameters in a specific way, the server returns data from areas of the system that should be restricted, revealing configuration files not intended for public access. Suspecting this behavior indicates a vulnerability, Ethan documents the issue to help the security team strengthen their defenses against potential unauthorized access.

Which technique is Ethan most likely using to uncover the vulnerability in Lone Star Credit Union's web server?

- A. Password Cracking
- B. Web Cache Poisoning
- C. HTTP Response Splitting
- D. Directory Traversal

Answer: D

Explanation

Directory Traversal, also called path traversal, is a web attack in which an attacker manipulates file path input so the server accesses files outside the intended web directory. In CEH guidance on web application attacks, this commonly happens when an application builds a file path from user-controlled input such as a URL parameter that indicates a filename, folder, language pack, template, or download resource. If the server does not properly validate and normalize the supplied path, an attacker can inject traversal sequences such as dot-dot-slash patterns or encoded equivalents to move up directories and retrieve sensitive files.

The scenario describes Ethan changing URL parameters and receiving "data from areas of the system that should be restricted," specifically "configuration files not intended for public access." That is the hallmark outcome of directory traversal: unauthorized read access to files like application configs, environment settings, keys, or server configuration that can later enable deeper compromise. This is not password cracking because no credential guessing or authentication attack is involved. It is not web cache poisoning, which targets shared caching infrastructure to serve poisoned content to other users. It is not HTTP response splitting, which relies on injecting CRLF characters to manipulate response headers and potentially cause caching or XSS side effects.

CEH-aligned remediation focuses on strict allowlisting of permitted file resources, canonicalizing paths before access, rejecting traversal tokens and their encoded forms, using indirect object references instead of raw file paths, and enforcing least-privilege permissions so sensitive configuration files are not web-accessible even if a validation mistake occurs.

Question #:49 - [Network and Perimeter Hacking]

In Denver, Colorado, ethical hacker Sophia Nguyen is hired by Rocky Mountain Insurance to assess the effectiveness of their network security controls. During her penetration test, she attempts to evade the

company's firewall by fragmenting malicious packets to avoid detection. The IT team, aware of such techniques, has implemented a security measure to analyze packet contents beyond standard headers. Sophia's efforts are thwarted as the system identifies and blocks her fragmented packets.

Which security measure is the IT team most likely using to counter Sophia's firewall evasion attempt?

- A. Deep Packet Inspection
- B. Anomaly-Based Detection
- C. Signature-Based Detection
- D. Stateful Packet Inspection

Answer: D

Explanation

Fragmentation is a well-known firewall and IDS evasion technique covered in CEH materials. The attacker breaks a malicious packet into smaller IP fragments so that simple filtering devices, especially those relying mainly on basic header checks or stateless rules, may fail to reconstruct the original payload and therefore miss the malicious content. To counter this, defenses must track packet state and perform reassembly or validation of fragmented traffic so the security control can evaluate the complete communication stream rather than isolated fragments.

Stateful Packet Inspection is the control most aligned with this requirement. A stateful inspection firewall maintains a state table of active connections and monitors traffic as part of an ongoing session. Because it tracks session context, it can handle fragmented packets more effectively by correlating fragments to the original flow and applying policy after reconstructing or normalizing traffic. In CEH-aligned descriptions, this directly reduces the effectiveness of fragmentation-based evasion, overlapping with the concept of traffic normalization that removes ambiguity attackers try to exploit.

Deep Packet Inspection examines payload beyond headers, but the key success factor in stopping fragmentation evasion is state tracking and reassembly, which is characteristic of stateful inspection and state-aware security devices. Signature-based and anomaly-based detection can help detect malicious patterns or unusual behavior, but without reliable reassembly and session context, fragmented payloads may not match signatures and may appear benign in isolation. Therefore, the most likely measure used to identify and block fragmented packets in this scenario is Stateful Packet Inspection.

Question #:50 - [Network and Perimeter Hacking]

A university's online registration system is disrupted by a combined DNS reflection and HTTP Slowloris DDoS attack. Standard firewalls cannot mitigate the attack without blocking legitimate users. What is the best mitigation strategy?

- A. Increase server bandwidth and implement basic rate limiting
- B. Deploy an Intrusion Prevention System (IPS) with deep packet inspection
- C. Configure the firewall to block all incoming DNS and HTTP requests

D. Utilize a hybrid DDoS mitigation service that offers both on-premises and cloud-based protection

Answer: D

Explanation

CEH v13 explains that multi-vector DDoS attacks, especially those combining volumetric reflection (DNS amplification) with application-layer exhaustion (Slowloris), require multi-layered mitigation. Standard firewalls and IPS devices cannot handle large-scale distributed attacks without causing collateral damage to legitimate traffic. CEH emphasizes the need for hybrid DDoS protection, combining on-premises appliances for real-time local filtering with cloud-based scrubbing centers capable of absorbing massive volumetric floods. Cloud scrubbing removes malicious traffic upstream, while on-prem devices mitigate application-layer anomalies. Increasing bandwidth (Option A) is ineffective against reflection attacks. IPS (Option B) cannot handle Slowloris-style partial requests at scale. Blocking all external DNS/HTTP (Option C) would deny service to legitimate users. The correct CEH-aligned solution is hybrid DDoS mitigation services.

Question #:51 - [Wireless Network Hacking]

Which WPA2 vulnerability allows packet interception and replay?

- A. Hole196 vulnerability
- B. KRACK vulnerability
- C. WPS PIN recovery
- D. Weak RNG

Answer: B

Explanation

The KRACK (Key Reinstallation Attack) vulnerability is a critical WPA2 flaw covered extensively in CEH v13 Wireless Network Hacking. KRACK exploits weaknesses in the four-way handshake process, allowing attackers to force reinstallation of encryption keys.

This key reinstallation resets nonces and counters, enabling attackers to decrypt, replay, and forge packets, even on encrypted WPA2 networks. CEH v13 highlights that KRACK does not break encryption mathematically but exploits protocol logic flaws.

Hole196 affects GTK misuse, and WPS PIN attacks target authentication, not replay of encrypted traffic. Weak RNG issues are unrelated to WPA2 replay.

Thus, Option B is correct.

Question #:52 - [System Hacking Phases]

In a highly secure online banking environment, customers report unauthorized access to their accounts despite robust authentication controls. Investigation reveals attackers are using advanced session hijacking techniques to perform fraudulent transactions. Which advanced session-hijacking attack, resembling a scenario-based attack, presents the greatest challenge to detect and mitigate?

- A. Covert Cross-Site Scripting (XSS) attack injecting malicious scripts into banking pages
- B. Man-in-the-Browser (MitB) attack using malicious browser extensions to intercept sessions
- C. Session fixation attack manipulating HTTP session identifiers
- D. Passive sniffing attack capturing encrypted session tokens over unsecured Wi-Fi

Answer: B

Explanation

According to the CEH System Hacking and Web Application Security modules, Man-in-the-Browser (MitB) attacks are among the most sophisticated and difficult session-hijacking techniques to detect. In MitB attacks, malware operates inside the victim's browser, allowing attackers to intercept, modify, or inject transactions after authentication has occurred.

CEH documentation highlights that MitB attacks bypass:

Multi-factor authentication

Encrypted cookies

HTTPS/TLS protections

Because the malicious activity occurs at the browser level, security controls perceive transactions as legitimate.

Option B is correct.

Option A (XSS) is detectable via content security policies.

Option C is mitigated by regenerating session IDs.

Option D is ineffective against encrypted sessions.

CEH emphasizes MitB attacks as a critical threat to online banking systems.

Question #:53 - [Cryptography]

A system analyst wants to implement an encryption solution that allows secure key distribution between communicating parties. Which encryption method should the analyst consider?

- A. Disk encryption

- B. Symmetric encryption
- C. Hash functions
- D. Asymmetric encryption

Answer: D

Explanation

The Certified Ethical Hacker (CEH) Cryptography module explains that one of the primary challenges in encryption is secure key distribution. Asymmetric encryption, also known as public-key cryptography, was specifically designed to address this issue.

In asymmetric encryption, each entity possesses a public key and a private key. The public key can be shared openly, allowing anyone to encrypt data securely, while only the corresponding private key can decrypt it. CEH documentation highlights that this model eliminates the need to transmit secret keys over insecure channels.

Option D is correct because asymmetric encryption enables secure key exchange without prior trust.

Option B (symmetric encryption) requires a shared secret key and suffers from key distribution challenges.

Option A refers to data-at-rest protection, not key exchange.

Option C provides integrity verification, not encryption.

CEH emphasizes that asymmetric encryption underpins secure protocols such as TLS and digital certificates.

Question #:54 - [Information Security and Ethical Hacking Overview]

An ethical hacker conducts testing with full knowledge and permission. What type of hacking is this?

- A. Blue Hat
- B. Grey Hat
- C. White Hat
- D. Black Hat

Answer: C

Explanation

White Hat Hacking is defined in CEH v13 as ethical hacking performed with explicit authorization to identify and remediate vulnerabilities. White hat hackers operate within legal frameworks and contractual agreements.

Grey hats act without permission but without malicious intent. Black hats conduct illegal attacks. Blue hats are external testers invited to find bugs before product release.

Thus, Option C is correct.

Question #:55 - [Security Operations and Incident Response]

During a quarterly vulnerability management review at RedCore Motors, Priya finalizes the deployment of Nessus Essentials across the company's IT infrastructure. The solution is selected for its ability to support diverse technologies including operating systems, databases, web servers, and virtual environments. While preparing a training session for junior analysts, Priya asks them to identify a capability that Nessus Essentials is specifically designed to provide as part of its scanning process.

Which capability is Nessus Essentials specifically designed to provide?

- A. Patch management for operating systems and third-party applications
- B. High-speed asset discovery
- C. Checks for outdated versions across a wide range of server and service technologies
- D. Agent-based detection

Answer: C

Explanation

The correct choice is C because Nessus Essentials is fundamentally a vulnerability assessment scanner. Its core purpose is to identify security weaknesses by checking systems and services against a large vulnerability knowledge base, which includes detecting outdated or vulnerable versions of operating systems, server software, databases, web servers, and common network services. In practical scanning, Nessus performs remote checks such as banner/version identification, configuration and patch-level assessment (where possible), and vulnerability plugin checks to flag software releases that are known to be insecure or end-of-life. This directly matches the scenario emphasis: supporting “diverse technologies including operating systems, databases, web servers, and virtual environments,” and asking for a capability it provides “as part of its scanning process.”

Why the other options are incorrect:

A (Patch management) is not what Nessus Essentials is designed to do. Nessus identifies missing patches and vulnerabilities, but it does not serve as an operating system and third-party application patch deployment platform.

B (High-speed asset discovery) is more characteristic of dedicated asset discovery/attack surface tools or broader platform features; while Nessus can discover hosts during scans, “high-speed asset discovery” is not the defining, primary capability being tested here.

D (Agent-based detection) refers to endpoint agents running locally for continuous monitoring. Nessus Essentials is primarily used for scanner-driven vulnerability assessment; agent-based functionality is a

separate approach/tooling concept and not the main Essentials scanning capability being targeted in this question.

Therefore, the best answer is C: Nessus Essentials is designed to scan and identify vulnerabilities, including detecting outdated/vulnerable versions across many server and service technologies.

Question #:56 - [Network and Perimeter Hacking]

During a review for DoS threats, several IP addresses generate excessive traffic. Packet inspection shows the TCP three-way handshake is never completed, leaving many connections in a SYN_RECEIVED state and consuming server resources without completing sessions. What type of DoS attack is most likely occurring?

- A. SYN Flood
- B. Ping of Death
- C. UDP Flood
- D. Smurf Attack

Answer: A

Explanation

In the CEH Denial-of-Service and Network Attacks coverage, a SYN flood is a classic TCP-based DoS technique that exploits the TCP connection establishment process. In a normal handshake, the client sends SYN, the server replies SYN/ACK, and the client completes with ACK. A SYN flood deliberately sends a high volume of SYN packets (often spoofed) but never completes the final ACK. As CEH describes, this leaves the server holding many half-open connections in SYN_RECEIVED, consuming memory and connection table resources (backlog queue). When the backlog fills, legitimate clients cannot establish connections, degrading availability.

The indicators in your scenario align exactly with CEH's SYN flood fingerprints: incomplete handshakes and accumulation of half-open connections. The goal is resource exhaustion at the connection-management layer rather than bandwidth saturation.

Option B (Ping of Death) involves malformed/oversized ICMP packets and does not match SYN_RECEIVED behavior. Option C (UDP flood) targets UDP services/ports and creates different symptoms (high UDP traffic, ICMP unreachable messages, service degradation) without half-open TCP states. Option D (Smurf) is ICMP-based amplification via broadcast addresses—again unrelated to incomplete TCP handshakes.

CEH also notes mitigations such as SYN cookies, increasing backlog, reducing SYN-RECEIVED timers, rate limiting, and upstream filtering—further reinforcing that the described event is a SYN flood.

Question #:57 - [System Hacking Phases]

During a forensic investigation of an attack on a media company in New York, analysts discovered that a non-privileged process loaded a malicious library instead of the intended library because the attacker placed the rogue file in a directory Windows searched before the legitimate location. When the trusted application

started, the attacker's code executed with the application's privileges. No registry changes or kernel exploits were involved. Which technique most likely enabled the privilege escalation?

- A. Privilege Escalation by Exploiting Vulnerabilities
- B. Privilege Escalation Using DLL Hijacking
- C. Access Token Manipulation
- D. Privilege Escalation by Bypassing User Account Control

Answer: B

Explanation

This scenario is a classic example of DLL hijacking (also called DLL search order hijacking). On Windows, when an application attempts to load a required DLL without using a fully qualified path, the operating system searches for that DLL in a defined search order (including, in many cases, the application directory and other locations that may be writable by a low-privileged user). If an attacker can place a malicious DLL with the same name as the expected library into a directory that is searched before the legitimate DLL's location, Windows will load the attacker's DLL first. When the trusted application starts, the malicious DLL is loaded into the process, causing the attacker's code to execute in the context and privileges of that application.

The question's clues align tightly with DLL hijacking:

A "non-privileged process loaded a malicious library instead of the intended library" indicates a library preloading/search-order issue rather than exploiting a kernel bug.

The attacker "placed the rogue file in a directory Windows searched before the legitimate location," which directly describes search order manipulation.

"When the trusted application started, the attacker's code executed with the application's privileges" reflects how DLL hijacking can lead to privilege escalation when the target process runs with higher privileges (e.g., as admin or SYSTEM).

"No registry changes ... were involved" helps rule out techniques like certain COM hijacks or registry-based persistence and also points away from UAC bypass methods that often rely on registry keys or auto-elevated behaviors.

Why the other options don't fit:

Exploiting vulnerabilities (A) is too generic and would typically reference a software flaw (buffer overflow, kernel exploit, etc.).

Access token manipulation (C) involves stealing/impersonating tokens, not DLL search order behavior.

Bypassing UAC (D) targets elevation prompts and auto-elevation mechanisms, not DLL loading precedence.

Therefore, the technique is B. Privilege Escalation Using DLL Hijacking.

Question #:58 - [Mobile Platform and IoT Hacking]

Attackers abused Android Debug Bridge (ADB) to issue unauthorized commands. What is the strongest countermeasure?

- A. Enforce VPN usage
- B. Adopt biometric authentication
- C. Disable ADB except in strictly controlled environments
- D. Frequently update MDM systems

Answer: C

Explanation

Android Debug Bridge (ADB) is a powerful debugging interface that, if misconfigured, allows attackers to execute commands remotely. CEH v13 identifies exposed ADB as a critical mobile security risk, especially in enterprise environments.

The most effective countermeasure is to disable ADB entirely, except when explicitly required for development or troubleshooting, and only within tightly controlled environments. This directly removes the attack vector.

VPNs and biometrics improve security but do not prevent ADB abuse. Updating MDM systems is important but does not eliminate the risk if ADB remains enabled.

CEH v13 explicitly recommends strict ADB control as a best practice. Therefore, Option C is the correct answer.

Question #:59 - [Reconnaissance Techniques]

You are a security analyst conducting a footprinting exercise for a new client to gather information without direct interaction. After using search engines and public databases, you consider using Google Hacking (Google Dorking) techniques to uncover further vulnerabilities. Which option best justifies this decision?

- A. Google Hacking can help locate phishing websites that mimic the client's website.
- B. Google Hacking can help discover hidden organizational data from the Deep Web.
- C. Google Hacking can help identify weaknesses in the client's website code.
- D. Google Hacking can assist in mapping the client's internal network structure.

Answer: C

Explanation

The Certified Ethical Hacker (CEH) Footprinting and Reconnaissance module defines Google Hacking, also known as Google Dorking, as the use of advanced search operators to uncover sensitive information unintentionally exposed on the public internet. This technique remains passive, making it ideal during early reconnaissance.

Google Hacking can reveal:

Exposed configuration files

Backup files (.bak, .old, .zip)

Error messages and stack traces

Source code fragments and scripting errors

These findings often indicate coding weaknesses or insecure configurations within a web application. CEH explicitly highlights Google Dorking as an effective way to identify web application weaknesses without scanning or exploiting the target directly.

Option C is correct because Google Hacking is commonly used to identify coding and configuration weaknesses exposed through indexed files.

Option A may be possible indirectly but is not the primary justification.

Option B is incorrect because Google does not index the Deep Web.

Option D involves internal network discovery, which Google Hacking cannot directly achieve.

CEH emphasizes Google Hacking as a powerful passive reconnaissance technique for discovering exposed vulnerabilities.

Question #:60 - [Web Application Hacking]

Which advanced session hijacking technique is the most difficult to detect and mitigate?

- A. Credential stuffing
- B. Clickjacking
- C. CSRF
- D. Session replay attack

Answer: D

Explanation

Session Replay Attacks are highlighted in CEH v13 Web Application Hacking as one of the most sophisticated and difficult-to-detect session hijacking techniques. In this attack, adversaries capture valid session tokens or encrypted session identifiers and replay them to impersonate legitimate users.

Unlike credential stuffing, which relies on login attempts and can be detected through authentication anomalies, session replay occurs after authentication, using legitimate session artifacts. Clickjacking and CSRF manipulate user interactions but do not directly hijack session tokens.

CEH v13 explains that session replay attacks are especially dangerous in environments where session tokens are predictable, long-lived, or improperly bound to client attributes such as IP address or device fingerprint. Because the attacker reuses valid session data, traditional detection mechanisms often fail.

The replayed session appears legitimate to the server, making fraud detection extremely difficult without advanced behavioral analytics. This makes session replay attacks particularly effective in online retail environments where transactions are frequent and time-sensitive.

Thus, Option D correctly identifies the most challenging attack.

Question #:61 - [Network and Perimeter Hacking]

A web server was compromised through DNS hijacking. What would most effectively prevent this in the future?

- A. Changing IP addresses
- B. Regular patching
- C. Implementing DNSSEC
- D. Using LAMP architecture

Answer: C

Explanation

DNS hijacking occurs when attackers manipulate DNS responses to redirect traffic to malicious servers. CEH v13 clearly identifies DNSSEC (Domain Name System Security Extensions) as the primary defense against such attacks.

DNSSEC adds cryptographic signatures to DNS records, enabling clients to verify authenticity and integrity of DNS responses. Without DNSSEC, attackers can spoof DNS responses even if servers are fully patched.

Changing IP addresses and using LAMP do not address DNS trust. Patching is essential but does not prevent DNS spoofing.

CEH v13 explicitly recommends DNSSEC for preventing cache poisoning and DNS hijacking attacks, making Option C the correct answer.

Question #:62 - [Wireless Network Hacking]

A penetration tester is assessing the security of a corporate wireless network that uses WPA2-Enterprise encryption with RADIUS authentication. The tester wants to perform a man-in-the-middle attack by tricking wireless clients into connecting to a rogue access point. What is the most effective method to achieve this?

- A. Set up a fake access point with the same SSID and use a de-authentication attack
- B. Use a brute-force attack to crack the WPA2 encryption directly
- C. Perform a dictionary attack on the RADIUS server to retrieve credentials
- D. Execute a Cross-Site Scripting (XSS) attack on the wireless controller's login page

Answer: A

Explanation

WPA2-Enterprise networks authenticate clients through 802.1X using a RADIUS server. A common attack method described in CEH training is to create an evil-twin access point broadcasting the same SSID as the legitimate one. Combined with de-authentication frames, clients are forced off the real AP and automatically reconnect to the stronger rogue AP. This allows the attacker to capture authentication exchanges for later misuse, including credential harvesting or EAP-based downgrade attacks.

Question #:63 - [Cryptography]

You are Riley, an incident responder at NovaEx Crypto in San Antonio, Texas, tasked with investigating a recent double-spend reported by a retail merchant that accepts the exchange's token. Your telemetry shows that a reseller node used by the merchant received blocks only from a small, fixed set of peers for several hours and accepted a conflicting history that later allowed the attacker to reverse a confirmed payment. The attacker appears to have controlled which peers that node communicated with and supplied it a private chain until they were ready to reveal it. Which blockchain attack does this behavior most closely describe?

- A. Finney Attack
- B. DeFi Sandwich Attack
- C. 51% Attack
- D. Eclipse Attack

Answer: D

Explanation

The behavior described most closely matches an Eclipse attack. In an eclipse attack, an adversary isolates a victim node by controlling its peer connections so that the node communicates only with attacker-controlled (or attacker-influenced) peers. Once isolated, the attacker can feed the victim a manipulated view of the blockchain—such as withholding blocks, delaying transactions, or presenting an alternative chain history. This can enable downstream impacts like double-spending against merchants who rely on that node's view for confirmation.

The scenario's strongest indicators are:

The node "received blocks only from a small, fixed set of peers for several hours," suggesting abnormal peer diversity and potential isolation.

The attacker "controlled which peers that node communicated with," which is essentially the definition of eclipsing a node.

The node "accepted a conflicting history" and the attacker supplied "a private chain until they were ready to reveal it," consistent with feeding the victim a tailored chain view and then releasing/realigning it to profit from reversed payments.

Why the other options are less fitting:

A Finney attack (A) involves a miner pre-mining a block containing a spend, making a payment to a merchant, and then releasing the pre-mined block to invalidate the merchant's transaction—this doesn't require isolating a specific node's peers for hours.

A DeFi sandwich attack (B) is a mempool/MEV tactic on decentralized exchanges involving front-running and back-running, unrelated to isolating node peer connections or feeding a private chain.

A 51% attack (C) involves controlling a majority of network hash power/stake to rewrite history at network scale. The scenario emphasizes isolation of a particular merchant-related node via peer control rather than majority network control.

Therefore, the attack is best identified as D. Eclipse Attack.

Question #:64 - [System Hacking Phases]

A penetration tester discovers that a system is infected with malware that encrypts all files and demands payment for decryption. What type of malware is this?

- A. Worm
- B. Spyware
- C. Keylogger
- D. Ransomware

Answer: D

Explanation

Ransomware encrypts user data and extorts payment for restoration. CEH covers ransomware as a major threat in system hacking, highlighting encryption-based extortion as its defining behavior.

Question #:65 - [Malware Threats]

During a simulated attack against a university's IT network in California, ethical hacker Sophia deploys custom malicious code onto one lab workstation. Without requiring further user interaction, she observes the malware automatically copying itself into shared folders and spreading through weak admin credentials. Within a short time, dozens of computers across multiple departments are infected with the same payload, even though only one machine was initially targeted.

Which type of malware is Sophia most likely demonstrating?

- A. Logic Bomb
- B. Worm
- C. Backdoor
- D. Fileless Malware

Answer: B

Explanation

The correct answer is B. Worm because the defining behavior described is self-replication and autonomous propagation across multiple systems without requiring additional user interaction after the initial infection. In CEH-aligned malware classifications, a worm is a standalone malicious program that can spread automatically over networks by copying itself to other hosts. Worms commonly leverage shared resources (such as shared folders), weak configurations, and credential weaknesses (such as weak administrative passwords or credential reuse) to move laterally and infect additional machines at scale.

The scenario includes multiple classic worm characteristics: (1) only one workstation is initially targeted, (2) the malware then “automatically copies itself into shared folders,” and (3) it spreads using “weak admin credentials,” resulting in rapid infection of “dozens of computers.” That pattern fits worm propagation mechanisms such as exploiting administrative shares, remote execution through obtained credentials, and leveraging network-accessible paths to drop copies of itself. The key discriminator is automation: after initial placement, the malware does the rest, scanning for reachable systems or shares and replicating to them without needing a user to click attachments or run the payload again.

Why the other options are not correct: a logic bomb is typically dormant code that triggers a malicious action when a specific condition or time is met; it is not defined by self-propagation. A backdoor provides unauthorized access for later control, but it does not inherently replicate across the network on its own. Fileless malware emphasizes execution primarily in memory using legitimate tools (e.g., PowerShell/WMI) and minimal disk artifacts; while fileless techniques can be used for lateral movement, the scenario’s emphasis is on the malware copying itself into shared folders and spreading widely, which is the hallmark of a worm.

Therefore, Sophia is most likely demonstrating a worm.

Question #:66 - [Security Operations and Incident Response]

Systems are communicating with unknown external entities, raising concerns about exfiltration or malware. Which strategy most directly identifies and mitigates the risk?

- A. Aggressive zero-trust shutdown
- B. Deep forensic analysis
- C. Behavioral analytics profiling normal interactions
- D. Employee awareness training

Answer: C

Explanation

CEH v13 highlights behavioral analytics as one of the most effective techniques for identifying ambiguous or stealthy threats such as data exfiltration, command-and-control traffic, and insider abuse. When interactions appear suspicious but not definitively malicious, behavioral profiling provides the most direct visibility.

Behavioral analytics tools establish a baseline of normal system and network behavior, including typical communication patterns, data transfer volumes, destinations, and timing. Deviations from this baseline trigger alerts, allowing analysts to detect previously unknown threats without relying on signatures.

Option C is the most appropriate because it both identifies anomalies and supports continuous mitigation. A full zero-trust shutdown (Option A) is disruptive. Forensics (Option B) is reactive and better suited after confirmation of compromise. Training (Option D) does not address system-level interactions.

CEH v13 emphasizes that modern attacks often blend into normal traffic, making behavioral analysis essential. Therefore, Option C is the correct answer.

Question #:67 - [Network and Perimeter Hacking]

During an internal penetration test within a large corporate environment, the red team gains access to an unrestricted network port in a public-facing meeting room. The tester deploys an automated tool that sends thousands of DHCPDISCOVER requests using randomized spoofed MAC addresses. The DHCP server's lease pool becomes fully depleted, preventing legitimate users from obtaining IP addresses. What type of attack did the penetration tester perform?

- A. DHCP starvation
- B. Rogue DHCP relay injection
- C. DNS cache poisoning
- D. ARP spoofing

Answer: A

Explanation

DHCP starvation is a network-level attack in which an attacker sends a massive number of DHCPDISCOVER requests, each appearing to originate from a different MAC address. CEH courseware explains that DHCP

servers assign IP leases based on unique MAC addresses, and when the lease pool is exhausted, legitimate clients are unable to obtain valid IP configurations. This disrupts network connectivity and can serve as a precursor to deploying a rogue DHCP server, enabling further attacks such as traffic redirection or credential interception. DHCP starvation is different from ARP spoofing, which manipulates MAC-IP mappings, or DNS poisoning, which corrupts domain resolution. Rogue DHCP relay attacks involve forwarding DHCP packets to unauthorized servers, not depleting leases. The scenario described—rapid MAC address spoofing and exhaustion of DHCP leases—matches the precise definition of DHCP starvation as documented in CEH materials.

Question #:68 - [Network and Perimeter Hacking]

Attackers exfiltrate data using steganography embedded in images. What is the best countermeasure?

- A. Block all outbound traffic
- B. Deploy IPS
- C. Monitor outbound traffic for anomalies
- D. Use steganalysis tools

Answer: D

Explanation

CEH v13 explains that steganography-based exfiltration hides data within benign-looking files, making it extremely difficult to detect via firewalls or IPS alone. Blocking all outbound traffic is impractical, and IPS systems are not designed to analyze file content deeply for hidden data.

The most effective countermeasure is steganalysis, which involves inspecting files for statistical anomalies, altered pixel distributions, or hidden payload patterns. CEH v13 identifies steganalysis tools as the only reliable method to detect and decode hidden data.

Traffic monitoring (Option C) helps identify suspicious transfers but cannot confirm steganography. Therefore, Option D is correct.

Question #:69 - [Malware Threats]

During a stealth penetration test for a multinational shipping company, ethical hacker Daniel Reyes gains local access to an engineering workstation and deploys a specialized payload that installs below the operating system. On subsequent reboots, the payload executes before any system-level drivers or services are active, giving Daniel covert control over the machine without triggering antivirus or endpoint detection tools. Weeks later, system administrators report suspicious network activity, but repeated forensic scans fail to locate any malicious processes or user-level traces.

Which type of rootkit did Daniel most likely use to maintain this level of stealth and persistence?

- A. Hypervisor Rootkit

- B. Firmware Rootkit
- C. Kernel-mode Rootkit
- D. Bootkit

Answer: D

Explanation

A bootkit is the rootkit type that best matches the described behavior because it compromises the system boot process and executes before the operating system fully loads, often before many security controls, drivers, and monitoring services start. CEH materials describe bootkits as a highly persistent class of malware that targets components such as the Master Boot Record, Volume Boot Record, or bootloader. By gaining execution at boot time, a bootkit can load malicious code very early, then hook or tamper with OS loading routines, kernel initialization, or security mechanisms. This early execution is exactly what the scenario emphasizes: the payload runs “before any system-level drivers or services are active,” enabling covert control while evading traditional user-mode detection.

This also explains why administrators see suspicious network activity but forensics do not easily find malicious user-level artifacts. Bootkits can hide by manipulating what the OS and security tools can see after startup, including concealing files, processes, registry keys, or even redirecting reads so scanners receive “clean” data. Because the malicious component is anchored in the boot chain, it can survive reboots and remain present even if many OS-level indicators are cleaned.

A kernel-mode rootkit operates within the OS kernel but typically loads after the OS begins booting and drivers initialize. A hypervisor rootkit relies on virtualization to sit beneath the OS at runtime, but the scenario specifically highlights boot-time execution prior to drivers and services. Firmware rootkits persist in BIOS /UEFI or device firmware, which is possible, but the most direct match to “boot process compromise below the OS” in CEH terminology is a bootkit.

Question #:70 - [Cryptography]

An attacker analyzes how small changes in plaintext input affect ciphertext output to deduce encryption key patterns in a symmetric algorithm. What technique is being used?

- A. Differential cryptanalysis
- B. Timing attack
- C. Chosen-ciphertext attack
- D. Brute-force attack

Answer: A

Explanation

The CEH Cryptanalysis module describes differential cryptanalysis as an attack that studies the relationship between differences in input and resulting differences in output to recover secret keys.

- Option A precisely matches this definition.
- Option B relies on execution timing.
- Option C requires ciphertext manipulation.
- Option D exhaustively tests keys.
- CEH lists differential cryptanalysis as a foundational theoretical attack.

Question #:71 - [Cloud Computing]

At a New York-based e-commerce company preparing for Black Friday sales, analyst Sarah evaluates cloud billing practices. She notices that the provider tracks compute hours, storage usage, and bandwidth consumption in detail, enabling the company to pay only for what is consumed while also supporting audits. Which cloud computing characteristic best explains this feature?

- A. Measured service
- B. Broad network access
- C. On-demand self-service
- D. Resource pooling

Answer: A

Explanation

The correct answer is A. Measured service because the scenario describes a core cloud characteristic where resource usage is metered, monitored, controlled, and reported, enabling pay-as-you-go billing and supporting accountability and auditability. In CEH cloud computing coverage (aligned with standard cloud definitions), measured service refers to the cloud provider's ability to automatically track and quantify consumption of resources such as CPU/compute time, storage capacity, memory, and network bandwidth. This metering is fundamental to cloud economics: customers pay based on actual usage rather than fixed, up-front infrastructure costs.

In the Black Friday context, demand is bursty and unpredictable. Measured service allows the organization to scale resources up during peak shopping hours and scale down afterward, while billing remains tied to what was truly consumed. This is especially important for cost control in e-commerce environments where overprovisioning for peak loads on-premises would be expensive and inefficient. Additionally, because the provider records usage in detail, the organization can perform chargeback/showback internally, validate invoices, and maintain evidence for audits and compliance reviews—all of which depend on accurate, granular measurement.

Why the other options are not the best fit: Broad network access describes availability over networks and access via standard mechanisms (not usage tracking). On-demand self-service refers to users provisioning

resources automatically without human interaction from the provider (not billing metering). Resource pooling refers to multi-tenant pooling of provider resources dynamically assigned and reassigned according to demand (again, not the billing/audit measurement function).

Therefore, the feature of detailed tracking of compute hours, storage usage, and bandwidth consumption that supports pay-per-use and auditing is best explained by measured service.

Question #:72 - [Network and Perimeter Hacking]

During a penetration test at Rocky Mountain Insurance in Denver, ethical hacker Sophia Nguyen attempts to evade detection by fragmenting malicious traffic into smaller packets. The IT security team counters her strategy with a system that monitors traffic for deviations from established baselines, flagging behavior that does not match normal network activity. This allows them to stop Sophia's evasion attempts in real time.

Which detection technique is the IT team most likely using in this case?

- A. Deep Packet Inspection
- B. Stateful Packet Inspection
- C. Signature-Based Detection
- D. Anomaly-Based Detection

Answer: D

Explanation

The correct answer is D. Anomaly-Based Detection because the scenario explicitly states that the system “monitors traffic for deviations from established baselines” and flags behavior that does not match normal network activity. In CEH-aligned IDS/IPS concepts, anomaly-based detection (also called behavior-based detection) works by building a profile of what “normal” looks like—such as typical packet rates, protocol usage, session patterns, timing, connection distributions, and expected traffic flows—and then identifying events that deviate significantly from those norms. This makes it particularly useful against evasion techniques and previously unseen patterns, because it is not limited to matching known signatures.

Sophia's tactic—packet fragmentation—is a classic evasion approach intended to bypass simplistic inspection systems by splitting malicious payloads or attack patterns across multiple fragments so they are harder to reconstruct or match. A baseline-driven anomaly system can still detect the attack because fragmentation itself (or the resulting traffic characteristics) may appear abnormal: unusual fragment counts, unexpected fragment sizes, atypical reassembly behavior, irregular session characteristics, or protocol violations compared to normal traffic profiles. Because the detection is based on behavior rather than a fixed pattern, it can trigger alerts even if the exact malicious payload is not recognized.

Why the other options are less correct: Signature-based detection relies on known patterns and may be evaded when attackers modify payloads or fragment traffic to avoid matches. Stateful packet inspection tracks connection state and can help with session validation, but it is not inherently a baseline deviation detector. Deep packet inspection inspects packet contents and can sometimes reassemble fragments depending on implementation, but the question's key clue is “deviations from established baselines,” which directly points to anomaly-based detection.

Therefore, the IT team is most likely using anomaly-based detection.

Question #:73 - [Social Engineering]

On a busy Monday morning at Horizon Financial Services in Chicago, accounts assistant Clara Nguyen receives an email that appears to come from the company's IT department. The email, addressed specifically to Clara and mentioning her role in the accounts team, warns of a critical system vulnerability requiring immediate action. It includes a link to a login page resembling the company's internal portal, urging her to update her credentials to prevent account suspension. The email's sender address looks legitimate, but Clara notices a slight misspelling in the domain name.

What social engineering technique is being attempted against Clara?

- A. Spear Phishing
- B. Impersonation
- C. Quid Pro Quo
- D. Vishing

Answer: A

Explanation

The attack described is spear phishing because it is a targeted phishing attempt crafted for a specific individual using personal and organizational context. In CEH social engineering coverage, spear phishing differs from generic phishing by its customization: the attacker addresses the victim by name, references the victim's job function, and tailors the message to create credibility and urgency. Here, the email is addressed specifically to Clara and mentions her role in the accounts team, which increases the likelihood she will trust the message and comply.

The message uses classic phishing psychological triggers emphasized in CEH materials: urgency and fear. By claiming a "critical system vulnerability" and threatening account suspension, the attacker pressures Clara to act quickly and ignore verification steps. The inclusion of a link to a login page that "resembles the company's internal portal" indicates credential harvesting, where the attacker's goal is to capture usernames and passwords or other authentication tokens. The subtle misspelling in the sender's domain is a common indicator of lookalike or typosquatting domains used to mimic legitimate corporate email addresses and bypass casual inspection.

The other options do not match as well. Impersonation is a broader category, but spear phishing is the specific technique using an email lure with personalization. Quid pro quo involves offering a benefit or service in exchange for information, which is not present. Vishing is voice-based phishing via phone calls, not email. Recommended defenses in CEH guidance include verifying sender domains, using out-of-band confirmation with IT, enabling email security controls like SPF, DKIM, and DMARC, and enforcing phishing awareness training and MFA to reduce credential theft impact.

Question #:74 - [Malware Threats]

Infected systems receive external instructions over HTTP and DNS, with fileless payloads modifying system components. What is the most effective action to detect and disrupt this malware?

- A. Update antivirus signatures regularly
- B. Allow only encrypted traffic via proxies
- C. Block common malware ports
- D. Use behavioral analytics to monitor abnormal outbound behavior

Answer: D

Explanation

This scenario describes fileless malware using covert command-and-control (C2) channels over commonly allowed protocols such as HTTP and DNS, a technique heavily emphasized in CEH v13 Malware Threats. Such malware avoids writing files to disk and instead leverages memory, legitimate system tools, and trusted protocols to evade traditional defenses.

Signature-based antivirus updates (Option A) are ineffective against fileless malware because there are no static artifacts to match. Blocking known malware ports (Option C) is also ineffective, as the malware intentionally uses ports 80 and 53, which must remain open for normal business operations. Restricting plain HTTP (Option B) may reduce visibility but does not stop DNS tunneling or encrypted malicious traffic.

CEH v13 identifies behavioral analytics as the most effective countermeasure against advanced malware. Behavioral solutions establish a baseline of normal system and network activity, then detect anomalies such as:

Unusual outbound DNS query patterns

Abnormal HTTP beaconing intervals

Legitimate applications behaving suspiciously

PowerShell or system tools generating network traffic unexpectedly

By monitoring how systems behave rather than what files exist, behavioral analytics can identify stealthy C2 communications and disrupt them early. Therefore, Option D is the most effective and CEH-aligned response.

Question #:75 - [Security Operations and Incident Response]

A penetration tester completes a vulnerability scan showing multiple low-risk findings and one high-risk vulnerability tied to outdated server software. What should the tester prioritize as the next step?

- A. Perform a brute-force attack on the server to gain access
- B. Ignore the high-risk vulnerability and proceed with testing other systems

- C. Focus on exploiting the low-risk vulnerabilities first
- D. Verify if the high-risk vulnerability is exploitable by checking for known exploits

Answer: D

Explanation

CEH methodology stresses prioritization based on risk, exploitability, and business impact. High-severity vulnerabilities—especially those related to outdated or unsupported server software—are frequently associated with known, publicly documented exploits. The proper next step after identifying such vulnerabilities is to confirm exploitability safely, typically by researching available exploit code, validating version-specific weaknesses, and determining whether the vulnerability can be successfully leveraged under the defined scope of engagement. CEH highlights that exploitation attempts must be evidence-driven, not arbitrary, and focusing on high-risk vulnerabilities allows testers to demonstrate meaningful security impacts. Brute-forcing (Option A) is unnecessary and high-noise. Ignoring or deprioritizing the high-risk finding (Options B and C) contradicts CEH risk-based assessment principles. Therefore, verifying exploitability of the high-risk vulnerability is the correct step.

Question #:76 - [Reconnaissance Techniques]

A penetration tester needs to identify open ports and services on a target network without triggering the organization's intrusion detection systems, which are configured to detect high-volume traffic and common scanning techniques. To achieve stealth, the tester decides to use a method that spreads out the scan over an extended period. Which scanning technique should the tester employ to minimize the risk of detection?

- A. Use a stealth scan by adjusting the scan timing options to be slow and random
- B. Perform a TCP SYN scan using a fast scan rate
- C. Execute a UDP scan targeting all ports simultaneously
- D. Conduct a TCP Xmas scan sending packets with all flags set

Answer: A

Explanation

The CEH v13 content explains that stealth scanning involves modifying scan timing parameters to reduce packet frequency, randomize intervals, and avoid recognizable patterns typically flagged by intrusion detection systems. Slow, randomized timing—often achieved with Nmap's T0 or T1 timing templates—prevents bursts of traffic and allows scans to blend into normal network noise. IDS/IPS systems tuned for high-volume events may fail to detect such gradual reconnaissance. Fast SYN scans generate distinctive patterns easily identified by security monitoring tools. UDP scans, especially across all ports, produce high traffic volume and are extremely noisy. Xmas scans, although sometimes used for stealth against stateless filters, are still signature-detectable and inappropriate when stealth over time is required. Therefore, applying slow, randomized timing options aligns with CEH-approved reconnaissance techniques for evading detection while enumerating open ports.

Question #:77 - [Mobile Platform and IoT Hacking]

At a smart retail outlet in San Diego, California, ethical hacker Sophia Bennett assesses IoT-based inventory sensors that synchronize with a cloud dashboard. She discovers that sensitive business records are sent across the network without encryption and are also stored in a retrievable format on the provider's cloud platform.

Which IoT attack surface area is most directly demonstrated in this finding?

- A. Insecure ecosystem interfaces
- B. Insecure data transfer and storage
- C. Insecure network services
- D. Insecure default settings

Answer: B

Explanation

The finding most directly demonstrates insecure data transfer and storage. The scenario includes two explicit problems: (1) sensitive business records are transmitted “across the network without encryption,” and (2) the same records are “stored in a retrievable format” in the cloud platform. Those two conditions map exactly to data-in-transit and data-at-rest weaknesses. When IoT devices transmit sensitive data without encryption (e.g., plain HTTP, unprotected MQTT, insecure proprietary protocols), attackers who gain network visibility can intercept, read, and potentially modify that data. Similarly, when cloud-stored data is kept in an easily retrievable or improperly protected form (e.g., weak access controls, lack of encryption at rest, overly permissive storage buckets, exposed APIs), attackers can access business records long after transmission.

In IoT ecosystems, data typically flows from sensors to gateways, then to cloud dashboards and analytics services. If encryption and strong access control are not consistently applied across these hops, confidentiality and integrity are at risk. This can lead to competitive harm (exposed inventory/business records), privacy impact (if customer data is included), and operational disruption (tampered records leading to wrong decisions). The scenario is not about the IoT device exposing services like Telnet/FTP (network services), nor about default passwords; it is specifically about how data is transported and stored.

Why the other options are less accurate:

Insecure ecosystem interfaces (A) focuses on APIs, web/mobile apps, and cloud interfaces; while cloud storage access might involve interfaces, the core weakness described is lack of encryption and retrievable storage, which is more directly the data transfer/storage category.

Insecure network services (C) refers to exposed services/ports on IoT devices, not data confidentiality across the pipeline.

Insecure default settings (D) relates to factory defaults (passwords, open ports, insecure configs), not specifically unencrypted transport and weak storage protection.

Therefore, the correct answer is B. Insecure data transfer and storage.

Question #:78 - [Security Operations and Incident Response]

Bob, a seasoned security analyst at XYZ Aerospace, was investigating a series of misaligned transaction timestamps coming from one of the data archival systems. Suspecting that the server might be syncing with an unstable time source, Bob decided to extract a detailed list of all peer servers associated with the target machine, including metrics such as delay, offset, and jitter, to determine whether the issue stemmed from time synchronization drift.

Which of the following commands should Bob use to retrieve this information?

- A. `ntptrace [-n] [-m maxhosts] [servername/IP_address]`
- B. `ntpq -p [host]`
- C. `ntpd -n [-s] [-c command] [host] [...]`
- D. `ntpq [-n] [-l] [-c command] [host] [...]`

Answer: B**Explanation**

The command that best matches Bob's goal is `ntpq -p`. In CEH-aligned coverage of network services and operational troubleshooting, NTP is highlighted as a critical dependency because inaccurate time can break authentication, distort logs, and cause incorrect transaction ordering. When investigating suspected time drift, the most useful first step is to view the active NTP associations and their quality metrics. The `ntpq` utility queries an NTP daemon and reports peer status and performance data. Specifically, `ntpq -p` displays a peer table that includes each configured or discovered time source along with fields such as delay, offset, and jitter. These values help determine whether the server is locked to a stable source or being influenced by a poor or rogue time server. Offset indicates how far the local clock differs from the peer, delay reflects network latency to the peer, and jitter shows the variability in timing measurements, all of which are directly mentioned in the question.

Option A, `ntptrace`, is used to trace the chain of NTP servers back to a reference clock and is useful for understanding hierarchy, but it does not provide the detailed delay, offset, and jitter peer metrics in the same way. Option C, `ntpd`, is an older monitoring tool that can query NTP, but CEH references more commonly emphasize `ntpq` for peer statistics and associations. Option D is a generic `ntpq` invocation with interactive command support, but the `-p` option is the explicit mode that outputs the peer list with the required metrics.

Question #:79 - [Wireless Network Hacking]

You are an ethical hacker at SecureNet Solutions, conducting a penetration test for BlueRidge Manufacturing in Denver, Colorado. While auditing their wireless network, you observe that the access point uses a security protocol that employs the RC4 algorithm with a 24-bit initialization vector IV to encrypt data between network clients. Based on the observed encryption characteristics, which wireless encryption protocol is the access point using?

- A. WPA
- B. WPA2

- C. WEP
- D. WPA3

Answer: C

Explanation

WEP is the only option that matches the combination of RC4 and a 24-bit initialization vector. In CEH materials, WEP is described as an early Wi-Fi security standard that uses the RC4 stream cipher together with a short 24-bit IV that is concatenated with a shared secret key to form the per-packet RC4 key stream. The critical weakness is that a 24-bit IV is far too small for busy networks. Because there are only about 16.7 million possible IV values, IV reuse occurs quickly, especially under high traffic. When IVs repeat, the same RC4 key stream can be reused, allowing attackers to apply statistical attacks against captured packets and recover the WEP key. CEH emphasizes that the problem is not only IV reuse but also weaknesses in how WEP uses RC4 with IVs, enabling practical key recovery using readily available tools once enough packets are collected.

WPA and WPA2 improved on WEP by introducing stronger key management and integrity protections. WPA uses TKIP, which still relies on RC4 in many deployments, but it does not use a simple 24-bit IV in the same weak manner as WEP and includes per-packet key mixing and additional integrity checks. WPA2 and WPA3 move away from RC4 entirely, using AES-based protections such as CCMP for WPA2 and more modern enhancements in WPA3. Therefore, the observed RC4 with a 24-bit IV precisely identifies WEP.

Question #:80 - [Network and Perimeter Hacking]

During a penetration test at a technology startup in Austin, Texas, an ethical hacker is tasked with evaluating defenses against stealthy scanning techniques. She selects an approach that involves sending TCP packets with no flags, relying on the way target systems respond to infer whether ports are open or closed. This allows her to remain less visible to intrusion detection systems compared to a full handshake. Which scanning method is she using?

- A. TCP Connect Scan
- B. FIN Scan
- C. NULL Scan
- D. ACK Scan

Answer: C

Explanation

The method described—sending TCP packets with no flags set—is a NULL scan. In TCP header terminology, a NULL packet has all control flags cleared (no SYN, ACK, FIN, RST, PSH, URG). The scanner then interprets the target's response behavior to infer port state. Traditionally, for many TCP/IP stacks, a closed

port responds with RST, while an open port may respond with no reply (silence) because the packet does not correspond to any valid state in the TCP state machine. This behavior can vary by OS and filtering devices, but the defining characteristic is the “no flags” probe.

The scenario also highlights stealth: compared to a TCP connect scan, which completes a full three-way handshake and is easily logged, NULL scans can be less conspicuous because they avoid a normal connection setup. Some intrusion detection systems focus heavily on repeated SYN handshakes or completed connections; unusual flag scans may slip through weak detection, though modern IDS/IPS can still detect them.

Why the other options are incorrect:

TCP Connect Scan (A) uses the operating system’s connect() call to establish a full TCP connection; it is not a “no flags” technique and is generally noisier.

FIN Scan (B) sends packets with the FIN flag set; it is a different “stealth” scan type, but not “no flags.”

ACK Scan (D) sends packets with the ACK flag set and is typically used to map firewall rules (filtered vs unfiltered), not to determine open vs closed ports in the same way, and again it is not “no flags.”

Therefore, the scanning method is C. NULL Scan.

Question #:81 - [Network and Perimeter Hacking]

During a penetration test at a manufacturing company in Detroit, Amanda, a senior security consultant, scans several legacy Linux servers. On one host, she discovers an open port used for file transfer that allows anonymous login. Once connected, she is able to view the directory structure and check available files, which helps her identify potential sensitive information exposure. She also notices background traffic on a UDP service related to NetBIOS name lookups, but she continues probing the file transfer service to confirm user access weaknesses.

Which ports and services should Amanda prioritize for this enumeration activity?

- A. TCP 23 and UDP 137, 138
- B. TCP 21 and UDP 137
- C. TCP 25 and UDP 138
- D. TCP 139 and UDP 137, 138

Answer: B

Explanation

Amanda’s primary enumeration focus is a “file transfer” service that allows anonymous login and directory listing. That clearly indicates FTP, which runs on TCP port 21 (control channel). Anonymous FTP misconfiguration is a well-known exposure risk because it can allow unauthenticated users to browse or

download files, and sometimes even upload content depending on permissions. Enumerating FTP typically includes validating anonymous access, listing directories, checking readable file contents, identifying writable folders, and verifying whether the server leaks banners, system type, or user/account hints.

The scenario also mentions background UDP traffic related to NetBIOS name lookups, which corresponds to UDP port 137 (NetBIOS Name Service). While NetBIOS is more common in Windows environments, it can still appear on networks with mixed systems or legacy compatibility services. The question asks which ports and services to prioritize given her enumeration activity, which includes FTP access weaknesses and noticing NetBIOS name lookup traffic.

Option B (TCP 21 and UDP 137) matches both:

TCP 21 = FTP control port, directly tied to anonymous login and directory enumeration.

UDP 137 = NetBIOS Name Service, matching the observed name-lookup traffic.

Why the other options don't fit:

TCP 23 is Telnet (A), not the described file transfer service.

TCP 25 is SMTP (C), unrelated to anonymous file transfer login.

TCP 139 is NetBIOS Session Service (D), more associated with SMB over NetBIOS, not specifically with UDP name lookups, and it omits the FTP port central to her activity.

Therefore, the correct choice is B. TCP 21 and UDP 137.

Question #:82 - [Web Application Hacking]

In the crisp mountain air of Denver, Colorado, ethical hacker Lila Chen investigates the security framework of MediVault, a U.S.-based healthcare platform used by regional clinics to manage patient data. During her review, Lila discovers that sensitive records are weakly protected, allowing attackers to intercept and manipulate the information in transit. She warns that such weaknesses could be exploited to commit credit-card fraud, identity theft, or similar crimes. Further analysis reveals that MediVault is vulnerable to well-documented flaws such as cookie snooping and downgrade attacks.

Which issue is MOST clearly indicated?

- A. Broken Access Control
- B. Cryptographic Failures
- C. Security Misconfiguration
- D. Identification and Authentication Failures

Answer: B

Explanation

The best answer is B. Cryptographic Failures because the scenario centers on weak protection of sensitive data in transit, enabling an attacker to intercept and manipulate the information. In CEH-aligned web and application security concepts (and consistent with modern web risk categories), cryptographic failures occur when an application does not properly use cryptography or secure transport protections to ensure confidentiality and integrity of sensitive data. If transport encryption is missing, weak, or incorrectly configured, attackers can perform man-in-the-middle style interception, tamper with traffic, steal session material, and exfiltrate regulated data—leading to outcomes like identity theft and payment card fraud, exactly as described.

The references to cookie snooping and downgrade attacks further reinforce this. Cookie snooping is commonly associated with session cookies being exposed due to insecure transport (for example, lack of HTTPS, mixed content, or cookies missing secure attributes), allowing an attacker on the network path to capture session identifiers and hijack accounts. Downgrade attacks occur when an attacker forces a connection to use weaker security settings (such as older TLS versions or insecure cipher suites) or coerces a fallback from HTTPS to HTTP when protections like HSTS are absent or misapplied. Both issues are tightly linked to improper cryptographic configuration and transport-layer security weaknesses.

Why the other options are not the best match: Broken Access Control concerns authorization—what users are allowed to access—not interception/manipulation of traffic. Identification and Authentication Failures focus on login/session identity mechanisms (passwords, MFA, session handling) but the key failure here is the weakness of cryptographic protection for data in transit. Security Misconfiguration can be a contributing cause (e.g., misconfigured TLS), but the question emphasizes the resulting weakness category—insufficient cryptographic/transport protections—making Cryptographic Failures the most precise answer.

Therefore, MediVault's exposure to interception, manipulation, cookie snooping, and downgrade attacks most clearly indicates Cryptographic Failures.

Question #:83 - [Network and Perimeter Hacking]

During a penetration test for a global e-commerce platform in Dallas, ethical hacker Maria simulates a large-scale DoS campaign. Instead of sending attack traffic directly, she forges requests to multiple open services across the internet. These services unknowingly reply to the victim system, multiplying the amount of traffic hitting the target. Within minutes, the victim's server is overwhelmed by a flood of responses, even though Maria's own machine generated only a small amount of traffic.

Which attack technique is Maria most likely demonstrating?

- A. Smurf Attack
- B. Distributed Reflection Denial-of-Service (DRDoS)
- C. Botnet
- D. NTP Amplification Attack

Answer: B

Explanation

The correct answer is B. Distributed Reflection Denial-of-Service (DRDoS) because the scenario describes the two defining elements of DRDoS: reflection and amplification at scale using third-party systems. Maria “forges requests” (i.e., spoofs the victim’s IP address as the source) to “multiple open services across the internet.” Those services then send their replies to the spoofed source—the victim—so the victim receives a large volume of unsolicited responses. This is reflection: the attacker does not attack the victim directly; instead, the attacker reflects traffic off other servers. The “multiplying the amount of traffic” indicates amplification: many protocols/services respond with packets significantly larger than the request, so the attacker’s small outbound traffic results in a much larger inbound flood against the target.

The mention of “multiple open services” and being overwhelmed by a “flood of responses” is classic DRDoS behavior. From a defender’s perspective, DRDoS attacks are difficult because the traffic often appears to come from legitimate servers, and the victim is receiving replies to requests it never sent. Mitigations include source address validation (BCP 38 anti-spoofing), rate limiting, filtering/ACLs for abused UDP services, and upstream scrubbing/CDN or DDoS protection.

Why the other options are less accurate: Smurf is a specific reflection/amplification attack using ICMP to a broadcast address (now largely mitigated by disabling directed broadcasts). Botnet describes the attacker’s infrastructure (many compromised machines) but not the reflection/amplification mechanism; a botnet can be used to launch many types of DDoS attacks. NTP amplification is one specific DRDoS variant using misconfigured NTP servers (UDP/123). The question describes the broader technique across “multiple open services” rather than naming NTP specifically, so the best match is the general category DRDoS.

Therefore, Maria is demonstrating a Distributed Reflection Denial-of-Service (DRDoS) attack.

Question #:84 - [Cryptography]

Michael, an ethical hacker at a New York-based e-commerce company, is evaluating the security of their online payment system after a recent incident where fraudulent transactions went undetected. His investigation reveals that the system uses an asymmetric encryption algorithm to ensure the authenticity of payment confirmations. He finds that the algorithm employs a public-key cryptosystem, where the sender signs the transaction with a private key, and the recipient verifies it using a corresponding public key located in a directory. During his test, Michael intercepts a signed message and notices that the algorithm supports modular exponentiation for generating digital signatures, a process critical for verifying the identity of the signatory. He aims to assess if the algorithm’s configuration could be vulnerable to a man-in-the-middle attack due to its key structure.

Which asymmetric encryption algorithm should Michael identify as the one used by the payment system?

- A. Diffie-Hellman
- B. RSA
- C. ElGamal
- D. DSA

Answer: B

Explanation

The algorithm described most accurately matches RSA. CEH cryptography coverage explains that RSA is a widely used public-key cryptosystem that supports both encryption and digital signatures. In a typical RSA-based signature process, the sender generates a hash of the message and applies their private key using modular exponentiation to create a digital signature. The recipient then uses the sender's public key to verify the signature, also through modular exponentiation operations involving large prime numbers and a modulus. The scenario specifically references modular exponentiation for generating digital signatures, which is a defining mathematical operation in RSA.

Diffie-Hellman is primarily a key exchange algorithm and does not provide digital signatures by itself. It enables two parties to establish a shared secret over an insecure channel but does not authenticate messages directly through signing. ElGamal does support encryption and can be adapted for signatures, but in standard CEH-oriented contexts, RSA is the most commonly referenced algorithm for public-key encryption and digital signatures in payment systems. DSA is strictly a digital signature algorithm and does not provide encryption functionality; the prompt describes a broader public-key cryptosystem used for authenticity of payment confirmations, which aligns more directly with RSA's dual capability.

Additionally, RSA's reliance on key pairs stored and retrieved from directories fits the description of public-key verification in enterprise payment infrastructures. Therefore, RSA is the correct identification.

Question #:85 - [Web Application Hacking]

During a red team assessment at Sunshine Credit Union in Miami, ethical hacker Laura demonstrates a weakness in the company's session handling process. She shows that once a user logs in, the same authentication token assigned before login continues to be valid without being refreshed. Laura explains that an attacker could exploit this flaw by tricking a victim into authenticating with a value already known to the attacker, gaining access afterward. To mitigate this risk, the IT team agrees to apply a countermeasure focused on proper session lifecycle management.

Which countermeasure should the IT team implement?

- A. Implement SSL to encrypt all information in transit via the network
- B. Use restrictive cache directives for all the web traffic through HTTP and HTTPS
- C. Regenerate the session ID after a successful login to prevent session fixation attacks
- D. Do not create sessions for unauthenticated users unless necessary

Answer: C

Explanation

The correct answer is C. Regenerate the session ID after a successful login to prevent session fixation attacks because the weakness described is the textbook condition for session fixation. In session fixation, an attacker sets or predicts a victim's session identifier before the victim authenticates (for example, by sending a crafted link containing a session ID, forcing a known token into the victim's browser via a URL parameter, or leveraging an application behavior that creates a session for unauthenticated users). If the application fails to issue a new session identifier after authentication, the attacker can reuse the already-known session ID once the victim logs in, effectively taking over the authenticated session.

The scenario explicitly states that “the same authentication token assigned before login continues to be valid without being refreshed,” and that the attacker could “trick a victim into authenticating with a value already known to the attacker.” Those statements describe session fixation precisely: authentication is “bound” to a pre-existing session identifier rather than a newly generated post-login token. The most direct and widely recommended mitigation is to invalidate the old session and regenerate a fresh session ID immediately after successful authentication (and also after privilege changes such as elevating to an admin role). This breaks the attacker’s knowledge advantage, because even if they forced a pre-login session ID, it becomes useless after login.

Why the other options are less correct: A (SSL/TLS) protects confidentiality and integrity in transit but does not prevent an attacker from fixing a session ID if they can set it through other means. B (restrictive cache directives) helps prevent sensitive pages from being stored in caches but does not address session ID reuse. D can reduce exposure by limiting pre-auth sessions, but many applications legitimately require them (shopping carts, CSRF tokens), and it is not as direct or complete as regenerating the session identifier at authentication boundaries.

Therefore, the correct countermeasure is to regenerate the session ID after login.

Question #:86 - [Web Application Hacking]

A penetration tester alters the "file" parameter in a web application (e.g., `view?file=report.txt`) to `../../../../etc/passwd` and successfully accesses restricted system files. What attack method does this scenario illustrate?

- A. Conduct a brute-force attack to obtain administrative credentials
- B. Use directory traversal sequences in URL parameters to retrieve unauthorized system content
- C. Inject malicious scripts into web pages to manipulate content via XSS vulnerabilities
- D. Exploit buffer overflow issues by injecting oversized data in HTTP request headers

Answer: B

Explanation

CEH v13 explains that directory traversal (also called path traversal) occurs when an application improperly handles user-supplied input used for file path generation. Attackers exploit this by inserting traversal sequences such as `../` beyond the intended directories, gaining access to sensitive files like `/etc/passwd`, configuration data, or source code. The vulnerability arises from missing input validation and failure to restrict file access to safe directories. CEH stresses that directory traversal is common in file handling functions such as `view`, `download`, or `include` operations. Brute-forcing credentials (Option A) is unrelated. XSS (Option C) targets script injection into web pages, not file access. Buffer overflow (Option D) manipulates memory, not file paths. Therefore, the scenario represents classic directory traversal exploitation.

Question #:87 - [Mobile Platform, IoT, and OT Hacking]

As a Certified Ethical Hacker evaluating a smart city project (traffic lights, public Wi-Fi, and water management), you find anomalous IoT network logs showing high-volume data exchange between a specific

traffic light and an external IP address. Further investigation reveals an unexpectedly open port on that traffic light. What should be your subsequent course of action?

- A. Isolate the affected traffic light from the network and perform a detailed firmware investigation
- B. Conduct an exhaustive penetration test across the entire network to uncover hidden vulnerabilities
- C. Analyze and modify IoT firewall rules to block further interaction with the suspicious external IP
- D. Attempt to orchestrate a reverse connection from the traffic light to the external IP to understand the transferred data

Answer: A

Explanation

CEH's approach to suspected compromise aligns with an incident-handling mindset: containment first, then analysis and remediation. In IoT and OT-adjacent environments (smart city infrastructure, SCADA-like components, embedded controllers), CEH emphasizes that suspicious external communications and unexplained open ports may indicate compromise, misconfiguration, exposed management services, or implanted malware/backdoors. Because IoT endpoints often have limited logging and are difficult to reimage safely, the safest next step is to isolate the suspected device to prevent further data exfiltration, command-and-control activity, or lateral movement to other city systems.

Option A best matches CEH guidance: isolate the device and investigate its firmware, services, and configuration, including checking for unauthorized binaries, altered firmware images, insecure default services, and hardcoded credentials. This also preserves evidence and reduces the blast radius.

Option C (blocking the external IP) can be helpful, but it's a partial control: attackers can rotate infrastructure, and the device could still be compromised internally. Option B (full network pen test) is too broad and delays containment when a specific high-risk indicator is already present. Option D (attempting a reverse connection) crosses into active exploitation behavior and is not an appropriate "next step" in a defensive investigation; CEH methodology stresses authorized, controlled testing and prioritizes risk reduction over interacting with suspicious external hosts.

Thus, CEH-aligned best practice is immediate isolation and firmware-level investigation.

Question #:88 - [Web Application Hacking]

A penetration tester discovers that a web application is using outdated SSL/TLS protocols (TLS 1.0) to secure communication. What is the most effective way to exploit this vulnerability?

- A. Conduct a Cross-Site Scripting (XSS) attack on the application
- B. Use a man-in-the-middle (MitM) attack to intercept and decrypt traffic
- C. Perform a brute-force attack on the SSL/TLS handshake
- D. Execute a SQL injection attack on the application's backend

Answer: B**Explanation**

Outdated encryption protocols such as SSL 3.0 and TLS 1.0 contain numerous cryptographic weaknesses, making them susceptible to downgrade attacks, cipher-suite vulnerabilities, and interception. CEH explains that weak SSL/TLS configurations expose encrypted traffic to man-in-the-middle attacks because attackers can exploit vulnerabilities such as BEAST, POODLE, or weak ciphers to decrypt or manipulate data in transit. These flaws compromise confidentiality and integrity, allowing attackers to observe login credentials, session identifiers, or sensitive information. XSS and SQL injection exploit entirely different web vulnerabilities unrelated to encryption strength. Brute-forcing SSL handshakes is computationally infeasible and not relevant. Therefore, a MitM attack targeting the outdated protocol is the most effective exploitation method.

Question #:89 - [Wireless Network Hacking]

You are an ethical hacker at Sentinel Cyberworks, engaged to assess the wireless defenses of HarborTrust Bank in Portland, Oregon. During your assessment, the security team shows you a production system that continuously places selected APs into a passive scan mode, aggregates alarms from multiple wireless controllers into a central engine for forensic storage, and can automatically apply countermeasures (for example, time-sliced channel scanning and remote configuration changes) across the campus when it classifies a nearby device as malicious. Based on the described capabilities, which Wi-Fi security solution is this most consistent with?

- A. WatchGuard Wi-Fi Cloud WIPS
- B. RFProtect
- C. Fern WiFi Cracker
- D. Cisco Adaptive Wireless IPS

Answer: D**Explanation**

The capabilities described match an enterprise Wireless Intrusion Prevention System (WIPS) tightly integrated with WLAN infrastructure: it uses access points as sensors (placing selected APs into passive scan/monitor mode), correlates and aggregates alarms from multiple controllers into a central engine for analysis and forensic retention, and can push automated countermeasures across the campus (such as coordinated channel scanning and remote configuration enforcement) when a device is classified as malicious. This is most consistent with Cisco Adaptive Wireless IPS.

Cisco's adaptive WIPS model uses the existing Cisco wireless architecture (controllers and APs) to provide campus-wide monitoring and enforcement. The phrase "selected APs into a passive scan mode" is a strong indicator of adaptive sensor use—APs can be dedicated or time-sliced for scanning, and the system can coordinate coverage across channels. The centralized engine concept also aligns with enterprise WIPS deployments that collect events and alarms from multiple controllers for correlation and long-term storage, supporting incident investigation and compliance.

Why the other options are less fitting:

Fern WiFi Cracker (C) is an attack/assessment tool, not a production defensive platform, and it does not provide centralized alarm aggregation and automated enterprise countermeasures.

RFProtect (B) is a known wireless security/WIPS solution family, but the question's feature set and wording ("adaptive," APs used for passive scanning, controller-integrated countermeasures) most closely matches Cisco's adaptive WIPS concept.

WatchGuard Wi-Fi Cloud WIPS (A) is a vendor-managed WIPS offering; while it can provide monitoring, the scenario stresses multi-controller aggregation into a central engine and coordinated campus countermeasures via WLAN infrastructure—again aligning best with Cisco's controller/AP ecosystem.

Therefore, the best answer is D. Cisco Adaptive Wireless IPS.

Question #:90 - [Reconnaissance Techniques]

Why explore the Deep Web during reconnaissance?

- A. Insider threats
- B. Physical attacker locations
- C. Learning hacking techniques
- D. Non-indexed company data exposure

Answer: D

Explanation

CEH v13 explains that the Deep Web contains content not indexed by search engines, including exposed databases, misconfigured portals, leaked credentials, and internal documents.

This makes it a critical area to assess unintended data exposure. The Deep Web is not primarily for attacker profiling or insider detection.

Thus, Option D is correct.

Question #:91 - [Network and Perimeter Hacking]

During a penetration test at a healthcare facility in Baltimore, Maryland, an ethical hacker demonstrates how attackers are mapping active hosts and open ports using ICMP-based techniques. To reduce the organization's exposure, the security team decides to implement a countermeasure that specifically disrupts ICMP discovery traffic by preventing error messages from being returned. Which action should they take?

- A. Use a custom rule set to lock down the network, block unwanted ports at the firewall, and filter specific ports

- B. Configure firewall and IDS rules to detect and block probes
- C. Block unwanted services running on the ports and update the service versions
- D. Block inbound ICMP message types and all outbound ICMP type 3 (Destination Unreachable) messages

Answer: D

Explanation

The correct choice is D because the question is specifically about disrupting ICMP-based discovery by preventing error messages from being returned. In ICMP reconnaissance, attackers often rely not only on ICMP Echo (ping) but also on ICMP error messages to infer host availability, filtering behavior, and port reachability. A key ICMP error category is ICMP Type 3: Destination Unreachable, which includes several codes (for example, “port unreachable” and “communication administratively prohibited”) that can reveal whether a host exists, whether a firewall is filtering traffic, and whether specific ports are reachable or blocked. When these ICMP Type 3 messages are allowed to leave the network, they provide valuable feedback that helps attackers map the environment accurately.

By blocking inbound ICMP message types (to reduce direct ICMP probing) and blocking outbound ICMP Type 3 unreachable messages, the organization reduces the “informational signals” that external scanners can use to distinguish between live hosts, filtered hosts, and closed ports. This directly aligns with the requirement in the prompt: stopping ICMP discovery by preventing error messages from being returned.

Why the other choices are less precise:

A and C focus on general hardening (port/service reduction), which is good practice but does not directly address ICMP error-message feedback.

B (firewall/IDS detection) is helpful, but the prompt asks for an action that specifically disrupts ICMP discovery traffic by suppressing error responses, which is more directly achieved via ICMP filtering rules.

Operational note: while blocking ICMP Type 3 can reduce reconnaissance visibility, organizations should apply this carefully because some ICMP is important for normal network operations and troubleshooting.

Question #:92 - [Wireless Network Hacking]

You are an ethical hacker at HarborLine Assessments, engaged to audit the Wi-Fi at Portside Freight in Tacoma, Washington. During an overnight reconnaissance, you enable your wireless interface’s monitor mode and run a command that silently records beacon frames, probe responses, and authentication frames from nearby APs and clients into a capture file for later offline analysis—you do not transmit any frames from your laptop. Based on the described activity, which Wi-Fi security auditing tool are you most likely using?

- A. Aircrack-ng
- B. Airodump-ng
- C. Airbase-ng
- D. Airodump-ng

Answer: D**Explanation**

The activity described is passive wireless packet capture in monitor mode—specifically collecting management frames (such as beacon frames and probe responses) and observing client/AP interactions (including authentication-related frames) while not injecting or transmitting anything. In the Aircrack-ng suite, the tool designed for exactly this reconnaissance-and-capture purpose is Airodump-ng.

Airodump-ng is the component that listens on the air interface once the card is placed into monitor mode, then captures 802.11 frames and displays useful reconnaissance data such as BSSID, channel, encryption type, signal strength, and associated clients (stations). Critically, it can write captured traffic to files (e.g., .cap) for offline analysis—which matches the scenario’s “record into a capture file for later offline analysis.” This is a common CEH workflow: reconnaissance # capture # analyze, keeping the initial step non-intrusive.

By contrast:

Aireplay-ng (A) is primarily used for active attacks / packet injection (e.g., deauthentication, replay) and would typically involve transmitting frames.

Aircrack-ng (B) is used mainly for key cracking (WEP/WPA/WPA2 handshakes) after capture, not for passive collection itself.

Airbase-ng (C) focuses on creating a rogue AP / MITM-style setups, which is also an active transmission role.

So, for silent monitoring + capturing beacons/probes/auth frames to a file, the best match is D. Airodump-ng.

Question #:93 - [Web Application Hacking]

Which payload is most effective for testing time-based blind SQL injection?

- A. AND 1=0 UNION ALL SELECT 'admin','admin
- B. UNION SELECT NULL, NULL, NULL --
- C. OR '1'='1';
- D. AND BENCHMARK(5000000,ENCODE('test','test'))

Answer: D**Explanation**

Time-based blind SQL injection is used when applications suppress error messages and do not display query results. According to CEH v13, attackers rely on response time delays to infer whether injected SQL statements are executed.

The BENCHMARK() function forces the database to perform a CPU-intensive operation repeatedly, causing a noticeable delay if the injected condition is executed successfully. Option D explicitly introduces such a delay and is a textbook time-based blind SQL injection payload.

Options A, B, and C are used for union-based or boolean-based SQL injection and rely on visible output or content changes, which are ineffective in blind scenarios.

CEH v13 clearly states that time-delay functions such as SLEEP(), WAITFOR DELAY, and BENCHMARK() are the primary indicators for time-based blind SQL injection testing. Hence, Option D is correct.

Question #:94 - [Network and Perimeter Hacking]

A web server experienced a DDoS attack that specifically targeted the application layer. Which type of DDoS attack was most likely used?

- A. HTTP flood attack
- B. ICMP flood attack
- C. UDP flood attack
- D. SYN flood attack

Answer: A

Explanation

An HTTP Flood attack is an Application Layer (Layer 7) DDoS attack, as defined in CEH v13. In this attack, the adversary sends a massive number of seemingly legitimate HTTP GET or POST requests to exhaust server resources such as CPU, memory, and application threads.

CEH v13 emphasizes that HTTP floods are difficult to detect because they mimic normal user behavior and often bypass traditional network-layer defenses.

Other attacks operate at lower layers:

ICMP, UDP, and SYN floods target network and transport layers.

Question #:95 - [Cloud Computing]

At a Chicago-based healthcare provider, security engineer Emily reviews the migration of critical applications to a cloud service. During her evaluation, she notes that administrators can provision new servers, increase storage, and expand compute power instantly through a web dashboard without any manual involvement from the cloud provider. Which NIST-defined characteristic of cloud computing best explains this capability?

- A. On-demand self-service
- B. Measured service

- C. Resource pooling
- D. Broad network access

Answer: A

Explanation

The capability described—administrators instantly provisioning servers, storage, and compute through a web portal without needing the provider to manually intervene—is the NIST cloud characteristic called on-demand self-service. In NIST’s cloud computing model, on-demand self-service means a consumer can unilaterally provision computing capabilities (such as server time and network storage) as needed automatically, without requiring human interaction with each service provider.

The scenario explicitly highlights that the admins can scale resources “instantly” through a dashboard and that there is “no manual involvement from the cloud provider.” That is exactly what on-demand self-service captures: rapid provisioning driven by the customer through automated orchestration and APIs/portals.

Why the other options are not the best match:

Broad network access (D) means cloud capabilities are available over the network and accessed through standard mechanisms by heterogeneous platforms (mobile, laptops, workstations). While the dashboard is accessed over the network, broad access is about reachability and standard access mechanisms, not the self-provisioning behavior.

Resource pooling (C) refers to the provider’s multi-tenant model where physical/virtual resources are pooled and dynamically assigned; it explains how the provider can offer elasticity, but the user-facing “provision it yourself” aspect is on-demand self-service.

Measured service (B) refers to metering and monitoring resource usage for billing/optimization; it doesn’t explain instant self-provisioning.

Therefore, the characteristic is A. On-demand self-service.

Question #:96 - [Mobile Platform, IoT, and OT Hacking]

SCADA anomalies suggest a side-channel attack. Which investigation best confirms this?

- A. Review user interfaces
- B. Measure hardware-level operational fluctuations
- C. Identify weak crypto settings
- D. Assess network latency

Answer: B

Explanation

Side-channel attacks, as explained in CEH v13 OT and SCADA Security, extract sensitive information by observing physical characteristics of a system rather than exploiting software flaws directly. These characteristics may include power consumption, electromagnetic emissions, timing variations, or thermal output.

In SCADA environments, side-channel attacks are especially dangerous because they bypass traditional network defenses. The most reliable way to confirm such an attack is by analyzing hardware-level anomalies—such as unexpected power usage spikes or irregular signal emissions during normal device operations.

Option B directly aligns with CEH v13 guidance.

Options A, C, and D focus on software, cryptography, or network behavior, which are not primary indicators of side-channel exploitation.

Therefore, Option B is correct.

Question #:97 - [Mobile Platform, IoT, and OT Hacking]

A penetration tester evaluates an industrial control system (ICS) that manages critical infrastructure. The tester discovers that the system uses weak default passwords for remote access. What is the most effective method to exploit this vulnerability?

- A. Perform a brute-force attack to guess the system's default passwords
- B. Execute a Cross-Site Request Forgery (CSRF) attack to manipulate system settings
- C. Conduct a denial-of-service (DoS) attack to disrupt the system temporarily
- D. Use the default passwords to gain unauthorized access to the ICS and control system operations

Answer: D

Explanation

Operational Technology and ICS environments often suffer from misconfigurations such as unchanged factory-default passwords. CEH identifies exploiting default credentials as a direct and effective method because ICS devices frequently lack strong authentication controls. Using these built-in credentials grants immediate unauthorized access to supervisory controls, enabling adversaries to manipulate configurations, disrupt processes, or escalate attacks across critical systems.

Question #:98 - [Reconnaissance Techniques]

Why is using Google Hacking justified during passive footprinting?

- A. Identifying weaknesses in website source code
- B. Locating phishing sites mimicking the organization

- C. Mapping internal network structures
- D. Discovering hidden organizational data indexed by search engines

Answer: D

Explanation

Google Hacking, also known as Google Dorking, is a passive reconnaissance technique covered in CEH v13 Reconnaissance Techniques. It involves using advanced search operators to uncover sensitive information that has been inadvertently indexed by search engines.

CEH v13 explains that Google Hacking can reveal exposed files, directories, configuration files, backups, login portals, error messages, and sensitive documents. This information often resides on the Deep Web, meaning it is not easily accessible through normal browsing but is still indexed by search engines.

Option D correctly reflects this capability. Google Hacking does not analyze source code directly (Option A), map internal networks (Option C), or primarily detect phishing sites (Option B), although it may indirectly assist with those tasks.

Because Google Hacking relies solely on publicly available data and does not interact directly with target systems, it fits perfectly within passive footprinting, making it legally and ethically appropriate when authorized.

CEH v13 emphasizes Google Hacking as a powerful method to identify unintended data exposure. Therefore, Option D is the correct justification.

Question #:99 - [Cloud Computing]

A biotech research firm in Boston, Massachusetts, migrates its laboratory management platform to the cloud. The vendor provides an environment where developers can deploy and test custom applications without managing the underlying servers, operating systems, or storage. The firm controls the application logic but not the runtime infrastructure.

Which cloud service model is the company using?

- A. Infrastructure as a Service (IaaS)
- B. Platform as a Service (PaaS)
- C. Software as a Service (SaaS)
- D. Anything as a Service (XaaS)

Answer: B

Explanation

This scenario describes Platform as a Service (PaaS) because the provider delivers a managed platform where developers can deploy and run custom applications while the provider manages the underlying infrastructure components—servers, operating systems, storage, and often middleware/runtime components. The customer is responsible for application code and logic (and usually data and application configuration), but not for provisioning or maintaining the base compute and OS layers.

The key phrasing is: “developers can deploy and test custom applications without managing the underlying servers, operating systems, or storage,” and “the firm controls the application logic but not the runtime infrastructure.” That is the hallmark responsibility split of PaaS: the provider handles infrastructure and platform operations, enabling rapid development and deployment through managed runtimes, build/deploy pipelines, and scalable services.

Why the other models don't fit:

IaaS (A) would require the customer to manage the OS and many platform components (patching, runtime configuration, middleware), even though the provider supplies the virtualized infrastructure. The scenario explicitly says they do not manage OS or servers.

SaaS (C) provides a complete finished application that the customer uses; customers typically cannot deploy their own custom application logic onto it in the way described.

XaaS (D) is a broad umbrella term, not the specific NIST-style service model classification being asked.

Therefore, the correct answer is B. Platform as a Service (PaaS).

Question #:100 - [Web Application Hacking]

You are an ethical hacker at ShieldPoint Security, hired by Pinecrest Travel Agency in Orlando, Florida, to perform a penetration test on their flight booking portal. During testing, you notice that normal SQL injection attempts are blocked by a security filter. To bypass it, you adjust your input so that key SQL keywords are broken apart with unexpected symbols, allowing the database to interpret them correctly while evading the filter. This manipulation allows you to retrieve hidden booking records despite the filter's restrictions. Based on the observed behavior, which SQL injection evasion technique are you employing?

- A. String Concatenation
- B. Hex Encoding
- C. In-line Comment
- D. Null Byte

Answer: C

Explanation

The described bypass is most consistent with using an in-line comment technique. Many simplistic SQL injection filters look for specific “blocked” keywords such as SELECT, UNION, OR, or DROP as contiguous strings. If the tester breaks a keyword apart by inserting tokens the database will ignore—most commonly

comment delimiters—the filter may fail to match the forbidden keyword, while the SQL parser still reconstructs the intended meaning. For example, inserting comment markers inside a keyword can cause the application-layer filter to miss the pattern, yet the database can still process the statement depending on the DBMS and parsing rules. This is why comment-based obfuscation is a common SQLi evasion approach against weak signature filters.

The scenario's wording "broken apart with unexpected symbols" maps well to comment markers such as `/**/` (or other DBMS-specific comment forms). These characters look "unexpected" to a naïve filter, but to the SQL engine they are treated as comments/whitespace and effectively ignored during parsing, allowing the attacker's intended keyword to be interpreted correctly.

Why the other options are less aligned:

String concatenation (A) is an obfuscation approach where attackers build keywords/strings using concatenation operators or functions (DBMS-specific). The scenario emphasizes splitting keywords with symbols that the DB interprets correctly as separators/ignored content, which more directly matches comment insertion.

Hex encoding (B) encodes parts of a payload (strings, sometimes function names) in hexadecimal form. That is a different technique than splitting keywords with inserted symbols.

Null byte (D) is historically used to terminate strings in certain contexts (more common in older file/path handling bugs) and is not the primary technique for bypassing keyword filters in modern SQL parsing.

Therefore, the SQL injection evasion technique is C. In-line Comment.

Question #:101 - [Security Operations and Incident Response]

During an internal red team simulation at a global insurance provider, Joe, a senior SOC analyst, is assigned to verify a surge in anomalous SYN packets targeting the perimeter firewall. The result of spoofed traffic. The organization has ruled out DNS poisoning and malformed header issues. Joe must now analyze packet behavior in real-time to determine authenticity without relying on host-level authentication. To identify spoofed traffic using techniques aligned with best practices taught in the organization, which approach should Joe take?

- A. TCP Flow Control Method
- B. IP Address Decoy
- C. Direct TTL Probes
- D. IP Identification Number IPID Monitoring
- E. DIn CEH-aligned traffic analysis, SYN floods frequently use spoofed source IP addresses to hide the attacker and complicate filtering. When host-level authentication or end-host validation is not available, defenders rely on characteristics in packet behavior that are difficult to forge consistently at scale. IP Identification Number monitoring is a classic technique for spotting spoofing because many operating systems generate the IPID field in a predictable manner, often incrementing sequentially or following a repeatable pattern per host or per flow.If the observed SYN packets truly originate from the same claimed source, the IPID values tend to show a coherent progression over time. In spoofed traffic,

especially when the attacker randomly changes source IPs or uses multiple generators, IPID values typically appear inconsistent, jump erratically, or reflect patterns that do not match what would be expected from the alleged sender. This makes IPID monitoring useful in real-time packet analysis to differentiate legitimate traffic bursts from fabricated packets without needing to complete a handshake or query the end host. The other options are weaker fits for the specific goal. TCP flow control relates to windowing and throughput behavior, not source authenticity. IP address decoy is a deception concept rather than a packet-authenticity test. Direct TTL probes can provide hints about hop distance, but TTL values are easily adjusted by an attacker and are less reliable than correlating a consistent IPID sequence pattern. Therefore, IPID monitoring best matches CEH-style spoofed-traffic identification under these constraints.

Answer: A B C D E

Question #:102 - [Web Application Hacking]

A penetration tester is evaluating a web application that does not properly validate the authenticity of HTTP requests. The tester suspects the application is vulnerable to Cross-Site Request Forgery (CSRF). Which approach should the tester use to exploit this vulnerability?

- A. Execute a directory traversal attack to access restricted server files
- B. Create a malicious website that sends a crafted request on behalf of the user when visited
- C. Perform a brute-force attack on the application's login page to guess weak credentials
- D. Inject a SQL query into the input fields to perform SQL injection

Answer: B

Explanation

CSRF occurs when a vulnerable application processes unauthorized state-changing requests because it does not verify whether the request was intentionally initiated by the authenticated user. CEH v13 explains that exploitation involves tricking a logged-in user into unknowingly executing a crafted HTTP request—usually via a malicious webpage, hidden form submission, embedded image tag, or JavaScript trigger. When the victim visits the attacker-controlled page, the browser automatically includes the user's active session cookies, allowing the server to treat the forged request as legitimate. This technique is central to CSRF attacks and is highlighted in the CEH curriculum as the correct exploitation path. Directory traversal, SQL injection, and brute-force attacks target different vulnerabilities and do not exploit missing request authenticity validation. The key requirement for CSRF exploitation is user interaction via a malicious external resource, making option B the correct CEH-aligned method.

Question #:103 - [Mobile Platform and IoT Hacking]

A penetration tester is tasked with assessing the security of an Android mobile application that stores sensitive user data. The tester finds that the application does not use proper encryption to secure data at rest. What is the most effective way to exploit this vulnerability?

- A. Access the local storage to retrieve sensitive data directly from the device
- B. Use SQL injection to retrieve sensitive data from the backend server

- C. Execute a Cross-Site Scripting (XSS) attack to steal session cookies
- D. Perform a brute-force attack on the application's login credentials

Answer: A

Explanation

CEH training emphasizes that mobile applications frequently mishandle local storage, leaving sensitive data such as tokens, passwords, API keys, or personal information unencrypted within SQLite databases, shared preferences, or flat-file storage. When encryption is absent or improperly implemented, attackers can directly access this data through filesystem extraction, Android Debug Bridge (ADB) access, physical device access, or rooted environments. CEH identifies “Insecure Data Storage” as one of the most critical mobile vulnerabilities because it bypasses server-side defenses entirely. Since the vulnerability specifically concerns data at rest, the most direct and effective exploitation method is to retrieve the locally stored unencrypted data. SQL injection (Option B) evaluates backend security, not device storage. XSS (Option C) is a web attack and unrelated to local encryption. Brute-forcing credentials (Option D) is unnecessary when sensitive information is already stored insecurely. Therefore, accessing local storage is the correct exploitation method.

Question #:104 - [Social Engineering]

During a red team exercise at Orion Tech Systems in San Jose, ethical hacker Nadia creates a campaign of fraudulent messages targeting employees. She uses compromised social media accounts to distribute bulk invitations that contain links to a fake cloud collaboration site. Several employees click the links and are prompted to log in with their corporate credentials, which Nadia captures. Although the lure appears to be a professional networking opportunity, the tactic relies on unsolicited deceptive messages delivered at scale.

Which social engineering threat is Nadia simulating in this campaign?

- A. Catfishing
- B. Angler Phishing
- C. Spam and Phishing
- D. Involuntary Data Leakage

Answer: C

Explanation

The correct answer is C. Spam and Phishing because the campaign is based on unsolicited deceptive messages sent in bulk with the intent to lure many recipients into clicking a link and submitting credentials on a fake site. In CEH-aligned social engineering concepts, phishing is a deception technique used to trick users into revealing sensitive information (such as corporate usernames and passwords) by impersonating a trusted entity or presenting a convincing pretext. When phishing is executed “at scale” using mass messaging—often through email, messaging platforms, or social media—it overlaps strongly with spam, which refers to unsolicited bulk communications distributed to large numbers of targets.

The scenario contains the classic phishing flow: a fraudulent invitation contains a link to a counterfeit “cloud collaboration” login page, and users are prompted to authenticate. Credential capture (“which Nadia captures”) confirms the objective is credential harvesting rather than mere awareness disruption. The detail that she used “compromised social media accounts” is consistent with modern phishing operations that abuse trusted accounts to increase credibility and bypass initial suspicion. This also helps attackers evade some basic filtering and encourages victims to trust the message because it appears to come from a legitimate profile.

Why the other options are less correct: Catfishing typically involves building a fake persona and maintaining a relationship over time (often one-to-one) to manipulate a victim; it is not mainly defined by bulk unsolicited messages. Angler phishing specifically refers to phishing conducted through social media channels, often by impersonating customer support or hijacking brand interactions. While the platform here is social media, the question’s strongest discriminator is “unsolicited deceptive messages delivered at scale,” which points to the combined threat category spam and phishing rather than the more specific “angler” support-impersonation pattern. Involuntary data leakage describes accidental exposure of information, not active deception.

Therefore, Nadia’s campaign most clearly simulates spam and phishing.

Question #:105 - [Web Application Hacking]

Which advanced session hijacking technique is hardest to detect and mitigate in a remote-access environment?

- A. Session sidejacking over public Wi-Fi
- B. ARP spoofing on local networks
- C. Brute-force session guessing
- D. Cookie poisoning

Answer: B

Explanation

ARP spoofing-based session hijacking is identified in CEH v13 Web Application and Network Attacks as one of the most stealthy and difficult-to-detect session compromise techniques, especially within internal or VPN-connected networks.

In ARP spoofing, attackers poison ARP caches to position themselves as a man-in-the-middle (MitM). Once in place, they can silently intercept, modify, or replay session data—even when encryption is used—by redirecting traffic transparently between endpoints.

Option A (sidejacking) is mitigated by HTTPS. Option C (session guessing) is noisy and detectable. Option D (cookie poisoning) relies on weak validation and is easier to detect via integrity checks.

CEH v13 highlights ARP spoofing as particularly dangerous because:

It exploits trusted local network behavior

It does not require breaking encryption directly

It is often invisible to users and applications

Therefore, Option B is the most challenging to detect and mitigate and is the correct answer.

Question #:106 - [Mobile Platform, IoT, and OT Hacking]

During an authorized penetration test of an organization's Operational Technology (OT) environment, the tester has already identified exposed industrial assets and now begins actively probing controllers, services, and interfaces to identify exploitable weaknesses. No exploitation attempts or persistence mechanisms have been performed yet.

According to the OT hacking methodology, which phase is currently being carried out?

- A. Gain Remote Access
- B. Information Gathering
- C. Launch Attacks
- D. Vulnerability Scanning

Answer: D

Explanation

In OT hacking methodology, once exposed industrial assets have been identified, the next logical step—before attempting exploitation—is to actively assess those assets for weaknesses. The scenario states the tester is “actively probing controllers, services, and interfaces to identify exploitable weaknesses” and explicitly confirms that no exploitation attempts or persistence mechanisms have occurred. That combination maps most closely to the Vulnerability Scanning phase.

Vulnerability scanning in OT contexts includes carefully enumerating and assessing industrial components such as PLCs, HMIs, historians, engineering workstations, and industrial gateways. The goal is to discover issues like outdated firmware, insecure services, weak authentication, exposed management interfaces, misconfigurations, and known CVEs affecting industrial protocols or device web consoles. “Actively probing” is an important clue: information gathering can be passive (asset inventories, diagrams, OSINT, passive network visibility), but scanning moves into active interaction with hosts and services to identify vulnerabilities—still short of exploitation.

The other answer choices do not align with the described boundaries. Gain Remote Access implies initial compromise or establishing access paths (e.g., leveraging credentials, remote services, or exploits) and is a later step once weaknesses are identified and selected. Launch Attacks is even further along, where exploitation or disruption actions occur. Information Gathering would fit earlier when the tester is identifying assets and collecting details with minimal interaction; however, the scenario says that stage is already past (“has already identified exposed industrial assets”) and that the tester is now probing for exploitable weaknesses.

Therefore, the current phase is D. Vulnerability Scanning.

Question #:107 - [Malware Threats]

A multinational corporation deploys a major internal tool built on a PowerShell-based automation framework. Shortly after a scheduled rollout, the IT team notices intermittent system slowdowns and unexplained bandwidth spikes. Despite running updated endpoint protection and restrictive firewall rules, traditional scanning tools report no malicious files on disk. However, internal telemetry flags a trusted process repeatedly executing obfuscated PowerShell commands in memory. The anomalous activity vanishes upon reboot and appears to leave no footprint behind on the system.

Which type of malware is most likely responsible for this behavior?

- A. Worm
- B. Trojan
- C. Rootkit
- D. Fileless Malware

Answer: D**Explanation**

Fileless malware is the best match because the scenario highlights memory-resident execution with no malicious files written to disk and activity that disappears after a reboot. In CEH-aligned malware concepts, fileless attacks commonly leverage legitimate system tools and trusted processes, often called living off the land, to execute malicious logic without dropping traditional executables. PowerShell is one of the most frequently abused components for this purpose because it can download, decode, and run scripts directly in memory, including obfuscated commands that evade simple signature-based scans. The prompt explicitly states that endpoint scanners find no malicious files on disk, yet telemetry detects a trusted process executing obfuscated PowerShell commands in memory. That combination strongly indicates fileless behavior.

The fact that the anomaly vanishes on reboot also fits fileless techniques that rely on volatile memory artifacts rather than persistent file-based implants. While fileless attacks can establish persistence through registry run keys, scheduled tasks, WMI, or other mechanisms, the question emphasizes no footprint and reboot clearing the activity, which is consistent with a purely in-memory foothold or a short-lived execution chain.

A worm is characterized by self-replication across systems, which is not described. A trojan usually involves a malicious file disguised as legitimate software, conflicting with the “no files on disk” observation. A rootkit focuses on stealth and hiding by modifying system internals and can persist, but the scenario’s defining indicators are PowerShell in-memory execution and lack of disk artifacts, which aligns most directly with fileless malware.

Question #:108 - [Security Operations and Incident Response]

During a quarterly security audit at a multinational logistics firm, network security manager Priya initiates a scheduled vulnerability assessment across the organization’s hybrid infrastructure. Her team begins by identifying all active IT assets and assigning them risk scores based on business criticality. The following week, they deploy scanning tools to detect security weaknesses, validate the findings manually, and classify vulnerabilities based on severity and exploitability. After coordinating with the IT operations team, they

develop a structured timeline to address the confirmed vulnerabilities, giving priority to high-risk findings affecting mission-critical systems. Finally, after the vulnerabilities are addressed, Priya ensures the affected systems are rescanned to confirm resolution and generates a compliance report for executive review.

Based on this workflow, which phase of the Vulnerability-Management Life Cycle is Priya executing?

- A. Remediation
- B. Vulnerability Analysis
- C. Verification
- D. Risk Assessment

Answer: A

Explanation

The best answer is Remediation because the workflow centers on fixing confirmed vulnerabilities through an organized, prioritized plan and coordinating corrective actions with operations teams. In CEH-aligned vulnerability management, the lifecycle typically moves from asset identification and risk context, to scanning and validation, to analysis and prioritization, and then into remediation where weaknesses are actually reduced or eliminated. The question explicitly states that after vulnerabilities are detected and validated, Priya's team "develop a structured timeline to address the confirmed vulnerabilities" and prioritize "high-risk findings affecting mission-critical systems." Creating the remediation plan, assigning owners, scheduling patch windows, implementing configuration hardening, disabling unnecessary services, updating vulnerable software, and applying compensating controls are all core remediation activities.

Although the final step mentions rescanning to confirm resolution and producing a compliance report, that verification step occurs after remediation work has been performed. Verification is an important follow-on phase, but it is not the main phase being executed throughout the described workflow. Vulnerability analysis refers more to interpreting scan results, validating false positives, mapping weaknesses to impact, and determining exploitability. Risk assessment focuses on evaluating business impact and likelihood to prioritize work. Here, those phases are present, but the primary emphasis is on coordinating and executing fixes and driving them to closure, which is remediation.

In short, Priya is in the remediation phase, with verification used afterward to confirm the remediation was effective.

Question #:109 - [Reconnaissance Techniques]

In a high-stakes cybersecurity exercise in Boston, Emily, an ethical hacker, is tasked with tracing a mock phishing email sent to a healthcare provider's staff. Using the email header, she identifies a series of IP addresses and server details, including multiple timestamps and server names. Her objective is to pinpoint the exact moment the email was processed by the sender's system. As part of her reconnaissance, what specific detail from the email header should Emily examine to determine this information?

- A. Date and time of message sent
- B. Sender's mail server

- C. Date and time received by the originator's email servers
- D. Authentication system used by sender's mail server

Answer: C

Explanation

Email headers typically contain multiple time-related fields, but they do not all carry the same evidentiary value for tracing message handling. In CEH-aligned reconnaissance and email analysis, the most reliable way to determine when an email was processed by the sender's infrastructure is to examine the earliest "Received" header entry—specifically, the timestamp showing when the message was accepted by the sender's originating mail server (the first mail transfer agent in the chain). This aligns with option C: the date and time received by the originator's email servers.

The "Date" header (option A) is set by the sender's mail client and can be manipulated or misconfigured, making it less trustworthy for forensic timing. Option B (sender's mail server) is useful for identifying infrastructure and routing, but it does not directly provide the exact processing moment unless paired with the correct "Received" timestamp. Option D (authentication system such as SPF/DKIM/DMARC results) helps validate whether a message is authorized for a domain and detect spoofing, but it does not pinpoint when the sender's system processed the email.

CEH guidance emphasizes that analysts should correlate multiple "Received" lines from bottom to top (earliest to latest), validate time zones, and look for inconsistencies such as impossible hops, private IP anomalies, or missing hops that indicate header forgery. However, for the specific "moment processed by the sender's system," the first acceptance timestamp at the origin mail server is the key artifact.

Question #:110 - [Network and Perimeter Hacking]

During a red team assessment at a retail bank in New York, ethical hacker Aisha launches a flood of TCP connection initiation packets against the bank's online portal. The target accepts each initial handshake packet but never receives the final ACK to complete the three-way handshake, exhausting the server's backlog of half-open connections and preventing legitimate users from establishing new sessions.

Which type of DoS attack is Aisha most likely simulating?

- A. ACK Flood
- B. TCP SACK Panic
- C. APT Attack
- D. SYN Flood Attack

Answer: D

Explanation

This is a SYN flood because the attack floods the target with TCP SYN packets (connection initiation). The server responds by allocating resources and sending SYN-ACK replies, moving each connection into a half-open state while it waits for the client's final ACK to complete the three-way handshake. In a SYN flood, that final ACK never arrives (often because the source addresses are spoofed or because the attacker deliberately does not complete the handshake). As a result, the server's backlog queue of pending connections fills up, consuming memory/connection slots and preventing legitimate users from establishing new sessions.

The scenario's language matches the mechanics precisely: "flood of TCP connection initiation packets," "exhausting the server's backlog of half-open connections," and "never receives the final ACK." Those are the classic identifiers of SYN flooding.

Why the other options are incorrect:

ACK flood (A) involves flooding with TCP ACK packets; it does not primarily create half-open handshakes because ACKs are not the connection-initiation step.

TCP SACK Panic (B) refers to a specific vulnerability/issue related to TCP Selective Acknowledgment processing, not a generic handshake backlog exhaustion attack pattern.

APT attack (C) is not a DoS attack type; it refers to advanced persistent threat campaigns and is unrelated to TCP handshake flooding.

Therefore, Aisha is simulating D. SYN Flood Attack.

Question #:111 - [Web Application Hacking]

A major financial institution is experiencing persistent DoS attacks against online banking, disrupting transactions. Which sophisticated DoS technique poses the greatest challenge to detect and mitigate effectively, potentially jeopardizing service availability?

- A. A synchronized Layer 3 Smurf attack flooding routers with ICMP echo requests
- B. A distributed SQL injection attack against online banking database servers causing resource exhaustion
- C. A zero-day buffer overflow exploit against the web server causing service unavailability via RCE
- D. A coordinated UDP flood targeting authoritative DNS servers to disrupt domain resolution

Answer: B

Explanation

CEH emphasizes that application-layer DoS attacks are often the most difficult to detect and mitigate because they can mimic legitimate user behavior while exhausting backend resources. A distributed SQL injection-driven DoS (Option B) can be especially challenging: attackers send requests that appear valid at the HTTP level, but the injected or crafted parameters force the application/database to execute expensive queries (heavy joins, sleep/delay functions, or costly operations). When distributed across many sources, the traffic

can look like normal customer usage—successful TCP handshakes, valid HTTP requests, and realistic user-agent patterns—while still causing database connection pool exhaustion, CPU spikes, lock contention, and degraded response times.

Option A (Smurf) and Option D (UDP/DNS flooding) are more volumetric/network-layer patterns and are typically mitigated with upstream DDoS scrubbing, rate limiting, and filtering, and are more readily detectable via traffic anomalies. Option C (zero-day RCE) is severe, but it is not primarily a “DoS technique” in CEH classification; it’s an exploitation scenario that may lead to service outage, but the detection/mitigation path centers on exploit prevention, EDR, patching, and containment rather than DoS controls. In CEH terms, Option B aligns best with a sophisticated, scenario-like DoS that blends into normal app activity.

CEH mitigation approaches for application-layer DoS include WAF rules, input validation/parameterization (preventing SQLi), query cost controls, rate limiting by behavior, caching, database hardening, and anomaly detection at the application and database tiers.

Question #:112 - [Reconnaissance Techniques]

An ethical hacker needs to gather sensitive information about a company's internal network without engaging directly with the organization's systems to avoid detection. Which method should be employed to obtain this information discreetly?

- A. Analyze the organization's job postings for technical details
- B. Exploit a public vulnerability in the company's web server
- C. Perform a WHOIS lookup on the company's domain registrar
- D. Use port scanning tools to probe the company's firewall

Answer: A

Explanation

CEH v13 stresses the importance of passive reconnaissance when the goal is to avoid any interaction with the target's systems. Job postings frequently reveal detailed information such as internal technologies, OS platforms, security tools, IDS brands, virtualization environments, scripting languages, and cloud services. CEH explicitly notes job ads as one of the richest passive intelligence sources because organizations inadvertently disclose their tech stack, often mentioning required experience with specific network components, databases, protocols, or internal tools. Options B and D involve direct interaction, violating the passive reconnaissance requirement. WHOIS lookups (Option C) provide DNS registrar information but do not reveal internal network details. Job postings, social media recruitment materials, and HR documentation are discussed in CEH as critical OSINT resources used during the footprinting phase to gather actionable intelligence while maintaining complete stealth. Thus, analyzing job postings is the correct method.

Question #:113 - [Social Engineering]

During a penetration test at Greenview Credit Union in Chicago, Illinois, ethical hacker Rebecca Hayes simulates an attacker who contacts employees using a voice channel. The number displayed on their devices appears identical to the institution's official line, convincing staff that the request is legitimate. Rebecca then

asks for account credentials under the pretense of a mandatory security check. Which mobile attack vector is she demonstrating?

- A. Call Spoofing
- B. OTP Hijacking
- C. Bluebugging
- D. SMiShing

Answer: A

Explanation

The correct answer is A. Call Spoofing because the defining behavior in the scenario is manipulating the caller ID information so that the victim's phone displays a trusted number—specifically, the credit union's official line. In CEH-aligned social engineering and mobile attack discussions, call spoofing is a technique where an attacker falsifies caller ID data to impersonate a legitimate organization, department, or known contact. This increases credibility and exploits human trust in recognized numbers, making victims more likely to comply with sensitive requests such as disclosing usernames, passwords, or one-time codes.

The attack is also a form of vishing (voice phishing), where the attacker uses phone calls and persuasive pretexts (“mandatory security check”) to trick employees into revealing credentials. The success factor here is the authority and legitimacy signal created by the spoofed number. When staff see what appears to be an official institutional phone number, they are more likely to assume the call is authentic and bypass normal verification steps, especially under time pressure or when framed as a security requirement.

Why the other options are incorrect: OTP hijacking refers to stealing or intercepting one-time passwords (for example via SIM swap, malware, or social engineering focused specifically on MFA/OTP codes). While the attacker could ask for OTPs, the scenario's core mechanism is the spoofed caller ID, not OTP interception. Bluebugging is a Bluetooth-based attack that gains unauthorized control over a device through Bluetooth vulnerabilities; it is unrelated to caller ID impersonation. SMiShing is phishing via SMS/text messages, not a voice call.

Therefore, the mobile attack vector demonstrated—displaying a trusted institutional number to deceive employees during a credential-harvesting call—is call spoofing.

Question #:114 - [Information Security and Ethical Hacking Overview]

You've recently joined an international software firm as part of the cybersecurity governance team. While preparing for an internal compliance review, your supervisor asks you to identify the ISO/IEC standard that serves as a comprehensive framework for managing an organization's information security. You examine several standards, including those focusing on risk management, cybersecurity, and control implementation. However, you need to select the one that defines the overarching structure for managing information security programs across the organization.

Which of the following standards should you choose?

- A. ISO/IEC 27002:2022

- B. ISO/IEC 27005:2022
- C. ISO/IEC 27001:2022
- D. ISO/IEC 27701:2019

Answer: C

Explanation

ISO/IEC 27001:2022 is the correct choice because it is the core standard that defines the requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). In CEH-aligned governance and security management concepts, an ISMS is the overarching management framework that ensures information security is handled systematically through policy, defined roles, risk-driven planning, implementation of controls, monitoring, internal audits, and continual improvement. ISO/IEC 27001 is the “structure” standard—meaning it specifies what an organization must do to run an information security program end-to-end and is the primary standard against which organizations can be formally certified.

The other standards are supporting standards rather than the overarching framework. ISO/IEC 27002:2022 provides guidance and best practices for information security controls (the “control catalog” and implementation guidance), but it does not define ISMS requirements. ISO/IEC 27005:2022 focuses on information security risk management—how to identify, analyze, evaluate, and treat risks—supporting the risk-based approach used by an ISMS, but it is not the ISMS framework itself. ISO/IEC 27701:2019 extends ISO/IEC 27001 and 27002 for privacy information management (PIMS), helping organizations manage personally identifiable information, but it is an extension, not the foundational ISMS standard.

Therefore, when asked for the standard that defines the overarching structure for managing information security across the organization, CEH governance principles align with selecting ISO/IEC 27001:2022.

Question #:115 - [Mobile Platform and IoT Hacking]

A penetration tester is assessing an IoT thermostat used in a smart home system. The device communicates with a cloud server for updates and commands. The tester discovers that communication between the device and the cloud server is not encrypted. What is the most effective way to exploit this vulnerability?

- A. Conduct a Cross-Site Scripting (XSS) attack on the thermostat’s web interface
- B. Perform a brute-force attack on the thermostat’s local admin login
- C. Execute a SQL injection attack on the cloud server's login page
- D. Use a man-in-the-middle (MitM) attack to intercept and manipulate unencrypted communication

Answer: D

Explanation

IoT devices that transmit data without encryption expose all communication to interception. CEH explains that attackers can position themselves between the IoT device and cloud service to manipulate or capture traffic. A MitM attack enables interception of commands, credentials, and firmware data due to the absence of TLS protections.

Question #:116 - [Web Application Hacking]

During a penetration test at IntelliCore Systems in Raleigh, North Carolina, ethical hacker Javier directs a wave of repetitive web requests against the company's portal that overloads backend scripts which process search queries and form submissions. As a result, legitimate customers experience long delays and occasional timeouts while attempting to log in or complete transactions.

Which DoS/DDoS technique is Javier most likely demonstrating?

- A. Slowloris
- B. UDP Flood
- C. Peer-to-Peer Attack
- D. HTTP GET/POST Attack

Answer: D

Explanation

The scenario describes a Layer 7 (application-layer) denial-of-service pattern: Javier sends a wave of repetitive web requests that specifically overload backend scripts responsible for search queries and form submissions. This is characteristic of an HTTP GET/POST attack, where the attacker floods a web application with large volumes of HTTP requests—commonly GET requests for pages/resources and POST requests that trigger server-side processing (login, checkout, searches, form handlers). Because these requests can be syntactically valid and target costly operations, they can quickly exhaust CPU, memory, threads, database connections, or application worker pools, resulting in slow responses and timeouts for legitimate users—exactly what the customers experience here.

Why the other options don't fit as well:

Slowloris (A) is also an application-layer technique, but it works differently: it holds many connections open by sending partial HTTP headers very slowly, aiming to exhaust the server's concurrent connection capacity. The question emphasizes repetitive requests overloading backend scripts, not slow, incomplete requests holding sockets open.

UDP Flood (B) is a network/transport-layer volumetric attack that sends massive UDP packets to random or targeted ports, consuming bandwidth and host resources. It doesn't specifically target web scripts handling search/forms.

Peer-to-Peer Attack (C) typically involves abusing P2P networks or reflection/amplification through distributed peers; it's not described as direct repetitive web requests to application endpoints.

The key indicators are: (1) web requests (2) targeting script-driven functions like search and form submissions, and (3) resulting in user-facing slowness/timeouts due to overwhelmed application processing. These align most directly with D. HTTP GET/POST Attack.

Question #:117 - [Cloud Computing]

An AWS security operations team receives an alert regarding abnormal outbound traffic from an EC2 instance. The instance begins transmitting encrypted data packets to an external domain that resolves to a Dropbox account not associated with the organization. Further analysis reveals that a malicious executable silently modified the Dropbox sync configuration to use the attacker's access token, allowing automatic synchronization of internal files to the attacker's cloud storage. What type of attack has likely occurred?

- A. Cloud Snooper attack leveraging port masquerading
- B. Man-in-the-Cloud (MITC) attack
- C. Side-channel attack exploiting CPU cache
- D. Cryptojacking using Coin Hive scripts

Answer: B

Explanation

Man-in-the-Cloud (MITC) attacks target cloud synchronization services such as Dropbox, Google Drive, and OneDrive by manipulating authentication tokens instead of user passwords. CEH courseware explains that cloud storage clients rely heavily on sync tokens stored locally, which authorize access without user interaction. If an attacker replaces or injects a malicious token, they can hijack the victim's cloud account or redirect synced data to attacker-controlled locations. In this scenario, the EC2 instance continues to operate normally, but its Dropbox client silently synchronizes data to an external account using the attacker's token. This bypasses traditional defenses such as perimeter firewalls, credential monitoring, or user behavior analytics, because the synchronization process appears legitimate and authenticated. MITC attacks are uniquely stealthy, as they require no further compromise once the sync token is stolen or replaced. Other choices, such as Cloud Snooper or cryptojacking, do not match the described behavior. Therefore, this attack clearly aligns with a Man-in-the-Cloud attack.

Question #:118 - [Web Application Hacking]

During a code review at a defense technology contractor in Virginia, penetration tester Lucas identifies that a newly deployed payroll application encrypts sensitive employee data using a weak custom algorithm. In addition, its session validation logic allows certain requests to bypass access controls altogether. These oversights are traced back to flawed system logic and poor encryption design decisions made during the development phase.

Which vulnerability category BEST describes the issue Lucas discovered?

- A. Design Flaws
- B. Application Flaws

- C. Misconfigurations/Weak Configurations
- D. Poor Patch Management

Answer: A

Explanation

The correct answer is A. Design Flaws because the weaknesses originate from fundamental development-time decisions in how the application was architected—specifically (1) selecting or creating a weak custom encryption algorithm and (2) implementing session validation in a way that allows requests to bypass access controls. In CEH-aligned vulnerability classification, design flaws are problems embedded in the application’s design and logic, not merely bugs from implementation mistakes, misconfiguration of a server setting, or missing vendor patches. They are often systemic: even if the code is “working as intended,” the intent itself is insecure.

The prompt explicitly states the issues are “traced back to flawed system logic and poor encryption design decisions made during the development phase.” That description maps directly to design flaws: using “homegrown crypto” instead of vetted cryptographic primitives and protocols is a classic design error because it typically lacks proper peer review, threat modeling, and proven resistance to cryptanalysis. Likewise, session validation that permits bypassing access controls indicates the application’s authorization/session model was designed incorrectly (for example, trusting client-side state, failing to enforce server-side checks consistently, or allowing unauthenticated endpoints to access privileged operations).

Why the other options are less accurate: Application flaws is a broad label that can include coding bugs, but the question is asking for the best category given that the root cause is architectural decisions rather than a narrow coding mistake. Misconfigurations/weak configurations usually refer to insecure settings in deployment (default credentials, permissive headers, weak TLS configuration), not a custom crypto algorithm and flawed session logic baked into the app. Poor patch management concerns failing to update known vulnerable components; here, the weakness is custom logic, not an unpatched third-party vulnerability.

Therefore, the most accurate category for these development-phase encryption and session/authorization weaknesses is Design Flaws.

Question #:119 - [Network and Perimeter Hacking]

During a stealth assessment, an attacker exploits intermittent delays in ARP responses from a target system. By injecting fake ARP replies before legitimate ones, the attacker temporarily redirects traffic to their own device, allowing intermittent packet capture. What type of sniffing attack is occurring?

- A. Passive sniffing on a switched network
- B. Duplicate IP conflict resolution attack
- C. Switch port stealing via timing-based ARP spoofing
- D. ARP poisoning for MiTM interception

Answer: C

Explanation

CEH teaches that ARP-based attacks vary in sophistication from basic poisoning to more specialized techniques such as switch port stealing. In environments where ARP poisoning defenses or inspection tools limit traditional attacks, attackers may exploit timing vulnerabilities in ARP reply behavior. Switch port stealing works by sending spoofed ARP replies at precisely the right moment—before the legitimate ARP response from the target host—causing the switch’s CAM table to update temporarily and associate the target’s IP address with the attacker’s MAC address. CEH emphasizes that switches trust the latest ARP update, so even brief timing windows enable partial packet interception. This is different from fully persistent ARP poisoning, which continuously overwrites ARP tables, and from passive sniffing, which cannot capture unicast traffic on a switched network. This attack is particularly useful when ARP spoofing is mitigated because it relies on opportunistic timing rather than full table poisoning. The intermittent nature of intercepted packets matches CEH’s description of switch port stealing behavior.

Question #:120 - [Social Engineering]

As part of an annual security awareness program at BrightPath Consulting in Denver, Colorado, the cybersecurity team conducts an ethical hacking experiment to test employee vigilance against physical social engineering threats. During a simulated attack, ethical hacker Liam Carter strategically places a USB drive labeled “Confidential 2025 Budget Plans” in the company’s parking lot, designed to look like it was accidentally dropped. The USB is programmed to install a harmless tracking script when plugged into a workstation, alerting the security team. Sarah, a project coordinator, finds the USB and considers plugging it into her office laptop to identify its owner.

What social engineering technique is being tested in this experiment?

- A. Phishing
- B. Hoax
- C. Pretexting
- D. Baiting

Answer: D

Explanation

The scenario clearly describes baiting, a physical social engineering technique covered in CEH under human-based attacks. Baiting involves enticing a victim with something appealing or intriguing, such as free software, confidential documents, or valuable information, in order to trick them into compromising security. In this case, the USB drive is deliberately labeled “Confidential 2025 Budget Plans,” which is designed to trigger curiosity and urgency. The attacker relies on human psychology, specifically curiosity and perceived importance, to motivate the target to plug the device into a company system.

Unlike phishing, which typically occurs through email or electronic communication, baiting often involves physical media such as USB drives left in public areas like parking lots or lobbies. CEH materials highlight that attackers may preload such devices with malware that executes automatically when inserted, granting access to the internal network. Even though this experiment uses a harmless tracking script, the methodology

mirrors real-world attacks where malicious payloads could establish backdoors, exfiltrate data, or deploy ransomware.

Hoaxes spread false warnings to create panic but do not necessarily require interaction with physical devices. Pretexting involves fabricating a scenario or identity to elicit information directly from a target through conversation or interaction. The use of a strategically placed USB labeled with enticing information fits the definition of baiting precisely. This test reinforces the importance of policies prohibiting unknown removable media usage and promoting employee awareness training.

Question #:121 - [Web Application Hacking]

In Austin, Texas, ethical hacker Michael Reyes is conducting a red team exercise for Horizon Tech, a software development firm. During his assessment, Michael crafts a malicious link that appears to lead to the company's internal project management portal. When an unsuspecting employee clicks the link, it redirects them to a login session that Michael has already initialized with the server. After the employee logs in, Michael uses that session to access the portal in a controlled test, demonstrating a vulnerability to the IT team.

Which session hijacking technique is Michael using in this red team exercise?

- A. Session donation attack
- B. Session replay attack
- C. Session sniffing
- D. Session fixation attack

Answer: D

Explanation

This scenario matches a session fixation attack because Michael sets up a valid session identifier with the application first, then forces the victim to authenticate while using that same pre-established session. In CEH terms, session fixation occurs when an attacker “fixes” or plants a known session ID in the victim’s browser, typically via a crafted URL parameter, cookie setting through a subdomain, or a redirect that preserves a session token. If the application does not regenerate the session ID after login, the victim’s authentication becomes bound to the attacker-known session. The attacker can then reuse that same session ID to access the application as the victim, exactly as described when Michael “uses that session to access the portal” after the employee logs in.

The other options do not fit the mechanism. Session sniffing relies on capturing session tokens from network traffic, usually when encryption is missing or weak, but the question focuses on a link and a pre-initialized session rather than intercepting traffic. Session replay generally refers to capturing and replaying authentication exchanges or tokens, not pre-setting a session before the victim authenticates. “Session donation” is not the standard CEH label for this behavior and is not the best match to the described flow.

CEH-recommended mitigations include regenerating session IDs immediately after authentication and privilege changes, rejecting session IDs supplied in URLs, setting Secure and HttpOnly cookie flags, enforcing SameSite where appropriate, implementing short idle timeouts, and adding server-side controls to detect concurrent use or abnormal session binding changes.

Question #:122 - [Network and Perimeter Hacking]

During a black-box internal penetration test, a security analyst identifies an SNMPv2-enabled Linux server using the default community string "public." The analyst wants to enumerate running processes. Which Nmap command retrieves this information?

- A. `nmap -sU -p 161 --script snmp-sysdescr`
- B. `nmap -sU -p 161 --script snmp-win32-services`
- C. `nmap -sU -p 161 --script snmp-processes`
- D. `nmap -sU -p 161 --script snmp-interfaces`

Answer: C

Explanation

CEH v13 highlights that SNMPv1/v2 environments configured with default community strings such as "public" or "private" present significant security risks because they allow unauthorized users to query system information. SNMP enumeration can reveal processes, interfaces, routing tables, users, device configurations, and more. The `snmp-processes` Nmap NSE script is specifically designed to enumerate running processes on an SNMP-enabled host. It queries the Host Resources MIB (HR-MIB), which stores operational information about system processes, CPU usage, and memory consumption. This information provides attackers with insights into what services may be exploitable or misconfigured. CEH stresses that SNMPv2 is particularly vulnerable due to lack of encryption and authentication hardening. By enumerating processes, penetration testers can identify potential privilege escalation paths, outdated services, or rogue applications that may aid lateral movement. Other scripts such as `snmp-sysdescr` or `snmp-interfaces` retrieve system description or interface data but do not enumerate processes.

Question #:123 - [Wireless Network Hacking]

You are Ava Mitchell, an ethical hacker at Sentinel Cyberworks, hired to test the wireless defenses of Horizon Financial, a bank in Boston, Massachusetts. During a covert night-time assessment, your objective is to simulate an attacker attempting to breach the bank's WPA-protected Wi-Fi network. You deploy a tool that allows you to capture wireless packets, send de-authentication packets to force client reconnections, and attempt to recover the encryption key, all within a single graphical interface. Based on the described functionality, which Wi-Fi security auditing tool are you using?

- A. Fern WiFi Cracker
- B. RFProtect
- C. Cisco Adaptive Wireless IPS
- D. WatchGuard Wi-Fi Cloud WIPS

Answer: A

Explanation

The tool described matches Fern WiFi Cracker because CEH wireless assessment workflows commonly reference GUI-based auditing utilities that combine packet capture, wireless injection support, and key recovery attempts in one interface. The scenario specifically mentions three core capabilities: capturing wireless packets, sending de-authentication frames to trigger client reconnects, and attempting to recover the encryption key. Those steps align with the typical WPA cracking methodology discussed in CEH learning paths: capture the WPA handshake when a client connects, optionally force a reconnection by sending de-authentication frames, then perform an offline attack against the captured handshake using a wordlist or brute-force approach. Fern WiFi Cracker is known for presenting these functions through a graphical interface, making it a common example of an “all-in-one” Wi-Fi auditing tool.

The other options are defensive monitoring and prevention platforms, not offensive auditing tools used to actively deauthenticate clients or attempt key recovery. RFProtect, Cisco Adaptive Wireless IPS, and WatchGuard Wi-Fi Cloud WIPS are Wireless Intrusion Prevention and Monitoring solutions designed to detect rogue access points, identify attacks such as deauthentication floods, enforce wireless security policies, and generate alerts for security teams. They are used to stop or respond to attacks rather than conduct packet capture plus key-recovery attempts as part of an assessment.

Because the question emphasizes a single graphical interface that captures traffic, injects deauth frames, and attempts key recovery, the correct match among the choices is Fern WiFi Cracker.

Question #:124 - [Social Engineering]

During security awareness training, which scenario best describes a tailgating social engineering attack?

- A. An attacker impersonates a customer to recover account credentials
- B. An attacker leaves a malicious USB labeled “Employee Bonus List”
- C. A person gains access to a secure building by following an authorized employee through a locked door
- D. An email urges employees to enter credentials for an urgent system update

Answer: C

Explanation

The Certified Ethical Hacker (CEH) Social Engineering module defines tailgating as a physical social engineering attack where an unauthorized person follows an authorized individual into a restricted area.

Option C precisely matches CEH’s definition.

Option A is pretexting.

Option B is baiting.

Option D is phishing.

CEH stresses physical security awareness as critical as cyber defenses.

Question #:125 - [Web Application Hacking]

While testing a web application that relies on JavaScript-based client-side security controls, which method is most effective for bypassing these controls without triggering server-side alerts?

- A. Reverse-engineering the proprietary encryption algorithm
- B. Disabling JavaScript in the browser and submitting invalid data
- C. Injecting malicious JavaScript into the login page
- D. Using a proxy tool to intercept and modify client-side requests

Answer: B

Explanation

The Certified Ethical Hacker (CEH) Web Application Security module emphasizes that client-side controls cannot be trusted.

Disabling JavaScript allows attackers to bypass:

Password complexity enforcement

CAPTCHA validation

Input validation logic

Option B is the simplest and most effective CEH-approved method.

Option A is unnecessary and noisy.

Option C risks detection.

Option D is effective but more complex and detectable.

CEH explicitly teaches testers to disable JavaScript to evaluate server-side enforcement.

Question #:126 - [Cloud Computing]

A serverless application was compromised through an insecure third-party API used by a function. What is the most effective countermeasure?

- A. Deploy a cloud-native security platform
- B. Enforce function-level least privilege permissions

- C. Use a CASB for third-party services
- D. Regularly update serverless functions

Answer: B

Explanation

In CEH v13 Cloud Computing, serverless architectures introduce unique security challenges, particularly around Function-as-a-Service (FaaS) permissions. When a serverless function is compromised through an insecure third-party API, the damage depends largely on what the function is allowed to do.

Implementing function-level permission models and enforcing the principle of least privilege ensures that even if a function is exploited, its ability to execute malicious actions is strictly limited. CEH v13 strongly emphasizes granular IAM controls in serverless environments.

While cloud-native security platforms (Option A) and CASBs (Option C) provide visibility and governance, they do not directly prevent excessive permissions. Regular patching (Option D) is important but does not mitigate permission abuse.

CEH v13 identifies least privilege as the single most critical control in preventing serverless abuse and privilege escalation. Therefore, Option B is the correct answer.

Question #:127 - [Security Operations and Incident Response]

In Portland, Oregon, ethical hacker Olivia Harper is hired by Cascade Biotech to test the security of their research network. During her penetration test, she simulates an attack by sending malicious packets to a server hosting sensitive genetic data. To evade detection, she needs to understand the monitoring system deployed near the network's perimeter firewall, which analyzes incoming and outgoing traffic for suspicious patterns across the entire subnet. Olivia's goal is to bypass this system to highlight vulnerabilities for the security team.

Which security system is Olivia attempting to bypass during her penetration test of Cascade Biotech's network?

- A. Network-Based Intrusion Detection System
- B. Host-Based Firewalls
- C. Network-Based Firewalls
- D. Host-Based Intrusion Detection System

Answer: A

Explanation

The system described is a Network-Based Intrusion Detection System because it is positioned near the perimeter firewall and inspects traffic flowing across the network segment rather than activity on a single endpoint. In CEH-aligned coverage, a NIDS is deployed at strategic network points such as behind a firewall, on core switches, or on SPAN or TAP links to monitor inbound and outbound packets. Its purpose is to detect

suspicious patterns, signatures, protocol anomalies, and indicators of scanning or exploitation attempts across multiple hosts and an entire subnet. The question explicitly says it “analyzes incoming and outgoing traffic” and looks for patterns “across the entire subnet,” which matches NIDS scope and placement.

A Host-Based IDS, by contrast, runs on individual servers or workstations and monitors local events such as system calls, logs, file integrity, registry changes, and local network connections for that specific host. That does not match the perimeter-positioned, subnet-wide traffic analysis described. Host-based firewalls also operate per endpoint, enforcing rules for that machine only, and do not provide centralized subnet-wide packet inspection from a perimeter vantage point. A network-based firewall primarily enforces allow or deny policy and may perform stateful filtering, but it is not primarily described as a detection tool analyzing suspicious patterns; IDS is the detection-focused control.

Therefore, Olivia is attempting to bypass a Network-Based Intrusion Detection System to demonstrate how malicious traffic might evade monitoring controls placed near the firewall and to help the security team strengthen detection coverage and alerting.

Question #:128 - [Reconnaissance Techniques]

A penetration tester needs to map open ports on a target network without triggering the organization's intrusion detection systems (IDS), which are configured to detect standard scanning patterns and abnormal traffic volumes. To achieve this, the tester decides to use a method that leverages a third-party host to obscure the origin of the scan. Which scanning technique should be employed to accomplish this stealthily?

- A. Conduct a TCP FIN scan with randomized port sequences
- B. Perform a TCP SYN scan using slow-timing options
- C. Execute a UDP scan with packet fragmentation
- D. Use an Idle scan by exploiting a "zombie" host

Answer: D

Explanation

CEH v13 identifies the Idle Scan as one of the most stealthy and advanced reconnaissance techniques due to its ability to avoid generating any traffic directly between the attacker and the target. Using a “zombie host,” which has predictable IP ID sequencing, the attacker forges packets so that all scan traffic appears to originate from the zombie. The IDS sees communication only between the zombie and the target, not the attacker. This allows evasion of network monitoring tools, traffic correlation systems, and intrusion detection signatures. CEH highlights Idle Scanning as a core technique for bypassing sophisticated detection controls because it leaves no direct fingerprint of the attacker. Options A and B still originate from the attacker's IP. Option C can evade some filters but remains detectable due to packet anomalies. Only Idle Scanning provides full origin obfuscation, making it the most appropriate method for stealth port enumeration.

Question #:129 - [Mobile Platform and IoT Hacking]

A cybersecurity research team identifies suspicious behavior on a user's Android device. Upon investigation, they discover that a seemingly harmless app, downloaded from a third-party app store, has silently

overwritten several legitimate applications such as WhatsApp and SHAREit. These fake replicas maintain the original icon and user interface but serve intrusive advertisements and covertly harvest credentials and personal data in the background. The attackers achieved this by embedding malicious code in utility apps like video editors and photo filters, which users were tricked into installing. The replacement occurred without user consent, and the malicious code communicates with a command-and-control (C&C) server to execute further instructions. What type of attack is being carried out in this scenario?

- A. Simjacker attack
- B. Man-in-the-Disk attack
- C. Agent Smith attack
- D. Camfecting attack

Answer: C

Explanation

CEH v13 describes Agent Smith-style attacks as malicious Android operations where an app silently replaces legitimate applications by exploiting weaknesses in the Android app update and installation processes. These attacks often begin when users download seemingly innocent apps from untrusted third-party marketplaces. Once installed, the malicious application injects harmful code into other apps, overwriting them while preserving their icons and interface, allowing the attacker to harvest credentials, display ads, or maintain persistence without detection. CEH explains that this technique takes advantage of Android's APK structure, sideloading vulnerabilities, and lack of signature validation in compromised environments. Simjacker (Option A) targets SIM toolkit vulnerabilities and does not replace apps. Man-in-the-Disk (Option B) abuses external storage operations but does not overwrite applications. Camfecting (Option D) refers to hijacking smartphone cameras. The described malicious replacement of legitimate apps exactly matches the Agent Smith attack pattern.

Question #:130 - [Cloud Computing]

At a Los Angeles-based online gaming company, penetration tester John investigates a recent cloud breach that caused downtime and delayed alerts. He finds that the root issue was management's lack of defined responsibilities for monitoring, auditing, and securing serverless services, which left critical functions unmanaged. Which cloud computing threat does this scenario best illustrate?

- A. Insufficient logging and monitoring
- B. Loss of governance
- C. Privilege escalation
- D. Side-channel attacks

Answer: B

Explanation

The scenario best illustrates loss of governance because the core problem is not a specific technical exploit but a failure in management oversight, accountability, and control assignment for cloud/serverless security responsibilities. The question describes “lack of defined responsibilities for monitoring, auditing, and securing serverless services,” resulting in critical functions being “unmanaged,” which led to downtime and delayed alerts. That is a governance failure: the organization did not establish clear ownership, policies, and operational processes to ensure cloud workloads—specifically serverless functions—were properly monitored, audited, and secured.

In cloud environments, governance includes defining roles and responsibilities (shared responsibility model understanding), establishing security baselines, ensuring logging/monitoring coverage, enforcing configuration management, and maintaining compliance oversight. When governance is weak, services may be deployed without consistent security controls, alerts may be misconfigured or ignored, and incident response can be delayed because no team is clearly accountable. Serverless increases this risk because it can be rapidly adopted by developers, spun up quickly, and overlooked by traditional infrastructure processes if the organization’s governance framework doesn’t explicitly include it.

While “insufficient logging and monitoring” (A) is closely related, the scenario frames the root cause as management’s lack of defined responsibilities, which is broader than missing logs. It’s about the absence of governance structures that ensure logging/monitoring are implemented and owned. Privilege escalation and side-channel attacks are technical attack categories not suggested by the description.

Therefore, the cloud threat illustrated is B. Loss of governance.

Question #:131 - [Cryptography]

During a cryptographic audit of a legacy system, a security analyst observes that an outdated block cipher is leaking key-related information when analyzing large sets of plaintext–ciphertext pairs. What approach might an attacker exploit here?

- A. Launch a key replay through IV duplication
- B. Use linear approximations to infer secret bits
- C. Modify the padding to obtain plaintext
- D. Attack the hash algorithm for collisions

Answer: B

Explanation

CEH covers classical cryptanalytic attacks, including linear cryptanalysis, which uses statistical correlations between plaintext and ciphertext to infer bits of the secret key. If a cipher leaks structural patterns across many data samples, linear approximations can be computed to break the cipher.

Question #:132 - [Information Security and Ethical Hacking Overview]

A penetration tester is assessing a company's HR department for vulnerability to social engineering attacks using knowledge of recruitment and onboarding processes. What is the most effective technique to obtain network access credentials without raising suspicion?

- A. Develop a fake social media profile to connect with HR employees and request sensitive information
- B. Create a convincing fake onboarding portal that mimics the company's internal systems
- C. Send a generic phishing email with a link to a fake HR policy document
- D. Conduct a phone call posing as a new employee to request password resets

Answer: B

Explanation

Social engineering attacks that target business processes are especially effective when they mimic legitimate workflows. CEH learning materials emphasize that attackers often exploit trust relationships and organizational procedures rather than attempting broad or generic phishing methods. In the context of HR operations, onboarding portals are highly trusted and frequently accessed by new employees who expect to enter personal information, submit documents, and receive initial network credentials. By creating a fake onboarding portal that closely resembles the organization's internal system, an attacker can collect credentials without triggering suspicion because the action being requested appears normal and expected. This method leverages procedural familiarity, brand consistency, and the implied authority of HR communications, making it far more effective than generic phishing emails or unsolicited social media messages. Phone calls, while sometimes useful, involve real-time interaction and increase the chance of detection. The fake portal, however, seamlessly integrates into existing processes, making it the most effective and lowest-profile approach for acquiring network credentials.

Question #:133 - [Network and Perimeter Hacking]

You perform a FIN scan and observe that many ports do not respond to FIN packets. How should these results be interpreted?

- A. Conclude the ports are closed
- B. Escalate as an active breach
- C. Attribute it to network congestion
- D. Suspect firewall filtering and investigate further

Answer: D

Explanation

According to CEH v13 Network Scanning Techniques, a FIN scan is a stealth scanning method that sends TCP packets with only the FIN flag set. Its behavior relies on RFC 793, which specifies that closed ports must respond with a TCP RST, while open ports should silently drop the packet.

However, modern firewalls, IDS/IPS systems, and hardened TCP/IP stacks often filter or silently drop FIN packets regardless of port state. Therefore, when a FIN scan results in no response from a large number of ports, it does not conclusively indicate that the ports are open. Instead, CEH v13 stresses that this behavior commonly points to packet filtering by firewalls or security controls.

Option A is incorrect because a lack of response does not definitively mean ports are closed. Option B is an overreaction; stealth scan anomalies alone do not indicate a breach. Option C is unlikely because congestion would impact multiple protocols, not selectively suppress FIN responses.

CEH v13 recommends that when FIN scans produce ambiguous results, analysts should correlate findings using additional scan types (such as SYN scans) and investigate firewall rules and filtering behavior. Thus, option D is the most accurate interpretation and aligns with CEH guidance.

Question #:134 - [Network and Perimeter Hacking]

During testing against a network protected by a signature-based IDS, the tester notices that standard scans are blocked. To evade detection, the tester sends TCP headers split into multiple small IP fragments so the IDS cannot reassemble or interpret them, but the destination host can. What technique is being used?

- A. IP decoying with randomized address positions
- B. SYN scan with spoofed MAC address
- C. Packet crafting with randomized window size
- D. Packet fragmentation to bypass filtering logic

Answer: D

Explanation

CEH v13 details that fragmentation attacks are a common IDS evasion strategy. Signature-based IDS systems depend on reassembling packets to detect malicious patterns. When attackers fragment TCP headers into smaller segments, the IDS may be unable to reconstruct the original packet sequence, especially if the fragments are intentionally crafted to confuse reassembly buffers. Meanwhile, the target host typically recombines the fragments correctly, allowing the scan or payload to pass undetected. This technique is specifically discussed under IDS evasion methods, where fragmentation prevents complete packet inspection. Options A and B describe unrelated evasion mechanisms such as IP spoofing and MAC spoofing, and Option C does not fundamentally affect IDS reconstruction. The tester is clearly using packet fragmentation to evade detection while still mapping open ports successfully.

Question #:135 - [Reconnaissance Techniques]

During a red team assessment of a multinational financial firm, you're tasked with identifying key personnel across various departments and correlating their digital footprints to evaluate exposure risk. Your objective includes mapping user aliases across platforms, identifying geotagged media, and pinpointing potential insider threats based on social posting behavior. The team has shortlisted multiple tools for the task.

Considering the technical capabilities and limitations described in the approved reconnaissance toolkit, which tool provides cross-platform username correlation by scanning hundreds of social networking sites, but does not natively support geolocation tracking or visualizing identity relationships?

- A. Creepy
- B. Social Searcher
- C. Maltego
- D. Sherlock

Answer: D

Explanation

Sherlock is the correct choice because it is specifically designed for OSINT-style username enumeration across a very large number of websites. In CEH-aligned reconnaissance, one common task is “alias correlation,” where the tester checks whether the same username exists across multiple social networks, forums, and content platforms. Sherlock automates this by querying many supported sites and reporting where an account with a given username appears to exist. This directly matches the question’s requirement: “cross-platform username correlation by scanning hundreds of social networking sites.”

The prompt also specifies what the tool does not do: it “does not natively support geolocation tracking or visualizing identity relationships.” That limitation aligns with Sherlock’s role as a focused username discovery tool rather than an analysis platform. By comparison, Creepy is associated with geolocation-focused OSINT, particularly collecting and correlating location metadata from social media posts and images, which is the opposite of the stated limitation. Maltego is well known for relationship analysis and link visualization, allowing investigators to build graphs of people, emails, domains, and social entities—again contradicting the “does not visualize identity relationships” constraint. Social Searcher is more oriented toward searching and monitoring public social media content and mentions, not primarily high-volume username existence checking across hundreds of sites in the same manner.

In CEH reconnaissance workflows, Sherlock fits early-stage enumeration to expand a target’s footprint, after which analysts may pivot into tools like Maltego for link analysis or geolocation tools when location exposure is part of the assessment.

Question #:136 - [Security Operations and Incident Response]

A penetration tester performs a vulnerability scan on a company’s web server and identifies several medium-risk vulnerabilities related to misconfigured settings. What should the tester do to verify the vulnerabilities?

- A. Use publicly available tools to exploit the vulnerabilities and confirm their impact
- B. Ignore the vulnerabilities since they are medium-risk
- C. Perform a brute-force attack on the web server’s login page
- D. Conduct a denial-of-service (DoS) attack to test the server’s resilience

Answer: A**Explanation**

CEH v13 emphasizes that after identifying vulnerabilities during scanning, testers must validate findings to determine real impact and eliminate false positives. This requires safe, controlled exploitation using approved tools such as Metasploit, Nikto, or custom proof-of-concept scripts. Misconfigurations labeled as medium-risk may still provide privilege escalation, data exposure, or footholds for further attacks. CEH methodology reinforces that exploitation should always follow the scope and rules of engagement and should avoid disruptive activities like brute-forcing or DoS attacks unless explicitly authorized. Ignoring the vulnerabilities is never acceptable in a professional assessment. Verifying the issue helps the organization prioritize remediation using evidence-based results. Therefore, the correct next step is to verify the vulnerability through controlled exploitation.

Question #:137 - [Malware Threats]

A security analyst is investigating a network compromise where malware communicates externally using common protocols such as HTTP and DNS. The malware operates stealthily, modifies system components, and avoids writing payloads to disk. What is the most effective action to detect and disrupt this type of malware communication?

- A. Blocking commonly known malware ports such as 6667 and 12345.
- B. Relying solely on frequent antivirus signature updates.
- C. Using behavioral analytics to monitor abnormal outbound traffic and application behavior.
- D. Blocking all unencrypted HTTP traffic at the proxy level.

Answer: C**Explanation**

The Certified Ethical Hacker (CEH) Malware Threats module explains that modern malware increasingly uses fileless techniques and living-off-the-land strategies, communicating over legitimate protocols like HTTP and DNS to evade detection.

Because this traffic blends with normal activity, port-based blocking and signature-based antivirus are often ineffective. CEH highlights behavioral analytics and network traffic analysis as the most reliable detection mechanisms for identifying anomalies such as:

Unusual outbound DNS queries

Abnormal HTTP beaconing patterns

Suspicious process behavior

Option C is correct because it focuses on detecting behavioral anomalies, which CEH identifies as essential for combating advanced malware and command-and-control (C2) channels.

Option D may disrupt business operations and does not address DNS-based C2.

Option A is outdated.

Option B cannot detect unknown or fileless malware.

CEH strongly recommends anomaly detection and behavioral monitoring for advanced threats.

Question #:138 - [Security Operations and Incident Response]

A system administrator observes that several machines in the network are repeatedly sending out traffic to unknown IP addresses. Upon inspection, these machines were part of a coordinated spam campaign. What is the most probable cause?

- A. Keyloggers were harvesting user credentials
- B. Devices were enslaved into a botnet network
- C. Browsers were redirected to adware-injected sites
- D. Worms exploited zero-day vulnerabilities

Answer: B

Explanation

CEH defines botnets as networks of compromised machines controlled remotely to perform coordinated activities such as DDoS attacks, spam campaigns, and credential theft. Systems showing outbound connections to unknown IPs and participating in mass spam dissemination are characteristic indicators of botnet infection.

Question #:139 - [Cloud Computing]

A penetration tester is assessing an organization's cloud infrastructure and discovers misconfigured IAM policies on storage buckets. The IAM settings grant read and write permissions to any authenticated user. What is the most effective way to exploit this misconfiguration?

- A. Use leaked API keys to access the cloud storage buckets and exfiltrate data
- B. Execute a SQL injection attack on the organization's website to retrieve sensitive information
- C. Create a personal cloud account to authenticate and access the misconfigured storage buckets
- D. Perform a Cross-Site Scripting (XSS) attack on the cloud management portal to gain access

Answer: C

Explanation

CEH notes that cloud IAM misconfigurations can unintentionally grant broad access. If any authenticated cloud account is permitted read/write access, attackers can simply authenticate with their own cloud identity and directly interact with the misconfigured storage buckets, enabling data exfiltration or manipulation.

Question #:140 - [Reconnaissance Techniques]

During a red team assessment, an ethical hacker must map a large multinational enterprise's external attack surface. Due to strict rules of engagement, no active scans may be used. The goal is to identify publicly visible subdomains to uncover forgotten or misconfigured services. Which method should the ethical hacker use to passively enumerate the organization's subdomains?

- A. Leverage tools like Netcraft or DNSdumpster to gather subdomain information
- B. Attempt to guess admin credentials and access the company's DNS portal
- C. Conduct a brute-force DNS subdomain enumeration
- D. Request internal DNS records using spoofed credentials

Answer: A

Explanation

CEH clearly distinguishes between active and passive reconnaissance. Passive methods involve gathering publicly available data without directly interacting with the target's infrastructure, thus avoiding detection. Tools such as Netcraft, DNSdumpster, VirusTotal, Certificate Transparency logs, and search engine indexing are recommended by CEH for discovering subdomains through public metadata, cached DNS records, WHOIS data, SSL certificate entries, and third-party enumeration databases. These platforms provide insights into externally accessible assets without sending packets or queries to the target organization. Brute-force enumeration is active and violates the rules of engagement. Attempting credential guessing or requesting internal DNS data are unauthorized and clearly active reconnaissance activities. Passive OSINT-based subdomain enumeration is a core CEH technique used to uncover hidden infrastructure safely and legally. It is especially crucial in red team operations where stealth is a priority.

Question #:141 - [Web Application Hacking]

Which action would most effectively increase the security of a virtual-hosted web server?

- A. Implement LAMP architecture
- B. Change IP addresses regularly
- C. Regularly update and patch server software
- D. Move document root to another disk

Answer: C

Explanation

According to CEH v13 Web Application and Server Security, regular patching and updates are the most effective way to reduce server attack surfaces. Vulnerabilities in web servers, proxies, and supporting services are frequently exploited if patches are delayed.

While architectural choices and directory placement influence organization, they do not mitigate known vulnerabilities. Changing IP addresses does not prevent exploitation, and moving directories does not address underlying software flaws.

CEH v13 consistently emphasizes patch management as a primary defensive control. Therefore, Option C is correct.

Question #:142 - [Malware Threats]

During a late-night shift at IronWave Logistics in Seattle, cybersecurity analyst Marcus Chen notices a pattern of high-port outbound traffic from over a dozen internal machines to a previously unseen external IP. Each system had recently received a disguised shipping report, which, when opened, initiated a process that spread autonomously to other workstations using shared folders and stolen credentials. Upon investigation, Marcus discovers that the machines now contain hidden executables that silently accept remote instructions and occasionally trigger coordinated background tasks. The compromised endpoints are behaving like zombies, and malware analysts confirm that the payload used worm-like propagation to deliver a backdoor component across the network.

Which is the most likely objective behind this attack?

- A. To exfiltrate sensitive information and tracking data
- B. To execute a ransomware payload and encrypt all data
- C. To establish a botnet for remote command and control
- D. To deploy a Remote Access Trojan (RAT) for stealthy surveillance

Answer: C

Explanation

The strongest indicator in this scenario is that multiple compromised hosts are “behaving like zombies,” communicating outbound to a single unfamiliar external IP over high ports, and “silently accept remote instructions” while performing “coordinated background tasks.” In CEH-aligned malware terminology, these are hallmark characteristics of a botnet: a collection of infected endpoints (bots/zombies) under centralized or semi-centralized command-and-control. Worm-like propagation explains how the compromise rapidly expanded across the internal network—using shared folders and stolen credentials for lateral spread—while the “backdoor component” provides persistent remote control functionality once a system is infected. The observed coordination across many hosts strongly suggests the attacker’s goal is not merely individual surveillance of a single machine, but scalable remote control of many machines at once.

Option A, data exfiltration, is plausible in many intrusions, but the question emphasizes orchestration and remote tasking across many endpoints rather than targeted theft from specific repositories. Option B is inconsistent because there is no mention of encryption, ransom notes, or disruption-focused behavior. Option

D, a RAT, typically describes remote control of a host, but the scenario's defining feature is the creation of many "zombies" with coordinated behavior—this aligns more precisely with building a botnet for command and control, which can later be used for data theft, DDoS, spam, or further intrusion operations.

CEH defensive guidance includes monitoring egress traffic anomalies, detecting C2 patterns, segmenting networks to limit worm spread, disabling unnecessary shares, enforcing strong credential hygiene, and using EDR to identify backdoors and lateral movement behaviors.

Question #:143 - [Malware Threats]

A penetration tester discovers malware on a system that disguises itself as legitimate software but performs malicious actions in the background. What type of malware is this?

- A. Trojan
- B. Spyware
- C. Worm
- D. Rootkit

Answer: A

Explanation

CEH v13 defines a Trojan as malware that appears as a legitimate, trusted software application while secretly executing malicious actions behind the scenes. Trojans rely on deception rather than replication, often masquerading as tools, utilities, updates, or installers. Once executed, they may install backdoors, steal credentials, exfiltrate data, or modify system settings. The defining characteristic emphasized in CEH is the legitimate-looking façade combined with hidden malicious intent, which matches the scenario perfectly. Spyware (Option B) focuses on monitoring and data collection but does not necessarily disguise itself as legitimate software. Worms (Option C) self-replicate across networks, which is not described here. Rootkits (Option D) hide system compromise but do not necessarily pose as legitimate software. Therefore, the malware described is a Trojan.

Question #:144 - [Web Application Hacking]

During a red team exercise, a Certified Ethical Hacker (CEH) is attempting to exploit a potential vulnerability in a target organization's web server. The CEH has completed the information gathering and footprinting phases and has mirrored the website for offline analysis. It has also been discovered that the server is vulnerable to session hijacking. Which of the following steps is most likely to be part of a successful attack methodology while minimizing the possibility of detection?

- A. Hijack an active session and immediately modify server configuration files.
- B. Attempt SQL injection to extract sensitive database information.
- C. Perform vulnerability scanning using automated tools to identify additional weaknesses.

D. Launch a direct brute-force attack to crack the server's administrative password.

Answer: B

Explanation

According to the Certified Ethical Hacker (CEH) attack methodology, once reconnaissance, footprinting, and website mirroring have been completed, the attacker proceeds cautiously to exploitation while maintaining stealth. CEH documentation emphasizes that low-noise, application-layer attacks are preferable when the objective is to minimize detection.

Option B, attempting SQL Injection, aligns directly with CEH's Web Application Hacking module. SQL Injection is a server-side attack that can often be executed through normal-looking HTTP requests, making it less likely to trigger intrusion detection systems (IDS) or security alerts. CEH materials highlight SQL injection as a common and effective technique for extracting sensitive data such as usernames, passwords, and business-critical information without disrupting server operations.

Option A is incorrect because immediately modifying server configuration files after session hijacking significantly increases the risk of detection. CEH guidelines stress post-exploitation restraint, especially during red team operations.

Option C is not ideal at this stage because automated vulnerability scanners generate substantial traffic and are highly detectable. CEH explicitly notes that vulnerability scanning is noisy and often logged.

Option D is the least stealthy option. Brute-force attacks generate numerous failed authentication attempts, triggering security alerts and account lockouts. CEH classifies brute-force attacks as high-risk and easily detectable.

Therefore, SQL Injection represents the most effective and stealthy next step in accordance with CEH's structured attack lifecycle.

Question #:145 - [Mobile Platform and IoT Hacking]

An attacker is analyzing traffic from a mobile app and finds that sensitive data like session tokens are being transmitted over HTTP instead of HTTPS. The attacker plans to intercept and manipulate the data during transmission. Which vulnerability is the attacker exploiting?

- A. Security Misconfiguration
- B. Improper SSL Pinning
- C. Insecure Communication
- D. Insufficient Input Validation

Answer: C

Explanation

Insecure communication is defined in CEH's mobile and IoT security modules as the failure to encrypt sensitive data transmitted between a device and a server. When applications use plain HTTP instead of HTTPS, all traffic—including authentication tokens, user identifiers, and session data—can be monitored and altered by an attacker through network sniffing or man-in-the-middle attacks. CEH emphasizes that insecure transport channels represent one of the most common and critical weaknesses in mobile ecosystems, allowing attackers to harvest credentials or inject malicious commands. Security misconfiguration refers to improper server settings, while SSL pinning issues involve certificate validation bypassing. Insufficient input validation pertains to application-side data validation. None of these align as directly as insecure communication, which precisely describes the unencrypted data exposure.

Question #:146 - [Mobile Platform, IoT, and OT Hacking]

In Pittsburgh, Pennsylvania, a major steel manufacturer operates a production plant with numerous automated loops that regulate temperature, pressure, and conveyor speed. During an audit, ethical hacker Marcus Reed observes that these loops are coordinated by a centralized supervisory network that links multiple controllers across the facility. Based on this design, which OT system concept is being applied?

- A. Manual loop
- B. Distributed Control System (DCS)
- C. Open loop
- D. Closed loop

Answer: B

Explanation

A Distributed Control System (DCS) is the best match because the scenario describes multiple automated control loops (temperature, pressure, conveyor speed) that are coordinated by a centralized supervisory network linking multiple controllers across a facility. In industrial environments, a DCS architecture distributes control functions across many controllers located near the process equipment, while supervisory control and operator interfaces coordinate and monitor the overall process. This makes DCS common in continuous and process industries such as steel, chemical, oil and gas, and manufacturing plants where many interdependent loops must operate reliably together.

The scenario's "centralized supervisory network" is a key DCS hallmark: operators and supervisory systems (often including engineering workstations and HMIs) provide centralized monitoring, setpoints, alarms, and coordination, while the actual loop control is executed by distributed controllers. This differs from a single isolated controller or purely manual operation. The purpose is to maintain stable process control and ensure coordinated behavior across different production areas.

Why the other options don't fit:

A manual loop (A) implies human-operated control rather than automated feedback loops. The plant is described as having "numerous automated loops," so manual loop is incorrect.

Open loop (C) control does not use feedback from the output to adjust the input; it is not typical for precise regulation of temperature and pressure where feedback is essential.

Closed loop (D) does describe feedback-based regulation and is true of many industrial loops; however, the question asks for the OT system concept applied based on the overall facility design—specifically a supervisory network coordinating multiple controllers—pointing to the architecture (DCS) rather than the loop type.

Therefore, the correct answer is B. Distributed Control System (DCS).

Question #:147 - [Network and Perimeter Hacking]

In a recent cybersecurity incident, Google's response team in the United States investigated a severe attack that briefly disrupted services and customer-facing platforms for approximately 2–3 minutes. Server logs recorded a sudden surge in traffic, peaking at 398 million requests per second, which caused active connections to drop unexpectedly. The attack was traced to numerous compromised devices, likely orchestrated through malicious tools promoted on social media. Based on this information, what type of attack was most likely executed against Google's infrastructure?

- A. SYN Flood Attack
- B. TCP SACK Panic Attack
- C. RST Attack
- D. HTTP GET POST Attack

Answer: D

Explanation

An HTTP GET POST attack is the most likely answer because the key indicator in the scenario is the measurement unit and behavior: 398 million requests per second. In CEH-aligned DoS and DDoS coverage, volumetric network-layer attacks like SYN floods are typically discussed in packets per second or bits per second, and they primarily exhaust connection tables or bandwidth at Layer 3 and Layer 4. By contrast, an HTTP flood targets Layer 7 and is commonly measured in requests per second because the attacker is sending large volumes of seemingly valid web requests. This overwhelms web servers, application stacks, and upstream components such as reverse proxies, load balancers, and API gateways, leading to degraded performance and dropped sessions, exactly as described when “active connections drop unexpectedly.”

The mention of “customer-facing platforms” and “numerous compromised devices” also matches typical botnet-driven application-layer flooding, where many distributed sources generate massive HTTP request rates to evade simple IP-based blocking. A TCP SACK panic attack is a vulnerability-triggered crash condition related to TCP handling, not a request-rate spike scenario. An RST attack involves sending TCP reset packets to tear down sessions, which would not normally present as an extreme requests-per-second event in server logs.

Therefore, the evidence most strongly supports an application-layer DDoS: an HTTP GET POST flood designed to exhaust server and application resources and cause intermittent service disruption.

Question #:148 - [Reconnaissance Techniques]

During LDAP-based enumeration, you observe that some critical information cannot be retrieved. What is the most likely reason?

- A. LDAP directory data is protected by Access Control Lists (ACLs)
- B. LDAP is running on a non-standard port
- C. Hosts are in a different subnet
- D. Network congestion is causing dropped requests

Answer: A

Explanation

CEH v13 explains that LDAP enumeration is often restricted by Access Control Lists (ACLs). Sensitive directory objects and attributes are frequently protected to prevent unauthorized disclosure.

Even when LDAP is accessible, ACLs can limit the visibility of users, groups, and configuration data.

Question #:149 - [Network and Perimeter Hacking]

As part of a quarterly security review at EvoTrans Logistics, a global freight optimization firm, you have been brought in as a senior cybersecurity analyst to audit perimeter firewall configurations across cloud-hosted application clusters. During your investigation, you notice that TCP port 1433 is open on a virtual machine tagged as svc-node-east-14, which was provisioned by a now-defunct third-party vendor. The node is not referenced in any current infrastructure diagrams, yet live traffic logs suggest it is still handling requests during peak hours. No documentation exists regarding its service role, but you are tasked with flagging misconfigurations that may violate policy or expose critical services unnecessarily. Based on your understanding of standard port assignments, you must determine what service this port likely represents and whether its exposure warrants escalation.

Which of the following services is most likely running on this port and requires immediate review?

- A. sqlsrv
- B. SqlNet
- C. ms-sql-s
- D. ms-sql-m

Answer: C

Explanation

TCP port 1433 is the well-known default port for Microsoft SQL Server, formally registered as ms-sql-s. In CEH network and perimeter security coverage, identifying services by their default port assignments is a critical reconnaissance and defensive skill. When reviewing firewall rules and exposed services, analysts correlate open ports with their associated protocols to determine risk exposure. Port 1433 is widely recognized as the primary listening port for Microsoft SQL Server instances configured with default settings.

The presence of an undocumented virtual machine actively handling traffic on port 1433 is particularly concerning because database services often store sensitive operational or customer data. If exposed unnecessarily, SQL Server can be targeted for brute-force authentication attacks, SQL injection exploitation, misconfiguration abuse, or exploitation of unpatched vulnerabilities. CEH materials emphasize that database services should not be directly exposed to the internet unless absolutely necessary and must be protected by strict access controls, segmentation, encryption, and monitoring.

Option B, SqlNet, typically refers to Oracle database communication over port 1521. Option D, ms-sql-m, is associated with SQL Server Browser service over UDP 1434, not TCP 1433. Option A, sqlsrv, is not the formal IANA-registered service name for port 1433. Because ms-sql-s is the standard designation for Microsoft SQL Server on TCP port 1433, and given the risk of exposing database services, this finding warrants immediate escalation and review.

Question #:150 - [Security Operations and Incident Response]

At a government research lab, cybersecurity officer Nikhil is compiling a vulnerability assessment report after scanning the internal subnet. As part of his documentation, he lists the IP addresses of all scanned hosts and specifies which machines are affected. He includes tables categorizing discovered vulnerabilities by type such as outdated software, default credentials, and open ports.

Which section of the vulnerability assessment report is Nikhil working on?

- A. Findings
- B. Risk Assessment
- C. Supporting Information
- D. Assessment Overview

Answer: A

Explanation

In CEH-aligned vulnerability assessment reporting, the Findings section is where the assessor documents what was discovered during scanning and validation in a clear, structured, and actionable way. This portion of the report typically contains the concrete results: identified assets, affected systems, vulnerability details, and evidence that supports each issue. The question states that Nikhil lists the IP addresses of scanned hosts, identifies which machines are affected, and includes tables categorizing vulnerabilities such as outdated software, default credentials, and open ports. These are classic “results” artifacts that belong in Findings because they communicate the observed security weaknesses and where they exist.

The Risk Assessment section generally builds on findings by assigning severity, likelihood, impact, and overall risk ratings, often mapping issues to business consequences and prioritization. While Nikhil may later

rate default credentials as critical or open ports as medium depending on exposure, the act of enumerating vulnerabilities and associating them with specific hosts is the findings activity, not risk scoring.

Supporting Information usually contains appendices such as tool configurations, raw scan outputs, methodology references, assumptions, scope boundaries, and glossary items. Although IP lists and tables might appear in an appendix for completeness, the way the prompt describes them, they are being used as the primary categorized presentation of discovered vulnerabilities, which is consistent with the Findings section.

Assessment Overview is typically a high-level summary of scope, objectives, timeline, and approach, not detailed host-by-host vulnerability tables. Therefore, the correct section is Findings.

Question #:151 - [Network and Perimeter Hacking]

During a red team assessment at a banking client in Chicago, ethical hacker David gains access to the internal LAN. He sets up a test machine and injects crafted messages into the network. Soon, all traffic between a finance workstation and the authentication server is silently routed through his system without changing switch configurations. He observes usernames and passwords passing through his interface, even though no proxy or VPN is in use.

Which sniffing technique did David most likely use?

- A. Switch Port Stealing
- B. ARP Spoofing
- C. STP Attack
- D. IRDP Spoofing

Answer: B

Explanation

The correct answer is B. ARP Spoofing because the described outcome—silently redirecting traffic between two hosts through the attacker’s machine on a LAN without changing switch configurations—is the classic effect of ARP poisoning (also called ARP spoofing). In CEH-aligned network sniffing and man-in-the-middle (MITM) techniques, ARP spoofing works by sending forged ARP replies onto the local network so that a victim host associates the attacker’s MAC address with the IP address of a legitimate system (commonly the default gateway or another target host). Once the victim’s ARP cache is poisoned, frames intended for the real destination are instead sent to the attacker, who can then forward them to the legitimate host to maintain connectivity while inspecting or altering the traffic.

The scenario states David “injects crafted messages” and then “all traffic between a finance workstation and the authentication server is silently routed through his system.” That behavior strongly indicates ARP spoofing performed in both directions: poisoning the workstation to believe the attacker is the authentication server (or gateway) and poisoning the server to believe the attacker is the workstation (or gateway). This enables a transparent MITM position where credentials can be observed—especially if protocols are unencrypted or if the attacker can downgrade or strip protections. The fact that “no proxy or VPN is in use” supports the idea that the redirection is happening at Layer 2/Layer 3 on the local segment rather than via an explicit application-level proxy.

Why the other options are less accurate: Switch port stealing targets switch CAM tables to redirect frames, but it is less directly described than ARP cache poisoning between two IP endpoints. An STP attack manipulates spanning tree to become the root bridge and can influence paths, but it is a different control-plane attack and usually affects broader Layer 2 topology. IRDP spoofing involves ICMP Router Discovery Protocol to advertise a rogue router, but the scenario fits the much more common and direct MITM sniffing technique on a switched LAN: ARP spoofing.

Therefore, David most likely used ARP spoofing.

Question #:152 - [Wireless Network Hacking]

You are an ethical hacker at Apex Cyber Defense contracted to audit Coastal Healthcare's wireless estate in Miami, Florida. During a network sweep, your logs show a previously unknown access point physically connected to the hospital's internal switch and issuing IP addresses to devices on the corporate VLAN - it was neither provisioned by IT nor listed in the asset inventory. The device is relaying internal traffic and providing remote connectivity back to an external host. Based on the observed behavior, which wireless threat has the attacker most likely introduced?

- A. Misconfigured AP
- B. Rogue AP
- C. Honeypot AP
- D. Evil Twin AP

Answer: B

Explanation

The correct answer is B. Rogue AP because the scenario describes an unauthorized access point that has been physically connected to the internal wired network and is providing network access on the corporate VLAN without approval or inventory records. In CEH-aligned wireless security concepts, a rogue access point is any AP that is installed on an organization's network without authorization, creating an unmanaged entry point that bypasses standard security controls. The key indicators here are: it is "previously unknown," "neither provisioned by IT nor listed in the asset inventory," and it is "physically connected to the hospital's internal switch."

The fact that the device is issuing IP addresses suggests it may be running a DHCP service or bridging into the internal network in a way that places clients directly onto the corporate VLAN. This can allow attackers to gain internal access from nearby wireless range and can also cause network instability if its DHCP responses conflict with the legitimate DHCP infrastructure. Additionally, the device "relaying internal traffic and providing remote connectivity back to an external host" points to an attacker using it as a covert foothold—effectively an unauthorized wireless bridge into the internal network and a channel for command-and-control or remote access.

Why not the other options: a misconfigured AP implies a legitimate AP deployed by IT but configured insecurely (weak encryption, default credentials, poor segmentation). A honeypot AP is typically deployed deliberately (often by defenders) to attract attackers for detection and research, not stealthy backhaul to an

external host. An evil twin AP is a spoofed wireless AP that impersonates a legitimate SSID to lure victims; it does not necessarily require being physically plugged into the internal switch, and the defining trait is impersonation of a real AP/SSID. The defining trait here is unauthorized installation on the wired network, which is most directly a rogue access point.

Question #:153 - [Web Application Hacking]

Working as an Information Security Analyst, you are creating training material on session hijacking. Which scenario best describes a side jacking attack?

- A. An attacker uses social engineering to trick an employee into revealing their password.
- B. An attacker intercepts network traffic, captures unencrypted session cookies, and uses these to impersonate the user.
- C. An attacker exploits a firewall vulnerability to gain access to internal systems.
- D. An attacker convinces an employee to visit a malicious site that injects a script into their browser.

Answer: B

Explanation

Side jacking, as defined in CEH v13 Web Application Hacking, is a form of session hijacking where an attacker captures valid session identifiers—usually cookies—by sniffing network traffic. This attack is particularly effective when applications fail to encrypt session cookies using HTTPS.

In CEH v13, side jacking is commonly associated with attacks performed on unsecured wireless networks, where attackers passively monitor traffic using packet sniffers such as Wireshark. If session cookies are transmitted in plaintext, the attacker can replay them to impersonate the victim without needing login credentials.

Option B precisely matches this definition: capturing unencrypted session cookies and reusing them to gain unauthorized access.

Other options describe different attack types:

A is credential harvesting via social engineering.

C is network exploitation.

D is cross-site scripting (XSS).

CEH v13 emphasizes enforcing HTTPS, Secure and HttpOnly cookie flags, and session regeneration as defenses against side jacking.

Question #:154 - [Network and Perimeter Hacking]

A global fintech company receives extortion emails threatening a severe DDoS attack unless ransom is paid. The attacker briefly launches an HTTP flood to demonstrate capability. The attack uses incomplete POST requests that overload application-layer resources, causing performance degradation. The attacker reinforces their demand with a second threat email. What type of DDoS attack is being carried out?

- A. RDDoS attack combining threat and extortion
- B. DRDoS attack using intermediaries
- C. Recursive GET flood disguised as crawling
- D. Pulse wave attack with burst patterns

Answer: A

Explanation

CEH materials describe RDDoS (Ransom DDoS) attacks as threat-driven extortion campaigns where attackers demand payment and demonstrate capability by launching a short-lived DDoS burst. The purpose is to intimidate the victim into paying before a larger, sustained attack begins. The attack described uses HTTP floods with incomplete POST requests—an application-layer DDoS technique that consumes server resources by forcing the target to hold open connections. This kind of demonstration followed by an extortion email aligns precisely with RDDoS behavior. DRDoS attacks involve reflection/amplification through third-party servers, which is not occurring here. Pulse wave attacks use timed bursts and do not involve extortion, while recursive GET floods do not match the incomplete POST behavior. Therefore, the correct classification is RDDoS.

Question #:155 - [Wireless Network Hacking]

You are a wireless auditor at SeaFront Labs in San Diego, California, engaged to review the radio-layer protections used by a biotech research facility. While capturing traffic in monitor mode, you observe frames that include a CCMP-like header and AES-based encryption, and you note the use of a four-way handshake with a packet number (PN) for replay protection — features that were introduced to replace older TKIP/RC4 approaches. Based on these observed characteristics, which wireless encryption protocol is the access point most likely using?

- A. WPA2
- B. WPA
- C. WPA3
- D. WEP

Answer: A

Explanation

The observed characteristics point most strongly to WPA2 because the scenario explicitly identifies CCMP-like headers and AES-based encryption, along with replay protection using a packet number (PN) and the familiar four-way handshake. WPA2 (based on IEEE 802.11i) replaced older approaches that relied on RC4 and TKIP, introducing AES-CCMP as the standard data confidentiality and integrity mechanism for Wi-Fi protected networks. CCMP uses AES in a mode designed for wireless frames and includes a per-packet number to prevent replay attacks.

The mention that these features were “introduced to replace older TKIP/RC4 approaches” is a major clue. Original WPA was designed as a transitional upgrade over WEP and commonly used TKIP with RC4, whereas WPA2 standardized the stronger AES-CCMP mechanism. The four-way handshake is used to derive and install fresh session keys (pairwise transient keys) between the client and access point, and the packet number increases with each encrypted frame to provide replay protection and maintain encryption correctness.

Why the other options don't fit as well:

WEP (D) uses RC4 with weak IV handling and lacks the robust key management and handshake properties described.

WPA (B) typically centers on TKIP/RC4 rather than AES-CCMP as the defining feature set, especially in CEH-style distinctions.

WPA3 (C) introduces improvements such as SAE (Simultaneous Authentication of Equals) replacing the legacy PSK handshake method in WPA2-Personal, and enhanced protections (e.g., stronger password-based authentication). While WPA3 can still use AES-based encryption, the scenario's emphasis is on CCMP/AES replacing TKIP/RC4—most directly the WPA2 shift.

Therefore, the access point is most likely using A. WPA2.

Question #:156 - [Wireless Network Hacking]

A WPA2-PSK wireless network is tested. Which method would allow identification of a key vulnerability?

- A. De-authentication attack to capture the four-way handshake
- B. MITM to steal the PSK directly
- C. Jamming to force PSK disclosure
- D. Rogue AP revealing PSK

Answer: A

Explanation

CEH v13 states that the only viable way to attack WPA2-PSK is by capturing the four-way handshake. De-authentication forces clients to reconnect, allowing the handshake to be captured and later cracked offline.

MITM, jamming, and rogue AP attacks do not directly expose the PSK.

Question #:157 - [Information Security and Ethical Hacking Overview]

What is the correct order of the five phases of ethical hacking?

- A. Gaining Access # Maintaining Access # Covering Tracks # Reconnaissance # Scanning
- B. Maintaining Access # Covering Tracks # Reconnaissance # Scanning # Gaining Access
- C. Reconnaissance # Scanning # Gaining Access # Maintaining Access # Covering Tracks
- D. Scanning # Reconnaissance # Gaining Access # Covering Tracks # Maintaining Access

Answer: C

Explanation

CEH v13 defines the five phases of ethical hacking as a structured methodology that mirrors real-world attack progression:

Reconnaissance – Information gathering

Scanning – Identifying live hosts, ports, and vulnerabilities

Gaining Access – Exploiting vulnerabilities

Maintaining Access – Establishing persistence

Covering Tracks – Removing evidence

Option C matches this exact sequence. CEH v13 emphasizes that understanding this order is critical for both attackers and defenders, as it enables systematic testing and effective mitigation strategies.

All other options misplace phases and contradict the CEH methodology.

Question #:158 - [Web Application Hacking]

A penetration tester is testing a web application's product search feature, which takes user input and queries the database. The tester suspects inadequate input sanitization. What is the best approach to confirm the presence of SQL injection?

- A. Inject a script to test for Cross-Site Scripting (XSS)
- B. Input DROP TABLE products; -- to see if the table is deleted
- C. Enter 1' OR '1'='1 to check if all products are returned
- D. Use directory traversal syntax to access restricted files on the server

Answer: C

Explanation

Tautology-based SQL injection tests, such as using ' OR '1'='1, are safe and effective methods to verify whether SQL queries are being manipulated by user input. CEH emphasizes avoiding destructive queries and using logical expressions that return all rows if injection is successful.

Question #:159 - [Network and Perimeter Hacking]

During a penetration test at Pacific Shipping Co. in Seattle, ethical hacker Mia Chen evaluates the defenses protecting the company's web-facing servers. She observes that the security system is not only checking basic packet headers but also validating session state and performing some application-level analysis. This multilayer approach makes it more difficult for Mia to bypass the firewall using simple fragmentation or tunneling attacks.

Which type of firewall is Mia most likely facing?

- A. Packet Filtering Firewall
- B. Stateful Multilayer Inspection Firewall
- C. Application-Level Firewall
- D. Circuit-Level Gateway Firewall

Answer: B

Explanation

The firewall described is doing more than simple header checks: it is validating session state and also performing some application-level analysis. That combination is characteristic of a Stateful Multilayer Inspection Firewall. This firewall type expands beyond traditional packet filtering by tracking the state of network connections (e.g., TCP handshake progression, established sessions, expected flags and sequence behavior) and applying inspection across multiple OSI layers. Because it understands whether traffic belongs to a legitimate, established session, it can block many spoofed or out-of-context packets that might pass a stateless filter.

The mention of being harder to bypass with fragmentation or tunneling attacks further supports this. Stateless packet-filtering firewalls mainly rely on source/destination IP, port, and protocol fields. Attackers may attempt fragmentation to split payloads across packets and evade simplistic inspection, or use tunneling to encapsulate traffic to hide prohibited content. A stateful multilayer firewall, by maintaining connection tables and reassembling or correlating traffic with session context, is better equipped to detect anomalies that do not align with valid session behavior and to apply deeper inspection policies.

Why the other choices are less fitting:

A Packet Filtering Firewall (A) focuses on basic header fields and is typically stateless, matching the opposite of what Mia observed.

An Application-Level Firewall (C) (proxy firewall) can do deep application inspection, but the scenario emphasizes a multilayer approach combining state tracking with application-level checks—more aligned with stateful multilayer inspection than a pure application proxy model.

A Circuit-Level Gateway Firewall (D) validates session establishment (e.g., TCP handshakes) and creates virtual circuits, but it generally does not perform meaningful application-level analysis of the content.

Therefore, the best match is B. Stateful Multilayer Inspection Firewall.

Question #:160 - [Web Application Hacking]

A penetration tester suspects that a web application's product search feature is vulnerable to SQL injection. The tester needs to confirm this by manipulating the SQL query. What is the best technique to test for SQL injection?

- A. Inject a malicious script into the search field to test for Cross-Site Scripting (XSS)
- B. Use directory traversal syntax in the search field to access server files
- C. Input 1 OR 1=1 in the search field to retrieve all products from the database
- D. Insert admin'— in the search field to attempt bypassing authentication

Answer: C

Explanation

SQL injection testing commonly involves using tautology-based payloads such as 1 OR 1=1, which force SQL queries to evaluate as true. CEH explains that this confirms improper input sanitization and exposes whether user-supplied fields directly influence database queries. The result often returns all records, indicating successful injection.

Question #:161 - [Reconnaissance Techniques]

During an external assessment of a healthcare insurance company in Houston, a penetration tester identifies a service running on TCP port 389. When queried, the service accepts anonymous binds and reveals directory data. By structuring his search filter, the tester is able to obtain usernames, departmental details, and organizational units. This information could potentially be used for targeted password attacks or privilege escalation.

Which classification best describes this enumeration activity?

- A. SMTP Enumeration
- B. DNS Enumeration
- C. LDAP Enumeration

D. NTP Enumeration

Answer: C

Explanation

TCP port 389 is the default port for LDAP (Lightweight Directory Access Protocol). The tester's actions—performing an anonymous bind and querying directory contents with structured search filters to extract usernames and organizational information—are definitive indicators of LDAP enumeration. LDAP is commonly used for centralized directory services (including environments integrated with Active Directory via LDAP interfaces). If misconfigured to allow anonymous binds or overly permissive searches, an attacker can retrieve valuable identity and structure data.

The scenario describes obtaining usernames, departmental details, and organizational units (OUs). Those are typical LDAP directory attributes and containers. Enumerating them can directly support follow-on attack paths: building targeted password-spraying lists, crafting spear-phishing that references accurate internal roles, identifying privileged groups, and mapping the organization's structure to prioritize high-value targets. Even without direct credential compromise, directory disclosure increases attacker effectiveness.

Why the other options are incorrect:

SMTP enumeration (A) focuses on email systems (e.g., VRFY/EXPN/RCPT TO behaviors) and typically uses TCP/25 or related mail ports, not 389.

DNS enumeration (B) involves querying DNS records (A/AAAA, MX, NS, TXT, zone transfers) and does not involve directory binds or LDAP filters.

NTP enumeration (D) relates to time services (UDP/123) and provides timing/monlist-style information, not user/OU directory attributes.

Because the service is on TCP/389 and the technique involves binds and directory searches, the correct classification is C. LDAP Enumeration.

Question #:162 - [Web Application Hacking]

You are an ethical hacker at HorizonSec Consulting, hired by Liberty Insurance in Philadelphia, Pennsylvania, to test the resilience of their online claim submission portal. During testing, you modify the claim ID parameter in the URL with conditions such as AND and AND 1=2. When the first condition is used, the portal displays claim details as normal; when the second condition is used, the page displays no results. You repeat this process to determine how the application responds to true and false conditions without error messages or delays.

Based on the observed behavior, which SQL injection technique are you employing?

- A. UNION SQL Injection
- B. Error-based SQL Injection
- C. Time-based Blind SQL Injection

D. Boolean Exploitation

Answer: D

Explanation

The behavior described matches Boolean-based blind SQL injection, which is represented here as Boolean Exploitation. In this technique, the tester injects conditions that evaluate to TRUE or FALSE and then infers the backend query behavior by observing differences in the application's response—such as returning normal content versus returning an empty page—without relying on explicit database error messages or time delays.

The scenario's key indicators are:

The injected payloads include conditional logic like `AND 1=2`, which is a classic always-false test.

When a true condition is used, the portal returns the expected claim details; when a false condition is used, it returns "no results."

The tester repeats these true/false tests specifically "without error messages or delays," which rules out error-based and time-based approaches and confirms the "blind" inference method.

Why the other options don't fit:

UNION SQL Injection (A) relies on combining a malicious UNION SELECT with the original query to extract additional rows/columns directly into the response. The scenario is not extracting unioned data; it is observing response differences from boolean conditions.

Error-based SQL Injection (B) depends on triggering database errors and reading error output. The scenario explicitly notes no error messages are involved.

Time-based Blind SQL Injection (C) infers truth values by forcing delays (e.g., SLEEP()), which is explicitly not occurring here.

Therefore, the technique is best identified as D. Boolean Exploitation (Boolean-based blind SQL injection).

Question #:163 - [Web Application Hacking]

A penetration tester suspects that the web application's "Order History" page is vulnerable to SQL injection because it displays user orders based on an unprotected user ID parameter in the URL. What is the most appropriate approach to test this?

- A. Inject JavaScript into the URL parameter to test for Cross-Site Scripting (XSS)
- B. Modify the URL parameter to `userID=1 OR 1=1` and observe if all orders are displayed
- C. Perform a directory traversal attack to access sensitive system files
- D. Use a brute-force attack on the login form to identify valid user credentials

Answer: B

Explanation

CEH v13 identifies URL parameters used in dynamic SQL queries as common injection points. When user-controlled values are passed directly into database queries without validation, attackers can manipulate query logic. Injecting a test payload such as `1 OR 1=1` into the `userID` parameter is a standard method to determine whether the application concatenates input into SQL statements. If the page displays all user orders instead of only the authenticated user's orders, this confirms SQL injection. CEH teaches that conditional tautologies are one of the safest and most reliable ways to probe SQL vulnerabilities, especially in GET parameters. JavaScript injection (Option A) tests XSS, not SQLi. Directory traversal (Option C) targets filesystem issues, not database logic. Brute-forcing user credentials (Option D) does not test query sanitization. Therefore, modifying the `userID` parameter with a SQL injection payload is the correct CEH-aligned method.

Question #:164 - [Network and Perimeter Hacking]

As an IT technician in a small software development company, you are responsible for protecting the network against various cyber threats. You learn that attackers often try to bypass firewalls. Which of the following is a common technique used by attackers to evade firewall detection?

- A. Changing the source IP address of packets to make traffic appear to originate from a trusted source
- B. Using encrypted communication channels to evade network monitoring tools
- C. Using social engineering techniques to trick employees into revealing sensitive information
- D. Implementing an open-source operating system to bypass proprietary software restrictions

Answer: B

Explanation

According to the CEH Network and Perimeter Security module, one of the most effective and widely used firewall evasion techniques is the use of encrypted communication channels. When traffic is encrypted using protocols such as HTTPS, TLS, or VPN tunnels, traditional firewalls and packet-inspection tools may be unable to inspect payload contents unless SSL/TLS inspection is explicitly enabled.

CEH documentation explains that attackers commonly encrypt command-and-control (C2) traffic to:

Blend in with legitimate encrypted traffic

Bypass content-based inspection

Evade signature-based detection

Option B is therefore correct.

Option A (IP spoofing) is less effective against stateful firewalls.

Option C is a human-focused attack, not firewall evasion.

Option D has no relevance to firewall bypass techniques.

CEH highlights encryption misuse as a major blind spot in perimeter defenses.

Question #:165 - [Web Application Hacking]

In the sunlit tech oasis of Phoenix, Arizona, ethical hacker Nadia Patel explores the security posture of LearnSphere, a U.S.-based e-learning platform serving thousands of students. During her testing, Nadia intentionally submits invalid inputs to the platform's content delivery system. Instead of returning a generic failure notice, the application responds with detailed system information, including database query strings and directory paths. Such responses provide attackers with valuable insights into the application's internal workings, which could be used to craft more precise and damaging attacks.

Which issue is being demonstrated?

- A. Improper Error Handling
- B. Directory Traversal
- C. Verbose Error Messages
- D. CORS Misconfiguration

Answer: C

Explanation

The issue described is verbose error messages, where an application reveals excessive technical details when handling invalid input. The scenario states that the platform returns “detailed system information, including database query strings and directory paths” instead of a generic error. Exposing internal paths and query strings is a common symptom of verbose error handling: stack traces, SQL statements, file system locations, framework versions, and configuration hints can appear in responses when exception handling is misconfigured or when debug settings are enabled in production.

These details are valuable to attackers because they reduce guesswork. Directory paths can reveal the operating system, deployment layout, and sensitive file locations; database query strings can reveal table /column names and query structure, enabling more effective SQL injection payloads or targeted data extraction. Verbose errors can also leak usernames, internal hostnames, API endpoints, and even secrets if mishandled. Even if the initial invalid request does not compromise the system, the leaked information can significantly improve the attacker’s ability to craft subsequent attacks with higher precision.

Why the other options are less accurate:

Improper error handling (A) is a broader category and could include verbose errors, but the question’s best match is the specific symptom: detailed internal information disclosure.

Directory traversal (B) involves manipulating path input to access unauthorized files; here, the application is revealing paths due to errors, not being coerced into reading arbitrary files.

CORS misconfiguration (D) relates to cross-origin browser access controls and is unrelated to leaking stack traces or database queries.

Therefore, the correct answer is C. Verbose Error Messages.

Question #:166 - [Information Security and Ethical Hacking Overview]

A penetration tester is hired to legally assess the security of a company's network by identifying vulnerabilities and attempting to exploit them. What type of hacker is this?

- A. Black Hat
- B. Grey Hat
- C. Script Kiddie
- D. White Hat

Answer: D

Explanation

CEH v13 defines a white hat hacker as a security professional with explicit authorization to perform penetration testing, vulnerability assessments, and exploitation attempts within legal and contractual boundaries. Their objective is to strengthen security, not compromise it. White hats follow structured methodologies, document findings, and provide remediation recommendations. A black hat (Option A) acts maliciously and without permission. A grey hat (Option B) operates without authorization but without harmful intent, which is not compliant with corporate penetration testing procedures. Script kiddies (Option C) rely on pre-built tools without deep knowledge and are not employed for legitimate engagements. Therefore, the individual described is a white hat, operating under legal and ethical guidelines with organizational consent.

Question #:167 - [Network and Perimeter Hacking]

Which technique is commonly used by attackers to evade firewall detection?

- A. Spoofing source IP addresses to appear trusted
- B. Using open-source operating systems
- C. Using encrypted communication channels
- D. Social engineering employees

Answer: C

Explanation

CEH v13 identifies encrypted communication channels as one of the most common and effective firewall evasion techniques. Firewalls that rely on packet inspection or signature-based filtering often cannot inspect encrypted payloads without SSL/TLS interception capabilities.

By encrypting malicious traffic—using HTTPS, VPN tunnels, or encrypted C2 channels—attackers can bypass firewall rules that inspect packet contents. CEH v13 emphasizes that this technique is widely used in malware communication, data exfiltration, and command-and-control operations.

IP spoofing (Option A) is limited by ingress and egress filtering and is less effective against modern firewalls. Open-source operating systems (Option B) do not inherently evade firewalls. Social engineering (Option D) targets users, not firewalls.

Therefore, Option C is the correct and CEH-aligned answer.

Question #:168 - [Malware Threats]

During a controlled red team engagement at a financial institution in New Jersey, ethical hacker Ryan tests the bank's resilience against stealth-based malware. He plants a custom malicious program on an employee workstation. After execution, he observes that the infected files continue to function normally, but his malware conceals its modifications by intercepting operating system calls. Antivirus scans repeatedly return “no threats detected,” even though the malicious code remains active and hidden on the system.

Which type of virus did Ryan most likely deploy in this assessment?

- A. Cavity Virus
- B. Stealth Virus
- C. Polymorphic Virus
- D. Macro Virus

Answer: B

Explanation

The correct answer is B. Stealth Virus because the defining characteristic described is hiding malicious presence by intercepting operating system calls and masking changes so that normal tools (including antivirus scans) do not observe the infection. In CEH-aligned malware concepts, stealth viruses are designed to evade detection by concealing modifications to files, boot records, or system areas. They commonly do this by hooking system functions or APIs so that when the OS or a security product requests file contents, sizes, checksums, directory listings, or other metadata, the virus returns clean-looking or original data instead of the infected/modified version. This makes infected files appear to “function normally,” while the malware remains active in memory and persists on disk.

The scenario explicitly mentions that “infected files continue to function normally” and that the malware “conceals its modifications by intercepting operating system calls.” That is the classic behavior of stealth techniques: manipulate what the system reports, not necessarily change the outward behavior of the

application. The repeated “no threats detected” results also align: signature-based or basic scanning can be blinded when the malware controls the interface through which the scanner reads target files or system structures.

Why the other options are less correct: a polymorphic virus focuses on changing its code/signature between infections to evade signature-based detection, but the key clue here is OS call interception and hiding modifications, not code mutation. A macro virus targets macro-enabled documents and spreads through macro execution in office applications; it is not primarily defined by OS-level call hooking. A cavity virus (spacefiller) hides by inserting itself into unused areas of a file without changing the file size, but the scenario’s emphasis is on intercepting OS calls to conceal changes, which is more directly the stealth-virus behavior.

Therefore, Ryan most likely deployed a stealth virus.

Question #:169 - [Reconnaissance Techniques]

You discover multiple NetBIOS responses during an nbtscan, but only one host returns a <1B> entry. What does this indicate?

- A. It is the local system
- B. It is a rogue DHCP server
- C. It is the domain master browser / Primary Domain Controller (PDC)
- D. NetBIOS over TCP/IP is disabled

Answer: C

Explanation

In CEH v13 Reconnaissance and Enumeration, NetBIOS name suffixes are used to identify the role of systems within a Windows network. The <1B> NetBIOS suffix is particularly significant because it uniquely identifies the Domain Master Browser, which in modern Windows environments corresponds to the Primary Domain Controller (PDC).

When an nbtscan is performed, multiple systems may respond with NetBIOS names, but only one system per domain will register the <1B> suffix. This is because the PDC is responsible for maintaining the master browse list and coordinating authentication services across the domain.

Option C is correct because the <1B> entry is explicitly defined in CEH documentation as belonging to the domain controller.

Option A is incorrect because the local system does not advertise <1B>.

Option B is incorrect because DHCP servers use different identifiers and do not register <1B>.

Option D is incorrect because NetBIOS must be enabled for <1B> to appear at all.

CEH v13 highlights identifying <1B> during enumeration as a high-value discovery, since domain controllers are prime targets during privilege escalation and lateral movement phases.

Question #:170 - [Web Application Hacking]

In the heart of Silicon Valley, ethical hacker Sophia Nguyen is hired by InnoVate Solutions, a San Francisco-based startup, to secure their cloud-based task management platform. On March 15, 2025, Sophia begins testing a feature that allows users to upload custom workflow templates to streamline project assignments. By carefully crafting a template file, she manipulates the platform's data processing, triggering unexpected behavior that grants her administrative access to restricted project dashboards. The issue arises from the platform's handling of user-supplied data during object reconstruction, not from database queries, client-side code execution, or session manipulation. Sophia documents her findings to help InnoVate's developers strengthen their application.

Which web application vulnerability is Sophia most likely exploiting in InnoVate Solutions' task management platform?

- A. Session Hijacking
- B. Local File Inclusion
- C. Verbose Error Messages
- D. Insecure Deserialization

Answer: D

Explanation

Insecure Deserialization is the best match because the scenario explicitly describes user-supplied data being processed during object reconstruction. In CEH-aligned web application security concepts, deserialization is the process of taking serialized data, such as JSON, XML, YAML, or binary objects, and converting it back into in-memory objects the application can use. When an application accepts serialized objects from an untrusted source and reconstructs them without strong validation, integrity checks, and safe type constraints, an attacker can tamper with the serialized content to alter object fields, inject unexpected object types, or trigger unsafe behaviors during reconstruction.

The key clue is that Sophia uploads a crafted template file and gains administrative access and access to restricted dashboards. That outcome commonly occurs when a deserialized object contains role, permission, or account attributes that the server trusts, or when deserialization triggers privileged logic through gadget chains or unsafe callbacks. The prompt also rules out database queries, client-side code execution, and session manipulation, which eliminates common alternatives like SQL injection, XSS, and session hijacking. Local file inclusion would involve forcing the server to include local files using path manipulation, which is not described here. Verbose error messages can leak information but do not directly grant admin access.

Mitigations emphasized in ethical hacking guidance include never deserializing untrusted data when avoidable, enforcing strict allowlists of types, applying cryptographic signing or HMAC integrity validation to serialized data, using safer data formats with explicit schemas, regenerating authorization decisions server-side rather than trusting client-provided object attributes, and logging and blocking anomalous deserialization attempts.

Question #:171 - [Wireless Network Hacking]

A penetration tester is attempting to gain access to a wireless network that is secured with WPA2 encryption. The tester successfully captures the WPA2 handshake but now needs to crack the pre-shared key. What is the most effective method to proceed?

- A. Perform a brute-force attack using common passwords against the captured handshake
- B. Use a dictionary attack against the captured WPA2 handshake to crack the key
- C. Execute a SQL injection attack on the router's login page
- D. Conduct a de-authentication attack to disconnect all clients from the network

Answer: B

Explanation

WPA2-PSK networks authenticate users using a pre-shared key derived from a passphrase. After capturing the 4-way handshake, CEH teaches that the standard and most effective method to recover the key is to perform an offline dictionary attack, where wordlist entries are hashed and compared against the captured handshake values. Offline cracking avoids detection and is significantly faster than brute-force attempts.

Question #:172 - [Web Application Hacking]

A payload causes a significant delay in response without visible output when testing an Oracle-backed application. What SQL injection technique is being used?

- A. Time-based SQL injection using WAITFOR DELAY
- B. Heavy query-based SQL injection
- C. Union-based SQL injection
- D. Out-of-band SQL injection

Answer: A

Explanation

This scenario precisely matches Time-Based Blind SQL Injection, a technique detailed in CEH v13 Web Application Hacking. When applications suppress error messages and sanitize outputs, attackers rely on response timing to infer whether injected SQL statements are executed.

In time-based SQL injection, the attacker injects database-specific delay functions (such as WAITFOR DELAY, DBMS_LOCK.SLEEP, or SLEEP()). If the injected condition is true, the database pauses execution, causing a noticeable delay.

The key indicators described—no visible output but increased response time—are classic signs of time-based SQL injection. CEH v13 explains that this method is particularly useful when:

Errors are hidden

UNION queries fail

Output is not reflected

Union-based and out-of-band SQL injections require data exfiltration channels or visible outputs, which are absent here. “Heavy query-based” is not a formal CEH classification.

Thus, Option A is the correct answer.

Question #:173 - [Malware Threats]

During an internal red team engagement at Orion Tech Labs, a leading software firm in Austin, Texas, ethical hacker Emily Carter was tasked with evaluating the resilience of the organization's software deployment processes. Knowing that the finance team frequently downloaded utility tools for generating PDFs, she repackaged a trusted PDF converter installer with a secondary payload. When an employee executed the installer, the converter installed and functioned normally, but in the background, a hidden executable silently initiated outbound network communication. The user remained unaware of any suspicious activity.

Which technique did Emily most likely use to ensure the malware executed alongside the legitimate application?

- A. Downloader
- B. Packer
- C. Dropper
- D. Wrapper

Answer: D

Explanation

A wrapper is the most accurate choice because it describes a technique where a legitimate program is bundled together with a malicious payload so that, when the user launches what appears to be a normal installer or application, both the real software and the malware run. CEH materials commonly explain wrappers in the context of Trojanization: the attacker “wraps” a trusted executable or installer with an additional hidden component. This preserves normal functionality to avoid suspicion while still achieving covert execution of the malicious code. In the scenario, the PDF converter installs and works as expected, but a hidden executable runs silently and begins outbound communication—this is classic wrapper behavior designed to maintain user trust and reduce detection through normal user experience.

The other options do not fit as well. A downloader is malware whose primary purpose is to fetch additional payloads from the network; while outbound communication occurs here, the scenario emphasizes bundling and simultaneous execution with a legitimate installer, not primarily downloading. A packer is used to compress/obfuscate an executable to evade signature-based detection; it changes how a binary looks, but it does not inherently describe combining a legitimate installer with another payload. A dropper is designed to

deliver and install malware onto a system, often extracting the payload; however, the hallmark detail here is that the legitimate application runs normally while the malicious component is hidden within the same package, which aligns more precisely with a wrapper/Trojanized installer.

Defensively, CEH recommends controls such as application allowlisting, verifying digital signatures and hashes, using trusted software repositories, endpoint detection and response, and monitoring unusual outbound connections after software installation

Question #:174 - [Network and Perimeter Hacking]

While conducting a covert penetration test on a UNIX-based infrastructure, the tester decides to bypass intrusion detection systems by sending specially crafted TCP packets with an unusual set of flags enabled. These packets do not initiate or complete any TCP handshake. During the scan, the tester notices that when certain ports are probed, there is no response from the target, but for others, a TCP RST (reset) packet is received. The tester notes that this behavior consistently aligns with open and closed ports. Based on these observations, which scanning technique is most likely being used?

- A. ACK flag scan to evaluate firewall behavior
- B. TCP Connect scan to complete the three-way handshake
- C. Xmas scan leveraging RFC 793 quirks
- D. FIN scan using stealthy flag combinations

Answer: D

Explanation

CEH describes FIN scans as stealthy scans that send packets with the FIN flag without initiating a TCP handshake. According to TCP RFC behavior, closed ports respond with RST packets while open ports ignore the probe, producing no response. This allows enumeration of port states while evading IDS systems that typically monitor SYN-based scans.

Question #:175 - [Web Application Hacking]

During a penetration test at Cascade Financial in Seattle, ethical hacker Elena Vasquez probes the input handling of the company's web server. She discovers that a single crafted request is processed as two separate ones, allowing her to inject malicious data into the server's communication. This type of attack falls into the same category of input validation flaws as cross-site scripting (XSS), cross-site request forgery (CSRF), and SQL injection.

Which type of web server attack is Elena most likely demonstrating?

- A. HTTP Response Splitting Attack
- B. Password Cracking Attack
- C. Directory Traversal Attack

D. Web Cache Poisoning Attack

Answer: A

Explanation

The correct answer is A. HTTP Response Splitting Attack because the scenario describes a flaw where one crafted request is interpreted in a way that causes the server (or an intermediary) to treat it as two separate HTTP messages, enabling the attacker to inject malicious data into the HTTP response stream. This is a classic input validation and header injection issue, typically involving the insertion of carriage return and line feed (CRLF) characters (`\r\n`) into user-controlled input that is later placed into HTTP headers (for example, in redirects, cookies, or custom headers). By injecting CRLF sequences, an attacker can “split” the server’s response: the first part completes a legitimate response header section, and the injected content begins a second, attacker-controlled response.

This aligns with the prompt’s emphasis that “a single crafted request is processed as two separate ones,” which is the fundamental mechanic of response splitting—turning one transaction into multiple interpreted HTTP entities. Once response splitting is possible, attackers may set or manipulate headers (such as Set-Cookie), inject arbitrary content, perform cross-user defacement, facilitate cache poisoning, or enable more effective delivery of client-side attacks by making browsers or proxies store and serve malicious content.

The question also frames it alongside XSS, CSRF, and SQL injection as “input validation flaws.” That matches response splitting’s root cause: insufficient sanitization/validation of untrusted input before including it in HTTP headers or responses.

Why the other options are incorrect: Password cracking is unrelated to HTTP parsing and input validation. Directory traversal abuses path handling to access files (e.g., `../`) and does not involve splitting HTTP messages. Web cache poisoning can be a consequence of response splitting, but the described behavior—splitting a single request/response into two—most directly identifies HTTP response splitting as the demonstrated attack.

Question #:176 - [Web Application Hacking]

In the vibrant startup scene of Austin, Texas, ethical hacker Daniel Ruiz is hired by TechNexus, a U.S.-based logistics software provider, to evaluate their internal administration portal. During testing, Daniel observes that certain input fields forward user-supplied data directly to underlying system functions. By carefully crafting his entries, he is able to trigger execution of unexpected system commands, resulting in unauthorized control over the operating environment. His findings reveal that the flaw stems from poor validation of input processed by system-level functions.

Which vulnerability is Daniel most likely demonstrating?

- A. Shell Injection
- B. LDAP Injection
- C. SQL Injection
- D. Cross-Site Scripting (XSS)

Answer: A**Explanation**

The described behavior is consistent with Shell Injection (OS Command Injection). The critical clues are that the application forwards user-supplied input to system-level functions and that crafted input can cause unexpected system commands to execute, resulting in unauthorized control of the underlying operating environment. That is the defining characteristic of command injection: the application constructs or passes command strings to the operating system (directly or indirectly), and inadequate input validation/escaping allows an attacker to alter command structure and execute arbitrary commands.

In an internal administration portal, this often occurs when developers integrate convenience features like “ping a host,” “lookup a file,” “run diagnostics,” “convert/export,” or “invoke a backend script,” and they pass user input into command interpreters or shell calls. If input is not strictly validated (allowlisting) and properly handled (parameterization, safe APIs, escaping), attackers can append operators or metacharacters to change execution flow, allowing system command execution under the application’s privileges.

The other options do not align with “system commands”:

LDAP Injection (B) targets directory queries by manipulating LDAP filter syntax to bypass authentication or extract directory data, not execute OS commands.

SQL Injection (C) manipulates database queries to read/modify database content; while severe, it is fundamentally a database-layer issue, not direct OS command execution as described.

XSS (D) executes script in a user’s browser context, impacting clients, sessions, and web content—not the server’s operating environment through system command execution.

Therefore, the vulnerability being demonstrated is A. Shell Injection.

Question #:177 - [Reconnaissance Techniques]

During a reconnaissance engagement at a law firm in Houston, Texas, you are tasked with analyzing the physical movement of employees through their publicly shared media. By examining geotagged images and mapping them to specific locations, you aim to evaluate whether staff are unintentionally disclosing sensitive information about office routines. Which tool from the reconnaissance toolkit would best support this task?

- A. Creepy
- B. Social Searcher
- C. Sherlock
- D. Maltego

Answer: A**Explanation**

The correct answer is A. Creepy because the task is specifically about extracting and analyzing geolocation information (geotags) from publicly shared media and mapping that data to real-world locations to infer employee movement patterns. In CEH-aligned reconnaissance/OSINT workflows, geolocation intelligence is a common element of footprinting because it can reveal sensitive operational details such as office locations, travel routines, meeting venues, home addresses, and patterns of presence/absence. Tools designed for geolocation OSINT help testers identify whether staff are unintentionally exposing location metadata through social media posts, uploaded photos, or other public sources.

Creepy is purpose-built for geolocation reconnaissance: it collects location metadata associated with content and presents results in a way that supports mapping and timeline-style analysis, helping analysts correlate people, posts, and coordinates. This directly supports the goal of evaluating whether employees are disclosing sensitive information about office routines by publishing geotagged images. When used in an authorized assessment, such tooling helps demonstrate risk in a measurable way—for example, showing clusters of posts around a specific building, repeated visits at predictable times, or regular travel routes that could support surveillance, targeted social engineering, or physical intrusion planning.

Why the other options are less suitable: Social Searcher is primarily used for monitoring and searching social media content by keywords, usernames, hashtags, and mentions; it is useful for broad OSINT collection but is not specifically focused on geotag extraction and movement mapping. Sherlock is designed to find a username across many platforms, helping link identities, but it does not specialize in geolocation mapping. Maltego is a powerful link-analysis platform that can correlate entities (people, domains, emails, social profiles) and can support OSINT investigations, but for the narrow requirement of extracting and mapping geotagged location data from media, Creepy is the most direct and purpose-specific tool.

Therefore, the best tool for this geotagged image movement analysis task is Creepy.

Question #:178 - [Web Application Hacking]

A tester evaluates a login form that builds SQL queries using unsanitized input. By submitting a single quote ('), the tester bypasses authentication and logs in. What type of SQL injection occurred?

- A. UNION-based SQL injection
- B. Error-based SQL injection
- C. Time-based blind SQL injection
- D. Tautology-based SQL injection

Answer: D

Explanation

The CEH Web Application Attacks module explains tautology-based SQL injection as an attack where input alters a conditional statement to always evaluate as TRUE (e.g., ' OR '1'='1').

Submitting a single quote often breaks query logic and allows attackers to manipulate authentication conditions.

Option D is correct.

Option A extracts data.

Option B relies on error messages.

Option C uses timing delays.

CEH identifies tautology attacks as one of the earliest and most common SQL injection techniques.

Question #:179 - [Cryptography]

A future-focused security audit discusses risks where attackers collect encrypted data today, anticipating they will be able to decrypt it later using quantum computers. What is this threat commonly known as?

- A. Saving data today for future quantum decryption
- B. Breaking RSA using quantum algorithms
- C. Flipping qubit values to corrupt output
- D. Replaying intercepted quantum messages

Answer: A

Explanation

The Certified Ethical Hacker (CEH) Cryptography and Quantum Computing section introduces the concept known as “Harvest Now, Decrypt Later”. This threat model describes adversaries capturing encrypted data today, even if they cannot decrypt it immediately, with the expectation that future quantum computers will be able to break currently secure public-key algorithms such as RSA and ECC.

Option A accurately reflects this concept.

Option B describes a method (Shor’s algorithm) but not the threat model itself.

Option C is unrelated to cryptographic attacks.

Option D refers to quantum communication attacks, not classical encrypted data harvesting.

CEH emphasizes post-quantum cryptography as a mitigation strategy.

Question #:180 - [Network and Perimeter Hacking]

During network analysis, clients are receiving incorrect gateway and DNS settings due to a rogue DHCP server. What security feature should the administrator enable to prevent this in the future?

- A. DHCP snooping on trusted interfaces
- B. ARP inspection across VLANs

- C. Port security on all trunk ports
- D. Static DHCP reservations for clients

Answer: A

Explanation

According to CEH v13, one of the most effective defenses against rogue DHCP servers is DHCP snooping, a Layer 2 security feature that classifies switch ports as either trusted or untrusted. DHCP responses are permitted only on trusted ports, typically those connected to legitimate DHCP servers. Any DHCP OFFER or ACK originating from an untrusted port is dropped automatically. In the scenario, the rogue DHCP server is sending unauthorized configuration settings because the switch is forwarding DHCP messages from all ports without restriction. CEH specifically warns that unmanaged or misconfigured switches allow rogue DHCP servers to assign malicious DNS, gateway, or IP configurations, enabling traffic redirection, interception, or man-in-the-middle attacks. ARP inspection (Option B) protects against ARP spoofing but not DHCP abuses. Port security (Option C) prevents MAC flooding, not DHCP impersonation. Static reservations (Option D) do not scale and do not stop rogue DHCP servers. DHCP snooping directly mitigates this threat.

Question #:181 - [Malware Threats]

On July 25, 2025, during a penetration test at Horizon Financial Services in Chicago, Illinois, cybersecurity specialist Laura Bennett is analyzing an attack simulation targeting the company's online banking portal. The system logs reveal a coordinated barrage of traffic from multiple compromised systems, orchestrated through a central command-and-control server, flooding the portal and rendering it unavailable to legitimate users. The attack leverages a network of infected devices, likely recruited via malicious links on social media.

What is the structure or concept most likely used to launch this coordinated attack?

- A. Smurf Attack
- B. Distributed Reflection Denial-of-Service DRDoS
- C. Botnet
- D. Central Source Propagation
- E. CA botnet is the most likely structure behind this attack because the scenario describes multiple compromised machines generating coordinated traffic under the direction of a central command-and-control server. In CEH-aligned terminology, a botnet is a collection of infected endpoints called bots or zombies that receive instructions from an attacker-controlled C2 infrastructure. Once commanded, these bots can simultaneously send large volumes of requests or packets toward a target, creating a distributed denial-of-service condition that overwhelms bandwidth, server resources, or application capacity and makes the service unavailable to legitimate users. Key clues strongly match botnet behavior. The traffic originates from many compromised systems rather than a single host, and it is “orchestrated through a central command-and-control server,” which is the defining control mechanism of botnets. The mention of devices “recruited via malicious links on social media” aligns with common bot recruitment vectors covered in CEH material, including drive-by downloads, phishing, malicious attachments, and social engineering that installs malware and enrolls the device into the botnet. The other options do not fit as

precisely. A Smurf attack is an older amplification technique using ICMP echo requests sent to a broadcast address with a spoofed source IP, not typically described as being centrally controlled infected devices. A DRDoS relies on reflection and amplification through third-party servers such as DNS or NTP, where traffic comes from reflectors rather than infected endpoints under direct control. “Central Source Propagation” is not the standard term for this coordinated DDoS structure. Therefore, the correct answer is Botnet.

Answer: A B C D E

Question #:182 - [Information Security and Ethical Hacking Overview]

Cyber experts conducting covert missions exclusively for national interests are best classified as:

- A. State-sponsored hackers
- B. Organized hackers
- C. Gray hat hackers
- D. Hacktivists

Answer: A

Explanation

CEH v13 classifies state-sponsored hackers as highly skilled professionals who operate under government direction to conduct espionage, intelligence gathering, sabotage, or cyber warfare. These attackers often target foreign governments, critical infrastructure, and strategic industries.

The defining characteristics are:

Government backing

National or geopolitical objectives

Advanced resources and long-term campaigns

Options B, C, and D do not fit. Organized hackers are typically financially motivated cybercriminal groups. Gray hats operate without authorization but not for national interests. Hacktivists pursue ideological or political causes independently.

CEH v13 explicitly associates covert intelligence operations with state-sponsored actors, making Option A correct.

Question #:183 - [Malware Threats]

A malware analyst finds JavaScript and /OpenAction keywords in a suspicious PDF using pdfid. What should be the next step to assess the potential impact?

- A. Upload the file to VirusTotal

- B. Extract and analyze stream objects using PDFStreamDumper
- C. Compute file hashes for signature matching

Answer: B

Explanation

CEH's Malware Analysis module outlines a structured approach:

Identify suspicious indicators (e.g., JavaScript, OpenAction)

Extract and analyze embedded objects

Determine behavior and exploit logic

PDFStreamDumper allows analysts to extract JavaScript code and embedded objects for detailed inspection.

Option B is correct.

Option A is useful but insufficient for deep analysis.

Option C only aids identification, not behavior understanding.

Question #:184 - [Network and Perimeter Hacking]

In Denver, Colorado, ethical hacker Rachel Nguyen is conducting a network security assessment for Apex Logistics, a transportation firm with a complex internal network. During her test, Rachel observes a client-server communication and injects specially crafted packets into the exchange, disrupting the client's session. As a result, the server continues interacting with Rachel's system while the legitimate client's connection becomes unresponsive. She uses this setup in a controlled environment to demonstrate vulnerabilities to the company's IT team.

What network-level session hijacking technique is Rachel employing in this assessment?

- A. Blind hijacking
- B. UDP hijacking
- C. RST hijacking
- D. TCP/IP hijacking

Answer: C

Explanation

RST hijacking is a TCP session hijacking technique emphasized in CEH materials under network attacks against established communications. In TCP, a Reset flag packet is used to abruptly tear down a connection. If an attacker can observe the session and determine the correct parameters such as IP addresses, ports, and an in-

window sequence number, they can forge a TCP RST packet that appears to come from one endpoint. This can force the victim side to drop the session, making the legitimate client suddenly lose responsiveness.

The key clue in the scenario is that Rachel “observes a client-server communication” and then injects crafted packets that disrupt the client while the server continues to communicate with Rachel’s system. That behavior matches the practical use of RST hijacking in demonstrations: terminate or desynchronize the victim endpoint while keeping the server-side session usable long enough for the attacker to inject traffic with valid sequence and acknowledgment values. In a switched LAN, this is often paired with sniffing or traffic visibility to reliably craft the reset packet and subsequent injected packets.

Blind hijacking is different because the attacker cannot see the traffic and must guess sequence numbers, which contradicts the “observes communication” detail. UDP hijacking is not applicable because UDP is connectionless and does not use session state or RST flags. “TCP/IP hijacking” is a broad category, but the question asks for the specific technique used to disrupt the client via crafted packets, which is best identified as RST hijacking.

Question #:185 - [Cryptography]

A cybersecurity company wants to prevent attackers from gaining information about its encrypted traffic patterns. Which of the following cryptographic algorithms should they utilize?

- A. HMAC
- B. RSA
- C. DES
- D. AES

Answer: D

Explanation

According to the CEH Cryptography module, strong symmetric encryption algorithms are essential for protecting data confidentiality and obscuring traffic content.

AES (Advanced Encryption Standard) is the industry-standard symmetric encryption algorithm approved by NIST and recommended by CEH for encrypting data in transit and at rest. AES provides strong resistance against cryptanalysis and prevents attackers from deriving meaningful information from encrypted traffic.

Option D is correct because AES is efficient, secure, and widely implemented.

Option A (HMAC) provides integrity and authentication, not encryption.

Option B (RSA) is computationally expensive and not suitable for bulk traffic encryption.

Option C (DES) is deprecated due to weak key length.

CEH materials clearly recommend AES over legacy algorithms.

Question #:186 - [Information Security and Ethical Hacking Overview]

You are leading an internal red team assessment for a multinational bank with a highly complex and distributed IT infrastructure. Your team is required to simulate attacks across cloud services, servers, and remote endpoints. Due to the sheer scale of the environment, you deploy an AI-based platform that automatically scans the entire network, flags anomalies based on prior breach data, and adjusts its threat detection models as new attack behaviors are encountered.

What key benefit of AI-driven ethical hacking is most critical to your success in this scenario?

- A. Predictive analysis
- B. Simulation and testing
- C. Scalability
- D. Enhanced reporting

Answer: C

Explanation

The most critical benefit in this scenario is scalability. CEH-aligned guidance on modern ethical hacking emphasizes that large, distributed enterprise environments create a fundamental operational challenge: the number of assets, configurations, cloud services, and remote endpoints is too large for purely manual assessment methods to maintain consistent coverage within acceptable timelines. The question highlights exactly this constraint by stating “highly complex and distributed” infrastructure and the “sheer scale of the environment.” An AI-driven platform that “automatically scans the entire network” and continuously flags anomalies is primarily valuable because it can expand assessment coverage across many systems simultaneously, helping the red team evaluate more of the attack surface efficiently.

While predictive analysis is a real AI capability, the scenario’s success requirement is not forecasting future attacks; it is executing assessment activities at enterprise scale and keeping pace as conditions change. Simulation and testing is what red teams do regardless of AI, but AI’s differentiator here is the ability to perform continuous, large-scale discovery and prioritization across cloud, servers, and endpoints without proportional increases in human effort. Enhanced reporting helps communicate results, but it is not the primary operational limiter described.

Additionally, the prompt mentions adapting detection models as new behaviors appear. That supports continuous operation, but the deciding factor is still the ability to operate across a massive environment and maintain broad visibility. Therefore, scalability is the key benefit most critical to success in this scenario.

Question #:187 - [Reconnaissance Techniques]

Amid the vibrant buzz of Miami’s digital scene, ethical hacker Sofia Alvarez embarks on a mission to fortify the web server of Sunshine Media’s streaming platform. Diving into her security assessment, Sofia sends a meticulously crafted GET / HTTP/1.0 request to the server, scrutinizing its response. The server obligingly

returns headers exposing its software version and operating system, a revelation that could empower malicious actors to tailor their attacks. Committed to bolstering the platform's defenses, Sofia documents her findings to urge the security team to address this exposure.

What approach is Sofia using to expose the vulnerability in Sunshine Media's web server?

- A. Information Gathering from Robots.txt File
- B. Vulnerability Scanning
- C. Directory Brute Forcing
- D. Web Server Footprinting Banner Grabbing

Answer: D

Explanation

The described action is classic web server footprinting through banner grabbing. In CEH reconnaissance methodology, banner grabbing is used to identify a target's service details by eliciting and analyzing standard protocol responses. When Sofia sends a simple HTTP request such as GET / HTTP/1.0, the server often responds with HTTP headers that may include fields like Server and sometimes X-Powered-By, which can reveal the web server product and version, and occasionally information that hints at the underlying operating system or framework. This disclosure is valuable to attackers because it enables targeted exploitation: once the exact server and version are known, an attacker can correlate that information with known vulnerabilities, misconfigurations, and exploit code.

This is not information gathering from robots.txt, which is a web file used to suggest crawler behavior and sometimes reveals hidden paths but does not inherently expose server software versions. It is also not directory brute forcing, which involves systematically guessing directories and files to find hidden endpoints. Vulnerability scanning is broader and typically involves automated checks to detect vulnerabilities; while banner information can be an input to scanning, the technique shown here is specifically identification through response headers.

CEH-aligned mitigation includes disabling or minimizing server signature information, removing unnecessary headers, keeping server software patched, and using secure configurations and reverse proxies to reduce information leakage during reconnaissance.

Question #:188 - [Mobile Platform and IoT Hacking]

A penetration tester is tasked with assessing the security of a smart home IoT device that communicates with a mobile app over an unencrypted connection. The tester wants to intercept the communication and extract sensitive information. What is the most effective approach to exploit this vulnerability?

- A. Perform a brute-force attack on the device's Wi-Fi credentials
- B. Use a man-in-the-middle (MitM) attack to intercept and analyze the unencrypted traffic
- C. Execute a SQL injection attack on the IoT device's cloud management portal

D. Use a dictionary attack to guess the admin login credentials of the device

Answer: B

Explanation

IoT devices often suffer from weak or missing encryption protocols, creating opportunities for attackers to intercept sensitive information. CEH courseware highlights that when device-to-app communication occurs in plaintext, a man-in-the-middle attack becomes one of the most effective exploitation methods. By positioning themselves between the device and the mobile application, the attacker can observe all transmitted data, including configuration updates, authentication tokens, and personal information. Tools such as Wireshark, mitmproxy, and specialized IoT interception frameworks allow testers to capture packets, decode protocols, and reconstruct application logic. The CEH curriculum stresses the importance of evaluating IoT device communication channels, because many rely on unsecured HTTP or proprietary plaintext protocols. Brute-force attempts, SQL injection, or dictionary attacks do not directly target the device-app communication pathway and would not exploit the fundamental weakness present here: lack of encryption. A MitM attack directly takes advantage of this flaw and provides comprehensive visibility into all transmitted data, making it the most effective and CEH-aligned method of exploitation.

Question #:189 - [Information Security and Ethical Hacking Overview]

What is the main difference between ethical hacking and malicious hacking?

- A. Ethical hacking is illegal, while malicious hacking is legal
- B. Ethical hackers use different tools than malicious hackers
- C. Ethical hacking is performed with permission, while malicious hacking is unauthorized
- D. Ethical hackers always work alone, while malicious hackers work in teams

Answer: C

Explanation

CEH defines ethical hacking as the authorized, structured, and permission-based process of identifying vulnerabilities to strengthen an organization's security posture. Ethical hackers operate under a signed scope-of-work and follow legal boundaries. Malicious hackers, by contrast, exploit systems without permission, often with harmful or criminal intent. CEH emphasizes that both ethical and malicious hackers may use similar tools, techniques, and methodologies; the distinction lies entirely in authorization, intent, and legality. Ethical hacking is conducted to improve defenses, while malicious hacking targets exploitation, theft, or disruption. Nothing in CEH materials suggests that toolsets or work styles distinguish the two groups; permission and lawful operation remain the central differentiators.

Question #:190 - [Web Application Hacking]

A payload drops a database table by injecting ; DROP TABLE users; --. What SQL injection method was used?

- A. Piggybacked queries
- B. UNION-based SQL injection
- C. Boolean-based SQL injection
- D. Error-based SQL injection

Answer: A

Explanation

This attack is a classic example of Piggybacked SQL Injection, covered in CEH v13 Web Application Hacking. Piggybacked queries allow attackers to append additional malicious SQL commands to an existing query using a delimiter such as a semicolon.

The payload executes the original query followed by a destructive command (DROP TABLE). UNION-based injections retrieve data, Boolean-based injections infer logic, and error-based injections rely on error messages—not destructive execution.

CEH v13 explicitly describes piggybacked queries as capable of data destruction and privilege escalation, making Option A correct.

Question #:191 - [Network and Perimeter Hacking]

In your role as a cybersecurity analyst at a large e-commerce company, you have been tasked with reinforcing the firm's defenses against potential Denial-of-Service (DoS) attacks. During a recent review, you noticed several IP addresses generating excessive traffic, causing an unusually high server load. Inspection of packets revealed that the TCP three-way handshake was never completed, leaving multiple connections in a SYN_RECEIVED state. The intent appears to be saturating server resources without completing connections. Which type of DoS attack is most likely being executed?

- A. SYN Flood
- B. Smurf Attack
- C. Ping of Death
- D. UDP Flood

Answer: A

Explanation

This scenario clearly indicates a SYN Flood attack, a classic Denial-of-Service technique discussed in CEH v13 Network and Perimeter Hacking. In a normal TCP three-way handshake, a client sends a SYN, the server responds with SYN-ACK, and the client completes the connection with an ACK. In a SYN flood, attackers send a massive number of SYN packets but never complete the handshake.

As described in CEH v13, the server allocates memory and resources for each half-open connection, placing them in the SYN_RECEIVED state. When these connections are not finalized, the server's connection table becomes saturated, preventing legitimate users from establishing new sessions.

Other options are incorrect:

Smurf attacks rely on ICMP amplification, not TCP handshakes.

Ping of Death uses malformed ICMP packets.

UDP Floods overwhelm ports using UDP, not TCP session states.

CEH v13 emphasizes SYN floods as one of the most common Layer 4 DoS attacks due to their simplicity and effectiveness.

Question #:192 - [Cloud Computing]

A red team member uses an access token obtained from an Azure function to authenticate with Azure PowerShell and retrieve storage account keys. What kind of abuse does this scenario demonstrate?

- A. Gathering NSG rule information
- B. Exploiting managed identities for unauthorized access
- C. Lateral movement via Stormspotter
- D. Enumeration of user groups with AzureGraph

Answer: B

Explanation

CEH cloud security modules highlight that Azure Managed Identities allow workloads such as functions, VMs, and automation tasks to authenticate to Azure resources without storing secrets. If an attacker obtains the token associated with a managed identity, they can impersonate that identity and access any Azure resources it is permitted to use. In this scenario, the captured access token is used to authenticate via Azure PowerShell and retrieve storage account keys, demonstrating unauthorized privilege usage by hijacking the managed identity. This aligns directly with managed identity abuse, where attackers leverage identity tokens instead of user credentials. NSG rule gathering and AzureGraph enumeration are reconnaissance activities, and Stormspotter is used for visualizing attack paths, not abusing identities. Therefore, this scenario clearly illustrates exploitation of managed identities.

Question #:193 - [Network and Perimeter Hacking]

During an internal red team engagement, an operator discovers that TCP port 389 is open on a target system identified as a domain controller. To assess the extent of LDAP exposure, the operator runs the command `ldapsearch -h <Target IP> -x -s base namingcontexts` and receives a response revealing the base distinguished name (DN): `DC=internal,DC=corp`. This naming context indicates the root of the LDAP directory structure.

With this discovery, the operator plans the next step to continue LDAP enumeration and expand visibility into users and objects in the domain. What is the most logical next action?

- A. Launch a brute-force attack against user passwords via SMB
- B. Conduct an ARP scan on the local subnet
- C. Attempt an RDP login to the domain controller
- D. Use the base DN in a filter to enumerate directory objects

Answer: D

Explanation

Once the base DN is identified through LDAP naming contexts, CEH teaches that the next step in enumeration is to query the directory tree using this DN. This allows retrieval of users, groups, computers, and other AD objects. LDAP-based enumeration requires valid search filters rooted in the base DN.

Question #:194 - [Network and Perimeter Hacking]

During a red team assessment of an enterprise LAN environment, the tester discovers an access switch that connects multiple internal workstations. The switch has no port security measures in place. To silently intercept communication between different hosts without deploying ARP poisoning or modifying the routing table, the tester launches a MAC flooding attack using the macof utility from the dsniff suite. This command sends thousands of Ethernet frames per minute, each with random, spoofed source MAC addresses. Soon after the flooding begins, the tester puts their network interface into promiscuous mode and starts capturing packets. They observe unicast traffic between internal machines appearing in their packet sniffer—traffic that should have been isolated. What internal switch behavior is responsible for this sudden exposure of isolated traffic?

- A. The switch performed ARP spoofing to misroute packets.
- B. The switch entered hub-like behavior due to a full CAM table.
- C. The interface performed DHCP starvation to capture broadcasts.
- D. The switch disabled MAC filtering due to duplicate address conflicts.

Answer: B

Explanation

CEH explains that MAC flooding overwhelms a switch's CAM table, causing it to fail open. When the table fills, the switch broadcasts frames out all ports, behaving like a hub. This exposes unicast traffic to attackers operating in promiscuous mode.

Question #:195 - [Mobile Platform and IoT Hacking]

A penetration tester evaluates the security of an iOS mobile application that handles sensitive user information. The tester discovers that the application is vulnerable to insecure data transmission. What is the most effective method to exploit this vulnerability?

- A. Execute a SQL injection attack to retrieve data from the backend server
- B. Perform a man-in-the-middle attack to intercept unencrypted data transmitted over the network
- C. Conduct a brute-force attack on the app's authentication system
- D. Use a Cross-Site Request Forgery (CSRF) attack to steal user session tokens

Answer: B

Explanation

The CEH v13 courseware states that insecure communication occurs when mobile applications transmit sensitive data over unencrypted or weakly encrypted channels, exposing information to interception. When an application uses plain HTTP or does not properly validate certificates, attackers can place themselves between the client and server using a man-in-the-middle (MitM) attack. This allows them to read session tokens, credentials, API keys, or personal user data as it travels across the network. CEH materials emphasize that MitM attacks are the primary exploitation technique for insecure data transmission because they exploit weaknesses in transport-layer security rather than weaknesses in backend code or authentication mechanisms. SQL injection and CSRF attacks target web application logic, not transport encryption. Brute-force attacks target authentication mechanisms and are unrelated to how data is transmitted. Therefore, the most effective exploitation method is intercepting traffic via MitM to capture or manipulate unencrypted communications.

Question #:196 - [Cryptography]

You are Evelyn, an ethical hacker at LoneStar Health in Austin, Texas, engaged to investigate a recent compromise of archived patient records. During the investigation you recover a large set of encrypted records from a compromised backup and, separately, obtain several original template records (standard headers and form fields) that correspond to some entries in the encrypted set. You plan to use these paired examples (the original templates and their encrypted counterparts) to attempt to recover keys or deduce other plaintext values. Which cryptanalytic approach is most appropriate for this situation?

- A. Chosen-ciphertext attack
- B. Known-plaintext attack
- C. Chosen-plaintext attack
- D. Ciphertext-only attack

Answer: B

Explanation

The correct answer is B. Known-plaintext attack because the scenario explicitly provides paired samples of plaintext and ciphertext for the same underlying data. In a known-plaintext attack, the analyst possesses one

or more examples where the original message (plaintext) is known and the corresponding encrypted output (ciphertext) is also available. These pairs can be used to analyze the cipher's behavior, validate hypotheses about modes/parameters, and—depending on the algorithm, implementation weaknesses, and key management—attempt to recover the encryption key or decrypt other ciphertexts encrypted under the same key.

Here, Evelyn has “original template records (standard headers and form fields)” and their “encrypted counterparts” in the stolen backup set. Medical record formats commonly contain predictable structures (fixed headers, repeated field names, standardized forms), which increases the likelihood of having accurate known plaintext segments. With enough known plaintext/ciphertext pairs, an attacker may identify patterns caused by weak encryption choices, reused keys, reused IVs/nonces, insecure modes (e.g., ECB revealing structure), or flawed custom crypto. Even when strong algorithms are used, known-plaintext material can still be valuable for confirming the encryption scheme and detecting implementation errors.

Why the other options are not correct: Ciphertext-only assumes the attacker has only encrypted data and no plaintext examples—contradicted by the templates. Chosen-plaintext requires the ability to submit arbitrary plaintexts to an encryption oracle and receive ciphertexts, which the scenario does not indicate. Chosen-ciphertext requires the ability to submit ciphertexts to a decryption oracle and observe outputs, also not described.

Because Evelyn has real, matching plaintext-ciphertext pairs from the same dataset, the most appropriate cryptanalytic approach is a known-plaintext attack.

Question #:197 - [Mobile Platform and IoT Hacking]

At Horizon Legal Services in Boston, Massachusetts, ethical hacker Daniel Price is tasked with assessing the security of the firm's mobile case-tracking app. During testing, he finds that confidential case notes and client records are kept locally on the device without encryption. By browsing the file system with a standard explorer tool, he can open sensitive information without any authentication. Which OWASP Top 10 Mobile Risk is most clearly present in the app?

- A. Insecure Communication
- B. Improper Credential Usage
- C. Insecure Data Storage
- D. Inadequate Privacy Controls

Answer: C

Explanation

The correct answer is C. Insecure Data Storage because the vulnerability described is the storage of sensitive information locally on the mobile device in a manner that is not encrypted and is accessible by simply browsing the file system. In mobile application security, this is a classic risk category: when an app stores confidential data (case notes, client records, tokens, documents, cached responses, databases, logs, or exported files) in clear text or in insecure locations, an attacker who gains device access—or uses backup extraction, file explorers, rooted/jailbroken access, or malware with storage permissions—may retrieve that data without needing to authenticate to the application.

The scenario makes the weakness unmistakable: Daniel can use a “standard explorer tool” to open sensitive records “without any authentication.” This indicates the app is failing to apply appropriate protections such as encryption at rest, secure key handling, proper file permissions, and secure storage mechanisms. In secure mobile design, sensitive records should be encrypted using platform-supported protections (e.g., using OS keystores/keychains for keys, encrypting databases/files, and minimizing local retention). Additionally, apps should avoid storing highly sensitive regulated data unless essential, and should implement secure session controls and data lifecycle management (cache control, expiration, remote wipe support in enterprise settings).

Why the other options are not the best fit: Insecure communication concerns data exposure while transmitted over networks (e.g., lack of TLS, weak TLS, MITM susceptibility), whereas the issue here is purely local storage. Improper credential usage relates to mishandling passwords, tokens, or authentication secrets (hard-coded credentials, weak storage of credentials), but the prompt focuses on stored records themselves. Inadequate privacy controls is broader and typically involves over-collection, improper disclosure, or weak user privacy settings, not direct clear-text storage exposure.

Therefore, the most clearly present OWASP Top 10 Mobile Risk is Insecure Data Storage.

Question #:198 - [Reconnaissance Techniques]

Which information CANNOT be directly obtained from DNS interrogation?

- A. Usernames and passwords
- B. Server geolocation (via IPs)
- C. Subdomains of the organization
- D. IP addresses of mail servers

Answer: A

Explanation

DNS interrogation is a core passive and semi-active reconnaissance technique described in CEH v13 Reconnaissance Techniques. It allows ethical hackers to gather publicly available information about a target's domain infrastructure.

Through DNS queries, testers can retrieve:

Subdomains (via zone transfers, brute force, or DNS records)

Mail server IP addresses (via MX records)

Server IP addresses, which can then be mapped to approximate geographic locations

However, DNS does not store authentication credentials such as usernames and passwords. That information resides in authentication systems like Active Directory, LDAP, or application databases, not DNS.

Therefore, Option A is the only choice that cannot be obtained via DNS interrogation. CEH v13 clearly distinguishes between naming infrastructure data and credential-based information, reinforcing why DNS enumeration cannot reveal user credentials.

Thus, Option A is correct.

Question #:199 - [Cryptography]

Alice, a software developer, digitally signs an email contract and sends it to Bob. Later, a dispute arises and Alice claims she never sent the agreement. However, Bob produces the email with Alice's unique digital signature, which unequivocally links the message to her. In information security terms, what principle is illustrated by Bob's ability to prove Alice's authorship of the email?

- A. Confidentiality
- B. Integrity
- C. Non-Repudiation
- D. Availability

Answer: C

Explanation

Non-repudiation is the security principle that prevents a sender from denying having performed a specific action, such as sending a message or approving a transaction. In CEH-aligned cryptography, non-repudiation is most commonly achieved using digital signatures backed by public key cryptography and, in many real-world deployments, supported by digital certificates and a trusted certificate authority. When Alice digitally signs the email contract, she uses her private key to create a signature that is mathematically tied to both her identity and the exact content of the message. Bob can then use Alice's corresponding public key to verify the signature. If verification succeeds, it provides strong evidence that the message originated from the holder of Alice's private key and that the content has not been altered since it was signed.

This is different from confidentiality, which is about preventing unauthorized disclosure of message contents through encryption. It is also distinct from integrity alone: integrity ensures the message was not modified, but non-repudiation adds accountability by binding the action to a specific signer in a way that can be demonstrated to a third party. Availability is unrelated here, as it concerns ensuring systems and data are accessible when needed.

CEH materials emphasize that non-repudiation depends on proper key management and trust infrastructure. If Alice's private key is compromised, the evidentiary value is weakened. Therefore, protecting private keys with secure storage, access controls, and revocation mechanisms is essential to preserve non-repudiation.

Question #:200 - [Wireless Network Hacking]

Which WPA vulnerability allowed packet injection and decryption attacks?

- A. Lack of AES encryption
- B. Predictable GTK
- C. Weak Initialization Vectors (IVs)
- D. Weak passwords

Answer: C

Explanation

WPA with TKIP suffers from vulnerabilities inherited from WEP, particularly the use of weak Initialization Vectors (IVs). CEH v13 explains that these weaknesses allow attackers to perform packet injection and partial decryption attacks.

Although WPA improved upon WEP, TKIP was designed as a temporary solution and still relies on predictable IV behavior. This makes Option C correct.

Lack of AES (Option A) explains why WPA is weaker than WPA2 but does not directly describe the exploit mechanism. Weak passwords (Option D) affect authentication, not packet injection. GTK predictability (Option B) is relevant but not the primary cause here.

CEH v13 explicitly states that IV reuse and predictability in TKIP enable practical attacks. Therefore, Option C is correct.

Question #:201 - [System Hacking Phases]

A penetration tester gains access to a target system through a vulnerability in a third-party software application. What is the most effective next step to take to gain full control over the system?

- A. Conduct a denial-of-service (DoS) attack to disrupt the system's services
- B. Execute a Cross-Site Request Forgery (CSRF) attack to steal session data
- C. Perform a brute-force attack on the system's root password
- D. Use a privilege escalation exploit to gain administrative privileges on the system

Answer: D

Explanation

According to the CEH attack methodology, once an attacker obtains initial access—whether through exploitation, misconfiguration, or credential compromise—the next critical phase is privilege escalation. Gaining system-level or administrative control is essential for maintaining persistence, accessing protected data, modifying system configurations, and pivoting further into the network. Privilege escalation exploits target kernel flaws, misconfigured services, improper permission settings, or vulnerable drivers. CEH emphasizes that performing a DoS attack disrupts the engagement and provides no strategic advantage. Similarly, CSRF targets web applications rather than operating systems, and brute-force password attempts

are inefficient, noisy, and often ineffective once local access has already been established. By leveraging privilege escalation techniques, the tester converts limited user access into full system control, enabling comprehensive post-exploitation activities aligned with CEH system hacking procedures.

Question #:202 - [Web Application Hacking]

A penetration tester is assessing a mobile application and discovers that the app is vulnerable to improper session management. The session tokens are not invalidated upon logout, allowing the tokens to be reused. What is the most effective way to exploit this vulnerability?

- A. Perform a replay attack by using the same session token after the user logs out
- B. Use a Cross-Site Request Forgery (CSRF) attack to steal the session tokens
- C. Use a brute-force attack to guess valid session tokens
- D. Execute a SQL injection attack to retrieve session tokens from the database

Answer: A

Explanation

In CEH's web application and mobile security modules, improper session management is defined as a failure to enforce session expiration, token invalidation, or secure session lifecycle controls. When an application does not invalidate a session token after logout, attackers can exploit this by performing a replay attack: reusing previously captured session identifiers to impersonate the user and gain unauthorized access. CEH teaches that replaying a live token is the simplest and most direct exploitation method because it does not require guessing or stealing new tokens—the attacker simply reuses a valid one that should have been invalidated. CSRF relies on exploiting a user's active session and is not required when the attacker already possesses a reusable token. Brute-forcing session tokens is computationally expensive and unnecessary. SQL injection is unrelated to session lifecycle flaws unless token storage is directly exposed. Therefore, a replay attack is the correct exploitation method.

Question #:203 - [Information Security and Ethical Hacking Overview]

As part of a red team campaign against a pharmaceutical company in Boston, ethical hacker Alex begins with a successful spear-phishing attack that delivers an initial payload to a manager's laptop. After gaining access, Alex pivots to harvesting cached credentials and using them to move laterally across the internal network. Soon, routers, printers, and several file servers are compromised, expanding the red team's control beyond the original host. At this point, Alex has not yet targeted sensitive research data, but the team has built a broader foothold within the environment.

Which phase of the Advanced Persistent Threat (APT) lifecycle is Alex simulating?

- A. Initial Intrusion
- B. Persistence
- C. Search & Exfiltration

D. Expansion

Answer: D

Explanation

The correct answer is D. Expansion because the scenario emphasizes that, after the initial foothold, the attacker harvests credentials and moves laterally to compromise additional systems—routers, printers, and file servers—thereby broadening control across the internal environment. In CEH-aligned APT lifecycle descriptions, this stage is commonly associated with internal reconnaissance, privilege/credential access, lateral movement, and widening the foothold to increase resilience and reach. The attacker is no longer limited to the original compromised endpoint; instead, they are deliberately spreading to other networked assets to build operational advantage.

The sequence in the prompt is important. Initial Intrusion (A) already occurred via spear-phishing delivering the first payload to the manager's laptop. The question asks what phase is being simulated at this point, after access is gained and the attacker is actively moving through the network. Persistence (B) refers to establishing mechanisms to maintain access (e.g., backdoors, scheduled tasks, services, persistence in credentials /accounts) so the attacker can survive reboots, password changes, or cleanup attempts. While an attacker might establish persistence during expansion, the defining action here is lateral movement and compromise of multiple internal systems, which is more directly expansion than persistence.

Search & Exfiltration (C) would involve identifying and collecting target data (in this case, sensitive research data) and transferring it out of the environment. The prompt explicitly states Alex has not yet targeted sensitive research data, which rules out the search/exfiltration phase as the primary activity being simulated right now.

Therefore, the phase of the APT lifecycle best matching credential harvesting followed by lateral movement and compromise of multiple internal devices/servers to build a broader foothold is Expansion.

Question #:204 - [Security Operations and Incident Response]

An IDS generates alerts during normal user activity. What is the most likely cause?

- A. Firewall failure
- B. IDS outdated
- C. Excessive IDS sensitivity causing false positives
- D. Users triggering protocols

Answer: C

Explanation

In CEH v13, IDS effectiveness is closely tied to proper signature tuning and sensitivity thresholds. When IDS alerts are triggered by legitimate user behavior, the most common cause is overly sensitive configuration, resulting in false positives.

False positives occur when normal traffic patterns match intrusion signatures. CEH v13 emphasizes that IDS systems must be calibrated to the organization's baseline traffic profile. Without tuning, IDS logs become noisy and reduce analyst effectiveness.

Firewall issues (Option A) and outdated IDS signatures (Option B) can cause missed detections, not excessive alerts. Users unintentionally triggering protocols (Option D) is not a root cause but a symptom of misconfiguration.

Thus, excessive IDS sensitivity is the correct explanation.

Question #:205 - [Web Application Hacking]

During a penetration test at an e-commerce company in Boston, ethical hacker Sophia launches an HTTP flood against the checkout page of the site. The simulated traffic consists of repeated GET and POST requests designed to overload application-layer resources. In response, the IT team activates a security tool that inspects and filters malicious HTTP traffic while allowing legitimate customer requests to pass, ensuring service continuity during the exercise.

Which DoS/DDoS protection tool is most likely being used in this scenario?

- A. Load Balancer
- B. Web Application Firewall
- C. Intrusion Prevention System
- D. Firewall

Answer: B

Explanation

An HTTP flood is an application-layer (Layer 7) DoS/DDoS technique that targets web application resources by sending large volumes of seemingly valid HTTP GET/POST requests. Because the traffic can look "legitimate" at the protocol level, controls that primarily focus on network/transport characteristics (such as basic firewalls) are often insufficient. The tool described in the scenario is explicitly inspecting and filtering malicious HTTP traffic while allowing legitimate customer requests—that behavior aligns most directly with a Web Application Firewall (WAF).

A WAF is designed to protect web applications by analyzing HTTP/S requests and responses, applying security rules that detect and block abnormal or malicious patterns. In an HTTP flood scenario, a WAF can enforce rate limiting, detect request anomalies (e.g., repeated requests to resource-intensive endpoints like checkout), identify bot-like behavior, and apply signatures/behavioral policies to mitigate attacks while continuing to permit valid users. The key clue is the focus on HTTP-level inspection and filtering to maintain service continuity—a classic WAF use case during Layer 7 attacks.

Why the other options are less suitable:

A Load Balancer (A) improves availability by distributing traffic across servers, but it does not inherently inspect and filter malicious HTTP requests. It can help absorb load, yet it's not primarily a security inspection/filtering control.

An Intrusion Prevention System (C) can block malicious activity, but many IPS deployments are stronger at network/transport-layer patterns and may not provide the same depth of application-aware HTTP policy enforcement as a WAF for targeted web endpoints.

A traditional Firewall (D) mainly filters by IP/port/protocol and cannot reliably distinguish malicious vs legitimate HTTP GET/POST floods when they use allowed ports (80/443).

Question #:206 - [Reconnaissance Techniques]

A penetration tester must enumerate user accounts and network resources in a highly secured Windows environment where SMB null sessions are blocked. Which technique should be used to gather this information discreetly?

- A. Utilize NetBIOS over TCP/IP to list shared resources anonymously
- B. Exploit a misconfigured LDAP service to perform anonymous searches
- C. Leverage Active Directory Web Services for unauthorized queries
- D. Conduct a zone transfer by querying the organization's DNS servers

Answer: B

Explanation

CEH v13 explains that when traditional enumeration techniques—such as SMB null sessions—are disabled, attackers often pivot to misconfigured LDAP services that still allow anonymous binding. LDAP anonymous bind, when not properly restricted, exposes directory information such as usernames, organizational units, group memberships, and other metadata. This aligns directly with the scenario, where the tester must avoid triggering alarms while still gathering internal data. LDAP queries generate minimal noise, often blending with normal authentication-related traffic, making them ideal for covert enumeration. Options A and C would require authentication or violate access restrictions, and DNS zone transfers (Option D) rarely succeed because modern DNS servers disable AXFR requests from unauthorized clients. CEH repeatedly stresses the importance of detecting and securing LDAP anonymous bind due to its potential for silent information leakage—making Option B the correct choice.

Question #:207 - [Security Operations and Incident Response]

As a cybersecurity professional at XYZ Corporation, you are tasked with investigating anomalies in system logs that suggest potential unauthorized activity. System administrators have detected repeated failed login attempts on a critical server, followed by a sudden surge in outbound data traffic. These indicators suggest a possible compromise. Given the sensitive nature of the system and the sophistication of the threat, what should be your initial course of action?

- A. Conduct real-time monitoring of the server, analyze logs for abnormal patterns, and identify the nature of the activity to formulate immediate countermeasures.
- B. Conduct a comprehensive audit of all outbound traffic and analyze destination IP addresses to map the attacker's network.
- C. Immediately reset all server credentials and instruct all users to change their passwords.
- D. Immediately disconnect the affected server from the network to prevent further data exfiltration.

Answer: A

Explanation

The Certified Ethical Hacker (CEH) Incident Response lifecycle begins with Identification, followed by containment, eradication, recovery, and lessons learned. CEH documentation stresses that understanding the scope and nature of an incident is critical before taking disruptive action.

Option A is the correct initial response because it focuses on real-time monitoring and log analysis, which are essential during the identification phase. CEH materials emphasize analyzing logs, authentication failures, and traffic anomalies to confirm whether an incident has occurred and determine the attacker's techniques, persistence level, and impact.

Option B, while valuable, is more appropriate after initial identification. Conducting deep outbound traffic audits without first understanding the attack vector can delay containment decisions.

Option C is premature. CEH warns that changing credentials too early may alert the attacker and cause them to escalate or destroy evidence.

Option D represents a containment strategy, not an initial response. CEH guidelines advise against immediately disconnecting systems unless there is confirmed active data exfiltration that cannot be otherwise controlled, as this may disrupt business operations and erase volatile forensic evidence.

Therefore, the CEH-approved approach is to monitor, analyze, and identify the incident before moving to containment and eradication.

Question #:208 - [Information Security and Ethical Hacking Overview]

A penetration tester is assessing a company's executive team for vulnerability to sophisticated social engineering attacks by impersonating a trusted vendor and leveraging internal communications. What is the most effective social engineering technique to obtain sensitive executive credentials without being detected?

- A. Develop a fake social media profile to connect with executives and request private information
- B. Conduct a phone call posing as the CEO to request immediate password changes
- C. Create a targeted spear-phishing email that references recent internal projects and requests credential verification
- D. Send a mass phishing email with a malicious link disguised as a company-wide update

Answer: C**Explanation**

CEH categorizes spear phishing as a highly targeted, research-driven social engineering technique that tailors the message to the victim's role, responsibilities, and current organizational activities. When attackers reference specific internal projects, personnel names, vendor relationships, or operational details, the message appears authentic and bypasses normal suspicion. Executives are especially vulnerable because they routinely receive sensitive operational updates and work closely with vendors and partners, making them prime targets for tailored deception. CEH stresses that spear phishing is significantly more effective than generic phishing because personalization increases trust. Social media-based attempts and mass phishing lack specificity and raise suspicion. Impersonating the CEO over the phone is riskier and more detectable due to real-time human interaction. A targeted spear-phishing email referencing internal projects best aligns with CEH-described advanced social engineering strategy.

Question #:209 - [Network and Perimeter Hacking]

During a red team assessment at New England Insurance in Boston, ethical hacker Daniel sends a series of spoofed TCP packets carrying the reset flag to a server hosting client applications. As a result, several active sessions between employees and the server are abruptly terminated, causing temporary disruption of legitimate work. Daniel uses this demonstration to highlight how attackers can forcibly tear down sessions without completing a full hijack.

Which type of network-level session hijacking technique is Daniel simulating?

- A. UDP Hijacking
- B. RST Hijacking
- C. Blind Hijacking
- D. TCP/IP Hijacking

Answer: B**Explanation**

The technique described is RST hijacking because the attacker sends spoofed TCP packets with the RST (reset) flag to forcibly terminate established TCP sessions. In TCP, an RST packet is used to immediately abort a connection. If an attacker can craft packets that appear to belong to an existing session (matching the 4-tuple and using plausible sequence/acknowledgment values), the receiving endpoint may accept the reset and tear down the connection. This creates disruption—sessions drop, users are disconnected, and applications experience errors—without the attacker needing to fully take over the session or inject meaningful application data.

The scenario matches this exactly: “spoofed TCP packets carrying the reset flag,” followed by “active sessions...abruptly terminated.” That is the hallmark outcome of RST-based session disruption. It is often used as a demonstration of how fragile sessions can be when attackers can spoof traffic within a path (or on the same network segment) and when defensive controls do not validate or protect sessions adequately.

Why the other options are incorrect:

UDP hijacking (A) doesn't apply because UDP is connectionless and has no RST flag or session teardown mechanism like TCP.

Blind hijacking (C) refers to injecting traffic without seeing responses (guessing sequence numbers), but the specific mechanism asked here is the reset-flag termination; "blind" could be a property of how it's done, not the named technique.

TCP/IP hijacking (D) is a broader category that includes multiple methods of taking over or manipulating TCP sessions. The question is specifically about using RST packets to kill sessions, which is most precisely called RST hijacking.

Therefore, the correct answer is B. RST Hijacking.

Question #:210 - [Reconnaissance Techniques]

As part of an insider threat simulation at a multinational insurance firm, lead red teamer John is asked to assess whether internal directory services are exposing sensitive user data. Gaining limited VPN access, he begins probing port 389 on a staging environment connected to the main domain infrastructure. After discovering that anonymous binds are accepted by the directory service, John launches a utility from his Kali machine that allows command-line interaction with directory entries. He structures his query to search for user objects with associated organizational units. Moments later, John reviews the output which includes usernames, group memberships, and departmental hierarchies all retrieved without authentication.

Which tool is John MOST likely using to perform this enumeration?

- A. smtp-user-enum
- B. nbtstat -A
- C. dig AXFR
- D. ldapsearch
- E. DThe scenario describes LDAP enumeration over port 389 with anonymous bind allowed. In CEH coverage, LDAP is a directory access protocol commonly used by enterprise directory services, including Active Directory via LDAP interfaces. When anonymous bind is enabled or misconfigured access controls allow broad read permissions, an attacker can query directory objects without valid credentials and extract valuable reconnaissance data such as user accounts, group membership, organizational units, and directory structure. That is exactly what John is doing: connecting to LDAP, performing searches for user objects, and retrieving organizational information and group relationships. The Kali utility that fits this behavior is ldapsearch. It is a standard command-line LDAP client used to bind to an LDAP server and execute directory queries using LDAP filters and a base DN. With anonymous bind, ldapsearch can run queries like searching for objectClass=user and requesting attributes such as cn, sAMAccountName, memberOf, and organizational details. CEH materials emphasize LDAP enumeration as a high-value recon step because it helps map the domain, identify privileged groups, and select targets for later attacks, especially when directory permissions are overly permissive. The other options do not match LDAP directory interaction. smtp-user-enum targets SMTP

for user enumeration through mail server responses. nbtstat -A queries NetBIOS name tables, typically for host and share-related information, not LDAP directory trees. dig AXFR attempts DNS zone transfers, which is DNS reconnaissance, not directory service enumeration. Therefore, ldapsearch is the most appropriate tool for this anonymous LDAP enumeration on port 389.

Answer: A B C D E

Question #:211 - [Web Application Hacking]

A penetration tester suspects that a web application's user profile page is vulnerable to SQL injection, as it uses the userID parameter in SQL queries without proper sanitization. Which technique should the tester use to confirm the vulnerability?

- A. Use the userID parameter to perform a brute-force attack on the admin login page
- B. Modify the userID parameter in the URL to ' OR '1'=1 and check if it returns multiple profiles
- C. Inject HTML code into the userID parameter to test for Cross-Site Scripting (XSS)
- D. Attempt a directory traversal attack using the userID parameter

Answer: B

Explanation

CEH describes SQL injection testing as a core part of web application assessment. One of the first and safest validation techniques is using a tautology-based SQL injection payload, such as ' OR '1'=1. If the application concatenates user input directly into SQL queries, such an input will cause the query to always evaluate as true, often returning additional records such as multiple user profiles. This confirms the presence of SQL injection without causing destructive effects like dropping tables. Testing XSS does not validate SQL injection, brute-forcing credentials is unrelated, and directory traversal attacks target file path manipulation rather than backend queries. CEH emphasizes avoiding destructive queries and starting with non-intrusive injection payloads that reveal improper input sanitization, making ' OR '1'=1 the correct technique for confirming SQL injection vulnerabilities in URL parameters.

Question #:212 - [Network and Perimeter Hacking]

In Seattle, Washington, ethical hacker Mia Chen is tasked with testing the network defenses of Pacific Shipping Co., a major logistics firm. During her penetration test, Mia targets the company's external-facing web server, which handles customer tracking requests. She observes that the security system filtering traffic to this server analyzes incoming SSH and DNS requests to block unauthorized access attempts. Mia plans to craft specific payloads to bypass this system to expose vulnerabilities to the IT department.

Which security system is Mia attempting to bypass during her penetration test of Pacific Shipping Co.'s web server?

- A. Stateful Multilayer Inspection Firewall
- B. Application-Level Firewall
- C. Packet Filtering Firewall

D. Circuit-Level Gateway Firewall

Answer: B

Explanation

An Application-Level Firewall, commonly called an application-level gateway or proxy firewall, inspects traffic at the application layer and enforces rules based on specific application protocols and commands. In CEH-aligned coverage of perimeter defenses, this firewall type is distinguished by its ability to understand protocol behavior and content for services such as DNS and SSH, rather than relying only on IP addresses, ports, and basic connection state.

The question states the filtering system “analyzes incoming SSH and DNS requests to block unauthorized access attempts.” That wording points directly to application-aware inspection: it is evaluating protocol-specific requests, not merely allowing or denying traffic based on port numbers. A packet filtering firewall generally makes decisions using network and transport layer information such as source and destination IP, protocol, and port, without parsing DNS queries or SSH negotiation details. A circuit-level gateway firewall focuses on validating session establishment and connection properties, typically without deep inspection of the application commands inside the session. A stateful multilayer inspection firewall can track connection state and sometimes incorporate deeper inspection, but the strongest and most explicit match to “analyzes SSH and DNS requests” in CEH terminology is the application-level firewall, which uses proxies or protocol engines to parse and filter application traffic.

From an ethical testing perspective, attempts to “craft specific payloads” often involve probing how the firewall validates protocol fields, handles malformed requests, or enforces policy on application commands. Defenders mitigate these risks through strict proxy policy configuration, robust protocol validation, patching, logging, and limiting exposed services to only what is required.

Question #:213 - [Web Application Hacking]

As a Certified Ethical Hacker assessing session management vulnerabilities in a secure web application using MFA, encrypted cookies, and a WAF, which technique would most effectively exploit a session management weakness while bypassing these defenses?

- A. Utilizing Session Fixation to force a victim to use a known session ID
- B. Executing a Cross-Site Request Forgery (CSRF) attack
- C. Exploiting insecure deserialization vulnerabilities for code execution
- D. Conducting Session Sidejacking using captured session tokens

Answer: A

Explanation

The CEH Web Application Hacking module identifies Session Fixation as a powerful session management attack that can bypass advanced authentication controls, including MFA.

In session fixation, the attacker forces the victim to authenticate using a session ID already known to the attacker. Once authentication completes, the attacker hijacks the valid session without needing credentials.

Option A directly targets session management logic.

Option B exploits authorization logic, not session handling.

Option C is unrelated to session management.

Option D is mitigated by encrypted cookies and HTTPS.

CEH explicitly warns that applications must regenerate session IDs after authentication.

Question #:214 - [Reconnaissance Techniques]

An ethical hacker needs to gather detailed information about a company's internal network without initiating any direct interaction that could be logged or raise suspicion. Which approach should be used to obtain this information covertly?

- A. Analyze the company's SSL certificates for internal details
- B. Examine email headers from past communications with the company
- C. Inspect public WHOIS records for hidden network data
- D. Utilize network scanning tools to map the company's IP range

Answer: B

Explanation

Passive reconnaissance focuses on collecting information without directly touching or interacting with the target's systems. CEH materials stress that any action that sends network traffic to the target—such as scanning, probing, fingerprinting, or enumeration—creates logs and increases the risk of detection. Email headers, however, are considered an excellent source of passive intelligence because they reveal internal IP structures, routing paths, mail server hostnames, internal domain formats, and technology stacks without requiring interaction with the target environment. Since these headers are already in the possession of the ethical hacker through legitimate communication records, examining them does not generate traffic or trigger monitoring systems. SSL certificates and WHOIS data provide valuable external information, but they rarely disclose internal addressing schemes. Active scanning tools, such as Nmap, would immediately violate the requirement to avoid detection. Therefore, analyzing previously received email headers is the most effective and covert method for extracting internal network details during the reconnaissance phase.

Question #:215 - [Reconnaissance Techniques]

During an assessment for a tech company in Seattle, Washington, an ethical hacker seeks to uncover details about the organization's domain ownership to identify potential points of contact. She uses an online service to retrieve publicly available records without direct interaction with the target. Which method is she most likely employing to achieve this?

- A. Email footprinting
- B. Network footprinting
- C. Whois lookup
- D. DNS interrogation

Answer: C

Explanation

The correct answer is C. Whois lookup because the scenario describes retrieving publicly available domain registration records using an online service without directly interacting with the target organization's infrastructure. In CEH-aligned reconnaissance (footprinting) techniques, WHOIS is a foundational passive information-gathering method used to identify details tied to a domain name, such as the registrant /organization, administrative and technical contacts, registration and expiration dates, and the authoritative name servers associated with the domain. These details are commonly used to establish ownership context, map the organization's external footprint, and identify potential points of contact for administrative or security coordination.

The prompt emphasizes that the ethical hacker wants "details about the organization's domain ownership" and "points of contact." That is precisely the kind of information WHOIS is intended to provide. It also explicitly notes "without direct interaction with the target," which aligns with WHOIS being passive: queries are made to registries/registrars or WHOIS aggregation services rather than probing the target's servers.

Why the other options are less correct: Email footprinting focuses on collecting email addresses, formats, mail servers, and potentially related metadata, but it is not the primary method for domain ownership/registrar contact records. Network footprinting is broader and often involves identifying IP ranges, network blocks, technologies, and topology—potentially including active probing. DNS interrogation (such as querying A, MX, NS, TXT records) can reveal technical DNS data and infrastructure mapping, but it typically does not provide the domain's registrant ownership details and formal contact records; that role is handled by WHOIS and registry data.

Therefore, the method most likely used here is a WHOIS lookup to obtain public domain registration and contact information.

Question #:216 - [Security Operations and Incident Response]

At RedCore Motors, the IT security lead, Priya, is tasked with selecting a vulnerability management solution for their expanding hybrid infrastructure. During the evaluation, she prioritizes tools that support agent-based detection across endpoints, offer constant monitoring and alerting capabilities, and provide comprehensive visibility into both on-premises and cloud-based systems. After thorough testing, she selects a platform that promises to scan for vulnerabilities everywhere accurately and efficiently, aligning with her organization's need for centralized visibility and real-time risk assessment.

Which vulnerability assessment tool did Priya MOST LIKELY select?

- A. Nessus

- B. Nikto
- C. Qualys VM
- D. OpenVAS

Answer: C

Explanation

Qualys VM is the best match because the scenario emphasizes enterprise vulnerability management for a hybrid environment with agent-based endpoint coverage, continuous monitoring, alerting, and centralized visibility across both on-premises and cloud systems. In CEH-aligned security operations concepts, vulnerability management is not only about running periodic scans, but also about maintaining an accurate, continuously updated view of asset exposure, prioritizing risk, and producing actionable remediation workflows. A platform designed for hybrid infrastructures commonly includes lightweight agents for endpoints, cloud connectors, unified dashboards, continuous assessment, and notification or alerting features to support real-time risk decisions. Qualys VM is widely recognized for delivering vulnerability management through a centralized cloud platform with broad asset visibility and support for continuous assessment models that align with large-scale, distributed environments.

The other options are less aligned with the full requirement set. Nikto is a focused web server and web application scanner and does not represent an enterprise-wide vulnerability management platform for endpoints and hybrid assets. OpenVAS is a capable open-source vulnerability scanner, but it is typically implemented as a scanning solution rather than a full hybrid vulnerability management platform with the same level of integrated agent-based endpoint coverage, centralized cloud visibility, and operational alerting described. Nessus is a strong vulnerability scanner and can support agents in some deployments, but the scenario's emphasis on broad hybrid infrastructure visibility and centralized, continuous monitoring with alerting most strongly aligns with Qualys VM as a vulnerability management platform.

Question #:217 - [Security Operations and Incident Response]

As a newly appointed network security analyst, you are tasked with ensuring that the organization's network can detect and prevent evasion techniques used by attackers. One commonly used evasion technique is packet fragmentation, which is designed to bypass intrusion detection systems (IDS). Which IDS configuration should be implemented to effectively counter this technique?

- A. Implementing an anomaly-based IDS that can detect irregular traffic patterns caused by packet fragmentation.
- B. Adjusting the IDS to recognize regular intervals at which fragmented packets are sent.
- C. Configuring the IDS to reject all fragmented packets to eliminate the risk.
- D. Employing a signature-based IDS that recognizes the specific signature of fragmented packets.

Answer: A

Explanation

According to the Certified Ethical Hacker (CEH) IDS/IPS and Evasion Techniques module, packet fragmentation is a technique attackers use to split malicious payloads into smaller fragments so that signature-based IDS sensors may fail to reassemble and inspect the complete packet.

CEH explains that anomaly-based IDS systems are more effective against fragmentation evasion because they analyze behavioral deviations rather than relying solely on known signatures. Fragmented traffic often deviates from baseline network behavior in terms of packet size, sequencing, and reassembly anomalies.

Option A is correct because anomaly-based detection can identify abnormal fragmentation behavior even if the payload itself does not match known signatures.

Option B is unreliable, as attackers do not use consistent intervals.

Option C is impractical, since legitimate traffic may be fragmented.

Option D is less effective because signature-based IDS systems can be bypassed by fragmentation techniques.

CEH recommends packet normalization and anomaly-based detection as effective countermeasures.

Question #:218 - [Cryptography]

An attacker extracts the initial bytes from an encrypted file container and uses a tool to iterate through numeric combinations. What type of cryptanalytic technique is being utilized?

- A. Seek identical digests across hash outputs
- B. Test every possible password through automation
- C. Force encryption key through quantum solving
- D. Analyze output length to spot anomalies

Answer: B

Explanation

CEH identifies brute-force cryptanalysis as a method in which an attacker systematically tests every possible key, password, or passphrase until the correct one is found. When an attacker obtains initial bytes from an encrypted container—often referred to as known plaintext—they can use this to validate attempts as the tool iterates through candidate keys. Automated brute-force tools compare decrypted results with known header patterns, file signatures, or expected byte structures to determine when the correct key is reached. This process aligns precisely with brute-force password testing described in CEH cryptography modules. Quantum solving is not part of CEH scope, digest comparison relates to collision attacks, and analyzing output length pertains to padding oracle detection. The correct classification is automated brute-force cryptanalysis.

Question #:219 - [System Hacking Phases]

A CEH has mirrored a website, identified session hijacking risk, and wants to minimize detection. What is the most appropriate next step?

- A. Attempt SQL Injection
- B. Hijack a session and modify server configuration
- C. Launch brute-force attacks
- D. Perform automated vulnerability scanning

Answer: B

Explanation

According to CEH v13 System Hacking and Web Application Hacking, once reconnaissance and footprinting are complete, attackers typically move into controlled exploitation while maintaining stealth. Since the CEH has already identified a session hijacking vulnerability, leveraging that weakness is the most logical and stealthy progression.

Session hijacking allows attackers to impersonate legitimate users without triggering authentication alerts, making it significantly less detectable than brute-force or scanning activities. Option B aligns with CEH methodology: hijacking a valid session provides authorized-level access, which can then be abused to make configuration changes discreetly.

SQL injection (Option A) may trigger database errors and IDS alerts. Brute-force attacks (Option C) are noisy and easily logged. Automated vulnerability scanning (Option D) generates excessive traffic and is typically avoided once exploitation begins.

CEH v13 emphasizes using already-identified weaknesses and minimizing footprint during exploitation. Therefore, Option B is correct.

Question #:220 - [Network and Perimeter Hacking]

You are a penetration tester hired to evaluate the security posture of a regional manufacturing company's network devices. During your assessment, you discover that one of the core routers allows external administrative access without requiring a password. Additionally, the router communicates with other devices using a protocol that does not provide encryption or validation. Based solely on these observations, which of the following network device vulnerabilities is most clearly present?

- A. Firewall vulnerabilities
- B. Insecure routing protocols
- C. Lack of password protection
- D. Lack of authentication

Answer: D

Explanation

The most clearly demonstrated vulnerability is Lack of authentication. In CEH-aligned network device security principles, authentication is the fundamental control that verifies a user or device is permitted to access administrative functions or participate in trusted communications. The scenario states that the router allows external administrative access without requiring a password. That directly indicates that authentication is not being enforced for management access, meaning an unauthorized user could potentially gain administrative control simply by reaching the management interface.

The second observation reinforces the same core weakness in a different context: the router uses a protocol that provides neither encryption nor validation. In CEH terms, “validation” in routing and management protocols commonly refers to authentication and integrity checks, ensuring that updates or communications are sent by trusted peers and not altered in transit. When a protocol lacks validation, an attacker may be able to inject rogue updates, impersonate a trusted neighbor, or manipulate routing behavior, depending on the protocol and topology. While this could also be described as “insecure routing protocols,” the question asks what vulnerability is most clearly present based on both observations together. The common denominator is the absence of authentication controls: no password for admin access and no validation for device-to-device protocol exchanges.

“Lack of password protection” addresses only the first issue and is narrower. “Firewall vulnerabilities” is not evidenced. Therefore, the clearest and most comprehensive vulnerability indicated by the observations is Lack of authentication.

Question #:221 - [Security Operations and Incident Response]

A penetration tester runs a vulnerability scan and identifies an outdated version of a web application running on the company’s server. The scan flags this as a medium-risk vulnerability. What is the best next step for the tester?

- A. Ignore the vulnerability since it is only flagged as medium-risk
- B. Brute-force the admin login page to gain unauthorized access
- C. Perform a denial-of-service (DoS) attack to crash the web application
- D. Research the vulnerability to check for any available patches or known exploits

Answer: D

Explanation

CEH methodology emphasizes validating and researching identified vulnerabilities to determine exploitability, patch status, and business impact. Even medium-risk findings require investigation to assess their real severity.

Question #:222 - [Cryptography]

You are Michael, an ethical hacker at a New York-based e-commerce company performing a security review of their payment-signing service. While observing the signing process (without access to private keys), you note the service generates a fresh random value for each signature operation, the signature algorithm uses modular arithmetic in a subgroup defined by public domain parameters, and signatures are verified with a

public verification key rather than by decrypting the message. Which asymmetric algorithm best matches the signing mechanism you observed?

- A. DSA
- B. RSA
- C. Diffie-Hellman
- D. ElGamal

Answer: A

Explanation

The observed behavior most closely matches the Digital Signature Algorithm (DSA). The strongest indicators are: (1) a fresh random value is generated for each signature operation, and (2) the math operates in a subgroup defined by public domain parameters using modular arithmetic, and (3) signatures are verified using a public verification key, not by “decrypting” the message.

DSA is a signature-only asymmetric algorithm derived from discrete logarithm principles. It uses public domain parameters commonly represented as (p, q, g) , where p is a large prime, q is a prime divisor of $p-1$, and g is a generator of a subgroup of order q . For each signature, DSA requires a unique per-message secret random number k . This ephemeral k is crucial: reusing it (or generating it predictably) can expose the private key. The scenario’s emphasis on “fresh random value for each signature operation” aligns directly with this core DSA requirement.

By contrast, RSA signatures can be implemented in different ways (often involving modular exponentiation with padding) and do not inherently require a fresh random per-signature secret like DSA’s k (although some padding schemes may involve randomness). Diffie-Hellman is primarily a key exchange algorithm, not a signing algorithm. ElGamal can be used for signatures and also uses randomness, but the mention of “subgroup defined by public domain parameters” and the classic per-signature random value requirement most strongly aligns with the standard description of DSA used in many security curricula and assessments.

Therefore, based on the signature process characteristics described, the best match is A. DSA.

Question #:223 - [Wireless Network Hacking]

You are Olivia Chen, an ethical hacker at CyberGuardians Inc., hired to test the wireless network of Skyline Media, a broadcasting company in Chicago, Illinois. Your mission is to breach their WPA2-protected Wi-Fi during a late-night penetration test. Using a laptop in monitor mode, you execute a command to transmit packets that force client devices to disconnect and reconnect, enabling you to capture a four-way handshake for cracking. Based on the described action, which tool are you using?

- A. Aircrack-ng
- B. Airbase-ng
- C. Aireplay-ng

D. Airodump-ng

Answer: C

Explanation

In the Aircrack-ng suite referenced throughout CEH wireless hacking coverage, Aireplay-ng is the tool used to inject frames into a wireless network. The key phrase in the question is “transmit packets that force client devices to disconnect and reconnect.” That describes a deauthentication attack, where the tester sends 802.11 deauth frames to a client or to the access point, causing the client to drop its association and then reconnect. When a WPA2 client reconnects, the WPA2 four-way handshake is performed again. By forcing this reconnection, an ethical hacker can capture the handshake and later attempt password recovery in an offline process.

Airodump-ng is primarily a passive capture and monitoring tool used to list access points and clients, hop channels, and capture packets and handshakes, but it does not perform packet injection itself. Aircrack-ng is the cracking component that attempts to recover the WPA/WPA2 pre-shared key from a captured handshake using a wordlist or other offline techniques; it is not the tool that kicks clients off the network. Airbase-ng is used for creating a rogue access point or conducting evil twin style attacks, which is different from transmitting deauthentication frames to trigger a handshake.

Therefore, the tool that matches the described action of actively sending frames to force disconnect and reconnect is Aireplay-ng.

Question #:224 - [Mobile Platform, IoT, and OT Hacking]

As part of a penetration test for a financial firm’s smart headquarters in Denver, Colorado, ethical hacker Jordan Lee begins evaluating the IoT infrastructure responsible for lighting, HVAC, and badge-controlled access. Jordan documents details such as device models, manufacturer names, firmware versions, and supported protocols like Zigbee and BLE. This information is used to understand the device ecosystem. Which step of the IoT hacking methodology is being carried out in this phase?

- A. Information gathering
- B. Launch attacks
- C. Vulnerability scanning
- D. Gain remote access

Answer: A

Explanation

This phase is Information Gathering, the first and most foundational step in an IoT penetration test methodology described in CEH-aligned material. The goal here is to build an accurate inventory of the IoT environment and understand how devices communicate, what hardware and software versions are present, and which protocols and interfaces are in use. Jordan is collecting device models, manufacturer names, firmware versions, and supported protocols such as Zigbee and BLE. That activity maps directly to enumeration and profiling of the target IoT ecosystem, which is performed before any intrusive testing. In CEH methodology

terms, this step helps identify the attack surface, including wireless interfaces, management ports, cloud backends, mobile apps, and gateways that bridge IoT networks to enterprise networks.

Information gathering is crucial because IoT risk is highly dependent on specific device types and firmware builds. Knowing a firmware version can reveal whether known CVEs apply, whether default credentials are likely, or whether insecure services are commonly enabled. Identifying Zigbee and BLE indicates potential avenues for wireless assessment, such as insecure pairing, weak encryption or key handling, misconfigured access control, and protocol-specific weaknesses.

The other options occur later. Vulnerability scanning is the step where the tester actively checks the identified devices and services for weaknesses using scanners, enumeration probes, or targeted validation. Launch attacks and gain remote access are exploitation steps that follow planning and discovery. Since Jordan is only documenting and understanding the ecosystem, the correct step is Information gathering.

Question #:225 - [Information Security and Ethical Hacking Overview]

Which of the following best describes the role of a penetration tester?

- A. A security professional hired to identify and exploit vulnerabilities with permission
- B. A developer who writes malicious code for cyberattacks
- C. A hacker who gains unauthorized access to systems for malicious purposes
- D. A hacker who spreads malware to compromise systems

Answer: A

Explanation

CEH v13 defines a penetration tester as an authorized security professional whose responsibility is to identify, exploit, and report vulnerabilities within an organization's systems, networks, applications, and processes. Unlike malicious hackers, penetration testers operate strictly within legal boundaries, under documented Rules of Engagement (RoE), and with explicit written permission from the organization. Their goal is not to harm systems but to simulate real-world cyberattacks to help organizations strengthen their defenses. CEH emphasizes the ethical responsibilities of penetration testers, including maintaining confidentiality, avoiding unauthorized data exposure, ensuring minimal operational impact, and providing actionable recommendations. Options B, C, and D describe malicious actors, malware authors, or unauthorized attackers—roles opposite to that of an ethical penetration tester. CEH makes a strong distinction between white-hat ethical hackers and black-hat attackers, with penetration testers firmly falling under the ethical, lawful category. Therefore, Option A accurately reflects CEH's definition of a penetration tester.

Question #:226 - [Reconnaissance Techniques]

A cyber adversary wants to enumerate firewall rules while minimizing noise and mimicking normal traffic behavior. Which reconnaissance technique enables mapping of firewall filtering behavior using TTL-manipulated packets?

- A. Sending ICMP Echo requests to the network's broadcast address

- B. Passive DNS monitoring to observe domain-to-IP relationships
- C. Conducting full SYN scans on all ports for each discovered IP
- D. Firewalking with manipulated TTL values to analyze ACL responses

Answer: D

Explanation

Comprehensive Explanation from CEH v13 Courseware:

CEH v13 describes Firewalking as a reconnaissance technique designed to determine which layer-4 protocols and ports a firewall allows. The attacker sends packets with carefully adjusted TTL values so that the packet expires just beyond the firewall. If the next hop generates ICMP Time Exceeded responses, the attacker can infer which ports the firewall permits. This method mimics normal TTL behavior, making it stealthier than full SYN scans or high-noise probing. Firewalking is expressly highlighted in CEH as a low-profile way to map firewall ACLs without triggering alarms. Broadcast pings are noisy and detectable, passive DNS monitoring does not reveal firewall rule sets, and full SYN scans are easily flagged by IDS systems. Firewalking's reliance on TTL behavior, combined with protocol-specific probes, makes it the correct and CEH-aligned technique for quietly discovering open ports and firewall filtering rules.

Question #:227 - [Network and Perimeter Hacking]

A financial services firm is experiencing a sophisticated DoS attack on their DNS servers using DNS amplification and on their web servers using HTTP floods. Traditional firewall rules and IDS are failing to mitigate the attack effectively. To protect their infrastructure without impacting legitimate users, which advanced mitigation strategy should the firm implement?

- A. Increase server capacity and implement simple rate limiting
- B. Block all incoming traffic from suspicious IP ranges using access control lists
- C. Deploy a Web Application Firewall (WAF) to filter HTTP traffic
- D. Utilize a cloud-based DDoS protection service with traffic scrubbing capabilities

Answer: D

Explanation

Cloud-based DDoS mitigation services provide upstream traffic scrubbing, detecting and filtering high-volume attacks such as DNS amplification and HTTP floods before the traffic reaches the victim's network. These services use distributed infrastructures capable of handling multi-vector attacks that surpass the capacity of traditional on-premises firewalls and IDS. Traffic scrubbing centers distinguish legitimate traffic from malicious traffic, allowing normal operations to continue without service disruption.

Question #:228 - [Cloud Computing]

One customer's malicious activity impacts other tenants. Which control would best prevent this?

- A. Strong encryption
- B. Secure log management
- C. Multi-tenant isolation
- D. Strong authentication

Answer: C

Explanation

In CEH v13 Cloud Computing, multi-tenancy is a core cloud characteristic—but also a major risk if isolation controls are weak. When one tenant's actions affect others, the issue is almost always insufficient isolation between tenants.

Multi-tenant isolation ensures that compute, storage, memory, and network resources are strictly separated. Without proper isolation, a malicious tenant can:

Exhaust shared resources

Access neighboring virtual machines

Damage the provider's reputation

Encryption and authentication protect data access but do not stop cross-tenant impact. Logging helps detect incidents but does not prevent them.

CEH v13 emphasizes strong logical isolation mechanisms—such as hypervisor hardening and tenant segmentation—as essential cloud security controls. Therefore, Option C is the correct answer.

Question #:229 - [Malware Threats]

“ShadowFlee” is fileless malware using PowerShell and legitimate tools. Which strategy offers the most focused countermeasure?

- A. Restrict and monitor script and system tool execution
- B. Isolate systems and inspect traffic
- C. Schedule frequent reboots
- D. Clean temporary folders

Answer: A

Explanation

CEH v13 classifies this malware as fileless malware, which resides in memory and abuses legitimate system tools (Living-off-the-Land techniques). Traditional antivirus solutions are often ineffective.

CEH v13 recommends:

Script control (PowerShell Constrained Language Mode)

Application whitelisting

Monitoring parent-child process relationships

These measures directly target the malware's execution method. Reboots and folder cleanup do not address in-memory persistence.

Question #:230 - [Cryptography]

Encrypted session tokens vary in length, indicating inconsistent encryption strength. What is the best mitigation?

- A. Rotate keys frequently
- B. Enforce MFA for privileged users
- C. Implement uniform encryption strength
- D. Centralized logging

Answer: C

Explanation

CEH v13 explains that cryptographic consistency is essential for secure session management. Variable token lengths can leak information about encryption methods, key sizes, or user privilege levels, making sessions vulnerable to cryptanalysis or targeted attacks.

The most effective mitigation is implementing uniform encryption strength across all roles, ensuring consistent key sizes, algorithms, and token formats. While MFA improves authentication and key rotation improves lifecycle management, neither directly resolves cryptographic inconsistency.

CEH v13 stresses that encryption should be role-agnostic and standardized. Therefore, Option C is correct.

Question #:231 - [Security Operations and Incident Response]

A Nessus scan reveals a critical SSH vulnerability (CVSS 9.0) allowing potential remote code execution on a Linux server. What action should be immediately prioritized?

- A. Redirect SSH traffic to another server

- B. Treat the finding as a possible false positive
- C. Immediately apply vendor patches and reboot during scheduled downtime
- D. Temporarily isolate the affected server, conduct a forensic audit, and then patch

Answer: D

Explanation

According to the CEH Vulnerability Assessment and Incident Response modules, vulnerabilities with high CVSS scores and potential RCE must be treated as active threats.

CEH best practices recommend:

Immediate containment (network isolation)

Investigation and impact analysis

Patch application

Recovery

Option D follows the CEH incident response lifecycle precisely.

Option C is incomplete without containment.

Options A and B are unsafe.

CEH emphasizes containment before remediation.

Question #:232 - [Reconnaissance Techniques]

During an external security review of a manufacturing firm in Detroit, Michigan, you're asked to prioritize patch baselines for internet-facing servers without logging in or establishing full sessions. To achieve this, you analyze network-level responses and capture application output in order to determine the underlying system and its software release. Which technique best fits this objective?

- A. Service Version Discovery
- B. Port Scanning
- C. OS Discovery
- D. Vulnerability Scanning

Answer: A

Explanation

The correct answer is A. Service Version Discovery because the objective is to identify the software release/version running on internet-facing services by analyzing network responses and application output—without authenticating or establishing full sessions. In CEH-aligned reconnaissance methodology, service/version discovery (often called version detection or banner grabbing) focuses on determining what service is running (e.g., HTTP server, SSH daemon, SMTP server) and which version/build it is (e.g., Apache/Nginx version, OpenSSH version, application framework release). This information directly supports “prioritizing patch baselines” because patch urgency depends heavily on exact product versions: knowing the version helps map exposure to known vulnerabilities and identify outdated builds.

The prompt’s wording “analyze network-level responses and capture application output” is consistent with techniques such as banner grabbing, protocol negotiation, and response fingerprinting. Many services disclose identifying strings in headers, greetings, error pages, TLS certificates, or protocol handshakes. Even when banners are minimized, subtle differences in responses can still indicate versions or at least narrow the product family. This is typically done externally and does not require credentials, matching the constraint “without logging in or establishing full sessions.”

Why the other options are less accurate: Port scanning identifies which ports are open and which services may be present, but it does not necessarily determine precise software releases. OS discovery (OS fingerprinting) aims to infer the operating system and sometimes kernel family from packet characteristics; it is helpful but the task emphasizes “software release” and “application output,” which aligns more with service version detection than OS detection. Vulnerability scanning goes further by testing for known weaknesses and misconfigurations; while it may include version detection, the question asks for the technique that best fits the stated objective—determining the underlying service/software release from network/application responses—making service version discovery the most direct match.

Therefore, the technique is Service Version Discovery.

Question #:233 - [Reconnaissance Techniques]

Using nbtstat -A <IP>, NetBIOS names including <20> and <03> are retrieved, but shared folders cannot be listed. Why?

- A. File and printer sharing is disabled
- B. NetBIOS runs on a non-standard port
- C. nbtstat cannot enumerate shared folders
- D. The host is not in an AD domain

Answer: C

Explanation

CEH v13 clarifies that nbtstat is used only for NetBIOS name table enumeration, not for listing shared resources. Tags such as <20> indicate file server services, but share enumeration requires tools like net view or SMB enumeration utilities.

Thus, the inability to list shares is due to tool limitation, not service configuration. Option C is correct.

Question #:234 - [Wireless Network Hacking]

An ethical hacker audits a hospital's wireless network secured with WPA using TKIP and successfully performs packet injection and decryption attacks. Which WPA vulnerability most likely enabled this?

- A. Use of weak Initialization Vectors (IVs)
- B. Dependence on weak passwords
- C. Lack of AES-based encryption
- D. Predictable Group Temporal Key (GTK)

Answer: C

Explanation

CEH documentation explains that WPA-TKIP was a transitional security protocol and does not use AES encryption, relying instead on RC4-based mechanisms.

The lack of AES-based encryption makes WPA-TKIP vulnerable to injection and replay attacks.

Option C is correct.

Options A applies to WEP.

Option B affects authentication, not TKIP weakness.

Option D is not the primary TKIP flaw.

CEH recommends WPA2/WPA3 with AES.

Question #:235 - [System Hacking Phases]

A penetration tester detects malware on a system that secretly records all keystrokes entered by the user. What type of malware is this?

- A. Rootkit
- B. Ransomware
- C. Keylogger
- D. Worm

Answer: C

Explanation

CEH v13 explains that a keylogger is a type of spyware designed to capture user input covertly, often storing or transmitting captured data—such as passwords, emails, chat messages, and financial information—to an attacker. Keyloggers can be implemented as software, firmware, or hardware, and they operate silently in the background without affecting system performance, making them ideal for credential theft. CEH categorizes keyloggers under spying and monitoring malware frequently used in the System Hacking phase to escalate privileges or move laterally once credentials are harvested. Unlike rootkits, which hide processes, or ransomware, which encrypts files, a keylogger's main purpose is passive surveillance. CEH emphasizes how attackers deploy keyloggers post-compromise or use phishing/social engineering to trick victims into installing them. Their covert nature and ability to bypass traditional AV solutions by masquerading as legitimate processes make identifying them crucial during forensics and incident response activities.

Question #:236 - [Network and Perimeter Hacking]

During a red team exercise at a financial institution in New York, penetration tester Bob investigates irregularities in time synchronization across critical servers. While probing one server, he decides to use a diagnostic command that allows him to directly interact with the NTP daemon and query its internal state. This command enables him to perform monitoring and retrieve statistics, but it is primarily focused on controlling and checking the operation of the NTP service rather than listing peers with delay, offset, and jitter values.

Which command should Bob use to accomplish this?

- A. `ntpq -p [host]`
- B. `ntptrace [-m maxhosts] [servername/IP_address]`
- C. `ntpd -ilnps [-c command] [host]`
- D. `ntpq [-inp] [-c command] [host]...`

Answer: C

Explanation

The command that best matches “directly interact with the NTP daemon and query its internal state,” enabling monitoring and retrieval of statistics, is `ntpd`. Option C is correct because `ntpd` is designed as a control/query utility for NTP that communicates with the NTP daemon using control messages. It can be used to request internal variables, statistics, and status information and to perform certain monitoring-style checks related to NTP daemon operation.

The scenario also gives a strong exclusion clue: Bob's goal is not primarily to list peers with delay, offset, and jitter values. That peer listing is most closely associated with `ntpq -p` (option A), which prints peer relationships and timing metrics. Similarly, `ntptrace` (option B) is used to trace the chain of NTP servers (who is syncing from whom), which is not what Bob is seeking. Option D (`ntpq` with `-c` command) can query certain runtime details, but the question emphasizes a diagnostic command focused on controlling/checking daemon operation and retrieving internal stats—this description aligns more closely with `ntpd` in many NTP administration and diagnostic workflows.

In practice, an assessor might use `ntpd` to query items like system status, clock variables, and monitoring statistics from the daemon, which can help diagnose synchronization irregularities and understand how the NTP service is behaving internally. That aligns with “query its internal state” and “retrieve statistics.”

Therefore, the correct command is `C. ntpdc [-ilnps] [-c command] [host]`.

Question #:237 - [Web Application Hacking]

A penetration tester is assessing a web application that does not properly sanitize user input in the search field. The tester suspects the application is vulnerable to a SQL injection attack. Which approach should the tester take to confirm the vulnerability?

- A. Use directory traversal in the search field to access sensitive files on the server
- B. Input a SQL query such as `1 OR 1=1 —` into the search field to check for SQL injection
- C. Perform a brute-force attack on the login page to identify weak passwords
- D. Inject JavaScript into the search field to perform a Cross-Site Scripting (XSS) attack

Answer: B

Explanation

SQL injection is one of the most common and dangerous vulnerabilities covered in CEH training. It occurs when an application accepts unsanitized input and directly passes it to a backend SQL query. To confirm the presence of SQL injection, the tester must insert a payload that alters the logic of the SQL query executed by the application. A classic test payload such as `“1 OR 1=1 —”` is widely used because it forces the database to return all rows instead of filtering based on the intended search value. This verifies whether the input field is being concatenated directly into a SQL command. The CEH methodology emphasizes starting with simple, non-destructive boolean-based payloads to safely evaluate the vulnerability without causing harm to the database or impacting server availability. Since directory traversal, brute-force login attempts, and XSS attacks target entirely different weaknesses, they are not appropriate for confirming SQL injection. The selected option aligns with proper CEH testing methodology for identifying insecure input handling and improper query construction.

Question #:238 - [Network and Perimeter Hacking]

During a penetration test at a financial services firm in Boston, ethical hacker Daniel simulates a DDoS against the customer portal. To handle the surge, the IT team sets a rule that caps the number of requests a single user can make per second; aggressive connections are delayed or dropped while most legitimate customers continue to use the service.

Which countermeasure strategy is the IT team primarily using?

- A. Rate Limiting
- B. Shutting Down Services

- C. Absorb the Attack
- D. Degrading Services

Answer: A

Explanation

The IT team's action—capping how many requests a single user can make per second and then delaying or dropping aggressive connections—is the defining behavior of rate limiting. In DDoS conditions, especially when the portal is under a surge of automated or abusive traffic, rate limiting enforces a policy that restricts request frequency from a source (such as an IP address, session, API key, or user identifier). This helps preserve availability by preventing any one client (or a small set of clients) from consuming a disproportionate share of application and infrastructure resources.

The key wording in the scenario is that “aggressive connections are delayed or dropped while most legitimate customers continue to use the service.” Rate limiting is designed for precisely this outcome: it introduces friction for abusive traffic patterns while allowing typical user behavior through. Depending on implementation, controls can respond with delays (throttling), temporary blocks, connection resets, or HTTP error responses (for example, “too many requests”) when limits are exceeded. This is commonly applied at the edge (reverse proxy/CDN), load balancer, WAF, or application gateway to reduce pressure on backend services.

Why the other options are not the best match:

Shutting Down Services (B) is an extreme measure that sacrifices availability to stop an attack; the scenario explicitly states service largely continues.

Absorb the Attack (C) refers to scaling capacity or using scrubbing centers/CDNs to handle volume without necessarily restricting individual requester behavior; the described control is specifically per-user request caps.

Degrading Services (D) generally means intentionally reducing functionality or quality (e.g., disabling non-essential features) to keep core services alive; here, the main technique is enforcing request-rate thresholds.

Thus, the countermeasure strategy being used is A. Rate Limiting.

Question #:239 - [System Hacking Phases]

During an internal assessment, a penetration tester gains access to a hash dump containing NTLM password hashes from a compromised Windows system. To crack the passwords efficiently, the tester uses a high-performance CPU setup with Hashcat, attempting millions of password combinations per second. Which technique is being optimized in this scenario?

- A. Spoof NetBIOS to impersonate a file server
- B. Leverage hardware acceleration for cracking speed
- C. Dump SAM contents for offline password retrieval

D. Exploit dictionary rules with appended symbols

Answer: B

Explanation

Password cracking is a core component of the system hacking phase. CEH materials highlight that once password hashes are obtained, attackers often perform offline cracking to avoid detection and bypass account lockout policies. Tools like Hashcat make use of hardware acceleration—specifically, GPU or multi-core CPU computing—to significantly increase cracking throughput. Hardware acceleration allows the system to perform thousands to millions of hash calculations simultaneously, dramatically improving cracking efficiency compared to traditional CPU-bound methods. While dumping SAM contents is part of credential extraction, it is not the optimization described in the scenario. Dictionary rules influence cracking strategy but not raw speed. NetBIOS spoofing is unrelated to password cracking. The emphasis here is on maximizing computational power to accelerate the hash-cracking process, aligning directly with CEH’s explanation of hardware-accelerated offline cracking techniques.

Question #:240 - [Cloud Computing]

During a security assessment of a fintech startup in San Francisco, ethical hacker Michael analyzes the company's cloud platform. He observes that the system automates deployment, scaling, service discovery, and workload management across multiple nodes, ensuring smooth operation of critical services without requiring manual coordination. Which Kubernetes capability is primarily responsible for these functions?

- A. Kube-controller-manager
- B. Self-healing
- C. Container orchestration
- D. Container vulnerabilities

Answer: C

Explanation

The correct answer is C. Container orchestration because the described features—automated deployment, scaling, service discovery, and workload management across multiple nodes—are the defining functions of a container orchestration platform, and Kubernetes is the most widely used orchestration system for containers. In CEH-aligned cloud and container security discussions, orchestration refers to the automated coordination of containerized workloads so that applications remain available, scalable, and manageable without administrators manually placing or maintaining each container instance.

In Kubernetes, orchestration is achieved through the control plane and a set of components that continuously maintain the desired state of applications. For example, scheduling places pods onto nodes based on resource availability and constraints; controllers ensure that the correct number of replicas are running; services and DNS enable stable naming and service discovery; and autoscaling mechanisms adjust capacity according to demand. These combined behaviors allow the platform to keep critical services operating “smoothly” even as nodes change, workloads shift, or failures occur.

Why the other options are not the best match: Self-healing is a specific benefit of orchestration (Kubernetes restarts failed containers, reschedules pods, and replaces unhealthy instances), but it does not fully encompass the broader set of capabilities listed, such as deployment automation, scaling, and service discovery. Kube-controller-manager is a particular Kubernetes control-plane component that runs controller processes; it contributes to orchestration internally, but the question asks for the overarching capability responsible for the set of functions, which is container orchestration as a whole. Container vulnerabilities is not a Kubernetes capability; it is a security risk category (e.g., vulnerable images, misconfigurations, runtime exploits).

Therefore, the capability primarily responsible for automated deployment, scaling, service discovery, and multi-node workload management in Kubernetes is container orchestration.

Question #:241 - [Reconnaissance Techniques]

During a red team engagement at a healthcare provider in Miami, ethical hacker Rachel suspects that a compromised workstation is running a sniffer in promiscuous mode. To confirm her suspicion, she sends specially crafted ICMP packets with a mismatched MAC address but a correct IP destination. Minutes later, the suspected machine responds to the probe even though ordinary systems would ignore it.

Which detection technique is Rachel most likely using to validate the presence of a sniffer?

- A. Ping Method
- B. ARP Method
- C. DNS Method
- D. Nmap sniffer-detect (NSE)

Answer: A

Explanation

Rachel is using the Ping method for sniffer detection. The distinguishing behavior in the scenario is that she sends ICMP echo requests (pings) crafted so that the Layer 2 MAC address is incorrect/mismatched, while the Layer 3 IP destination is correct. Under normal circumstances, a host's network interface card (NIC) should drop frames not addressed to its MAC address. However, when a NIC is set to promiscuous mode (as sniffers often require), it can accept frames regardless of destination MAC and pass them up the stack. If the operating system then processes the encapsulated IP packet and responds (e.g., sends an ICMP echo reply), that response suggests the host is accepting frames it normally would ignore—an indicator consistent with promiscuous mode sniffing.

This technique is used as a heuristic: by intentionally violating normal Ethernet delivery rules and observing whether the target still responds, you can infer that the interface may be capturing traffic not explicitly addressed to it. It's not perfect—modern drivers, switches, VLAN configurations, and host firewall behavior can affect results—but the scenario's "mismatched MAC but correct IP" plus "the suspected machine responds" is the classic signature of the ping-based promiscuous-mode test.

Why the other options are less suitable:

ARP method (B) typically involves ARP-based tricks (non-broadcast ARP requests or crafted ARP traffic) to test how the target responds; the scenario explicitly describes ICMP behavior.

DNS method (C) relates to DNS queries/resolution behavior and does not match the ICMP/MAC mismatch test.

Nmap sniffer-detect (NSE) (D) is a specific scripted approach, but the question asks for the underlying technique being used; the described action matches the Ping method.

Therefore, the correct answer is A. Ping Method.

Question #:242 - [Social Engineering]

During a red team engagement for a client in the financial sector, ethical hacker Tyler Brooks conducts a phishing campaign using a crafted internal web page disguised as a company VPN login. After several users enter their credentials, Tyler confirms that the payload successfully recorded input without triggering antivirus or requiring local installation privileges. The captured keystrokes came exclusively from a web-based form embedded in the fake login page.

Based on the technique used, which type of keylogger did Tyler most likely deploy?

- A. Keylogger Keyboard
- B. Hypervisor-based Keylogger
- C. Application Keylogger
- D. JavaScript-based Keylogger

Answer: D

Explanation

The scenario points to a JavaScript-based keylogger because the data capture occurs entirely within a web page and does not require installing software on the victim's machine. In CEH-aligned social engineering and web attack concepts, phishing pages commonly include client-side scripts that capture form inputs in real time. When a user types credentials into a fake login form, JavaScript event handlers can record keystrokes or the final field values and transmit them to an attacker-controlled endpoint. This explains why Tyler's "payload" works without local privilege, without dropping executables, and without triggering traditional antivirus focused on file-based malware. The key detail is that "captured keystrokes came exclusively from a web-based form embedded in the fake login page," which matches browser-based capture rather than OS-level logging.

The other options imply deeper system access than the prompt describes. A keyboard keylogger typically operates at the operating-system level by intercepting keyboard input system-wide, which usually requires running code on the host and is more likely to be detected by endpoint protections. A hypervisor-based keylogger is a highly advanced technique that relies on virtualization-layer control and is not consistent with a simple phishing web page. An application keylogger usually targets specific processes on the endpoint (such as browsers or email clients), again requiring execution on the local machine.

From a defensive viewpoint emphasized in CEH, mitigations include user awareness training to spot phishing pages, enforcing MFA to reduce the value of stolen credentials, using anti-phishing protections and URL filtering, monitoring for lookalike domains, and deploying browser and email security controls that detect credential-harvesting pages and suspicious form-post destinations.

Question #:243 - [Web Application Hacking]

During a red team engagement at a retail company in Atlanta, ethical hacker James crafts a session with the company's shopping portal and deliberately shares that session ID with an unsuspecting employee by embedding it in a link. When the employee clicks and logs in, their activity is bound to the attacker's pre-assigned session. Later, James retrieves the employee's input from that same session to demonstrate the flaw to management.

Which session hijacking technique is James most likely using?

- A. Session Donation Attack
- B. Session Replay Attack
- C. Session Prediction
- D. Session Fixation Attack

Answer: D

Explanation

This scenario is a classic session fixation attack. In session fixation, the attacker sets or “fixes” a known session identifier (session ID) for the victim before the victim authenticates. The attacker then persuades the victim to use that predetermined session—often by embedding the session ID into a URL, link, or cookie setting mechanism. Once the victim logs in, the application incorrectly continues using the same session ID (rather than issuing a new one upon authentication). As a result, the attacker can reuse that known session ID to access the victim’s authenticated session context.

The described sequence matches session fixation exactly: James first crafts a session and obtains a session ID, then shares it with the victim via a link, the victim clicks and logs in, and “their activity is bound to the attacker’s pre-assigned session.” Later, James accesses the session and retrieves the victim’s input—demonstrating that authentication was tied to an attacker-controlled session token.

Why the other options do not fit:

Session replay (B) involves capturing a valid session token (e.g., via sniffing, XSS, or leakage) and replaying it, but it does not require pre-setting the token before the victim logs in.

Session prediction (C) is about guessing or calculating valid session IDs due to weak randomness. Here the attacker does not guess; he deliberately provides a session ID he already controls.

“Session donation (A)” is not the standard classification for this well-known web session weakness in CEH-style taxonomy; the described behavior aligns with fixation.

Therefore, the correct answer is D. Session Fixation Attack.

Question #:244 - [Reconnaissance Techniques]

Which scenario best describes a slow, stealthy scanning technique?

- A. FIN scanning
- B. TCP connect scanning
- C. Xmas scanning
- D. Zombie-based idle scanning

Answer: D

Explanation

CEH v13 identifies Idle (Zombie) Scanning as one of the most stealthy reconnaissance techniques. In this method, attackers use a third-party system (the zombie) to send probes to the target, obscuring the attacker's true identity.

Because the attacker never directly interacts with the target, detection and attribution become extremely difficult. FIN and Xmas scans are stealthy but still originate from the attacker's IP. TCP connect scans are noisy and easily detected.

CEH v13 highlights idle scanning as the gold standard for stealth reconnaissance, making option D correct.

Question #:245 - [Web Application Hacking]

During a red team test, a web application dynamically builds SQL queries using a numeric URL parameter. The tester sends the following request:

<http://vulnerableapp.local/view.php?id=1;>

DROP TABLE users;

The application throws errors and the users table is deleted. Which SQL injection technique was used?

- A. UNION-based SQL injection
- B. Stacked (Piggybacked) queries
- C. Boolean-based SQL injection
- D. Error-based SQL injection

Answer: B

Explanation

The CEH SQL Injection module defines stacked (piggybacked) queries as attacks where an attacker appends an additional SQL statement using a statement delimiter such as a semicolon.

In this scenario, the attacker executed a second query (DROP TABLE users) after the original query, resulting in destructive behavior.

Option B is correct.

Option A retrieves data, not execute destructive commands.

Option C infers logic outcomes.

Option D relies on error messages for data extraction.

CEH classifies stacked queries as high-impact SQL injection attacks.

Question #:246 - [Security Operations and Incident Response]

At Norwest Freight Services, Simon, a junior analyst, is tasked with running a vulnerability scan on several departmental servers. This time, he is provided with administrator-level credentials to input into the scanner. The scan takes significantly longer than usual but returns detailed results, including weak registry permissions, outdated patches, and insecure configuration files that would not have been visible to an outsider. SIEM logs confirm that successful logins occurred during the scanning process.

Which type of vulnerability scan best explains the behavior observed in Simon's assessment?

- A. External Scanning
- B. Credentialed Scanning
- C. Internal Scanning
- D. Non-Credentialed Scanning

Answer: B

Explanation

This is best explained by credentialed scanning because the scanner is given administrator-level credentials, and the SIEM confirms successful logins occurred during the scan. Credentialed scans authenticate to the target systems (via SMB/WMI/WinRM for Windows, SSH for Linux/Unix, APIs for certain platforms) and then perform deeper inspection from an “inside” perspective. That allows the scanner to enumerate details that are not reliably visible from unauthenticated network probing—such as installed patch levels, local security policy settings, registry permissions, configuration files, running services with their exact versions, and misconfigurations that require local access to verify.

The scenario's outcomes strongly match this: the scan takes significantly longer, which is common because authenticated checks involve logging in and performing many local queries; the results include weak registry

permissions, outdated patches, and insecure configuration files, all of which typically require authenticated access to assess comprehensively. In addition, credentialed scanning reduces false positives and improves accuracy, because it can confirm vulnerability conditions directly rather than inferring from banners or open ports.

Why the other options are less accurate:

Non-credentialed scanning (D) is performed from an external perspective without logins; it would not normally retrieve detailed registry/config file permission findings, and SIEM logs would not show successful authentication events caused by the scanner.

External scanning (A) describes the scan's network location (outside the organization) rather than the authentication mode. You can do external credentialed scans, but the defining feature here is authenticated logins and deep host checks.

Internal scanning (C) also refers to where the scan originates. While the scan might be internal, the question's key differentiator is that admin credentials were used to log in and gather detailed local information.

Therefore, the scan type is B. Credentialed Scanning.

Question #:247 - [Network and Perimeter Hacking]

A multinational corporation recently survived a severe Distributed Denial-of-Service (DDoS) attack and has implemented enhanced security measures. During an audit, you discover that the organization uses both hardware- and cloud-based solutions to distribute incoming traffic in order to absorb and mitigate DDoS attacks while ensuring legitimate traffic remains available. What type of DDoS mitigation strategy is the company utilizing?

- A. Black Hole Routing
- B. Load Balancing
- C. Rate Limiting
- D. Sinkholing

Answer: B

Explanation

This scenario clearly describes Load Balancing as a DDoS mitigation strategy, which is covered under the CEH v13 Network and Perimeter Hacking module. Load balancing distributes incoming network or application traffic across multiple servers or resources to prevent any single system from becoming overwhelmed.

According to CEH v13, modern DDoS mitigation architectures often combine hardware load balancers with cloud-based scrubbing centers or Content Delivery Networks (CDNs). These systems absorb high traffic volumes and ensure availability by spreading requests across multiple nodes. This approach aligns perfectly with the organization's strategy of absorbing and distributing traffic rather than blocking it outright.

Other options are incorrect:

Black hole routing drops all traffic, including legitimate traffic.

Rate limiting restricts traffic volume rather than distributing it.

Sinkholing redirects traffic for analysis, not load distribution.

Question #:248 - [Reconnaissance Techniques]

A security analyst is tasked with gathering detailed information about an organization's network infrastructure without making any direct contact that could be logged or trigger alarms. Which method should the analyst use to obtain this information covertly?

- A. Examine leaked documents or data dumps related to the organization
- B. Use network mapping tools to scan the organization's IP range
- C. Initiate social engineering attacks to elicit information from employees
- D. Perform a DNS brute-force attack to discover subdomains

Answer: A

Explanation

Passive reconnaissance focuses on collecting intelligence without interacting with the target's systems. CEH materials emphasize reviewing publicly available information, including leaked documents, breach data, reports, or exposed metadata, as this yields internal network structure details while generating no detectable traffic. This method avoids triggering monitoring systems and aligns with stealth requirements for covert intelligence gathering.

Question #:249 - [Cryptography]

A penetration tester submits altered ciphertexts to a web server and pays close attention to how the server responds. When the server produces different error messages for certain inputs, the tester starts to infer which inputs result in valid internal processing. Which cryptanalytic method is being used in this scenario?

- A. Exploit padding error feedback to recover data
- B. Compare traffic timing to deduce the key
- C. Flip bits randomly to scramble the decryption
- D. Inspect randomness across multiple sessions

Answer: A

Explanation

Padding oracle attacks exploit systems that reveal differences in error responses when incorrectly padded ciphertext is submitted. CEH explains that these variations allow attackers to iteratively determine valid padding bytes and ultimately decrypt or modify encrypted data without knowledge of the key.

Question #:250 - [Reconnaissance Techniques]

A penetration tester is tasked with mapping an organization's network while avoiding detection by sophisticated intrusion detection systems (IDS). The organization employs advanced IDS capable of recognizing common scanning patterns. Which scanning technique should the tester use to effectively discover live hosts and open ports without triggering the IDS?

- A. Execute a FIN scan by sending TCP packets with the FIN flag set
- B. Use an Idle scan leveraging a third-party zombie host
- C. Conduct a TCP Connect scan using randomized port sequences
- D. Perform an ICMP Echo scan to ping all network devices

Answer: B

Explanation

CEH v13 highlights the Idle Scan as one of the stealthiest reconnaissance methods available, designed specifically to avoid detection by IDS and security monitoring tools. Idle scanning leverages a “zombie host”—a system with a predictable IPID sequence—to route all probe packets through it. Since no packets ever originate directly from the attacker’s IP, IDS systems are unable to attribute the port scan to the attacker. CEH emphasizes that this technique creates zero direct traffic between the attacker and the target, making it extremely evasive and ideal for highly monitored networks. FIN scans (Option A) are somewhat stealthy but still originate from the attacker and are detectable. TCP Connect scans (Option C) are the most detectable because they complete full connections. ICMP Echo scans (Option D) are easily logged and flagged by IDS. Idle scanning is uniquely suited for bypassing advanced detection systems while still identifying open ports and live hosts.

Question #:251 - [Network and Perimeter Hacking]

Lily, a network security analyst at a regional healthcare provider, is preparing defenses ahead of a scheduled external vulnerability assessment. During internal simulation drills, she observes that scanners are successfully identifying open ports and service banners across critical systems. Tasked with reducing exposure to such reconnaissance efforts, Lily is instructed to apply measures that specifically hinder port scanning activity without disrupting legitimate traffic.

Which of the following actions should Lily implement?

- A. Block unwanted services running on the ports and update the service versions
- B. Use a custom rule set to lock down the network, block unwanted ports at the firewall, and filter specific ports

- C. Configure firewall and IDS rules to detect and block probes
- D. Block inbound ICMP message types and all outbound ICMP type 3 unreachable messages
- E. CConfiguring firewall and IDS rules to detect and block probes is the most direct and CEH-aligned countermeasure for hindering port scanning while preserving legitimate traffic. Port scans typically generate recognizable patterns such as many connection attempts across multiple ports in a short time window, repeated SYN packets, abnormal TCP flag combinations, or sequential targeting of hosts and ports. An IDS or IPS can detect these behaviors using thresholds and signatures and then alert or actively block the scanning source through shunning, dynamic ACL updates, or automated firewall integration. This approach focuses on stopping the reconnaissance activity itself, rather than only addressing the symptoms after exposure has already occurred. Option B is partially valid because blocking unwanted ports at the firewall reduces the attack surface, but it is primarily hardening and exposure reduction. It does not necessarily hinder scanning behavior, and overly broad filtering can unintentionally block legitimate services if not carefully scoped. Option A improves security by removing unnecessary services and patching, but scanning can still occur and banners may still be collected from required services. Option D is not appropriate because blocking ICMP type 3 unreachable messages can interfere with normal network operations, troubleshooting, and path MTU discovery, and it does not reliably stop modern scanning techniques that use TCP-based probing. Therefore, the best action specifically aimed at disrupting port scanning activity with minimal impact on legitimate traffic is tuning firewall and IDS controls to detect and block scan probes.

Answer: A B C D E

Question #:252 - [Malware Threats]

A cybersecurity team identifies suspicious outbound network traffic. Investigation reveals malware utilizing the Background Intelligent Transfer Service (BITS) to evade firewall detection. Why would attackers use this service to conceal malicious activities?

- A. Because BITS packets appear identical to normal Windows Update traffic.
- B. Because BITS operates exclusively through HTTP tunneling.
- C. Because BITS utilizes IP fragmentation to evade intrusion detection systems.
- D. Because BITS traffic uses encrypted DNS packets.

Answer: A

Explanation

The Certified Ethical Hacker (CEH) Malware Threats module explains that attackers often abuse legitimate system services to blend malicious traffic with normal system behavior. Background Intelligent Transfer Service (BITS) is a Windows service designed to transfer files in the background using idle network bandwidth.

Attackers leverage BITS because its traffic closely resembles legitimate Windows Update traffic, which is commonly allowed through firewalls and proxy servers. CEH documentation states that BITS-based malware can download payloads, upload stolen data, and maintain persistence without triggering security alerts.

Option A is correct because BITS traffic appears legitimate and trusted, making it difficult for security devices to distinguish malicious usage.

Option B is incorrect because BITS does not operate exclusively through HTTP tunneling; it primarily uses HTTP/HTTPS in a legitimate manner.

Option C is incorrect because IP fragmentation is not a core feature of BITS.

Option D is incorrect because BITS does not rely on encrypted DNS traffic.

CEH emphasizes that living-off-the-land (LotL) techniques—using native tools like BITS—are increasingly favored by attackers due to their stealth and reliability.

Question #:253 - [Mobile Platform and IoT Hacking]

At a financial headquarters in Denver, Colorado, ethical hacker Jordan Lee moves beyond cataloging IoT devices and begins testing them for weaknesses. He runs specialized tools against smart lighting and HVAC systems to check for outdated firmware, default passwords, and open service ports. Which step of the IoT hacking methodology is Jordan carrying out?

- A. Vulnerability scanning
- B. Gain remote access
- C. Information gathering
- D. Launch attacks

Answer: A

Explanation

Jordan is in the vulnerability scanning step because he has already moved past identification/cataloging (information gathering) and is now actively testing IoT devices for weaknesses such as outdated firmware, default credentials, and exposed/open service ports. In IoT hacking methodology, information gathering focuses on discovering devices, mapping the environment, identifying device types, interfaces, protocols, and versions, and understanding how data flows between endpoints, gateways, mobile apps, and cloud services. Once that baseline inventory exists, the next step is to assess the devices and their ecosystem components for known and observable security gaps.

The specific checks described are classic vulnerability scanning targets in IoT environments:

Outdated firmware can indicate known vulnerabilities, missing security fixes, and unpatched components.

Default passwords are a common IoT weakness and can enable trivial compromise when not changed.

Open service ports reveal exposed management interfaces or unnecessary services that can be enumerated or exploited.

Running “specialized tools” to systematically evaluate these elements is consistent with vulnerability scanning because it is structured assessment aimed at finding exploitable conditions, but it stops short of actually exploiting or establishing persistence.

Why the other options do not fit:

Information gathering (C) would focus on identifying devices and collecting details, not actively checking them for outdated firmware/default passwords/open ports as vulnerabilities.

Gain remote access (B) implies exploitation or obtaining unauthorized control/access, which the scenario does not indicate—he is checking and assessing.

Launch attacks (D) implies executing exploitation, disruption, or compromise steps. The question explicitly frames this as testing for weaknesses, not carrying out attacks.

Therefore, Jordan is performing A. Vulnerability scanning.

Question #:254 - [Network and Perimeter Hacking]

During a red team operation on a segmented enterprise network, the testers discover that the organization’s perimeter devices deeply inspect only connection-initiation packets (such as TCP SYN and HTTP requests). Response packets and ACK packets within established sessions, however, are minimally inspected. The red team needs to covertly transmit payloads to an internal compromised host by blending into normal session traffic. Which approach should they take to bypass these defensive mechanisms?

- A. Port knocking
- B. SYN scanning
- C. ICMP flooding
- D. ACK tunneling

Answer: D

Explanation

CEH teaches that certain advanced intrusion evasion techniques rely on understanding how firewalls differentiate between new connections and established traffic. Most perimeter firewalls scrutinize SYN packets and initial HTTP requests but allow ACK packets from established sessions to pass with minimal filtering. ACK tunneling leverages this behavior by embedding malicious payloads inside ACK packets, which appear to be part of a legitimate, pre-established session. Because ACK packets are often considered “safe,” they bypass deep inspection engines, intrusion detection systems, and application-layer gateways. This method allows attackers to move data or commands covertly between compromised internal systems and external hosts. CEH references such evasion strategies when discussing bypassing stateful firewalls and making malicious traffic appear legitimate. Port knocking and SYN scans would initiate new connections—precisely what the firewall is heavily inspecting. ICMP flooding is noisy and easily detected. ACK tunneling is specifically designed for stealth and is aligned with red team tradecraft for avoiding packet-level inspection mechanisms.

Question #:255 - [Reconnaissance Techniques]

During a covert red team engagement, a penetration tester is tasked with identifying live hosts in a target organization's internal subnet (10.0.0.0/24) without triggering intrusion detection systems (IDS). To remain undetected, the tester opts to use the command `nmap -sn -PE 10.0.0.0/24`, which results in several "Host is up" responses, even though the organization's IDS is tuned to detect high-volume scans. After the engagement, the client reviews the logs and is surprised that the scan was not flagged. What allowed the scan to complete without triggering alerts?

- A. It used TCP ACK packets that were allowed through.
- B. It used UDP packets that bypassed ICMP inspection.
- C. It scanned only the ports open in the firewall whitelist.
- D. It performed an ICMP Echo ping sweep without port probing.

Answer: D**Explanation**

CEH v13 explains that IDS systems are often tuned to detect active scanning behavior, especially port scans and TCP/UDP probing that generate recognizable signatures. The command `nmap -sn -PE` performs a pure ICMP Echo Request ping sweep without sending any TCP SYN, UDP probes, or other packets normally associated with port enumeration. Since this mode disables port scanning entirely, it produces minimal traffic that resembles legitimate network behavior. CEH emphasizes that many networks allow ICMP Echo traffic internally for diagnostics, so such pings may not be treated as suspicious unless rate thresholds are exceeded. Because the tester avoided SYN packets, ACK probes, and UDP scans, the IDS saw no malicious pattern or connection attempts. The effectiveness of this technique is highlighted in CEH under passive and stealth reconnaissance, where minimal interaction is used to avoid detection. Thus, the scan succeeded because it relied solely on ICMP host discovery, not port scanning.

Question #:256 - [Network and Perimeter Hacking]

A financial institution's online banking platform is experiencing intermittent downtime caused by a sophisticated DDoS attack that combines SYN floods and HTTP GET floods from a distributed botnet. Standard firewalls and load balancers cannot mitigate the attack without affecting legitimate users. To protect their infrastructure and maintain service availability, which advanced mitigation strategy should the institution implement?

- A. Configure firewalls to block all incoming SYN and HTTP requests from external IPs
- B. Increase server bandwidth and apply basic rate limiting on incoming traffic
- C. Deploy an Intrusion Prevention System (IPS) with deep packet inspection capabilities
- D. Utilize a cloud-based DDoS protection service that offers multi-layer traffic scrubbing and auto-scaling

Answer: D**Explanation**

Comprehensive Explanation from CEH v13 Courseware:

CEH v13 underscores that modern multi-vector DDoS attacks—particularly SYN floods combined with Layer 7 HTTP floods—cannot be effectively mitigated by traditional firewalls, IPS devices, or local traffic filters. These systems become overwhelmed or risk blocking legitimate clients. CEH emphasizes the use of cloud-based DDoS mitigation platforms that provide traffic scrubbing, distributed filtering, rate shaping, and automatic scaling to absorb massive volumes of malicious traffic. Such services differentiate legitimate versus malicious traffic using global intelligence, behavioral analysis, and multi-layer protection strategies. Increasing bandwidth or blocking broad traffic categories is ineffective and harmful to users. An IPS cannot scale to handle volumetric attacks. Only cloud scrubbing solutions (e.g., Cloudflare, Akamai, AWS Shield Advanced) meet CEH's recommended defenses for high-volume distributed attacks. These services ensure continuous availability and minimize collateral damage by filtering traffic upstream before it reaches the organization's infrastructure.

Question #:257 - [Mobile Platform and IoT Hacking]

You are Sofia Patel, an ethical hacker at Nexus Security Labs, hired to test the mobile device security of Bayview University in San Francisco, California. During your assessment, you are given an Android 11-based Samsung Galaxy Tab S6 with USB debugging disabled and OEM unlock restrictions in place. To simulate an attacker attempting to gain privileged access, you install a mobile application that exploits a system vulnerability to gain root access directly on the device without requiring a PC. This allows you to bypass OS restrictions and retrieve sensitive research data. Based on this method, which Android rooting tool are you using?

- A. Magisk Manager
- B. One Click Root
- C. KingoRoot
- D. RootMaster

Answer: C**Explanation**

The scenario describes an on-device, app-based rooting approach that does not rely on a PC connection, USB debugging, or a bootloader unlock workflow. In CEH mobile platform coverage, this aligns with “one-click” rooting tools that package exploits to elevate privileges directly from user space to root on the device. These tools typically target known vulnerabilities in the Android OS, vendor kernels, or system services to obtain root privileges and then install a management component to maintain elevated access.

KingoRoot is commonly cited in ethical hacking training contexts as a popular one-click rooting solution that can run as an Android application and attempt to root a device without a computer, depending on the device model, Android version, and patch level. This directly matches the prompt: Sofia installs a mobile application, it “exploits a system vulnerability,” and it achieves root “without requiring a PC.” The constraints given, USB

debugging disabled and OEM unlock restrictions, make PC-assisted ADB workflows or bootloader-based rooting less feasible, which further supports an exploit-driven, on-device rooting tool.

Magisk Manager is primarily a root management and systemless modification framework and typically assumes the device is already rooted or that the user can patch the boot image and flash it, often requiring bootloader unlock steps that OEM restrictions would block. “One Click Root” is a generic label rather than a specific tool in many CEH-style question banks. RootMaster is another one-click tool, but KingoRoot is the most widely recognized and frequently referenced for direct APK-based rooting in this context.

Question #:258 - [Security Operations and Incident Response]

Which patch management strategy is most effective?

- A. External-only patches
- B. Automated patch management with monitoring
- C. Manual patching on live servers
- D. Applying all patches regardless of source

Answer: B

Explanation

CEH v13 identifies automated patch management as the most secure and scalable approach. Automated tools ensure timely deployment, validation, rollback capability, and compliance reporting.

Manual patching increases human error. Applying patches from unknown sources introduces malware risk. Limiting patches contradicts best practices.

Therefore, Option B is correct.

Question #:259 - [Network and Perimeter Hacking]

A security analyst investigates unusual east-west traffic on a corporate network. A rogue device has been physically inserted between a workstation and the switch, enabling unauthorized access while inheriting the workstation’s authenticated network state. Which evasion technique is being used?

- A. Exploiting a wireless rogue access point to tunnel through the firewall
- B. NAC bypass using a pre-authenticated device for network bridging
- C. Spoofing ARP responses from a dynamic IP allocation pool
- D. VLAN double tagging to shift between network segments

Answer: B

Explanation

Network Access Control (NAC) solutions often authenticate only the first device connected to a port. CEH explains that attackers can insert a rogue device behind an already authenticated host, bypassing NAC checks. This creates a transparent bridge that forwards legitimate traffic while injecting attacker-controlled communications.

Question #:260 - [System Hacking Phases]

During a security assessment, an attacker identifies a flaw in a multi-user file system. The system first verifies access rights to a temporary file created by a user. However, immediately after this verification, and before the file is processed, the attacker manages to swap the original file with a malicious version. This manipulation happens in the brief interval between the system's access verification and the moment it handles the file, resulting in the malicious file being treated as legitimate. Which vulnerability is the attacker exploiting?

- A. Time-of-validation/time-of-execution issue in resource management logic.
- B. Improper certificate validation in trusted communication channels.
- C. Integer overflow during arithmetic computations with limited memory bounds.
- D. Null pointer dereference leading to unexpected application behavior.

Answer: A

Explanation

Comprehensive Explanation from CEH v13 Courseware:

CEH v13 explains that TOCTOU (Time-of-Check Time-of-Use) vulnerabilities arise when a system checks a condition (such as file permissions) and then later uses the resource based on that assumption. If there is even a tiny gap between the validation and the actual use, attackers can exploit this race condition by replacing or modifying the resource after validation but before execution. This is common in file-handling operations involving temporary files, symbolic links, or shared directories. CEH emphasizes that TOCTOU attacks often lead to privilege escalation, unauthorized execution, or tampering with data because the system trusts the earlier validation step. The attacker swaps the file at precisely the right moment, taking advantage of a race window. The other options—certificate validation, integer overflow, and null pointer dereference—do not involve timing-based race conditions. The scenario exactly matches CEH's description of TOCTOU exploitation, where attackers manipulate file access in the interval between validation and execution.

Question #:261 - [Web Application Hacking]

A penetration tester is assessing a web application that employs secure, HTTP-only cookies, regenerates session IDs upon login, and uses strict session timeout policies. To hijack a user's session without triggering the application's security defenses, which advanced technique should the tester utilize?

- A. Perform a session token prediction by analyzing session ID entropy and patterns

- B. Conduct a network-level man-in-the-middle attack to intercept and reuse session tokens
- C. Execute a Cross-Site Request Forgery (CSRF) attack to manipulate session states
- D. Implement a session fixation strategy by pre-setting a session ID before user authentication

Answer: A

Explanation

When standard protections such as HTTPS, HTTP-only flags, and session regeneration are properly implemented, CEH teaches that predictable session identifiers become one of the few remaining avenues for session hijacking. Session token prediction involves analyzing entropy, randomness, or generation patterns within session IDs to mathematically infer future or valid tokens. If the application uses weak randomization algorithms, insufficient entropy sources, or predictable sequences, attackers may generate a valid session ID without direct interception. Techniques such as MitM interception or CSRF manipulation do not bypass strong transport-layer protections and cookie restrictions. Session fixation fails because the application regenerates the session ID upon login, invalidating pre-set identifiers. Therefore, the advanced and CEH-aligned method to hijack a protected session is predicting session IDs through side-channel or pattern analysis.

Question #:262 - [Cryptography]

You are Alex, a forensic responder at HarborHealth in Seattle, Washington. During a live incident response you must secure an enterprise Windows server's system partition and attached data volumes without rebooting user machines or disrupting domain authentication. The IT team prefers a solution that integrates with Windows platform features (including hardware-backed startup protection and centralized key escrow via Active Directory/management policies) and provides transparent full-disk protection for the OS volume. Which disk-encryption solution should you deploy?

- A. FileVault
- B. BitLocker Drive Encryption
- C. VeraCrypt
- D. Rohos Disk Encryption

Answer: B

Explanation

The correct answer is B. BitLocker Drive Encryption because the requirements describe native Windows full-disk encryption that integrates tightly with enterprise Windows security features and centralized management. BitLocker is Microsoft's built-in disk encryption technology designed to provide transparent encryption for the operating system volume and additional fixed/removable drives. It supports hardware-backed startup protection through integration with the Trusted Platform Module (TPM), which can help protect encryption keys and validate boot integrity before unlocking the OS volume. This matches the prompt's requirement for "hardware-backed startup protection."

The scenario also emphasizes “centralized key escrow via Active Directory/management policies.” In enterprise deployments, BitLocker recovery information can be backed up to Active Directory and managed through Group Policy / MDM controls, enabling standardized enforcement (encryption settings, recovery key handling, compliance reporting) across servers and endpoints. This is a core operational advantage in regulated environments like healthcare: it enables rapid response (recoverability), consistent policy application, and audit-friendly control of encryption keys—without requiring third-party key management tooling for basic escrow needs.

Additionally, the prompt calls for securing the “system partition and attached data volumes” in a way that is compatible with Windows platform behavior and minimizes disruption. BitLocker supports encrypting both the OS volume and data volumes, and it is designed for transparent operation once enabled, so normal server use and domain authentication continue as expected.

Why the other options are not correct: FileVault is Apple’s full-disk encryption for macOS, not Windows. VeraCrypt and Rohos Disk Encryption are third-party solutions that can provide disk encryption, but they do not match the stated preference for deep Windows enterprise integration with TPM-based startup protection and Active Directory–based recovery key escrow through standard Microsoft management policies.

Therefore, the best solution for this Windows enterprise requirement is BitLocker Drive Encryption.

Question #:263 - [Malware Threats]

During a routine software update at Horizon Solutions, a mid-sized IT firm in Raleigh, North Carolina, an employee downloads a file utility from a popular third-party site to streamline document processing. During the installation, the user is prompted to install an optional “productivity toolbar” and a “system optimization tool,” which are bundled with vague descriptions. Shortly after, the employee notices intermittent pop-up ads, an altered browser homepage, and sluggish PC performance, though network logs also show occasional unexplained data transfers during off-hours. A security scan flags the additional programs as potentially harmful, but a deeper analysis reveals no immediate file encryption or self-replicating code.

What type of threat are these unwanted programs most likely classified as?

- A. Potentially Unwanted Applications (PUAs)
- B. Worms
- C. Botnet agents
- D. Logic bombs

Answer: A

Explanation

The correct classification is Potentially Unwanted Applications (PUAs). In CEH malware taxonomy, PUAs refer to software that is not strictly malicious in the traditional sense but exhibits undesirable behavior such as displaying intrusive advertisements, modifying browser settings, collecting user data, degrading system

performance, or bundling with other freeware without clear user awareness. In this scenario, the toolbar and optimization tool were bundled with a legitimate utility installer and presented with vague descriptions—an extremely common PUA distribution method known as software bundling.

The symptoms described—pop-up ads, homepage modification, sluggish performance, and background data transfers—are consistent with adware or browser hijackers, which fall under the broader PUA classification. Importantly, the question specifies there is no immediate file encryption (which would suggest ransomware) and no self-replication (which would suggest a worm). Botnet agents typically establish command-and-control communication and are designed for coordinated malicious activity such as DDoS or spam campaigns; while unexplained traffic may raise suspicion, the described behavior aligns more closely with adware-style monetization rather than structured botnet activity. Logic bombs are dormant code triggered by specific conditions, which is not indicated here.

From a defensive perspective, CEH recommends secure software acquisition policies, user awareness training, disabling unnecessary bundled installations, implementing endpoint protection with PUA detection enabled, and enforcing application allowlisting to prevent unauthorized or bundled software from executing within the enterprise environment.

Question #:264 - [Web Application Hacking]

You are an ethical hacker at Titan Cyber Defense, hired by BrightWave Publishing in New York City to assess the security of their content management system (CMS). While testing the article search function, you input malformed strings such as multiple single quotes. The application responds with system feedback that unexpectedly reveals the database type and internal query structure, including table and column information. You use these disclosures to better understand how the backend query is built.

Which of the following methods to detect SQL injection are you employing?

- A. Function Testing
- B. Testing String
- C. Dynamic Testing
- D. Fuzz Testing

Answer: B

Explanation

The correct answer is B. Testing String because the scenario describes a classic SQL injection detection approach where the tester submits special characters and malformed input strings—most notably single quotes (')—to observe how the application processes them and whether it produces database error feedback. In SQL injection discovery, inserting a single quote (or multiple quotes) into a parameter commonly breaks the intended SQL syntax if the input is concatenated into a query without proper validation/escaping or parameterization. When this happens, the backend database often returns error messages that may disclose critical information such as the DBMS type (e.g., MySQL, Microsoft SQL Server, Oracle), query fragments, and sometimes references to table/column names. That is exactly what you observed: “system feedback that unexpectedly reveals the database type and internal query structure.”

This method is specifically called “testing strings” in CEH-style SQL injection identification: using quote characters, delimiters, comment markers, and other metacharacters to see whether the application is vulnerable and whether errors or abnormal behavior occur. The goal is not to fully exploit the injection immediately, but to confirm whether input is being interpreted as part of an SQL statement and to collect clues that help the tester model the backend query and proceed with safe, authorized validation steps.

Why the other options are less accurate: Function testing is a broader web-testing concept and is not the specific SQLi detection tactic shown. Dynamic testing generally refers to testing an application while it is running to observe behavior, but it does not name this specific SQLi discovery technique. Fuzz testing involves sending large volumes of random or semi-random unexpected inputs to trigger crashes or errors; while multiple quotes could be part of fuzzing, the described method is the targeted, well-known SQLi testing string approach used to elicit informative SQL errors.

Therefore, the method being employed is Testing String.

Question #:265 - [Social Engineering]

Which social engineering attack involves impersonating a co-worker or authority figure to extract confidential information?

- A. Phishing
- B. Pretexting
- C. Quid pro quo
- D. Baiting

Answer: B

Explanation

Pretexting is defined in CEH v13 Social Engineering as an attack where the attacker fabricates a believable scenario and impersonates a trusted individual to gain sensitive information.

This differs from phishing (mass messaging), baiting (malicious incentives), and quid pro quo (exchange of favors).

Question #:266 - [Reconnaissance Techniques]

An attacker performs DNS cache snooping using the dig command with the +norecurse flag against a known DNS server. The server returns NOERROR but provides no answer to the query. What does this most likely suggest?

- A. The record was found in the DNS cache and successfully returned.
- B. The DNS server failed to resolve the request.
- C. No client from the DNS server’s network has recently accessed the queried domain.

D. The queried domain has expired and no longer exists.

Answer: C

Explanation

According to the Certified Ethical Hacker (CEH) Reconnaissance and Footprinting module, DNS cache snooping is a passive information-gathering technique used to determine whether a specific DNS record exists in a server's cache. Attackers commonly use the `dig +norecurse` option to prevent the DNS server from querying other DNS servers, thereby revealing only cached results.

When a DNS server responds with NOERROR but does not return an answer, it indicates that the domain name itself is valid, but the requested record is not present in the DNS cache. CEH documentation explains that this situation usually occurs when no internal client has recently queried that domain, so the DNS server has no cached entry for it.

Option A is incorrect because a cached record would return a valid answer section.

Option B is incorrect because NOERROR explicitly means the DNS query was processed successfully.

Option D is incorrect because an expired or non-existent domain would typically return NXDOMAIN, not NOERROR.

CEH materials highlight that attackers use DNS cache snooping to infer user behavior, internal browsing habits, and potential target systems within an organization—making option C the correct conclusion.

Question #:267 - [Wireless Network Hacking]

A multinational organization is implementing a security upgrade for its corporate wireless infrastructure. The current WPA2-Personal configuration relies on a shared passphrase, which the IT team finds difficult to rotate and manage securely across hundreds of employee devices. To enhance security and scalability, the organization decides to migrate to WPA2-Enterprise. The new setup must allow for centralized control of user authentication, support certificate-based identity verification, and ensure that each authenticated client is assigned a unique session encryption key to prevent key reuse and limit the blast radius of potential breaches.

Which component is essential for enabling this centralized, certificate-based authentication with unique key generation per session in a WPA2-Enterprise environment?

- A. Opportunistic Wireless Encryption (OWE)
- B. Pre-Shared Key (PSK)
- C. Temporal Key Integrity Protocol (TKIP)
- D. RADIUS with Extensible Authentication Protocol (EAP)

Answer: D

Explanation

CEH v13 explains that WPA2-Enterprise replaces the static, shared password model of WPA2-Personal with a centralized authentication system that relies on the 802.1X framework. The essential component of this architecture is RADIUS integrated with EAP, which manages user authentication, device identity verification, and dynamic session key generation. RADIUS acts as the backend authentication server, while EAP provides a flexible authentication framework supporting certificates, smartcards, or credentials. This combination allows organizations to enforce per-user access control policies, revoke individual users without changing network-wide passwords, and generate unique Pairwise Master Keys (PMKs) for every authenticated session. CEH highlights that one of the major advantages of WPA2-Enterprise is its ability to produce unique encryption keys for each client, preventing key reuse and mitigating lateral movement if one device is compromised. Certificate-based EAP types such as EAP-TLS introduce mutual authentication, ensuring both client and server validate each other's identity before allowing network access. This significantly increases security posture compared to PSK networks, which cannot scale securely for large enterprise deployments.

Question #:268 - [Cloud Computing]

Sarah, a cybersecurity analyst at a US-based e-commerce company in New York, is tasked with evaluating the company's transition to a cloud-based infrastructure to support its growing online platform. The company aims to optimize resource allocation to handle fluctuating customer demand during peak shopping seasons, such as Black Friday. Sarah must recommend a key characteristic of cloud computing that ensures resources are efficiently shared across multiple users while maintaining scalability.

Which cloud computing characteristic should Sarah recommend ensuring efficient resource sharing and scalability for the e-commerce platform?

- A. Measured service
- B. Broad network access
- C. Resource pooling
- D. On-demand self-service

Answer: C

Explanation

In Certified Ethical Hacker cloud computing coverage, the essential characteristics of cloud services align with the widely adopted NIST cloud model. The requirement in this scenario is twofold: efficient sharing of resources across multiple users and the ability to scale to meet spikes in demand such as Black Friday traffic. The cloud characteristic that directly addresses efficient sharing is resource pooling. Resource pooling means the cloud provider aggregates compute, storage, memory, and network resources into a shared pool that serves multiple customers using a multi-tenant model. Resources are dynamically assigned and reassigned according to consumer demand, which enables rapid scaling without requiring the organization to purchase and install new physical infrastructure for each surge.

This matches the scenario's emphasis on optimizing resource allocation and ensuring scalability. With resource pooling, the platform can draw from shared infrastructure capacity when demand rises and release it

when demand drops, improving efficiency and cost effectiveness. In CEH terms, this also influences security considerations such as tenant isolation, hypervisor security, and access control, because multiple customers may rely on the same underlying physical hardware while remaining logically separated.

The other options are not the best match for “efficiently shared across multiple users.” Measured service focuses on metering and pay-as-you-go billing. Broad network access describes availability over networks and standard client platforms. On-demand self-service refers to a consumer’s ability to provision resources automatically without human interaction from the provider. Those are important cloud traits, but the one that specifically enables shared infrastructure and elastic allocation is resource pooling.

Question #:269 - [Web Application Hacking]

As a network administrator, you explain to your team that a recent DDoS attack targeted the application layer of your company’s web server. Which type of DDoS attack was most likely used?

- A. HTTP flood attack
- B. UDP flood attack
- C. ICMP flood attack
- D. SYN flood attack

Answer: A

Explanation

According to the CEH Denial-of-Service (DoS/DDoS) module, application-layer DDoS attacks specifically target services such as HTTP, HTTPS, DNS, or APIs by sending requests that appear legitimate but overwhelm server resources.

An HTTP flood attack sends a massive number of HTTP GET or POST requests, consuming CPU, memory, and application threads. CEH highlights that these attacks are particularly dangerous because they:

Mimic normal user behavior

Are difficult to distinguish from legitimate traffic

Bypass traditional network-layer defenses

Option A is correct.

Options B, C, and D operate primarily at the network or transport layers, not the application layer.

CEH stresses that HTTP floods are among the most challenging DDoS attacks to mitigate due to their stealthy nature.

Question #:270 - [Reconnaissance Techniques]

During enumeration, a tool sends requests to UDP port 161 and retrieves a large list of installed software due to a publicly known community string. What enabled this technique to work so effectively?

- A. Unencrypted FTP services storing software data
- B. The SNMP agent allowed anonymous bulk data queries due to default settings
- C. Remote access to encrypted Windows registry keys
- D. SNMP trap messages logged in plain text

Answer: B

Explanation

This scenario describes SNMP Enumeration, a technique covered under CEH v13 Reconnaissance and Enumeration. Simple Network Management Protocol (SNMP) operates over UDP port 161 and is widely used for monitoring and managing network devices. A common and critical weakness arises when organizations leave default or publicly known community strings such as public (read-only) or private (read-write) unchanged.

CEH v13 explains that when an SNMP agent is configured with default community strings, it allows unauthenticated or weakly authenticated queries, enabling attackers to retrieve extensive system information. This includes installed software, running processes, system descriptions, network interfaces, and routing tables. The ability to perform bulk data queries using SNMP GET and WALK commands makes enumeration highly effective and fast.

Option B correctly identifies the root cause: misconfigured SNMP agents permitting anonymous or default access. The other options are incorrect because SNMP does not rely on FTP, registry access, or trap logging for enumeration. Traps (Option D) are unsolicited notifications sent to managers and are not used for querying system details.

CEH v13 strongly recommends disabling SNMP when not required, changing default community strings, restricting SNMP access via ACLs, and using SNMPv3, which supports authentication and encryption. Therefore, Option B is the correct and CEH-aligned answer.

Question #:271 - [Malware Threats]

During a covert assessment at a logistics company in Dallas, penetration tester Emily delivers a disguised attachment to test employee awareness. When a staff member opens the file, normal content appears, but behind the scenes the attacker quietly gains full access to the workstation. Over the following week, Emily monitors emails, keystrokes, and local files without alerting the user, confirming long-term stealthy control of the machine.

Which type of malware is most likely responsible for this activity?

- A. Remote Access Trojan (RAT)
- B. Botnet

- C. Adware
- D. Spyware

Answer: A

Explanation

The described activity is most consistent with a Remote Access Trojan (RAT). A RAT is designed to provide an attacker with remote, covert, and persistent control over a compromised system. The scenario explicitly states that after the attachment is opened, the attacker gains “full access to the workstation” and then monitors emails, keystrokes, and local files over an extended period without alerting the user. That combination—remote control plus long-term stealthy monitoring—fits a RAT’s typical capabilities, which often include keylogging, file browsing/exfiltration, screen capture, command execution, and maintaining persistence.

Although spyware can also monitor keystrokes and user activity, spyware is typically described as focusing on surveillance and data collection rather than providing broad interactive remote administration. The scenario emphasizes “full access” and ongoing control, which is more characteristic of a RAT than spyware alone. In many real-world cases, RATs include spyware-like features; however, when the question asks which malware type best matches full remote control and stealth monitoring, RAT is the strongest match.

Why the other options are less suitable:

Botnet (B) refers to a network of infected systems (bots) controlled as a group, often for DDoS, spam, or distributed operations. The scenario focuses on a single workstation being remotely controlled and monitored.

Adware (C) focuses on delivering advertisements and tracking for marketing purposes; it does not align with covert full access and credential monitoring.

Spyware (D) overlaps on surveillance, but it does not inherently imply comprehensive remote administration and control the way a RAT does.

Therefore, the most likely malware type is A. Remote Access Trojan (RAT).

Question #:272 - [Web Application Hacking]

Which method best bypasses client-side controls without triggering server-side alarms?

- A. Disable JavaScript in the browser
- B. Intercept and modify requests using a proxy tool
- C. Inject malicious JavaScript into the login form
- D. Reverse-engineer the encryption algorithm

Answer: B

Explanation

Client-side controls, such as JavaScript validation and CAPTCHA enforcement, are explicitly described in CEH v13 as inherently untrustworthy, since they run on the user's device. The most effective way to bypass them is by intercepting and modifying HTTP requests after client-side validation but before server-side processing.

Using a proxy tool (such as Burp Suite) allows the tester to manipulate parameters invisibly, without disabling JavaScript or injecting code that could raise alarms. This makes Option B the most stealthy and effective method.

Disabling JavaScript (Option A) is noisy and easily detected. Injecting JavaScript (Option C) may trigger client-side protections. Reverse-engineering encryption (Option D) is complex and unnecessary.

CEH v13 emphasizes proxy-based manipulation as the preferred technique for bypassing client-side security mechanisms. Therefore, Option B is correct.

Question #:273 - [Social Engineering]

Which scenario best describes a tailgating attack?

- A. Following an employee through a secured door
- B. Phishing email requesting credentials
- C. Phone-based impersonation
- D. Leaving a malicious USB device

Answer: A

Explanation

Tailgating, as defined in CEH v13 Social Engineering, is a physical social engineering attack where an unauthorized individual gains access by following an authorized person into a restricted area.

The attacker exploits human courtesy rather than technical vulnerabilities. Options B, C, and D describe phishing, pretexting, and baiting respectively.

Thus, option A is the correct representation of tailgating.

Question #:274 - [Mobile Platform, IoT, and OT Hacking]

In the neon-lit sprawl of Las Vegas, Nevada, a luxury hotel's smart room control system suffered a breach, allowing an intruder to manipulate guest room settings. The incident investigation revealed that the IoT devices lacked any mechanism to verify the integrity or authenticity of software prior to execution, allowing tampered instructions to run unchecked. As Emna Ruza, a cybersecurity consultant brought in to assess the breach, you recommend a solution that ensures only authorized, validated code is executed on the devices.

Which secure development practice are you advising the hotel to implement?

- A. Allow code signing
- B. Ensure secure boot
- C. Secure firmware or software updates
- D. Utilize secure communication protocols

Answer: A

Explanation

The core weakness described is that the IoT devices “lack any mechanism to verify the integrity or authenticity of software prior to execution,” which directly maps to the need for code signing. In CEH-aligned IoT security guidance, code signing ensures that firmware and software images are cryptographically signed by a trusted authority and verified on the device before they are installed or executed. This verification confirms two critical properties: integrity, meaning the code has not been altered or tampered with, and authenticity, meaning the code genuinely originated from an authorized publisher. If an attacker attempts to introduce modified binaries or malicious instructions, signature verification fails and the device can reject execution, preventing unauthorized code from running.

While secure boot is closely related, it is specifically a boot-time chain-of-trust mechanism that verifies the bootloader and early-stage firmware during startup. The question, however, emphasizes a general lack of verification “prior to execution,” which is broader than boot only and is most directly addressed by code signing as a secure development and release practice. Secure firmware or software updates is also important, but secure updates typically rely on code signing as the fundamental control that makes updates trustworthy. Secure communication protocols protect data in transit, but they do not stop tampered code already on the device from executing.

Therefore, the most appropriate secure development practice to ensure only authorized, validated code runs on the devices is to implement code signing with mandatory signature verification.

Question #:275 - [Security Operations and Incident Response]

At Norwest Freight Services, a rotating audit team is asked to evaluate host exposure across multiple departments following a suspected misconfiguration incident. Simon, a junior analyst working from a trusted subnet, initiates a network-wide scan using the default configuration profile of his assessment tool. The tool completes quickly but returns only partial insights such as open service ports and version banners while deeper registry settings, user policies, and missing patches remain unreported. Midway through the report review, Simon notices that system login prompts were never triggered during scanning, and no credential failures were logged in the SIEM.

Which type of vulnerability scan BEST explains the behavior observed in Simon’s assessment?

- A. Unauthenticated Scanning
- B. Authenticated Scanning
- C. Internal Scan

D. Credentialed Scanning

Answer: A

Explanation

The behavior described is most consistent with an unauthenticated scan. In CEH-aligned vulnerability assessment methodology, unauthenticated scanning evaluates systems from the perspective of an external or non-privileged entity. The scanner can typically identify network-reachable services, open ports, service banners, protocol fingerprints, and sometimes known vulnerabilities inferred from versions or exposed configurations. However, it cannot reliably inspect host-internal posture such as registry settings, local security policies, installed patch levels, missing hotfixes, detailed configuration baselines, or user and group policy settings because those require authenticated access to query the operating system and installed software inventory directly.

The prompt explicitly states that the results were limited to “open service ports and version banners” and that “deeper registry settings, user policies, and missing patches remain unreported.” That limitation is a hallmark of unauthenticated scanning. The additional clue that “system login prompts were never triggered” and “no credential failures were logged in the SIEM” further confirms that the scanner never attempted to authenticate to endpoints using accounts, SSH/WinRM/WMI, SMB, or agent-based credential checks. If the scan were authenticated or credentialed, you would expect authentication attempts, potential login prompts on some services, and often audit logs or SIEM events reflecting successful or failed logons.

Option C, internal scan, only describes where the scan originates, not whether credentials were used. Options B and D imply authentication and host-level interrogation, which contradicts the observed lack of credential activity and missing patch/policy visibility. Therefore, unauthenticated scanning best explains the outcome.

Question #:276 - [Web Application Hacking]

You are investigating unauthorized access to a web application using token-based authentication. Tokens expire after 30 minutes. Server logs show multiple failed login attempts using expired tokens within a short window, followed by successful access with a valid token. What is the most likely attack scenario?

- A. The attacker captured a valid token before expiration and reused it
- B. The attacker brute-forced the token generation algorithm
- C. The attacker exploited a race condition allowing expired tokens to be validated
- D. The attacker performed a token replay attack that confused the server

Answer: C

Explanation

The CEH Web Application Security module explains that race conditions occur when systems improperly handle simultaneous requests, leading to unexpected behavior. In token-based authentication systems, poor synchronization between token expiration checks and validation logic can allow attackers to exploit timing gaps.

The observed pattern—failed attempts with expired tokens followed by successful access—suggests the attacker exploited a race condition where the application inconsistently validated token state.

Option C is correct.

Option A would not involve expired tokens.

Option B is highly impractical given secure token entropy.

Option D typically succeeds without repeated failures.

CEH highlights race conditions as subtle but dangerous logic flaws.

Question #:277 - [System Hacking Phases]

A penetration tester identifies malware on a system that hides its presence and gives an attacker access to administrative functions without being detected. What type of malware is this?

- A. Virus
- B. Keylogger
- C. Ransomware
- D. Rootkit

Answer: D

Explanation

CEH courseware describes rootkits as specialized malware designed to conceal their presence while providing persistent, unauthorized access to system-level functions. Rootkits typically modify low-level components of the operating system—such as kernel modules, drivers, or system processes—to hide files, processes, registry keys, and network connections. Their primary purpose is to grant attackers administrative privileges without triggering alerts, making them extremely stealthy and dangerous. CEH emphasizes that rootkits often accompany other malware to maintain long-term control after initial compromise. In contrast, viruses replicate by attaching to files, keyloggers record keystrokes but do not hide system-level access, and ransomware encrypts data rather than conceals operations. The defining characteristics in this scenario—cloaking activity, providing admin-level control, persisting undetected—are directly aligned with rootkit behavior as described in CEH training material.

Question #:278 - [Reconnaissance Techniques]

Maria is conducting passive reconnaissance on a competitor without interacting with their systems. Which method would be least appropriate and potentially risky?

- A. Using the Wayback Machine
- B. Running an intensive port scan on public IPs

- C. Reviewing forums and social media
- D. Examining patent databases and public records

Answer: B

Explanation

CEH v13 defines passive reconnaissance as information gathering without directly interacting with the target's systems. Activities such as reviewing archived websites, social media, forums, and public records are all passive and legal.

Running an intensive port scan, however, is an active reconnaissance technique. According to CEH v13, port scanning directly interacts with target systems and can trigger IDS/IPS alerts, logs, and even legal consequences if done without authorization.

Therefore, option B violates the principles of passive reconnaissance and is the riskiest choice.

Question #279 - [Malware Threats]

A penetration tester finds malware that spreads across a network without user interaction, replicating itself from one machine to another. What type of malware is this?

- A. Keylogger
- B. Ransomware
- C. Virus
- D. Worm

Answer: D

Explanation

Comprehensive Explanation from CEH v13 Courseware:

CEH v13 describes worms as standalone malicious programs capable of self-replication without requiring user assistance. Unlike viruses, which need a host file and are triggered typically by user actions, worms propagate autonomously by scanning networks, exploiting vulnerabilities, or copying themselves to accessible machines. Worms are known for causing rapid, widespread damage by consuming bandwidth, degrading system performance, and creating backdoors for attackers. Classic examples such as Conficker, WannaCry, and SQL Slammer reinforce the destructive potential of automated propagation. CEH stresses that worms often use network shares, open ports, or unpatched vulnerabilities to move laterally. In contrast, keyloggers harvest keystrokes, ransomware encrypts data and demands payment, and viruses require user involvement to spread. The behavior in the scenario—automatic replication across the network—is the defining characteristic of worm activity according to CEH's malware taxonomy.

Question #:280 - [System Hacking Phases]

A penetration tester identifies malware that monitors the activities of a user and secretly collects personal information, such as login credentials and browsing habits. What type of malware is this?

- A. Worm
- B. Rootkit
- C. Spyware
- D. Ransomware

Answer: C

Explanation

CEH defines spyware as malware designed to covertly observe user behavior and transmit sensitive information to attackers without the victim's knowledge. Spyware commonly records keystrokes, browser activity, form submissions, application usage, and other personally identifiable information. CEH highlights that spyware often operates silently and may disguise itself as legitimate software, making detection difficult. Unlike rootkits—which hide processes and files—or worms that self-replicate, spyware focuses exclusively on monitoring and data exfiltration. It is frequently installed through phishing, drive-by downloads, browser vulnerabilities, or malicious installers. Spyware can serve as a stepping stone for further system compromise by providing attackers with credentials for privilege escalation, lateral movement, or financial theft. CEH emphasizes the need for endpoint hardening, updated anti-malware engines, and behavioral analysis tools to detect such stealthy monitoring programs.

Question #:281 - [Mobile Platform and IoT Hacking]

At Apex Financial Services in Houston, Texas, ethical hacker Javier Ruiz evaluates mobile security practices under the company's BYOD policy. He demonstrates that employees often install applications that request access to contact lists, cameras, and messaging services, even though these functions are unrelated to the apps' intended purpose. This behavior allows a malicious program to harvest sensitive corporate information.

Which security guideline would most directly prevent this issue?

- A. Use encryption mechanisms to store data
- B. Enforce automatic device locking or implement biometric authentication
- C. Review permissions requested by apps before installing them
- D. Set passwords for apps to restrict others from accessing them

Answer: C

Explanation

The issue described is excessive or inappropriate application permission granting in a BYOD environment. Employees install apps that request access to sensitive device resources—contacts, camera, messaging—despite those permissions not being necessary for the app’s stated purpose. This creates a risk of data harvesting and corporate information leakage if a malicious or overly intrusive app is installed. The most direct guideline to prevent this behavior is to review the permissions requested by apps before installing them.

Mobile operating systems rely heavily on permission models to control access to sensitive data and device capabilities. When users approve broad permissions without scrutiny, they effectively authorize the app to collect and transmit sensitive information. Enforcing a culture and policy of checking permissions (and denying or uninstalling apps that request unnecessary access) directly addresses the root cause in the scenario: user consent enabling excessive privilege at the app level. In a corporate BYOD program, this guideline is often paired with mobile security controls such as enterprise app stores, allowlists/denylists, MDM/MAM policies, and user awareness training, but the question asks for the most direct preventive guideline.

Why the other options are less direct:

Encryption at rest (A) helps protect stored data if the device is lost or compromised, but it does not stop an authorized app from accessing data via granted permissions.

Automatic locking/biometrics (B) reduces unauthorized physical access, but it does not constrain what a permitted app can access while the device is in use.

App passwords (D) can help restrict casual access to an app, but they do not solve the problem of an app legitimately being granted invasive permissions.

Therefore, the best answer is C. Review permissions requested by apps before installing them.

Question #:282 - [Mobile Platform, IoT, and OT Hacking]

A BLE attack captured LL_ENC_REQ and LL_ENC_RSP packets but not the LTK. What is the next step?

- A. Decrypt pcap using -o option
- B. Attack cannot continue without LTK
- C. Use hcitool inq
- D. Use Btlejacking

Answer: D

Explanation

In CEH v13 Mobile, IoT, and OT Hacking, Bluetooth Low Energy (BLE) attacks often involve capturing pairing exchanges. If the Long-Term Key (LTK) is not captured, decryption is not immediately possible.

CEH v13 explains that in such cases, attackers may attempt Btlejacking, which hijacks an existing BLE connection rather than decrypting it. This allows command injection and data manipulation without needing the LTK.

Options A and B are incorrect because decryption is not the only attack path. hctool is for discovery, not exploitation. Therefore, Option D is correct.

Question #:283 - [Network and Perimeter Hacking]

As a security analyst, you are testing a company's network for potential vulnerabilities. You suspect an attacker may be using MAC flooding to compromise network switches and sniff traffic. Which of the following indicators would most likely confirm your suspicion?

- A. An increased number of ARP requests in network traffic.
- B. Multiple MAC addresses assigned to a single IP address.
- C. Multiple IP addresses assigned to a single MAC address.
- D. Numerous MAC addresses associated with a single switch port.

Answer: D

Explanation

The Certified Ethical Hacker (CEH) Network and Perimeter Hacking module describes MAC flooding as an attack targeting switch CAM (Content Addressable Memory) tables. The attacker overwhelms the switch by sending frames with spoofed MAC addresses, forcing the switch to broadcast traffic like a hub.

Option D is the correct indicator because MAC flooding results in many different MAC addresses being learned on a single switch port, which is abnormal behavior. CEH documentation identifies this as the primary forensic sign of a MAC flooding attack.

Option A relates more closely to ARP poisoning rather than MAC flooding.

Option B can occur in network misconfigurations but is not a primary MAC flooding indicator.

Option C is common in NAT environments and is not malicious by itself.

CEH emphasizes monitoring CAM table behavior and port security violations to detect MAC flooding attacks effectively.

Question #:284 - [Cryptography]

Sarah, an ethical hacker at a San Francisco-based financial firm, is testing the security of their customer database after a recent data exposure incident. Her analysis reveals that the sensitive client information is safeguarded using a symmetric encryption algorithm. She observes that the algorithm processes data in 64-bit blocks and supports a variable key size from 32 to 448 bits. During her penetration test, Sarah intercepts a ciphertext transmission and notes that the encryption was developed as a replacement for DES, an older algorithm. She aims to determine if the algorithm's flexible key size could be susceptible to brute-force attacks. The algorithm is also noted for its use in secure storage, a critical application for the firm's data protection.

Which symmetric encryption algorithm should Sarah identify as the one used by the firm?

- A. RC4
- B. Twofish
- C. AES
- D. Blowfish

Answer: D

Explanation

Blowfish is the only option that matches all the technical characteristics described. In CEH cryptography concepts, symmetric algorithms are commonly distinguished by their structure (block cipher versus stream cipher), block size, and supported key lengths. The question states the algorithm encrypts data in 64-bit blocks and supports a variable key size ranging from 32 bits up to 448 bits, and it was introduced as a replacement for DES. Blowfish fits precisely: it is a symmetric block cipher with a 64-bit block size and a configurable key length from 32 to 448 bits, designed to be fast in software and positioned historically as an alternative to older ciphers such as DES.

The other choices do not align with these identifying properties. RC4 is a stream cipher and does not operate on fixed-size blocks, so it cannot match the 64-bit block requirement. AES is a block cipher but uses a 128-bit block size with fixed key sizes of 128, 192, or 256 bits, not 32 to 448 bits. Twofish, while related historically as a successor-era design, also uses a 128-bit block size and fixed key sizes up to 256 bits, so it does not match either.

From a CEH perspective, the mention of variable key sizes also hints at risk evaluation: shorter keys in any cipher can be brute-forced, so secure deployments require strong key length selection and proper key management. Additionally, Blowfish's 64-bit block size can be a concern in large-volume encryption scenarios due to block collision risks, which is why modern systems often prefer 128-bit block ciphers for new designs.

Question #:285 - [Reconnaissance Techniques]

A cybersecurity analyst monitors competitors' web content for changes indicating strategic shifts. Which missing component is most crucial for effective passive surveillance?

- A. Participating in competitors' blogs and forums
- B. Setting up Google Alerts for competitor names and keywords
- C. Using a VPN to hide the analyst's IP address
- D. Hiring a third party to hack competitor databases

Answer: B

Explanation

The CEH Footprinting and Reconnaissance module highlights Google Alerts as a key passive reconnaissance tool for monitoring changes in web content, news, and online mentions.

Option B is correct.

Option A is active engagement.

Option C aids anonymity but not monitoring.

Option D is illegal and unethical.

CEH strongly promotes automated alerting for competitive intelligence.

Question #:286 - [Social Engineering]

You are part of the red team assigned to evaluate the physical and social vulnerabilities of a government contractor's office located in a metropolitan business hub. During your pretexting phase, you decide to simulate the role of a third-party IT technician. Upon arrival, the receptionist allows you entry without verifying credentials, assuming you're there for scheduled printer maintenance. While moving through the workspace, you casually observe open terminals, unattended printouts, and discarded sticky notes at workstations. You later report several user credentials and partial access details acquired during this visit.

Which social engineering technique does this scenario best illustrate?

- A. Shoulder Surfing
- B. Eavesdropping
- C. Impersonation
- D. Dumpster Diving

Answer: C

Explanation

This scenario best illustrates impersonation, which is a core social engineering technique emphasized in CEH under pretexting and physical security testing. Impersonation occurs when an attacker assumes a believable identity, such as an IT technician, vendor, maintenance worker, or delivery person, to gain trust and bypass access controls. In the prompt, the red team member adopts a third-party IT technician role and is granted entry because the receptionist assumes the visit is legitimate and does not verify credentials. That is the defining moment of impersonation: exploiting human trust and procedural gaps to obtain unauthorized physical access.

While the attacker later observes open terminals, unattended printouts, and sticky notes, those observations are opportunistic data collection that becomes possible only after successful impersonation. Shoulder surfing is specifically observing a user entering credentials or viewing a screen while standing nearby, typically during active use. Eavesdropping focuses on capturing spoken or transmitted information, such as listening to

conversations or intercepting communications. Dumpster diving involves retrieving sensitive information from trash or discarded materials in waste bins, not simply seeing sticky notes left on desks.

CEH guidance highlights that impersonation often succeeds when organizations lack visitor verification, badge enforcement, escort policies, and security awareness training. Controls include validating work orders, requiring government-issued ID, issuing visitor badges, escorting visitors, enforcing clean desk practices, locking workstations, and secure printing to prevent exposure of credentials and sensitive data.

Question #:287 - [Mobile Platform, IoT, and OT Hacking]

A large chemical plant uses operational technology (OT) networks to control its industrial processes. Recently, abnormal behavior is observed from PLCs, suggesting a stealthy compromise via malicious firmware. Which action should the team take FIRST to verify and neutralize the issue?

- A. Immediately isolate suspicious devices
- B. Perform detailed inspections of device software for unauthorized modifications
- C. Implement enhanced IDS rules
- D. Restrict remote administrative access

Answer: B

Explanation

In CEH v13 Mobile, IoT, and OT Hacking, firmware-level attacks on Programmable Logic Controllers (PLCs) are categorized as high-impact and stealth-oriented threats, often designed to evade traditional network-based defenses. Malicious firmware compromises the integrity of the device itself, allowing attackers persistent and covert control over industrial processes.

The first and most critical step is to verify the integrity of the firmware and software running on the PLCs. CEH v13 emphasizes that before containment or mitigation actions are applied, accurate identification and confirmation of compromise must occur. Firmware inspection enables analysts to detect unauthorized code injections, modified logic blocks, altered checksums, or tampered boot loaders—hallmarks of OT malware such as Stuxnet-like attacks.

Immediate isolation (Option A) may be necessary later, but premature isolation can disrupt industrial operations and destroy volatile forensic evidence. IDS enhancements (Option C) focus on traffic patterns and are ineffective against firmware-resident malware. Restricting remote access (Option D) is preventative but does not validate or remove an existing firmware compromise.

CEH v13 stresses that OT environments require forensic verification at the device level, especially when abnormal behavior originates from controllers themselves. Firmware validation using vendor-approved tools and hash verification is the correct first step to confirm compromise and plan remediation without risking operational safety.

Question #:288 - [Web Application Hacking]

A penetration tester is evaluating a secure web application that uses HTTPS, secure cookie flags, and regenerates session IDs only during specific user actions. To hijack a legitimate user's session without triggering security alerts, which advanced session hijacking technique should the tester employ?

- A. Perform a man-in-the-middle attack by exploiting certificate vulnerabilities
- B. Use a session fixation attack by setting a known session ID before the user logs in
- C. Conduct a session token prediction attack by analyzing session ID patterns
- D. Implement a Cross-Site Scripting (XSS) attack to steal session tokens

Answer: C

Explanation

CEH v13 emphasizes that well-secured applications use HTTPS, secure cookies, and session regeneration to defend against common session hijacking techniques. In such hardened environments, traditional attacks like session fixation or simple XSS-based token theft often fail because session IDs change at login and secure flags prevent exposure. The remaining viable approach is session token prediction, an advanced attack that analyzes statistical patterns, entropy weaknesses, or timing issues in session ID generation algorithms. CEH discusses that weak pseudorandom number generators (PRNGs) or predictable sequences can allow attackers to compute a valid session ID without intercepting traffic. This method bypasses cookie security and does not rely on manipulating user input, making it suitable for environments with strong defenses. MITM attacks (Option A) require certificate compromise, which is impractical. Session fixation (Option B) fails because the application regenerates tokens. XSS (Option D) is ineffective when secure flags prevent JavaScript access to cookies. Thus, token prediction is the correct answer.

Question #:289 - [Cryptography]

An attacker examines differences in ciphertext outputs resulting from small changes in the input to deduce key patterns in a symmetric algorithm. What method is being employed?

- A. Differential cryptanalysis on input-output differences
- B. Timing attack to infer key bits based on processing time
- C. Brute-force attack to try every possible key
- D. Chosen-ciphertext attack to decrypt arbitrary ciphertexts

Answer: A

Explanation

This scenario describes Differential Cryptanalysis, a powerful cryptanalytic technique covered in CEH v13 Cryptography. Differential cryptanalysis focuses on analyzing how small changes in plaintext input affect the resulting ciphertext output, with the goal of uncovering patterns related to the secret encryption key.

CEH v13 explains that symmetric algorithms rely on complex transformations—such as substitution and permutation—to obscure relationships between plaintext and ciphertext. However, in some algorithms, predictable differences may propagate through encryption rounds in a way that reveals statistical biases. By carefully selecting pairs of plaintext inputs with controlled differences and comparing the resulting ciphertexts, attackers can infer information about intermediate states and eventually the encryption key.

This method does not attempt every possible key (brute force), nor does it rely on execution timing or system performance metrics (timing attacks). It also differs from chosen-ciphertext attacks, which involve submitting chosen ciphertexts for decryption rather than observing encryption behavior.

Differential cryptanalysis was instrumental in breaking early block ciphers and is a key reason why modern algorithms like AES are designed with resistance to differential attacks. CEH v13 emphasizes that understanding this attack is critical for evaluating the strength of symmetric encryption algorithms and their internal structure.

Therefore, Option A accurately describes the technique being employed.

Question #:290 - [Mobile Platform and IoT Hacking]

During a security evaluation of a smart agriculture setup, an analyst investigates a cloud-managed irrigation controller. The device is found to transmit operational commands and receive firmware updates over unencrypted HTTP. Additionally, it lacks mechanisms to verify the integrity or authenticity of those updates. This vulnerability could allow an adversary to intercept communications or inject malicious firmware, leading to unauthorized control over the device's behavior or denial of essential functionality. Which IoT threat category does this situation best illustrate?

- A. Insecure default settings
- B. Insecure ecosystem interfaces
- C. Insufficient privacy protection
- D. Insecure network services

Answer: D

Explanation

CEH IoT security modules describe insecure network services as vulnerabilities arising when IoT devices communicate over unencrypted channels, use unauthenticated update mechanisms, or expose services that fail to validate data integrity. When operational commands and firmware updates are transmitted over HTTP without cryptographic safeguards, attackers can intercept, replay, or modify the data stream. Firmware integrity verification is a critical component of secure device lifecycle management. Without it, adversaries can perform firmware injection, allowing them remote control, persistent compromise, or sabotage of device functionality. This aligns directly with insecure network services, which CEH defines as improperly protected communication mechanisms and service interactions within IoT ecosystems. Insecure ecosystem interfaces generally relate to cloud APIs and web dashboards, insecure default settings involve weak credentials or factory configurations, and insufficient privacy protection relates to data confidentiality rather than command manipulation. The described scenario most clearly fits insecure network services.

Question #:291 - [Web Application Hacking]

In the bustling tech hub of Boston, Massachusetts, ethical hacker Zara Nguyen dives into the digital fortifications of CloudCrafter, a US-based platform hosting web applications for small businesses. Tasked with probing the application's input processing, Zara submits specially crafted inputs to a server administration panel. Her tests uncover a severe vulnerability: the system performs unintended operations at the system level, enabling access to restricted server resources. Further scrutiny reveals the flaw lies in the application's failure to sanitize user input passed to system-level execution, not in altering directory service queries, injecting newline characters, or targeting cloud-specific environments. Dedicated to strengthening the platform, Zara drafts a precise report to guide CloudCrafter's security team toward urgent fixes.

Which injection attack type is Zara most likely exploiting in CloudCrafter's web application?

- A. Shell Injection
- B. CRLF Injection
- C. LDAP Injection
- D. Command Injection

Answer: D**Explanation**

The scenario describes user input being passed into system-level execution and causing "unintended operations at the system level," which is the defining behavior of command injection in CEH web application hacking coverage. Command injection occurs when an application constructs or invokes operating system commands using unsanitized, user-controlled input. By inserting shell metacharacters or command separators such as ;, &&, |, or backticks, an attacker can cause the server to execute additional commands beyond what the developer intended. The impact often includes reading sensitive files, listing directories, creating users, downloading malware, pivoting, or otherwise interacting with restricted server resources, matching the prompt's "access to restricted server resources."

The question also rules out other injection families. LDAP injection targets directory service queries and manipulates LDAP filters, which the prompt explicitly excludes. CRLF injection involves inserting carriage return and line feed characters to manipulate HTTP headers or split responses; it does not primarily produce OS-level execution. "Shell Injection" is sometimes used informally to describe the same concept, but in CEH-style terminology and exam question patterns, the standard label for injecting into OS command execution is Command Injection, making option D the best and most precise answer.

Effective mitigations emphasized in CEH-aligned guidance include avoiding OS command calls where possible, using safe APIs that do not invoke shells, strict allowlisting and canonical validation of input, proper escaping for the target interpreter when needed, running services with least privilege, and applying segmentation and monitoring to limit blast radius.

\

Question #:292 - [Cryptography]

Emma, an ethical hacker at a Chicago-based healthcare provider, is performing a penetration test on the organization's patient record system following a recent data breach. During her investigation, she discovers that attackers gained access to a large volume of encrypted patient records but had no knowledge of the original data or encryption keys. Emma observes that the system uses a block cipher and suspects the attackers may have applied a cryptanalytic method that examines encrypted outputs in bulk to detect structural or statistical patterns in the encrypted data.

Which cryptanalysis technique should Emma investigate to assess the system's vulnerability in this scenario?

- A. Chosen-plaintext attack
- B. Known-plaintext attack
- C. Chosen-ciphertext attack
- D. Ciphertext-only attack

Answer: D

Explanation

The correct answer is D, ciphertext-only attack, because the attackers possess only encrypted data and have neither the encryption key nor any confirmed samples of the original plaintext. In CEH-aligned cryptography concepts, cryptanalytic attacks are categorized by what information and capabilities the attacker has. A ciphertext-only attack is the most constrained model: the attacker attempts to infer the plaintext or key by analyzing ciphertext alone, often leveraging statistical properties, repetitions, formatting assumptions, and structural patterns that may leak information when encryption is misused.

The scenario highlights that the attacker “examines encrypted outputs in bulk” to detect “structural or statistical patterns.” That wording maps directly to ciphertext-only analysis: looking for patterns caused by weak modes of operation, poor IV/nonce handling, deterministic encryption, repeated blocks (common in ECB mode), predictable headers, or consistent record templates. With block ciphers, large datasets increase the chance that repeated plaintext blocks produce repeated ciphertext blocks if the system uses an unsafe mode or reuses IVs, allowing an attacker to correlate records, identify fields, or sometimes recover content when combined with protocol or file-format knowledge.

The other options require more attacker capability than the prompt provides. Known-plaintext attacks require some plaintext-ciphertext pairs. Chosen-plaintext attacks require the ability to encrypt attacker-chosen inputs. Chosen-ciphertext attacks require a decryption oracle or the ability to submit ciphertext for decryption. Since none of those are present here, Emma should evaluate ciphertext-only exposure and specifically validate the cipher mode, IV/nonce uniqueness, padding behavior, and whether encryption is semantically secure for stored patient records.

yes do please

Question #:293 - [Information Security and Ethical Hacking Overview]

A penetration tester evaluates a company's susceptibility to advanced social engineering attacks targeting its executive team. Using detailed knowledge of recent financial audits and ongoing projects, the tester crafts a highly credible pretext to deceive executives into revealing their network credentials. What is the most effective social engineering technique the tester should employ to obtain the necessary credentials without raising suspicion?

- A. Send a mass phishing email with a link to a fake financial report
- B. Create a convincing fake email from the CFO asking for immediate credential verification
- C. Conduct a phone call posing as an external auditor requesting access to financial systems
- D. Develop a spear-phishing email that references specific financial audit details and requests login confirmation

Answer: D

Explanation

Spear-phishing is a targeted form of phishing that uses personalized and context-rich information to increase credibility. CEH emphasizes that referencing specific internal projects, financial data, or organizational events significantly raises the success rate when attacking high-value targets such as executives. This tailored approach avoids suspicion and exploits trust more effectively than broad or generic phishing attempts.

Question #:294 - [Cloud Computing]

During a routine security audit, administrators discover that cloud storage backups were illegally accessed and modified. Which countermeasure would most directly mitigate such incidents in the future?

- A. Implementing resource auto-scaling
- B. Regularly conducting SQL injection testing
- C. Deploying biometric entry systems
- D. Adopting the 3-2-1 backup model

Answer: D

Explanation

The Certified Ethical Hacker (CEH) Cloud Computing and Data Protection module emphasizes the importance of resilient backup strategies to protect against data tampering, ransomware, and unauthorized modification.

The 3-2-1 backup model is a widely recommended best practice referenced in CEH materials. It requires maintaining:

3 copies of data

Stored on 2 different media types

With 1 copy stored offsite

This approach ensures that even if cloud backups are compromised or altered, clean and uncompromised versions remain available. CEH documentation highlights this model as a core defense against data integrity attacks in cloud environments.

Option D directly mitigates the risk of backup tampering.

Options A, B, and C address unrelated security concerns and do not protect backup integrity.

Question #:295 - [Network and Perimeter Hacking]

An attacker exploits medical imaging protocols to intercept patient data. Which sniffing technique is most challenging?

- A. MRI firmware interception
- B. Ultrasound malware
- C. Covert channel within administrative messages
- D. Embedding data inside CT scan images

Answer: D

Explanation

This scenario describes steganographic sniffing, a highly sophisticated technique covered in CEH v13 Network Sniffing and Steganography. By embedding sensitive data inside legitimate image files—such as CT scans—attackers can intercept or exfiltrate patient information while avoiding detection.

Option D represents a steganography-based covert channel, which is extremely difficult to identify because:

The file appears legitimate

Standard encryption and IDS tools do not flag it

Medical images naturally contain large data volumes

Options A and B involve malware, which is more detectable. Option C involves text-based covert channels, which are easier to analyze than binary image embedding.

CEH v13 identifies steganography as one of the hardest data-hiding techniques to detect, making Option D correct.

Question #:296 - [Security Operations and Incident Response]

During a quarterly vulnerability management cycle at a multinational logistics firm, Priya's team has already applied patches and fixes to address confirmed vulnerabilities. Now, she directs the analysts to run follow-up scans and review the attack surface to confirm that the applied remedies have effectively eliminated the risks. Only after this step will she prepare a compliance report for the executive board.

Which phase of the Vulnerability-Management Life Cycle is Priya executing?

- A. Monitoring
- B. Verification
- C. Risk Assessment
- D. Remediation

Answer: B

Explanation

Priya is performing Verification because the team has already completed the remediation work (patches and fixes), and is now conducting follow-up scans and attack-surface review to confirm that the applied changes actually resolved the identified vulnerabilities. In a standard vulnerability-management lifecycle, remediation is the phase where vulnerabilities are addressed through actions such as patching, configuration hardening, compensating controls, or removing vulnerable services. Verification comes immediately after remediation to ensure fixes are effective, nothing was missed, and no new issues were introduced.

The scenario's sequencing is the strongest clue: "already applied patches and fixes" means remediation is done; "run follow-up scans...to confirm" indicates validation of remediation outcomes; and "only after this step will she prepare a compliance report" reflects that organizations typically require evidence that remediation is effective before reporting status to leadership or auditors. Verification often includes rescanning the affected assets, checking configuration baselines, validating that vulnerable versions are no longer present, ensuring services are running as intended, and confirming that the original finding cannot be reproduced.

Why the other options do not match:

Remediation (D) would be the patching/fixing activity itself, which has already occurred.

Risk Assessment (C) is the prioritization and impact evaluation stage, typically performed before remediation to decide what to fix first and how urgently.

Monitoring (A) is ongoing observation and continuous assessment (tracking exposure, trends, new vulnerabilities), but Priya's specific task is a post-fix confirmation step, which is verification.

Therefore, the correct phase is B. Verification.

Question #:297 - [Wireless Network Hacking]

Bluetooth devices are suspected of being targeted by a Bluesnarfing attack. What is the most effective countermeasure?

- A. Disable discoverable mode
- B. Update firmware regularly
- C. Increase Bluetooth PIN complexity
- D. Encrypt Bluetooth traffic

Answer: A

Explanation

Bluesnarfing is a Bluetooth attack described in CEH v13 Wireless Network Hacking, where attackers exploit misconfigured Bluetooth devices to access sensitive data such as contacts, messages, and files—often without user interaction.

One of the most critical enablers of Bluesnarfing is Bluetooth discoverable mode. When devices are discoverable, attackers can easily identify them and attempt unauthorized connections or exploit vulnerabilities in Bluetooth services.

Disabling discoverable mode significantly reduces the attack surface by preventing unauthorized devices from locating Bluetooth-enabled systems. CEH v13 explicitly recommends setting Bluetooth devices to non-discoverable mode when not pairing.

While firmware updates (Option B) are important, they do not immediately prevent discoverability-based attacks. Stronger PINs (Option C) help against pairing attacks but do not stop unauthorized queries. Network-level encryption (Option D) is inherent in Bluetooth protocols and does not mitigate discovery abuse.

CEH v13 highlights that visibility control is the most immediate and effective defense against Bluesnarfing. Therefore, Option A is the correct answer.

Question #:298 - [Network and Perimeter Hacking]

During a penetration test at TechTrend Innovations in California, ethical hacker Jake Henderson reviews the company's web server exposure to network-based threats. He finds that the server is running with multiple open services and protocols that are not required for its operation, such as NetBIOS and SMB. Jake explains to the IT team that attackers could exploit these unnecessary services to gain unauthorized access to the server.

Which hardening measure should the IT team implement to mitigate this risk?

- A. Use a dedicated machine as a web server
- B. Conduct risk assessment for patching
- C. Eliminate unnecessary files

D. Block all unnecessary ports, ICMP traffic, and protocols

Answer: D

Explanation

The risk described is increased attack surface caused by unnecessary services and protocols running on a web server—specifically NetBIOS and SMB. The most direct hardening action to mitigate this is to block/disable unnecessary ports and protocols so they are not exposed to the network and cannot be abused by attackers. Option D captures that principle: reduce exposure by closing ports and restricting protocols that are not required for the server's role.

A well-hardened web server should run only the services needed to deliver its intended web functionality (e. g., HTTP/HTTPS and necessary management interfaces under strict control). Services like SMB (commonly TCP 445/139) and NetBIOS (UDP 137/138, TCP 139) are not normally required for public-facing web hosting and are frequent targets for enumeration and exploitation. Leaving such services open can enable attackers to perform credential attacks, exploit legacy vulnerabilities, access shared resources, or pivot further into the environment. By blocking or disabling these ports at the host firewall and/or perimeter firewall, the organization reduces reachable attack paths and limits what an external attacker can interact with.

Why the other options are less direct:

Dedicated machine (A) can help separation of duties, but if unnecessary services still run, the attack surface remains.

Risk assessment for patching (B) is important, but it doesn't immediately remove the exposure created by unneeded services.

Eliminating unnecessary files (C) addresses file-system exposure, not open network services like SMB /NetBIOS.

Because the problem is explicitly about unnecessary open services/protocols, the best mitigation is D. Block all unnecessary ports, ICMP traffic, and protocols (i.e., minimize exposed services).

Question #:299 - [Network and Perimeter Hacking]

In the hushed offices of Pinecrest Solutions in Denver, network security analyst Lisa Nguyen began a covert review of a recent spike in network access issues reported by the sales team. The trouble surfaced during a low-traffic period when agents couldn't reach their CRM system, prompting Lisa to examine the subnet logs. She spotted irregular IP assignment attempts linked to an unfamiliar device. Acting quickly, Lisa entered a series of commands on the Cisco switches and later confirmed that connectivity issues had ceased without any new devices appearing in the logs.

Which command did Lisa most likely use to address the issue?

- A. Switch(config)# ip dhcp snooping vlan 10
- B. Switch(config)# ip arp inspection vlan 10
- C. Switch(config)# ip dhcp snooping

D. Switch(config-if)# switchport port-security

Answer: A

Explanation

The symptoms point to a rogue DHCP scenario, which CEH materials commonly describe as a method attackers use to disrupt networks or perform man-in-the-middle attacks. If an unauthorized device begins answering DHCP requests faster than the legitimate DHCP server, endpoints may receive incorrect IP settings such as a fake default gateway or DNS server. This causes loss of connectivity to internal applications like a CRM system and can silently redirect traffic through an attacker-controlled host. The question explicitly mentions “irregular IP assignment attempts” tied to an unfamiliar device, which aligns strongly with rogue DHCP behavior rather than ARP-only manipulation or simple MAC-limit violations.

DHCP snooping is a Layer 2 security feature on Cisco switches that filters untrusted DHCP messages and allows only authorized DHCP servers on trusted ports. When enabled for the affected VLAN, the switch will drop DHCP offers and acknowledgments arriving on untrusted access ports, stopping the rogue device from leasing addresses. Option A, `ip dhcp snooping vlan 10`, is the command that applies DHCP snooping protection to the specific VLAN experiencing the issue, which matches the “subnet logs” and the localized impact described.

Option B, Dynamic ARP Inspection, primarily mitigates ARP spoofing and relies on DHCP snooping bindings, but it does not directly stop rogue DHCP leasing. Option D, port security, can limit MAC addresses but does not specifically block DHCP server behavior. Option C enables the feature globally but does not target the VLAN; the VLAN-specific activation in A best matches the scenario and the immediate restoration of correct addressing and connectivity.

Question #:300 - [Network and Perimeter Hacking]

During a penetration testing engagement at First Union Bank in Chicago, ethical hacker Rachel Morgan is assigned to assess the internal network for potential sniffing activity that could compromise sensitive customer data. While inspecting traffic in the loan processing department, Rachel observes that a workstation is receiving packets not addressed to it, raising suspicion of a sniffing tool operating in promiscuous mode. To validate her hypothesis, she prepares to conduct an active verification using a classic detection approach.

Which detection technique should Rachel use to confirm the presence of a sniffer in this case?

- A. Sniffer detection using an NSE script to check for promiscuous mode
- B. DNS method by monitoring reverse DNS lookup traffic
- C. ARP method by sending non-broadcast ARP requests
- D. Ping method by sending packets with an incorrect MAC address

Answer: D

Explanation

In CEH network security concepts, a common way to verify whether a host is running a sniffer is to test for promiscuous-mode behavior using an active stimulus and then observing whether the suspected machine reacts to traffic it should normally discard. The “ping method” is a classic approach: the tester sends ICMP Echo Request traffic crafted so the Ethernet frame uses an incorrect destination MAC address, while the IP layer still targets the suspected host’s IP. Under normal NIC operation, frames with a destination MAC that does not match the interface (and is not broadcast/multicast) are dropped at the data-link layer and never reach the IP stack, so the host will not respond.

If the interface is in promiscuous mode, the NIC passes more frames up to the operating system for processing. In some configurations, this can allow the IP stack to see and respond to the ICMP request even though the frame’s MAC destination was wrong. That unexpected reply is used as an indicator that the host may be capturing traffic promiscuously, consistent with sniffer presence.

The other options are less aligned with the “classic active verification” described. Reverse DNS monitoring is an indirect heuristic and not a reliable confirmation of promiscuous mode. An NSE script is tool-specific rather than the classic foundational technique the question emphasizes. ARP-based methods exist for sniffer detection, but the option presented is less directly tied to the well-known ICMP incorrect-MAC confirmation described in CEH materials.

Question #:301 - [Mobile Platform, IoT, and OT Hacking]

At a power distribution facility in Phoenix, Arizona, ethical hacker Sameer Das is performing an OT security assessment. He demonstrates that a programmable controller accepts modifications delivered over the network without checking the origin or cryptographic validity of the package. By uploading altered instructions, he changes how the controller processes commands during operations. Which IoT/OT threat best represents this technique?

- A. Firmware update attack
- B. Forged malicious device
- C. Remote access using backdoor
- D. Exploit kits

Answer: A

Explanation

The correct answer is A. Firmware update attack because the scenario describes an attacker delivering an unauthenticated, non-cryptographically verified update/package to a controller and successfully altering its operational logic. In IoT/OT environments, controllers (PLCs, RTUs, PACs, and embedded industrial devices) often support updating firmware or logic over the network for maintenance. If the device does not verify the source, integrity, and authenticity of update packages—typically through signed firmware, certificates, and secure update channels—an attacker can replace legitimate code with a maliciously modified version.

Sameer’s demonstration maps directly to a firmware/logic update compromise: he uploads “altered instructions” and changes how the controller processes commands during operations. This is exactly the type of risk highlighted in OT security: unauthorized modification of controller logic can cause unsafe states,

disrupt production, damage equipment, or create stealthy manipulation that is difficult to detect. The explicit mention of “without checking the origin or cryptographic validity” indicates missing controls like digital signatures, hash verification, and trusted update mechanisms, which are central to firmware update security.

Why the other options are less accurate: Forged malicious device usually refers to introducing a rogue or cloned device into the environment to impersonate legitimate equipment. Remote access using backdoor implies an existing hidden access mechanism rather than abuse of the update mechanism itself. Exploit kits are typically collections of exploits used to compromise systems, commonly discussed more in endpoint/web contexts; they don't specifically describe the act of pushing an altered firmware/logic package that the controller accepts due to missing validation.

Therefore, the technique is best categorized as a firmware update attack, leveraging weak or absent authenticity/integrity checks on update packages to modify OT controller behavior.

Question #:302 - [Reconnaissance Techniques]

While assessing a web server, a tester sends malformed HTTP requests and compares responses to identify the server type and version. What technique is being employed?

- A. Fingerprinting server identity using banner-grabbing techniques
- B. Sending phishing emails to extract web server login credentials
- C. Conducting session fixation using malformed cookie headers
- D. Injecting scripts into headers for persistent XSS attacks

Answer: A

Explanation

CEH v13 explains that fingerprinting is a core reconnaissance technique used to identify software versions, server types, and configurations by analyzing how systems respond to crafted or abnormal input. When testers send malformed HTTP verbs, unusual headers, or atypical URI structures, the server's specific response codes, banners, and error messages reveal distinctive behavioral patterns. These patterns allow tools like httpprint, Nmap NSE scripts, and custom probes to match the responses to known server profiles. This technique is part of active reconnaissance, enabling attackers to determine vulnerabilities associated with specific versions. Phishing (Option B) is unrelated to protocol analysis. Session fixation (Option C) manipulates session identifiers, not HTTP response patterns. Persistent XSS (Option D) relies on web application vulnerabilities, not server fingerprinting. Thus, the tester is performing HTTP-based server fingerprinting.

Question #:303 - [Web Application Hacking]

A tester evaluates a login form that constructs SQL queries using unsanitized user input. By submitting 1 OR "T"="T"; --, the tester gains unauthorized access to the application. What type of SQL injection has occurred?

- A. Tautology-based SQL injection

- B. Error-based SQL injection
- C. Union-based SQL injection
- D. Time-based blind SQL injection

Answer: A

Explanation

This scenario represents a Tautology-Based SQL Injection, a fundamental SQL injection technique covered under the Web Application Hacking module in the CEH v13 curriculum. The defining characteristic of this attack is the injection of a condition that always evaluates to TRUE, thereby bypassing authentication or authorization controls.

In the given example, the injected input `1 OR 'T'='T'; --` manipulates the logical condition of the SQL query. A typical vulnerable login query may resemble:

```
SELECT * FROM users WHERE user_id = 1 AND password = 'input';
```

When the attacker submits the injected payload, the resulting SQL statement becomes:

```
SELECT * FROM users WHERE user_id = 1 OR 'T'='T'; --;
```

The expression `'T'='T'` is a tautology, meaning it always evaluates to TRUE regardless of context. As a result, the database returns records without properly validating the user's credentials, granting unauthorized access.

According to EC-Council CEH v13, tautology-based SQL injection is classified as a Boolean-based injection technique where attackers exploit improper input validation to alter the logical flow of SQL queries. This attack does not depend on database error messages (as in Error-Based SQL Injection), does not extract data using UNION statements (Union-Based SQL Injection), and does not rely on response delays (Time-Based Blind SQL Injection).

CEH v13 emphasizes that such attacks are especially effective against login forms and authentication mechanisms when developers fail to implement input sanitization, parameterized queries, or prepared statements. This attack is one of the most common and exam-tested SQL injection types because it clearly demonstrates how flawed logic can compromise application security without advanced techniques.

Understanding tautology-based SQL injection is critical for ethical hackers, as it forms the foundation for identifying and mitigating more complex SQL injection variants.

Question #:304 - [Social Engineering]

An attacker impersonates a technician and gains physical access to restricted areas. What tactic is this?

- A. Help desk impersonation
- B. Dumpster diving
- C. Remote tech support scam

D. Physical impersonation (Tailgating/Impersonation)

Answer: D

Explanation

This scenario illustrates physical impersonation, a social engineering tactic discussed in CEH v13 Social Engineering. The attacker exploits trust in appearance and role assumption, dressing as a network technician to gain access without challenge.

Unlike tailgating (which involves following someone), this attack relies on assumed authority and familiarity. CEH v13 categorizes this under impersonation attacks, where attackers pose as employees, contractors, or vendors.

Other options describe different social engineering vectors:

A: Phone-based pretexting

B: Dumpster diving

C: Vishing

Physical impersonation is particularly dangerous because it bypasses technical controls entirely. Option D best matches the scenario.

Question #:305 - [Web Application Hacking]

A penetration tester evaluates a secure web application using HTTPS, secure cookies, and multi-factor authentication. To hijack a legitimate user's session without triggering alerts, which technique should be used?

- A. Exploit a browser zero-day vulnerability to inject malicious scripts
- B. Implement a man-in-the-middle attack by compromising a trusted network device
- C. Perform a Cross-Site Request Forgery (CSRF) attack to manipulate session tokens
- D. Utilize a session token replay attack by capturing encrypted tokens

Answer: C

Explanation

CEH v13 describes Cross-Site Request Forgery (CSRF) as a technique that forces authenticated users to unknowingly execute actions within a web application without their intent. Unlike session hijacking methods that require stealing or replaying session cookies, CSRF exploits the trust relationship that the server has with a user's browser. Even with HTTPS, secure cookies, and MFA, once a user is authenticated, the browser automatically sends session cookies with each request. If the attacker convinces the victim to load a maliciously crafted webpage or URL, the browser sends a forged request to the target application, executing actions under the user's authenticated session. CEH notes that secure cookies and MFA do not stop CSRF

because no credentials are stolen—only forced actions occur. This technique is sophisticated because it leaves minimal traces, avoids direct cookie manipulation, bypasses robust authentication mechanisms, and leverages design weaknesses rather than technical misconfigurations. Protection typically requires anti-CSRF tokens and proper origin validation.

Question #:306 - [Web Application Hacking]

A large media-streaming company receives complaints that its web application is timing out or failing to load. Security analysts observe the web server is overwhelmed with a large number of open HTTP connections, transmitting data extremely slowly. These connections remain open indefinitely, exhausting server resources without consuming excessive bandwidth. The team suspects an application-layer DoS attack. Which attack is most likely responsible?

- A. A UDP flooding attack targeting random ports.
- B. An ICMP Echo Request flooding attack.
- C. A Slowloris attack that keeps numerous HTTP connections open to exhaust server resources.
- D. A fragmented packet attack with overlapping offset values.

Answer: C

Explanation

The Certified Ethical Hacker (CEH) Web Application Hacking and DoS/DDoS module identifies Slowloris as an application-layer denial-of-service attack that targets web servers by maintaining a large number of half-open HTTP connections.

Slowloris works by sending partial HTTP requests very slowly, preventing the server from closing the connections. CEH documentation highlights that this attack does not rely on high bandwidth, making it difficult to detect using traditional network-based defenses.

Option C accurately matches the described symptoms and CEH's definition.

Options A and B are network-layer flooding attacks, which were explicitly ruled out.

Option D is a packet fragmentation attack, not an application-layer DoS technique.

CEH stresses tuning connection timeouts and using reverse proxies as mitigations.

Question #:307 - [Network and Perimeter Hacking]

A company's online service is under a multi-vector DoS attack using SYN floods and HTTP GET floods. Firewalls and IDS cannot stop the outage. What advanced defense should the company implement?

- A. Configure the firewall to block all incoming SYN packets from external IPs
- B. Use DDoS mitigation services that offer multi-layer protection

- C. Deploy a Web Application Firewall (WAF) with anomaly detection
- D. Increase server bandwidth and apply basic rate limiting

Answer: B

Explanation

CEH v13 highlights that multi-vector DDoS attacks require multi-layer DDoS mitigation services, often cloud-based, capable of analyzing, filtering, and scrubbing traffic across network, transport, and application layers. These providers maintain massive bandwidth capacity, global scrubbing centers, and behavioral analysis engines that distinguish legitimate sessions from malicious floods. SYN floods and HTTP GET floods require different mitigation techniques simultaneously, which typical firewalls or WAFs cannot handle without dropping legitimate traffic. Blocking SYN packets (Option A) would disrupt normal users. A WAF (Option C) handles only Layer 7 traffic and does not mitigate network-layer volumetric attacks. Increasing bandwidth (Option D) is ineffective against large botnet attacks. Therefore, deploying a multi-layer cloud DDoS protection service is the most effective solution for resilient, real-time mitigation.

Question #:308 - [Mobile Platform, IoT, and OT Hacking]

What is the most plausible attack vector an APT group would use to compromise an IoT-based environmental control system?

- A. Exploiting zero-day firmware vulnerabilities
- B. Using stolen user credentials
- C. Encrypted MitM attack
- D. DDoS attack

Answer: A

Explanation

According to CEH v13 Mobile, IoT, and OT Hacking, Advanced Persistent Threat (APT) groups prioritize stealth, persistence, and long-term control. In IoT environments, the most attractive and effective entry point is firmware-level zero-day vulnerabilities.

IoT devices often:

Run outdated or proprietary firmware

Lack regular patching mechanisms

Operate with high privileges

Have minimal monitoring

Exploiting a zero-day vulnerability in firmware allows attackers to gain deep, persistent access that survives reboots and avoids traditional security controls. This aligns directly with APT objectives.

Credential theft (Option B) is common but less reliable for IoT systems. Encrypted MitM (Option C) is complex and less persistent. DDoS (Option D) disrupts services but does not provide control.

CEH v13 explicitly identifies firmware exploitation as the primary APT vector in IoT and OT environments. Therefore, Option A is correct.

Question #:309 - [Wireless Network Hacking]

Which countermeasure best mitigates brute-force attacks on Bluetooth SSP?

- A. Use BLE exclusively
- B. Increase Diffie-Hellman key length
- C. Apply rate-limiting
- D. Device whitelisting

Answer: C

Explanation

In CEH v13 Wireless Hacking, brute-force attacks against Secure Simple Pairing (SSP) exploit repeated attempts to guess cryptographic values. The most effective defense is rate limiting, which restricts how many pairing attempts can be made in a given timeframe.

Increasing key length does not stop brute-force attempts if unlimited tries are allowed. BLE still uses pairing mechanisms and is not immune. Whitelisting controls access but does not prevent cryptographic attacks during pairing.

CEH v13 explicitly recommends rate limiting and pairing attempt thresholds as primary mitigations. Therefore, Option C is correct.

Question #:310 - [Reconnaissance Techniques]

During a black-box penetration test, an attacker runs the following command:

```
nmap -p25 --script smtp-enum-users --script-args EXPN,RCPT <target IP>
```

The script successfully returns multiple valid usernames. Which server misconfiguration is being exploited?

- A. The SMTP server allows authentication without credentials
- B. The SMTP server has disabled STARTTLS, allowing plaintext enumeration
- C. SMTP user verification commands are exposed without restrictions

D. DNS MX records point to an internal mail relay

Answer: C

Explanation

The CEH Enumeration module explains that SMTP supports commands such as VRFY, EXPN, and RCPT TO, which can be abused to enumerate valid email users if not properly restricted.

In this scenario, the smtp-enum-users Nmap script successfully uses EXPN and RCPT, indicating that the server responds differently to valid and invalid usernames.

Option C is correct because unrestricted SMTP user verification allows attackers to harvest usernames for further attacks such as phishing or brute force.

Option A involves authentication, not enumeration.

Option B affects confidentiality, not user discovery.

Option D is unrelated to SMTP enumeration.

CEH strongly recommends disabling or restricting these SMTP commands.

Question #:311 - [Social Engineering]

At a fast-growing startup in Austin, Texas, an ethical hacker is asked to simulate how attackers might gather information to gain initial access. During the assessment, she poses as a recruiter on a professional networking site and convinces several employees to share details about the company's internal software and VPN setup. Which type of threat best represents this adversary's method of information gathering?

A. System and Network Attacks

B. Social Engineering

C. Information Leakage

D. Corporate Espionage

Answer: B

Explanation

The correct answer is B. Social Engineering because the attacker's primary method is manipulating people—not exploiting a technical vulnerability—to obtain information that can enable initial access. In CEH-aligned security concepts, social engineering is defined by the use of deception, impersonation, and psychological influence to persuade victims to reveal sensitive information, perform actions, or bypass normal security procedures. Here, the ethical hacker “poses as a recruiter” on a professional networking site, which is a classic impersonation / pretexting approach. The goal is to build credibility and trust so employees voluntarily disclose internal details that should not be shared externally.

The information gathered—“internal software and VPN setup”—is exactly the sort of intelligence attackers seek during reconnaissance and pre-attack planning. VPN details, remote access workflows, authentication methods, and internal tooling can be used to craft highly convincing phishing messages, identify weak points (such as outdated clients or exposed portals), or target specific employees and administrators. In a real intrusion, this social engineering-driven intelligence collection often precedes credential harvesting, password spraying, MFA fatigue attempts, or tailored malware delivery.

Why the other options are less correct: System and Network Attacks refer to direct technical exploitation such as scanning, sniffing, or attacking services and protocols; the scenario contains none of that. Information Leakage describes the condition where sensitive data is exposed (for example, public documents, misconfigured repositories, error messages), but the scenario focuses on active interpersonal manipulation to extract information. Corporate Espionage is a broader motive/category describing theft of trade secrets, often by competitors or nation-state actors; while social engineering can be used in espionage, the question asks about the method of information gathering, which is clearly social engineering.

Therefore, the threat method demonstrated is social engineering (pretexting/impersonation via a recruiter persona).

Question #:312 - [Information Security and Ethical Hacking Overview]

During a red team exercise at a financial services firm in Phoenix, Arizona, an ethical hacker sends a phishing email with a disguised attachment to employees. The purpose is to transmit the payload into the environment so later attack steps can proceed. In the cyber kill chain model, which phase does this represent?

- A. Reconnaissance
- B. Exploitation
- C. Delivery
- D. Weaponization

Answer: C

Explanation

In the Cyber Kill Chain, Delivery is the phase where the attacker transmits the weaponized payload to the target. The scenario states the red teamer “sends a phishing email with a disguised attachment” specifically “to transmit the payload into the environment so later attack steps can proceed.” That is precisely the purpose of Delivery: getting the malicious content to the victim through a chosen vector such as email attachments, links, drive-by downloads, USB drops, or other transfer mechanisms.

This is distinct from Weaponization, which occurs earlier. Weaponization is when the attacker prepares the payload—combining an exploit with a malware/RAT or crafting the malicious document/attachment. Once weaponized, the attacker must deliver it. The phishing email itself is the delivery vehicle, and the attachment is the delivered object. The next phases would typically include Exploitation (triggering the exploit when the user opens the attachment), Installation (establishing malware/persistence), Command and Control, and Actions on Objectives.

Why the other options do not match:

Reconnaissance (A) is gathering information about the target (people, infrastructure, technologies) before sending anything.

Weaponization (D) is building/preparing the malicious attachment and exploit, not sending it.

Exploitation (B) is the moment the delivered content successfully triggers a vulnerability or executes code (e.g., when the victim opens the attachment and the exploit runs).

Because the described action is the actual transmission of the payload via phishing email, the kill chain phase is C. Delivery.

Question #:313 - [Malware Threats]

Ethical hacker Ryan Brooks, a skilled penetration tester from Austin, Texas, was hired by Skyline Aeronautics, a leading aerospace firm in Denver, to conduct a security assessment. One stormy morning, Ryan noticed an unexpected lag in the routine system update process while running his tests, sparking his curiosity. During a late-night session, he observed a junior analyst, Chris Miller, cautiously modifying a legacy server's configuration, including a scheduled task set to a specific date. The lead developer, Jessica Hayes, casually mentioned receiving an odd email from an unfamiliar source, which she ignored as clutter. As Ryan probed deeper, he detected a faint increase in network activity only after the scheduled date passed, and a systems admin, Mark Thompson, quickly pointed out some unusual code traces on a dormant workstation.

Which type of threat best characterizes this attack?

- A. Logic Bomb
- B. Fileless Malware
- C. Advanced Persistent Threat APT
- D. Ransomware

Answer: A

Explanation

A logic bomb is malware or malicious code that is deliberately planted within a system and configured to execute when a specific condition is met, such as a particular date and time, a user action, or the presence or absence of a file. CEH materials describe logic bombs as condition-based triggers that can remain dormant for extended periods, producing minimal indicators until the trigger occurs. The most decisive clue in this scenario is the "scheduled task set to a specific date," followed by abnormal behavior that appears only after that date passes. This is a textbook trigger mechanism used to activate malicious actions while avoiding early detection.

The "odd email from an unfamiliar source" suggests an initial delivery or social engineering vector, but the core behavior is the delayed activation. The later "faint increase in network activity only after the scheduled

date passed” aligns with a logic bomb executing a payload such as beaconing, data exfiltration, or enabling remote access. The “unusual code traces on a dormant workstation” further supports the idea of implanted code that was inactive until triggered.

Fileless malware emphasizes execution in memory using legitimate tools such as PowerShell or WMI and is defined more by its living-off-the-land technique than by a date-based trigger. An APT describes a broader campaign style involving long-term, multi-stage intrusion, not a single defining trigger artifact. Ransomware is characterized by encryption and extortion behavior, which is not described. Therefore, the threat is best characterized as a logic bomb.

Question #:314 - [Cryptography]

While evaluating a smart card implementation, a security analyst observes that an attacker is measuring fluctuations in power consumption and timing variations during encryption operations on the chip. The attacker uses this information to infer secret keys used within the device. What type of exploitation is being carried out?

- A. Disrupt control flow to modify instructions
- B. Observe hardware signals to deduce secrets
- C. Crack hashes using statistical collisions
- D. Force session resets through input flooding

Answer: B

Explanation

CEH v13 explains that Side-Channel Attacks exploit physical characteristics of cryptographic devices—such as power consumption, timing variations, electromagnetic leakage, or acoustic emissions—to infer confidential data like encryption keys. These attacks do not break the cryptographic algorithm itself but instead analyze unintended signals produced during computation. The scenario describes a classic power analysis and timing analysis attack, where the attacker monitors fluctuations during encryption operations on a smart card. CEH details how Differential Power Analysis (DPA) and Simple Power Analysis (SPA) allow attackers to extract secret keys by statistically correlating measured power traces to cryptographic operations. This type of attack is extremely dangerous because it bypasses mathematical strength and targets hardware implementation flaws. Options A, C, and D do not relate to side-channel exploitation. CEH specifically categorizes this method as observing hardware emissions to deduce secrets, making Option B the most accurate match.

Question #:315 - [Social Engineering]

During a security assessment at Apex Technologies in Austin, Texas, the cybersecurity team identifies a high risk of social engineering attacks, including phishing, vishing, and baiting, targeting employees across departments. To strengthen defenses, the team plans to implement a countermeasure to reduce the likelihood of employees disclosing sensitive information. Which of the following countermeasures should Apex Technologies prioritize to mitigate the risk of social engineering attacks?

- A. Conduct security awareness and training programs
- B. Employees must verify the identity of individuals requesting information
- C. Use two-factor authentication
- D. Establish policies and procedures for handling sensitive information

Answer: A

Explanation

Security awareness and training is the most effective primary countermeasure against social engineering because these attacks exploit human trust, curiosity, urgency, and lack of familiarity with deception tactics rather than purely technical weaknesses. In CEH guidance, phishing, vishing, and baiting succeed when users fail to recognize red flags such as unexpected requests, pressure to act quickly, suspicious links or attachments, caller spoofing, or offers that seem too good to be true. A structured awareness program directly reduces the chance of disclosure by teaching employees how to identify common pretexts, verify unusual requests, and follow safe reporting procedures.

While identity verification (option B) is an important practice, employees typically perform it correctly only when they have been trained on verification steps, escalation paths, and what “good verification” looks like under pressure. Two-factor authentication (option C) helps protect accounts even if credentials are stolen, but it does not prevent employees from sharing sensitive information such as customer data, internal documents, OTP codes, or approving fraudulent requests—many social engineering campaigns aim beyond passwords. Policies and procedures (option D) are necessary, but policies alone are often ignored or misunderstood without ongoing training, reinforcement, and real-world simulations.

CEH-aligned best practice is a layered approach: start with awareness training, reinforce it with clear handling policies, require verification for sensitive requests, conduct phishing simulations, and ensure employees know how to report suspicious emails/calls immediately. This combination reduces both successful compromise and the impact of attempts, but training is the foundational priority because it directly targets the human element being attacked.

Question #:316 - [Network and Perimeter Hacking]

At Liberty Mutual's cybersecurity operations center in Boston, network engineer Marcus is troubleshooting a critical issue during peak transaction hours. Multiple VLANs are experiencing intermittent access delays, and several endpoints including those on isolated VLANs are receiving network traffic not intended for them, raising concerns about data exposure. Marcus notices that the issue began after a newly imaged workstation used by an intern named Lisa was connected to a trunk port in the server room. Switch logs indicate abnormal traffic patterns overwhelming the network.

Which sniffing technique is Lisa's workstation most likely using to cause this behavior?

- A. DNS Cache Poisoning
- B. ARP Poisoning
- C. MAC Flooding

D. Switch Port Stealing

Answer: C

Explanation

The symptoms strongly match MAC flooding, a classic Layer 2 sniffing-related attack discussed in CEH under switch-based network attacks. Ethernet switches maintain a CAM table that maps MAC addresses to physical switch ports. This table allows the switch to forward frames only to the correct destination port, preventing other hosts from seeing traffic not intended for them. In a MAC flooding attack, an attacker generates a very large number of frames with spoofed, random source MAC addresses. The goal is to overflow the switch CAM table so it can no longer reliably store legitimate MAC-to-port mappings.

When the CAM table is full or unstable, many switches fail open by flooding frames out of multiple ports, behaving more like a hub for unknown destinations. That leads to exactly what Marcus observes: devices on segments that should be isolated start receiving traffic they normally would not see, and overall performance degrades due to excessive broadcast-like forwarding. The prompt also mentions “abnormal traffic patterns overwhelming the network,” which aligns with the high-volume frame injection required to poison or overflow the CAM table.

ARP poisoning would primarily redirect traffic through the attacker by manipulating IP-to-MAC mappings within a VLAN, but it would not typically cause widespread flooding and generalized delays across multiple VLANs. DNS cache poisoning affects name resolution rather than Layer 2 forwarding behavior. Switch port stealing targets a specific victim MAC entry to redirect that host’s traffic, but the widespread flooding and overload indicators are more characteristic of MAC flooding. Therefore, MAC flooding is the most likely technique in this scenario.

Question #:317 - [Network and Perimeter Hacking]

While performing a SYN (half-open) scan using Nmap, you send a SYN packet to a target IP address and receive a SYN/ACK response. How should this result be interpreted?

- A. The scanned port is open and ready to establish a connection
- B. The target IP is unreachable
- C. The port is filtered by a firewall
- D. The port is closed but acknowledged

Answer: A

Explanation

According to the CEH Network Scanning module, a SYN scan works by analyzing TCP handshake responses.

SYN # SYN/ACK = Port OPEN

SYN # RST = Port CLOSED

No response = FILTERED

Option A is correct.

CEH emphasizes SYN scanning as stealthy because the handshake is never completed.

Question #:318 - [System Hacking Phases]

Working as an Information Security Analyst at a technology firm, you are designing training material for employees about the dangers of session hijacking. As part of the training, you want to explain how attackers could use sidejacking to compromise user accounts. Which of the following scenarios most accurately describes a sidejacking attack?

- A. An attacker exploits a vulnerability in the company's network firewall to gain unauthorized access to internal systems.
- B. An attacker intercepts network traffic, captures unencrypted session cookies, and uses them to impersonate the user.
- C. An attacker uses social engineering techniques to trick an employee into revealing their password.
- D. An attacker convinces an employee to visit a malicious website that injects a harmful script into their browser.

Answer: B

Explanation

According to the Certified Ethical Hacker (CEH) System Hacking and Session Hijacking module, sidejacking is a form of session hijacking where an attacker passively intercepts network traffic to capture unencrypted session cookies. These cookies are then reused to impersonate the authenticated user without needing credentials.

CEH documentation explains that sidejacking commonly occurs on unencrypted HTTP connections, public Wi-Fi networks, or improperly secured internal networks. Once the session cookie is stolen, the attacker can replay it to gain access to the victim's active session.

Option B correctly describes this mechanism and directly matches CEH's definition of sidejacking.

Option A refers to perimeter exploitation, not session hijacking.

Option C describes social engineering, which is unrelated to sidejacking.

Option D is an example of cross-site scripting (XSS), not sidejacking.

CEH emphasizes HTTPS enforcement and secure cookie attributes as key countermeasures.

Question #:319 - [Security Operations and Incident Response]

A corporation uses both hardware-based and cloud-based solutions to distribute incoming traffic and absorb DDoS attacks, ensuring legitimate requests remain unaffected. Which DDoS mitigation strategy is being utilized?

- A. Black Hole Routing
- B. Load Balancing
- C. Sinkholing
- D. Rate Limiting

Answer: B

Explanation

The CEH DDoS Mitigation Strategies section explains that load balancing distributes traffic across multiple servers or infrastructure components to prevent any single resource from being overwhelmed.

By using hardware load balancers and cloud-based traffic distribution, organizations can:

Absorb large volumes of attack traffic

Maintain service availability

Ensure legitimate users are served

Option B is correct and directly matches CEH's definition.

Option A drops all traffic, including legitimate requests.

Option C focuses on traffic analysis rather than distribution.

Option D limits traffic rather than distributing it.

CEH strongly recommends load balancing as a core DDoS resilience mechanism.

Question #:320 - [Network and Perimeter Hacking]

During a penetration test at Lone Star Healthcare in Austin, ethical hacker Liam evaluates the hospital's perimeter defenses by generating controlled traffic flows through the firewall. He uses a tool that can create and replay diverse traffic patterns to test how well the firewall enforces its rules against both legitimate and malicious traffic types. This allows him to demonstrate whether the device properly identifies evasion attempts under simulated attack conditions.

Which tool is Liam most likely using in this test?

- A. Nmap
- B. Traffic IQ Professional

C. Colasoft Packet Builder

D. Metasploit

Answer: B

Explanation

The scenario best matches Traffic IQ Professional because it describes a tool used to generate and replay diverse traffic patterns through a firewall to validate rule enforcement and detection under simulated attack conditions. The key functions here are traffic generation, replay, and the ability to model both legitimate and malicious flows to test whether the firewall correctly handles evasion attempts and policy enforcement. Traffic generation/replay platforms are used in security validation and firewall testing to emulate real-world network behaviors at scale and to assess how devices respond to crafted or replayed traffic profiles.

Why the other tools are less suitable:

Nmap (A) is primarily a scanner for host discovery, port scanning, and service enumeration, with some scripting capabilities. It is not chiefly a traffic generation/replay system for exercising a firewall with diverse controlled flows.

Colasoft Packet Builder (C) can craft packets and build custom traffic at the packet level, which is useful for creating specific test packets. However, the scenario emphasizes broader “diverse traffic patterns” and replay of flows in a way typically associated with traffic modeling/validation suites rather than single-packet construction.

Metasploit (D) is an exploitation framework used to develop and execute exploits and payloads. While it can generate certain traffic, its primary purpose is not comprehensive traffic generation and replay to validate firewall policies under many traffic types.

Traffic IQ Professional is the best fit because it aligns with a firewall test plan focused on simulating legitimate and malicious traffic profiles, including evasion-style patterns, and demonstrating how the perimeter device behaves under controlled conditions. This approach is often used to evaluate whether a firewall can consistently enforce security policies, detect anomalies, and resist evasion techniques without overblocking legitimate traffic.

Therefore, the most likely tool is B. Traffic IQ Professional.

Question #:321 - [Web Application Hacking]

You are a security analyst at Sentinel IT Services, monitoring the web application of GreenValley Credit Union in Portland, Oregon. During a log analysis, you identify an SQL injection attempt on the customer login portal, where the attacker inputs a malicious string to manipulate the query logic. The application mitigates this by replacing special characters with their escaped equivalents to prevent query manipulation before the query is executed, ensuring the SQL statement remains unchanged. Based on the observed defense mechanism, which SQL injection countermeasure is the application employing?

A. Perform user input validation

- B. Encoding the single quote
- C. Restrict database access
- D. Use parameterized queries or prepared statements

Answer: B

Explanation

The behavior described matches the countermeasure commonly referred to in CEH materials as escaping or encoding special characters, most notably the single quote character. SQL injection frequently relies on breaking out of a quoted string in the SQL statement using the single quote, then appending logical operators such as OR 1=1, comments, or additional clauses. When an application replaces special characters with escaped equivalents before the SQL statement is executed, it attempts to ensure the input is treated purely as data rather than executable SQL syntax. A classic example is transforming a single quote into an escaped form such as \' or doubling it to " depending on the database and escaping rules. By doing so, the database parser interprets the quote as part of the literal string value, preventing the attacker from terminating the string and altering query logic.

Option B is therefore the best fit because it precisely describes encoding or escaping the single quote, which is the most commonly targeted delimiter in SQL injection payloads. Option A, user input validation, is broader and typically refers to allowlisting accepted characters and formats, but the question specifically emphasizes replacement with escaped equivalents rather than rejecting invalid input. Option D, parameterized queries or prepared statements, is the strongest modern control recommended in CEH guidance because it separates code from data at the API level, but it is different from character escaping and does not rely on rewriting input characters. Option C limits damage but does not prevent injection. The observed mechanism is clearly single-quote encoding.

Question #:322 - [Cloud Computing]

During a cloud security assessment, you discover a former employee still has access to critical cloud resources months after leaving. Which practice would most effectively prevent this?

- A. Real-time traffic analysis
- B. Regular penetration testing
- C. Enforcing timely user de-provisioning
- D. Multi-cloud deployment

Answer: C

Explanation

The CEH Cloud Security module highlights identity and access management (IAM) failures as a major source of cloud breaches. Ensuring timely de-provisioning of user accounts when employees leave is a core security control.

Option C is correct.

Options A and B detect issues but don't prevent access persistence.

Option D is unrelated to access control.

CEH stresses joiner–mover–leaver (JML) processes.

Question #:323 - [Malware Threats]

A kernel-level rootkit is discovered. What is the safest remediation strategy?

- A. Power down immediately
- B. Deploy honeypots
- C. Full system format and reinstall
- D. Use rootkit scanners and tailored removal

Answer: C

Explanation

CEH v13 identifies kernel-level rootkits as among the most dangerous malware types. Because they operate at the lowest OS level, they can hide processes, files, and system calls.

CEH v13 states that the only guaranteed remediation is a complete system wipe and clean OS reinstallation from a trusted source. Attempting removal risks incomplete eradication.

Powering down alone does not remove the rootkit. Honeypots are for detection, not remediation. Tailored removal tools may fail at kernel depth.

Thus, Option C is correct.

Question #:324 - [Network and Perimeter Hacking]

During a penetration test at Pacific Trust Bank in Seattle, ethical hacker Mia Chen suspects that a server hosting customer transaction data may be a honeypot. To investigate, she repeatedly sends crafted queries and observes how quickly the system responds. She notices that responses are consistently faster and more uniform than those of other production servers, raising her suspicion that the environment is designed to lure attackers.

Which technique is Mia most likely using to determine if the server is a honeypot?

- A. Analyzing MAC Address
- B. Analyzing Response Time

- C. Fingerprinting the Running Service
- D. Analyzing System Configuration and Metadata

Answer: B**Explanation**

The correct answer is B. Analyzing Response Time because the scenario explicitly describes Mia's method as repeatedly sending crafted queries and comparing the speed and consistency of responses with other production servers. In CEH-aligned honeypot and deception detection concepts, one practical way to suspect a decoy environment is to measure how it behaves under interaction and whether that behavior differs from real production systems. Honeypots are often instrumented to monitor attacker activity and may run simplified stacks, isolated resources, or simulated services. This can produce response characteristics that are noticeably different—such as responses that are too fast, too consistent, or unusually uniform even under varying query conditions—because the system may be returning pre-generated or emulated outputs rather than processing real workloads.

Real production servers typically show natural variance in response time due to legitimate traffic load, database I/O, caching effects, rate limiting, and resource contention. When a target consistently responds with minimal jitter and unusually stable latency, it can indicate a controlled or simulated environment designed for observation rather than normal business operations. By baselining and comparing response timing across multiple hosts, Mia is using timing behavior as a distinguishing signal to assess whether the server is behaving like a genuine production system or a monitored decoy.

Why the other options are less correct: Analyzing MAC Address is generally a local-network technique and not a primary way to validate honeypot behavior for an external-facing transaction server; it also does not align with the described repeated query timing. Fingerprinting the running service can help identify service type/version, but the question centers on consistency and speed rather than identifying signatures. Analyzing system configuration and metadata would involve inspecting headers, banners, OS/service metadata, or environment artifacts; useful, but not what Mia is doing here.

Therefore, Mia is most likely using response time analysis to assess whether the server behaves like a honeypot.

Question #:325 - [System Hacking Phases]

In a vertical privilege escalation scenario, the attacker attempts to gain access to a user account with higher privileges than their current level. Which of the following examples describes vertical privilege escalation?

- A. An attacker exploits weak access controls to access and steal sensitive information from another user's account with alike privileges.
- B. An attacker leverages a lack of session management controls to switch accounts and access resources assigned to another user with the same permissions.
- C. An attacker uses an unquoted service path vulnerability to gain unauthorized access to another user's data with equivalent privileges.
- D. An attacker escalates from a regular user to an administrator by exploiting administrative functions.

Answer: D**Explanation**

CEH v13 distinguishes between vertical and horizontal privilege escalation. Vertical escalation occurs when an attacker moves upward in the hierarchy of privileges—such as from a regular user to an administrator or root—by exploiting vulnerabilities, misconfigurations, or insecure privilege boundaries. This allows the attacker to perform tasks that were previously restricted, such as modifying system settings, accessing sensitive data, installing malware, or controlling the entire environment. Horizontal escalation, on the other hand, involves accessing another user's resources at the same privilege level, which the other options describe. Exploiting unquoted service paths or weak access controls may facilitate privilege abuse, but they do not inherently elevate the user to a higher privilege tier unless they specifically lead to administrative execution. The scenario that aligns perfectly with the CEH definition of vertical privilege escalation is the escalation from regular user to administrator.

Question #:326 - [Malware Threats]

Malware remains dormant until triggered and changes its code with each infection. What malware type is responsible, and how should it be mitigated?

- A. Adware
- B. Polymorphic malware
- C. Worm
- D. Rootkit

Answer: B**Explanation**

This scenario precisely matches polymorphic malware, a type of advanced malware described in CEH v13 Malware Threats. Polymorphic malware dynamically alters its code, encryption, or signature each time it propagates, allowing it to evade traditional signature-based antivirus detection.

Additionally, the malware's ability to remain dormant until triggered indicates logic-based activation, which is common in advanced threats designed to avoid sandbox detection.

CEH v13 emphasizes that polymorphic malware cannot be reliably detected using static signatures. Instead, organizations must rely on behavior-based detection, heuristic analysis, and advanced threat protection systems capable of identifying suspicious runtime behavior.

Options A, C, and D do not match the described behavior. Adware focuses on advertising. Worms self-propagate aggressively. Rootkits focus on stealth and persistence, not code mutation.

Therefore, Option B is the correct answer.

Question #:327 - [Web Application Hacking]

A penetration tester evaluates a company's secure web application, which uses HTTPS, secure cookie flags, and strict session management to prevent session hijacking. To bypass these protections and hijack a legitimate user's session without detection, which advanced technique should the tester employ?

- A. Utilize a session fixation attack by forcing a known session ID during login
- B. Perform a Cross-Site Scripting (XSS) attack to steal the session token
- C. Exploit a timing side-channel vulnerability to predict session tokens
- D. Implement a Man-in-the-Middle (MitM) attack by compromising a trusted certificate authority

Answer: D

Explanation

CEH materials explain that modern web applications deploy multiple layers of security—HTTPS, secure cookies, HttpOnly flags, and strict session regeneration—to defend against standard hijacking methods such as token theft through XSS or fixation. When these protections are properly implemented, attackers must compromise the underlying trust relationship between the client and server to successfully intercept or manipulate session tokens. One of the most advanced techniques described in CEH is compromising a trusted certificate authority or injecting a forged certificate into the victim's trust store. This enables the attacker to perform a transparent MITM attack despite HTTPS protections. Because the victim's browser trusts the forged certificate, encrypted traffic—including session tokens—is exposed to the attacker without generating browser warnings or IDS alerts. Timing side-channel attacks are not considered session hijacking methods; XSS is mitigated by secure flags; and session fixation is ineffective when session regeneration occurs. Therefore, compromising a trusted certificate authority to enable an undetectable MITM attack is the most viable method.

Question #:328 - [Wireless Network Hacking]

You are an ethical hacker at Northpoint Assessments, engaged to map the wireless footprint around Harborview Plaza in San Francisco, California. To enumerate nearby networks and prompt devices to reveal SSIDs and capabilities, you actively send crafted management frames from your laptop and log each AP's immediate responses (including probe responses and capability information), rather than only listening for broadcasts. Based on the described activity, which Wi-Fi discovery technique are you performing?

- A. Network Discovery Software
- B. Passive Footprinting
- C. Wash Command
- D. Active Footprinting

Answer: D

Explanation

The activity described is active footprinting because you are not merely listening for wireless broadcasts; you are transmitting crafted 802.11 management frames to elicit responses and gather information. In Wi-Fi reconnaissance, passive methods rely on monitoring beacon frames and other naturally occurring traffic. Active methods, by contrast, deliberately interact with the environment—often by sending probe requests or other management frames—to prompt access points or client devices to respond with details such as SSID, supported data rates, security capabilities, and other parameters.

The scenario explicitly states you “actively send crafted management frames” and then log “immediate responses (including probe responses and capability information).” That is the defining difference between active and passive wireless footprinting. Active footprinting can reveal SSIDs that may not be visible through beacons alone (for example, networks that do not broadcast SSID in beacons may still respond under certain conditions), and it can speed discovery by forcing responses rather than waiting for periodic broadcasts or client activity.

Why the other options are less accurate:

Passive footprinting (B) contradicts the scenario because passive recon involves no transmissions from the auditor’s device.

Wash command (C) refers to a specific tool/command typically associated with WPS enumeration workflows, not the general technique classification being asked here.

Network discovery software (A) is too generic; the question is asking for the technique (active vs passive), and the described behavior is clearly active.

Therefore, the correct answer is D. Active Footprinting.

Question #:329 - [Cryptography]

You are Maya, a security engineer at HarborPoint Cloud Services in Chicago, Illinois, performing a post-incident hardening review after an internal audit flagged multiple services that rely on legacy public-key algorithms. The engineering team must prioritize actions company-wide to reduce long-term risk from future quantum-capable adversaries while development continues on a large refactor of several services. Which proactive control should Maya recommend as the highest-priority change to embed into the organization's development lifecycle to improve future resistance to quantum-based attacks?

- A. Include quantum-resistance checks in SDLC and code review processes
- B. Encrypt stored data with quantum-resistant algorithms
- C. Use quantum-specific firewalls to protect quantum communication channels
- D. Break data into fragments and distribute it across multiple locations

Answer: A

Explanation

The highest-priority proactive control “to embed into the organization’s development lifecycle” is including quantum-resistance checks in the SDLC and code review processes. The scenario emphasizes a company-wide, long-term risk reduction strategy while development continues on a major refactor. In that context, the most scalable and durable control is governance and engineering hygiene: ensuring that new features and refactored components do not reintroduce weak or legacy cryptography and that teams consistently select algorithms and key sizes aligned with modern guidance and future migration plans.

Embedding checks into the SDLC means instituting standards and guardrails such as approved cryptographic libraries, banned algorithm lists (e.g., legacy RSA key sizes, deprecated curves, weak hashes), cryptography design reviews, automated dependency scanning for crypto usage, and CI/CD policy gates that flag noncompliant implementations. This approach reduces “crypto sprawl,” prevents new technical debt, and creates a structured path to transition toward post-quantum or quantum-resistant approaches as the organization modernizes systems.

Why the other choices are not the best “highest priority” SDLC-embedded control:

Encrypt stored data with quantum-resistant algorithms (B) may be appropriate for protecting long-lived sensitive data (“harvest now, decrypt later”), but it is a targeted technical control and may not be feasible immediately across many services during refactoring. It also does not by itself prevent developers from continuing to implement legacy public-key schemes elsewhere.

Quantum-specific firewalls (C) is not a realistic or standard control for post-quantum readiness in typical enterprise environments.

Fragmenting data across locations (D) can help resilience/confidentiality in some designs but does not address the core issue: preventing continued reliance on weak public-key cryptography.

Therefore, the best answer is A. Include quantum-resistance checks in SDLC and code review processes.

Question #:330 - [Reconnaissance Techniques]

A cybersecurity team at a regional healthcare provider is conducting an internal red team exercise to assess their exposure to service enumeration attacks. Amanda, a senior penetration tester, is assigned to probe the internal network for services that may reveal usernames, group information, or system details without requiring prior authentication. She decides to target common services running on specific ports that are often misconfigured or loosely monitored. During her reconnaissance, Amanda identifies several open ports across various hosts and must now prioritize which ones to probe first for maximum information gain related to enumeration. Which of the following services should Amanda target as a priority to enumerate usernames and group information without authentication?

- A. TCP 139 and UDP 137, 138
- B. TCP 21 and UDP 137, 138
- C. TCP 23 and UDP 137, 138
- D. TCP 25 and UDP 133

Answer: A

Explanation

TCP 139 and UDP 137 and 138 correspond to NetBIOS over TCP/IP services that are closely associated with Windows file and printer sharing and legacy SMB browsing. In CEH methodology, these ports are high-value enumeration targets because NetBIOS name service and datagram service can disclose hostnames, domain or workgroup names, logged-in users, and shared resource details, often before any strong authentication occurs. UDP 137 is used for NetBIOS Name Service, which supports name registration and lookup. UDP 138 supports NetBIOS Datagram Service, commonly tied to browsing and announcement traffic. TCP 139 supports NetBIOS Session Service, historically used to establish sessions for SMB traffic and to query share and user-related information when configurations are weak.

In real environments, misconfigurations such as permissive share settings, legacy protocols, or anonymous and guest-access allowances can allow an attacker to enumerate user accounts, groups, and policies indirectly through browsing data, share lists, and RPC-related exposure that frequently accompanies SMB environments. CEH training emphasizes prioritizing enumeration against Windows networking services because the information gained can rapidly support follow-on attacks such as password spraying, targeted phishing, lateral movement, and privilege escalation planning.

The other choices include TCP 21 FTP, TCP 23 Telnet, and TCP 25 SMTP, which may expose banners or allow limited user enumeration in specific configurations, but they are not the primary ports associated with classic Windows user and group enumeration. UDP 133 is not a standard enumeration target in this context. Therefore, TCP 139 with UDP 137 and 138 is the best priority set for username and group-related enumeration.

Question #:331 - [Information Security and Ethical Hacking Overview]

Which of the following is the primary goal of ethical hacking?

- A. To disrupt services by launching denial-of-service attacks
- B. To identify and fix security vulnerabilities in a system
- C. To steal sensitive information from a company's network
- D. To spread malware to compromise multiple systems

Answer: B

Explanation

Ethical hacking, as defined throughout CEH courseware, is the authorized and legitimate process of identifying vulnerabilities, weaknesses, and misconfigurations in information systems. The primary objective is to strengthen security by discovering issues before malicious actors can exploit them. Ethical hackers follow strict legal guidelines, obtain written permission, and operate within a defined scope to ensure their activities contribute positively to the organization's security posture. Unlike malicious hacking, the intent is not to steal data, cause harm, or disrupt operations. Ethical hackers use the same tools, techniques, and methodologies that attackers use, but with the purpose of remediation and risk reduction. CEH emphasizes

that ethical hacking supports defense-in-depth strategies by enabling organizations to harden their environments and proactively mitigate threats. Therefore, identifying and fixing vulnerabilities is the central mission of ethical hacking.

Question #:332 - [Reconnaissance Techniques]

As a cybersecurity analyst conducting passive reconnaissance, you aim to gather information without interacting directly with the target system. Which technique is least likely to assist in this process?

- A. Using a tool like Nmap to scan the organization's public IP range
- B. Inspecting the WHOIS database for domain registration details
- C. Using search engines and public data sources
- D. Monitoring publicly available social media and professional profiles

Answer: A

Explanation

CEH defines passive reconnaissance as collecting information without directly engaging the target.

Option A is incorrect for passive reconnaissance because Nmap scanning actively probes systems, generating detectable traffic.

Options B, C, and D rely on publicly available information and are standard passive techniques.

CEH classifies Nmap scanning as active footprinting.

Question #:333 - [Web Application Hacking]

A penetration tester identifies that a web application's login form is not using secure password hashing mechanisms, allowing attackers to steal passwords if the database is compromised. What is the best approach to exploit this vulnerability?

- A. Perform a dictionary attack using a list of commonly used passwords against the stolen hash values
- B. Input a SQL query to check for SQL injection vulnerabilities in the login form
- C. Conduct a brute-force attack on the login form to guess weak passwords
- D. Capture the login request using a proxy tool and attempt to decrypt the passwords

Answer: A

Explanation

If a system stores passwords in weak or reversible formats, attackers can perform offline cracking. CEH emphasizes dictionary attacks as the fastest and most efficient method to exploit weak hashing practices. This avoids detection and leverages known password patterns to recover plaintext credentials.

Question #:334 - [Reconnaissance Techniques]

In a tense red team exercise at a mid-sized university in Austin, Texas, an ethical hacker named Jake targeted a legacy Linux server in the engineering department. Late one afternoon, he discovered TCP port 2049 was open during his first sweep, suggesting hidden file-sharing capabilities. Intrigued, Jake used a standard utility to request a list of remote file systems shared across the network, aiming to map accessible resources. Meanwhile, he idly checked for Telnet access and probed a time-sync service out of routine, but both proved fruitless on this host.

Which enumeration method is actively demonstrated in this scenario?

- A. NFS Enumeration
- B. SNMP Enumeration
- C. NetBIOS Enumeration
- D. NTP Enumeration

Answer: A

Explanation

NFS Enumeration is the correct choice because the scenario is centered on TCP port 2049 and the use of a standard utility to list exported remote file systems. In CEH-aligned reconnaissance and enumeration, port 2049 is the primary service port for Network File System NFS. When a tester identifies 2049 as open on a Linux or UNIX-like host, a common next step is to enumerate NFS exports to learn which directories are shared and what access rules apply. The “standard utility” described is consistent with tools such as showmount, which queries the target to retrieve a list of exported file systems and, in some cases, the clients allowed to mount them. This directly supports the stated objective of “requesting a list of remote file systems shared across the network” to map accessible resources.

The distractor checks mentioned in the scenario reinforce why the answer is NFS. Telnet enumeration would relate to TCP 23 and interactive plaintext terminal access, not file-share exports. NTP enumeration aligns to UDP 123 and focuses on time synchronization information and server behavior, not shared directories. SNMP enumeration typically involves UDP 161 and extracts device and system details via community strings and management information bases. NetBIOS enumeration is associated with Windows networking services such as UDP 137 and TCP 139, which are unrelated to NFS on 2049.

Therefore, the active enumeration method demonstrated is NFS enumeration through export listing on TCP port 2049.

Question #:335 - [Network and Perimeter Hacking]

During a red team simulation at a bank in Chicago, Illinois, the SOC team suspects that some of the incoming traffic may be spoofed. To verify this, an analyst begins monitoring the sequence values assigned to packets, looking for irregularities that indicate they were not generated by the legitimate source. Which spoofing detection technique is the analyst using?

- A. Packet Filtering
- B. TCP Flow Control Method
- C. IP Identification Number (IPID) Monitoring
- D. Direct TTL Probes
- E. BThe analyst is using the TCP Flow Control Method because the scenario focuses on monitoring TCP sequence values for irregularities. In TCP communications, sequence (and acknowledgment) numbers are fundamental to flow control and reliability. A legitimate TCP stream follows predictable rules: sequence numbers progress according to the amount of data transmitted, acknowledgments align with received bytes, and the relationship between seq/ack values is consistent for each direction of the session. When traffic is spoofed—especially if an attacker injects packets without fully participating in the legitimate TCP state—those packets often contain sequence numbers that do not match the expected window for the established connection. This can create anomalies such as out-of-window sequence values, incorrect acknowledgments, or resets triggered by the endpoints. By monitoring sequence-related behavior, defenders can spot signs of forged or injected packets that were not produced by the true endpoint. This technique is particularly relevant when dealing with suspected TCP session spoofing or injection, where attackers attempt to insert data or disrupt sessions by guessing or stealing sequence numbers. Why the other options don't match the "sequence values" clue: Packet Filtering (A) is a preventive control (blocking by rules), not a detection method based on analyzing sequence progression. IPID Monitoring (C) focuses on the IP Identification field behavior patterns to infer spoofing (often OS-specific IPID increments), but the scenario is clearly about TCP sequence values, not IP header ID patterns. Direct TTL Probes (D) examine TTL characteristics (hop count anomalies) to infer spoofing or path differences; again, not sequence-number analysis. Therefore, the spoofing detection technique described is B. TCP Flow Control Method.

Answer: A B C D E

Question #:336 - [Security Operations and Incident Response]

After a breach, investigators discover attackers used modified legitimate system utilities and a Windows service to persist undetected and harvest credentials. What key step would best protect against similar future attacks?

- A. Disable unused ports and restrict outbound firewall traffic
- B. Perform weekly backups and store them off-site
- C. Ensure antivirus and firewall software are up to date
- D. Monitor file hashes of critical executables for unauthorized changes

Answer: D

Explanation

CEH materials describe this attack pattern as Living-off-the-Land (LotL), where attackers abuse legitimate tools to avoid detection. Because these binaries are normally trusted, traditional antivirus solutions may not flag them.

CEH recommends file integrity monitoring (FIM), which tracks cryptographic hashes of sensitive executables and alerts administrators when unauthorized modifications occur.

Option D is correct.

Options A and B support resilience but do not detect tampering.

Option C alone is insufficient against LotL attacks.

Question #:337 - [Mobile Platform and IoT Hacking]

You discover an unpatched Android permission-handling vulnerability on a device with fully updated antivirus software. What is the most effective exploitation approach that avoids antivirus detection?

- A. Develop a custom exploit using obfuscation techniques
- B. Use Metasploit to deploy a known payload
- C. Install a rootkit to manipulate the device
- D. Use SMS phishing to trick the user

Answer: A

Explanation

The CEH Mobile Platform Security module explains that mobile antivirus solutions rely heavily on signatures and known exploit patterns. A custom exploit with obfuscation is far more likely to bypass detection.

CEH explicitly teaches that:

Zero-day or unpatched vulnerabilities

Custom, obfuscated payloads

Minimal use of known frameworks

are the most effective for bypassing endpoint defenses during controlled testing.

Option A is correct.

Options B and C are easily detected.

Option D is social engineering, not a technical exploit.

Question #:338 - [Web Application Hacking]

A penetration tester is assessing a web application that uses dynamic SQL queries for searching users in the database. The tester suspects the search input field is vulnerable to SQL injection. What is the best approach to confirm this vulnerability?

- A. Input DROP TABLE users; -- into the search field to test if the database query can be altered
- B. Inject JavaScript into the search field to test for Cross-Site Scripting (XSS)
- C. Use a directory traversal attack to access server configuration files
- D. Perform a brute-force attack on the user login page to guess weak passwords

Answer: A

Explanation

CEH explains that SQL injection testing should begin with controlled, intentional manipulation of SQL syntax to determine whether user input is improperly concatenated into backend queries. While destructive queries like DROP TABLE are not recommended in real-world ethical hacking engagements, CEH uses this example as a conceptual demonstration of how SQLi can influence database commands. In practice, a penetration tester would more safely use benign tautologies such as ' OR '1'='1 to test whether unauthorized data is returned. However, within CEH's theoretical framing, injecting a clearly malicious SQL command demonstrates whether the input is executed at the database level. This validates improper sanitization, the use of dynamic SQL queries, and missing parameterized input handling. CEH stresses that SQLi is among the most critical vulnerabilities because it allows attackers to bypass authentication, exfiltrate data, or manipulate the database structure. XSS, brute-forcing, and directory traversal do not test SQL query manipulation and therefore do not confirm SQL injection.

Question #:339 - [Network and Perimeter Hacking]

During a penetration test at Horizon Tech in Austin, ethical hacker Michael sets up a man-in-the-middle attack to intercept traffic between employees and the company's internal web applications. He uses a lightweight tool capable of performing ARP spoofing, DNS manipulation, and packet injection while providing an interactive interface for real-time monitoring. This allows him to capture and manipulate session tokens in transit, which he later presents to the security team as proof of risk.

Which tool is Michael most likely using in this exercise?

- A. Wireshark
- B. Hetty
- C. Caido
- D. Bettercap

Answer: D

Explanation

The tool described is most consistent with Bettercap. Bettercap is a lightweight, extensible framework commonly used in controlled security testing for man-in-the-middle (MITM) operations on local networks. It supports ARP spoofing/ARP poisoning to position the attacker between victims and gateways, enabling interception of traffic. It also supports DNS manipulation/spoofing (e.g., redirecting domain lookups to attacker-controlled destinations) and packet injection capabilities for modifying or inserting traffic. Importantly, it provides an interactive interface that allows real-time session visibility and control, which matches the scenario's emphasis on interactive monitoring while intercepting internal web application traffic.

The objective described—capturing and manipulating session tokens in transit—is consistent with a MITM platform that can observe HTTP traffic (or influence traffic where TLS is not properly enforced or where testing includes trusted certificates in a lab). Bettercap's design as an “all-in-one” local network attack and monitoring tool makes it a typical choice for demonstrating risks from weak network segmentation, insecure DNS, lack of HTTPS/HSTS, or insufficient endpoint protections against ARP spoofing.

Why the other options are less suitable:

Wireshark (A) is primarily a packet analyzer/sniffer; it does not inherently perform ARP spoofing, DNS manipulation, or injection as an active MITM tool.

Hetty (B) and Caido (C) are web-focused interception/testing tools (proxy-style workflows). They can intercept HTTP/S when configured as a proxy, but they do not natively specialize in LAN-layer ARP spoofing and DNS manipulation for transparent MITM in the same way as Bettercap.

Therefore, the most likely tool is D. Bettercap.

Question #:340 - [Cloud Computing]

A corporation migrates to a public cloud service, and the security team identifies a critical vulnerability in the cloud provider's API. What is the most likely threat arising from this flaw?

- A. Distributed Denial-of-Service (DDoS) attacks on cloud servers
- B. Unauthorized access to cloud resources
- C. Physical security compromise of data centers
- D. Compromise of encrypted data at rest

Answer: B

Explanation

The CEH Cloud Computing module identifies cloud APIs as one of the most critical attack surfaces in public cloud environments. APIs control provisioning, configuration, authentication, and management of cloud resources.

A vulnerability in a cloud API can allow attackers to:

Bypass authentication

Escalate privileges

Access or modify cloud resources

Create or delete services

Option B is therefore correct.

Option A relates to availability, not API flaws.

Option C is managed by the provider and unrelated to APIs.

Option D would require key compromise, not just API weakness.

CEH strongly emphasizes API security as a top cloud risk.

Question #:341 - [Information Security and Ethical Hacking Overview]

During a physical penetration test simulating a social engineering attack, a threat actor walks into the lobby of a target organization dressed as a field technician from a known external vendor. Carrying a fake ID badge and referencing a known company name, the attacker confidently claims they've been dispatched to perform a routine server room upgrade. Using internal-sounding terminology and referencing real employee names gathered via OSINT, the individual conveys urgency. The receptionist, recognizing the vendor name and the convincing language, allows access without verifying the credentials.

- A. Perceived authority and reliance on third-party familiarity
- B. Leaked credentials on public networks and forums
- C. Trust in physical security logs used by security teams
- D. Misconfigured network segmentation allowing unauthorized access

Answer: A

Explanation

CEH's social engineering principles highlight psychological manipulation techniques such as authority, urgency, trust exploitation, and impersonation. In this scenario, the attacker leverages "perceived authority," a powerful influence tactic where the social engineer poses as someone with legitimate power or sanctioned access—such as a technician, auditor, or vendor representative. CEH emphasizes that referencing real employee names, using technical terminology, and impersonating trusted third-party partners increases believability and reduces verification resistance. The receptionist's acceptance of the attacker's presence without verifying credentials matches classical authority-based exploitation. Leaked credentials, physical security logs, and network segmentation issues do not relate to human-layer social engineering. The situation clearly reflects the manipulation of trust and authority as described in CEH's psychological attack vectors.

Question #:342 - [Network and Perimeter Hacking]

During a red team simulation, an attacker crafts packets with malformed checksums so the IDS accepts them but the target silently discards them. Which evasion technique is being employed?

- A. Insertion attack
- B. Polymorphic shellcode
- C. Session splicing
- D. Fragmentation attack

Answer: A

Explanation

CEH v13 outlines insertion attacks as IDS evasion methods in which attackers send packets deliberately crafted so that the IDS processes them differently from the target host. In an insertion attack, malformed packets appear legitimate to the IDS—allowing malicious traffic to blend with benign inspection results—while the end host rejects or modifies the packets due to incorrect checksums, invalid flags, or protocol inconsistencies. As a result, the IDS sees one set of reconstructed data, while the actual host processes a different version or nothing at all. CEH emphasizes that intrusion detection systems may not follow full TCP/IP stack validation, making them susceptible to deception by malformed or borderline-conformant packets. Polymorphic shellcode (Option B) changes payload signatures, not packet structure. Session splicing (Option C) splits payload across packets to evade pattern matching but does not rely on checksum manipulation. Fragmentation attacks (Option D) divide traffic into smaller fragments, not alter validity fields. The described behavior fits insertion attacks precisely.

Question #:343 - [Information Security and Ethical Hacking Overview]

A penetration tester is hired by a company to assess its vulnerability to social engineering attacks targeting its IT department. The tester decides to use a sophisticated pretext involving technical jargon and insider information to deceive employees into revealing their network credentials. What is the most effective social engineering technique the tester should employ to maximize the chances of obtaining valid credentials without raising suspicion?

- A. Conduct a phone call posing as a high-level executive requesting urgent password resets
- B. Send a generic phishing email with a malicious attachment to multiple employees
- C. Create a convincing fake IT support portal that mimics the company's internal systems
- D. Visit the office in person as a maintenance worker to gain physical access to terminals

Answer: C

Explanation

CEH training emphasizes that highly tailored social engineering attacks—those exploiting trust in internal workflows and perceived technical authority—are far more effective than generic or mass-distributed phishing attempts. A fake IT support portal that mirrors internal systems leverages procedural familiarity: IT departments commonly instruct employees to log into support portals for troubleshooting, credential verification, or ticket updates. When the attacker enhances the pretext with insider terminology and references to real internal systems, employees are more likely to trust the portal and enter credentials. CEH highlights that successful social engineering attacks mimic legitimate processes to avoid suspicion. Phone calls posing as executives often introduce risk due to real-time interaction and scrutiny. Generic phishing lacks personalization and is easily detected. Physical impersonation introduces operational risk and may not yield credentials. Therefore, a fake IT support portal aligned with IT workflows is the optimal method.

Question #:344 - [Web Application Hacking]

In Miami, Florida, cybersecurity analyst Laura Bennett is responding to a series of unauthorized access attempts targeting Sunshine Credit Union's online banking platform. She observes unusual network activity that suggests attackers may be intercepting session IDs transmitted over unsecured connections to hijack active user sessions. To prevent further compromise, Laura works with the network team to apply a control that secures session-related communications throughout the entire portal, ensuring sensitive tokens are no longer exposed to interception during user interactions.

What countermeasure should Laura implement to prevent session hijacking in this scenario?

- A. Regenerate the session ID after a successful login
- B. Implement SSL to encrypt all information in transit via the network
- C. Use restrictive cache directives such as Cache-Control no-cache
- D. Do not create sessions for unauthenticated users

Answer: B

Explanation

The scenario clearly indicates session hijacking risk caused by interception of session IDs over unsecured connections. In CEH-aligned web security, when session tokens are transmitted without strong transport encryption, an attacker positioned on the same network path can sniff traffic and capture cookies or URL-based session IDs, then reuse them to impersonate the victim. The most effective control that directly addresses interception in transit across the entire portal is enforcing SSL/TLS for all session-related communications, meaning every page and request that could carry authentication state is protected by HTTPS. This prevents passive eavesdropping and significantly reduces the feasibility of man-in-the-middle capture of session identifiers during normal user interactions.

Option A, regenerating the session ID after login, is an important defense against session fixation, but it does not stop an attacker from stealing the new session token if it is later transmitted over plaintext HTTP. Option C, cache-control directives, helps prevent sensitive pages from being stored in shared caches or browser history, but it does not protect session IDs from network sniffing. Option D, avoiding sessions for unauthenticated users, can reduce some tracking exposure, yet the core issue here is hijacking of authenticated sessions due to unencrypted transport.

Therefore, implementing SSL/TLS across the portal, typically combined with secure cookie flags and strict HTTPS enforcement, is the correct countermeasure for the described interception-based session hijacking.

Question #:345 - [Mobile Platform, IoT, and OT Hacking]

A multinational company plans to deploy an IoT-based environmental control system across global manufacturing units. The security team must identify the most likely attack vector an Advanced Persistent Threat (APT) group would use to compromise the system. What is the most plausible method?

- A. Launching a DDoS attack to overload IoT devices
- B. Compromising the system using stolen user credentials
- C. Exploiting zero-day vulnerabilities in IoT device firmware
- D. Performing an encryption-based Man-in-the-Middle attack

Answer: C

Explanation

The CEH IoT and APT Threat modules describe APT groups as highly skilled adversaries that favor stealth, persistence, and advanced exploitation techniques. IoT environments are particularly attractive due to:

Limited monitoring

Infrequent firmware updates

Weak or proprietary security mechanisms

CEH highlights that APT actors often exploit zero-day vulnerabilities in firmware to gain long-term, covert access to IoT systems. Firmware-level exploitation allows attackers to maintain persistence while evading traditional security controls.

Option C is correct.

Option A is noisy and short-term.

Option B is common but less sophisticated for APTs.

Option D is possible but secondary compared to firmware exploitation.

CEH emphasizes firmware security as a critical concern in IoT deployments.

Question #:346 - [Mobile Platform and IoT Hacking]

During a security assessment of a metropolitan public transportation terminal, a penetration tester examines a network-connected IoT surveillance camera system used for 24/7 video monitoring. The camera uses outdated

SSLv2 encryption to transmit video data. The tester intercepts and decrypts video streams due to the weak encryption and absence of authentication mechanisms. What IoT vulnerability is most likely being exploited in this scenario?

- A. Insecure data transfer and storage
- B. Jamming attack on RF communication
- C. Credential theft via web application
- D. Replay attack on wireless signals

Answer: A

Explanation

CEH identifies insecure data transfer as a critical IoT weakness. Outdated encryption protocols such as SSLv2 fail to protect confidentiality or integrity. Without strong encryption and authentication, attackers can intercept, decrypt, and manipulate video feeds.

Question #:347 - [System Hacking Phases]

A penetration tester is tasked with identifying vulnerabilities on a web server running outdated software. The server hosts several web applications and is protected by a basic firewall. Which technique should the tester use to exploit potential server vulnerabilities?

- A. Conduct a SQL injection attack on the web application's login form
- B. Perform a brute-force login attack on the admin panel
- C. Execute a buffer overflow attack targeting the web server software
- D. Use directory traversal to access sensitive configuration files

Answer: C

Explanation

Outdated server software often contains memory corruption flaws. CEH notes that buffer overflow exploits are a primary method for compromising vulnerable server binaries, allowing remote code execution. This approach targets the underlying service rather than application-layer input validation issues.

Question #:348 - [System Hacking Phases]

A penetration tester has gained access to a target system using default credentials. What is the most effective next step to escalate privileges on the system?

- A. Perform a denial-of-service (DoS) attack to crash the system

- B. Use a known local privilege escalation vulnerability to gain admin access
- C. Execute a Cross-Site Scripting (XSS) attack on the system's login page
- D. Use a dictionary attack to brute-force the root password

Answer: B

Explanation

Once initial access is obtained—especially through weak or default credentials—the CEH system hacking methodology directs the tester to proceed to privilege escalation. The objective is to elevate user-level access to administrative or system-level privileges so the attacker can perform unrestricted actions such as installing tools, modifying configurations, accessing protected files, and pivoting laterally. CEH materials emphasize using privilege escalation vulnerabilities, such as misconfigured services, kernel exploits, unpatched local privilege escalation flaws, weak file permissions, and token impersonation. A denial-of-service attack is counterproductive and does not support post-exploitation goals. XSS is a web application attack vector and unrelated to operating system privilege manipulation. Brute-forcing the root password is noisy, slow, and unnecessary when authenticated access is already established. Therefore, exploiting a known local privilege escalation vulnerability is the appropriate CEH-aligned next step.

Question #:349 - [Cryptography]

A hacker is analyzing a system that uses two rounds of symmetric encryption with different keys. To speed up key recovery, the attacker encrypts the known plaintext with all possible values of the first key and stores the intermediate ciphertexts. Then, they decrypt the final ciphertext using all possible values of the second key and compare the results to the stored values. Which cryptanalytic method does this approach represent?

- A. Flood memory with brute-forced credentials
- B. Scrape electromagnetic leakage for bits
- C. Use midpoint collision to identify key pair
- D. Reverse permutations to bypass encryption

Answer: C

Explanation

CEH covers advanced cryptanalytic attacks, including Meet-in-the-Middle (MITM) attacks, which are especially effective against multi-round symmetric encryption schemes. When an algorithm encrypts data twice using different keys, the naive brute-force method would require testing every possible combination of both keys—a time complexity of $2^n \times 2^n$. Meet-in-the-Middle dramatically reduces this complexity by splitting the problem in half. Attackers encrypt the plaintext using all potential values of the first key and store the results. They then decrypt the final ciphertext using all possible values of the second key. When an intermediate value matches one in storage, the corresponding key pair is identified. CEH highlights that this approach exploits the lack of key independence between two encryption layers, demonstrating how doubling

encryption does not always double security. This attack is well-known for targeting 2DES, one of the historical examples covered in CEH. It is not related to side-channel attacks, brute-force flooding, or permutation reversal; it strictly relies on midpoint matching to reduce computational workload.

Question #:350 - [Security Operations and Incident Response]

During an IDS audit, you notice numerous alerts triggered by legitimate user activity. What is the most likely cause?

- A. Regular users are unintentionally triggering security protocols
- B. The firewall is failing to block malicious traffic
- C. The IDS is outdated and unpatched
- D. The IDS is configured with overly sensitive thresholds

Answer: D

Explanation

According to the CEH IDS/IPS module, false positives occur when legitimate activity is incorrectly flagged as malicious. The most common cause is overly sensitive IDS rules or thresholds.

Option D correctly identifies this issue.

Option A describes the symptom, not the root cause.

Option B is unrelated to IDS alert behavior.

Option C can cause missed detections, not excessive alerts.

CEH recommends proper tuning and baseline profiling.

Question #:351 - [Social Engineering]

During a security penetration test at Sterling Manufacturing in Cleveland, Ohio, the ethical hacking team evaluates the company's physical security controls. On a chilly evening in July 2025, ethical hacker Priya Desai, posing as a facilities contractor, accesses the company's loading dock area after regular business hours. Behind the employee entrance, she comes across an unsecured maintenance container with discarded packaging, shipping labels, and shredded office material. Among the clutter, Priya retrieves a crumpled document listing temporary access codes for the employee break room, along with a partially shredded memo referencing an upcoming audit. The exercise tests whether sensitive information discarded improperly can be exploited. The next day, Priya uses the recovered access codes to enter the break room undetected during a shift change, logging her entry on a controlled test system to simulate a breach.

What social engineering technique is Priya's exercise primarily simulating?

- A. Tailgating

- B. Eavesdropping
- C. Dumpster Diving
- D. Shoulder Surfing

Answer: C

Explanation

This scenario primarily simulates dumpster diving because the key action involves retrieving sensitive information from discarded materials and then using it to gain access. In CEH social engineering coverage, dumpster diving is a physical information-gathering technique where an attacker searches trash, recycling bins, unsecured disposal containers, or shredding waste to find documents and artifacts that can be exploited. Common targets include access codes, employee directories, printed emails, shipping labels, invoices, internal memos, and partially shredded documents—exactly what Priya finds in the unsecured maintenance container. The question even emphasizes “discarded packaging,” “shipping labels,” “shredded office material,” and a “crumpled document listing temporary access codes,” which are classic dumpster-diving indicators.

The later use of recovered access codes to enter the break room is the impact of the dumpster-diving phase, but the primary social engineering technique tested is how improper disposal leads to compromise. Tailgating would involve following an authorized person through a secure door without proper authentication. Eavesdropping refers to listening in on conversations or communications to capture sensitive information. Shoulder surfing involves visually observing someone’s screen or keyboard while they enter credentials or view confidential data. None of those describe the initial method of obtaining the access codes.

CEH-aligned mitigations include enforcing clean-desk and secure disposal policies, using locked disposal bins, shredding sensitive documents properly with secure destruction processes, training staff on handling printed data, and restricting access to loading docks and waste areas. Regular audits of disposal practices and physical security checks reduce the likelihood that attackers can harvest usable access details from trash.

Question #:352 - [Network and Perimeter Hacking]

Which technique is most likely used to evade detection by an Intrusion Detection System (IDS)?

- A. Fragmenting malicious packets into smaller segments
- B. Using self-replicating malware
- C. Sending phishing emails
- D. Flooding the IDS with ping requests

Answer: A

Explanation

CEH v13 explains that packet fragmentation is a classic and effective IDS evasion technique. By breaking malicious payloads into smaller fragments, attackers attempt to prevent the IDS from reconstructing the full packet stream correctly, thereby avoiding signature detection.

Many IDS systems rely on packet reassembly and pattern matching. Fragmented packets can confuse or overload the reassembly process, especially if the IDS is poorly configured. CEH v13 specifically lists fragmentation, overlapping fragments, and out-of-order packets as evasion techniques used to bypass network defenses.

Option B describes malware propagation, not IDS evasion. Option C is a social engineering attack, unrelated to IDS detection. Option D is a denial-of-service attempt, not a stealth evasion method.

CEH v13 highlights that defending against fragmentation-based evasion requires proper normalization and reassembly configuration in IDS/IPS systems. Therefore, Option A is the correct answer.

Question #:353 - [Security Operations and Incident Response]

A Nessus scan reports a CVSS 9.0 SSH vulnerability allowing remote code execution. What should be immediately prioritized?

- A. Apply the vendor patch and reboot during maintenance
- B. Dismiss it as a false positive if unverified
- C. Reroute SSH traffic to another server
- D. Isolate the server, audit it, and apply patches

Answer: D

Explanation

CEH v13 states that vulnerabilities with a CVSS score # 9.0 are critical and require immediate containment. When remote code execution is possible, the system may already be compromised.

The recommended response is to isolate the affected system, preventing lateral movement, then perform a forensic audit before applying patches. Immediate patching without isolation may alert attackers or destroy evidence.

Thus, option D aligns with CEH incident response best practices.

Question #:354 - [Network and Perimeter Hacking]

An attacker exploits legacy protocols to perform advanced sniffing. Which technique is the most difficult to detect and neutralize?

- A. HTTP header overflow extraction

- B. SMTP steganographic payloads
- C. Covert channel via Modbus protocol manipulation
- D. X.25 packet fragmentation

Answer: C

Explanation

CEH v13 identifies covert channels in legacy industrial protocols as among the hardest sniffing techniques to detect. Modbus, widely used in OT and ICS environments, lacks authentication and encryption, making it ideal for covert communication.

Attackers can manipulate function codes and payload timing to exfiltrate data without triggering traditional IDS signatures. CEH v13 highlights that OT protocols often bypass deep inspection tools, making covert channels extremely stealthy.

Other options are less realistic or less persistent in modern enterprise environments.

Question #:355 - [Reconnaissance Techniques]

In a controlled testing environment in Houston, Sarah, an ethical hacker, is tasked with evaluating the security posture of a financial firm's network using the cyber kill chain methodology. She begins by simulating an attack, starting with gathering publicly available data about the company's employees and infrastructure. Next, she plans to craft a mock phishing email to test employee responses, followed by deploying a harmless payload to assess system vulnerabilities. As part of her authorized penetration test, what phase of the cyber kill chain should Sarah prioritize to simulate the adversary's approach effectively?

- A. Exploitation
- B. Reconnaissance
- C. Weaponization
- D. Delivery

Answer: B

Explanation

Reconnaissance is the correct phase because the scenario explicitly states Sarah starts by gathering publicly available information about employees and infrastructure. In the Cyber Kill Chain, reconnaissance is the first phase where an attacker collects intelligence to understand the target and identify the most effective paths for compromise. In CEH-aligned methodology, this includes open-source intelligence activities such as discovering employee names, roles, emails, technology stack clues, exposed services, and organizational patterns that help craft realistic and convincing attack lures.

The question mentions that Sarah plans to craft a mock phishing email and later deploy a harmless payload. Those actions map to later kill chain phases: delivery is when the phishing email or malicious link is sent to

the target, and exploitation is when a vulnerability is triggered to execute code or gain access. Weaponization is the step where an attacker prepares the malicious artifact, such as packaging an exploit with a payload or preparing a document or link to deliver. However, the key wording is that Sarah “begins” by collecting public information and is asked which phase she should prioritize to simulate the adversary’s approach effectively. That is reconnaissance, because effective phishing and subsequent steps depend on accurate target profiling, believable pretexts, and identifying likely weak points based on what is learned during intelligence gathering.

Therefore, to match the described starting point and the kill chain sequence, the prioritized phase is Reconnaissance.

Question #:356 - [Network and Perimeter Hacking]

A global media streaming platform experiences traffic surges every 10 minutes, with spikes over 300 Gbps followed by quiet intervals. Which DDoS attack explains this behavior?

- A. UDP flood sustained attack
- B. Recursive HTTP GET flood
- C. Permanent DoS (PDoS)
- D. Pulse Wave attack

Answer: D

Explanation

This scenario clearly aligns with a Pulse Wave DDoS attack, a sophisticated denial-of-service technique described in CEH v13 Network and Perimeter Hacking. Unlike traditional volumetric DDoS attacks that rely on sustained flooding, pulse wave attacks deliver short, extremely high-volume bursts of traffic, followed by periods of inactivity.

The defining characteristics described—intermittent spikes exceeding 300 Gbps, regular intervals (every 10 minutes), and temporary recovery—are hallmark indicators of pulse wave attacks. CEH v13 explains that attackers use this method to overwhelm server resources, trigger auto-scaling failures, exhaust mitigation thresholds, and evade detection systems that rely on sustained traffic baselines.

Option A is incorrect because UDP floods are continuous. Option B (HTTP GET flood) targets the application layer with sustained requests. Option C (PDoS) permanently damages hardware, which does not match the recurring pattern.

Pulse wave attacks are particularly effective against large platforms like streaming services because they:

Exploit elasticity limits of cloud infrastructure

Confuse rate-based detection systems

Cause repeated service degradation without long attack durations

CEH v13 emphasizes that pulse wave attacks are difficult to mitigate without adaptive, behavior-based DDoS protection. Therefore, Option D is the correct and CEH-aligned answer.

Question #:357 - [Network and Perimeter Hacking]

During a security audit, a penetration tester observes abnormal redirection of all traffic for a financial institution's primary domain. Users are being redirected to a phishing clone of the website. Investigation shows the authoritative DNS server was compromised and its zone records modified to point to the attacker's server. This demonstrates total manipulation of domain-level resolution, not cache poisoning or client-side attacks. Which technique is being used in this scenario?

- A. Establish covert communication using DNS tunneling over standard DNS queries
- B. Perform DNS rebinding to manipulate browser-origin interactions
- C. Carry out DNS server hijacking by tampering with the legitimate name-resolution infrastructure
- D. Initiate a DNS amplification attack using recursive servers

Answer: C

Explanation

CEH v13 states that DNS server hijacking occurs when attackers compromise the authoritative DNS infrastructure and alter DNS zone records to redirect all legitimate queries to malicious destinations. Unlike DNS cache poisoning, which affects specific resolvers temporarily, server hijacking manipulates the core DNS authority controlling the domain. This results in a complete redirect for all users, regardless of geographic location or device configuration. CEH emphasizes that such attacks can lead to large-scale credential theft, phishing, financial fraud, and session compromise because the attacker presents an identical clone site while retaining full control of DNS routing. DNS tunneling is used for covert data exfiltration and does not redirect traffic. DNS rebinding targets browser policies, not global DNS redirection. DNS amplification is a volumetric DDoS technique unrelated to zone manipulation. The scenario matches DNS server hijacking exactly.

Question #:358 - [Web Application Hacking]

Which technique best exploits session management despite MFA, encrypted cookies, and WAFs?

- A. CSRF
- B. Side jacking
- C. Session fixation
- D. Insecure deserialization

Answer: D

Explanation

CEH v13 emphasizes that insecure deserialization is one of the most dangerous application vulnerabilities because it can lead to arbitrary code execution, bypassing authentication, authorization, and session protections entirely.

Even with MFA, encrypted cookies, and WAFs, deserialization flaws allow attackers to manipulate serialized objects used in session handling. When deserialized without validation, these objects may execute attacker-controlled code.

CSRF relies on authenticated users. Side jacking is mitigated by encryption. Session fixation is ineffective if session regeneration and MFA are implemented. Insecure deserialization, however, attacks the application logic itself, making it the most effective option.

Thus, Option D is correct.

Question #:359 - [Security Operations and Incident Response]

Repeated failed login attempts are followed by a sudden surge in outbound data traffic from a critical server. What should be your initial course of action?

- A. Audit all outbound traffic and analyze destination IPs
- B. Immediately disconnect the server from the network
- C. Perform real-time monitoring and log analysis to understand the activity
- D. Change server credentials and force password resets

Answer: C

Explanation

According to CEH v13 Security Operations and Incident Response, the first step in incident handling is identification and analysis, not immediate containment or remediation. The observed sequence—failed logins followed by abnormal outbound traffic—suggests a potential compromise, but the exact nature, scope, and impact are still unknown.

Option C aligns precisely with CEH v13's incident response lifecycle. Real-time monitoring and detailed log analysis allow the analyst to determine whether the activity represents credential stuffing, brute-force compromise, malware-based exfiltration, or a false positive. This step preserves evidence, establishes timelines, and helps identify indicators of compromise (IOCs).

Immediately disconnecting the server (Option B) may be necessary later, but doing so prematurely can destroy volatile forensic evidence, disrupt business operations, and alert the attacker. Auditing outbound traffic alone (Option A) is too narrow and skips proper correlation of authentication logs, system logs, and process activity. Forcing credential changes (Option D) without understanding the attack vector may fail to stop malware-based persistence.

CEH v13 emphasizes that containment actions must be informed by analysis, otherwise organizations risk responding to symptoms rather than root causes. Therefore, the correct initial action is to observe, analyze, and identify, making Option C the correct answer.

Question #:360 - [Malware Threats]

Malware infecting multiple systems remains dormant until triggered and changes its code or encryption with each infection to evade detection. Which malware type best fits this description, and what is the most effective mitigation?

- A. Rootkit – use anti-rootkit tools and patch systems
- B. Adware – deploy anti-adware tools and train users
- C. Worm – isolate infected systems and scan the network
- D. Polymorphic malware – use behavior-based detection and ensure systems are patched

Answer: D

Explanation

The CEH Malware Threats module defines polymorphic malware as malicious code that mutates its appearance (code, encryption, packing) each time it propagates, making signature-based detection ineffective. Dormancy and trigger-based activation are also common characteristics.

CEH emphasizes that behavior-based detection, sandboxing, and heuristic analysis are the most effective countermeasures against polymorphic threats.

Option D is correct.

Options A, B, and C do not address polymorphic evasion techniques.

Question #:361 - [System Hacking Phases]

During a high-stakes engagement, a penetration tester abuses MS-EFSRPC to force a domain controller to authenticate to an attacker-controlled server. The tester captures the NTLM hash and relays it to AD CS to obtain a certificate granting domain admin privileges. Which network-level hijacking technique is illustrated?

- A. Hijacking sessions using a PetitPotam relay attack
- B. Exploiting vulnerabilities in TLS compression via a CRIME attack
- C. Stealing session tokens using browser-based exploits
- D. Employing a session donation method to transfer tokens

Answer: A

Explanation

CEH v13 describes relay attacks as credential forwarding techniques where attackers trick systems into authenticating to malicious servers, capturing hashes, and relaying them to privileged services. The described scenario aligns exactly with the PetitPotam attack, a known MS-EFSRPC abuse method that forces Windows domain controllers to perform NTLM authentication to attacker-controlled hosts. CEH discusses how relay attacks combined with Active Directory Certificate Services (AD CS) misconfigurations can allow attackers to request privileged certificates, effectively gaining domain administrator privileges without cracking hashes or accessing LSASS. CRIME (Option B) targets TLS compression and is unrelated. Browser token theft (Option C) applies to web sessions, not domain controllers. Session donation (Option D) is not part of Windows authentication hijacking. Thus, the scenario clearly represents a PetitPotam NTLM relay attack.

Question #:362 - [Web Application Hacking]

During an investigation, an ethical hacker discovers that a web application's API has been compromised, leading to unauthorized access and data manipulation. The attacker is using webhooks and a webshell. To prevent further exploitation, which of the following actions should be taken?

- A. Implement a Web Application Firewall (WAF) with rules to block webshell traffic and increase the logging verbosity of webhooks.
- B. Perform regular code reviews for the webhooks and modify the API to block connections from unknown IP addresses.
- C. Harden the web server security, add multi-factor authentication for API users, and restrict the execution of scripts server-side.
- D. Implement input validation on all API endpoints, review webhook payloads, and schedule regular scanning for webshells.

Answer: D

Explanation

This question focuses on API Security, Webhooks abuse, and Webshell mitigation, all of which are addressed in the CEH v13 Web Application Hacking and Security Operations modules. The most appropriate corrective action is Option D, as it directly addresses the root causes and persistence mechanisms of the compromise.

According to CEH v13, attackers frequently exploit improper input validation in APIs and insecure webhook implementations to inject malicious payloads or gain remote command execution. Webhooks, when not properly validated, can accept malicious requests that trigger backend processes, making them a common vector for API abuse.

Input validation on all API endpoints is critical to prevent injection attacks, including command injection and SQL injection. CEH v13 explicitly emphasizes validating request parameters, headers, and payload structures to prevent malicious manipulation.

Reviewing webhook payloads ensures that only trusted sources can trigger automated actions, preventing attackers from abusing webhook functionality. This includes validating signatures, enforcing authentication, and restricting allowed payload formats.

Finally, regular scanning for webshells is essential because webshells provide persistent backdoor access. CEH v13 identifies webshell detection as a key defensive measure during incident response and post-exploitation containment.

Other options are incomplete:

A WAF alone cannot detect all webshells.

IP blocking is ineffective against spoofed or cloud-based attacks.

MFA and server hardening are valuable but do not directly address webhook abuse or existing webshells.

Therefore, Option D provides the most comprehensive, CEH v13-aligned mitigation strategy.

Question #:363 - [Malware Threats]

During a penetration test at a shipping company in Miami, ethical hacker Daniel delivers a disguised email attachment containing a hidden payload. Once executed by employees, the compromised workstations begin to silently communicate with a remote server under Daniel's control. Over the following week, he confirms that multiple infected endpoints can receive synchronized commands and perform background tasks simultaneously, including sending bursts of outbound traffic on demand.

Which type of malicious component is Daniel most likely simulating in this assessment?

- A. Spyware
- B. Botnet Agents
- C. Scareware
- D. Potentially Unwanted Applications (PUAs)

Answer: B

Explanation

The correct answer is B. Botnet Agents because the behavior described matches a command-and-control (C2) driven malware model where multiple compromised systems ("bots" or "zombies") communicate with a remote controller and can be issued coordinated commands. In CEH-aligned malware concepts, a botnet is a collection of infected endpoints under centralized or distributed control. The malicious component installed on each infected workstation is commonly referred to as a bot/bot agent, which "checks in" to a C2 server to receive instructions and execute tasks silently in the background.

Several details strongly indicate botnet agent behavior: the payload is delivered via a disguised email attachment (a common initial infection vector), compromised machines silently communicate outbound to a

remote server, and—most importantly—Daniel confirms multiple infected endpoints can receive synchronized commands and carry out actions simultaneously. The example of “sending bursts of outbound traffic on demand” aligns with typical botnet capabilities such as orchestrated DDoS traffic generation, mass scanning, spam sending, credential stuffing, or distributed task execution. The sustained observation “over the following week” also fits a botnet model where infected hosts maintain persistence and periodically beacon to C2 for updates and instructions.

Why the other options do not fit: Spyware primarily focuses on covertly collecting information (keystrokes, screenshots, browsing data) rather than executing synchronized commands across many machines. Scareware relies on alarming messages to trick users into paying or installing unwanted software; it does not describe silent C2 coordination. PUAs are typically unwanted but not necessarily malicious, often installed via bundling and usually lack structured C2 for coordinated remote command execution.

Therefore, the malicious component being simulated is best identified as botnet agents operating under C2 control.

Question #:364 - [Web Application Hacking]

During a security assessment, a consultant investigates how the application handles requests from authenticated users. They discover that once a user logs in, the application does not verify the origin of subsequent requests. To exploit this, the consultant creates a web page containing a malicious form that submits a funds transfer request to the application. A logged-in user, believing the page is part of a promotional campaign, fills out the form and submits it. The application processes the request successfully without any reauthentication or user confirmation, completing the transaction under the victim's session. Which session hijacking technique is being used in this scenario?

- A. Hijacking a user session using a session fixation attack
- B. Hijacking a user session using a session replay attack
- C. Hijacking a user session using a cross-site request forgery attack
- D. Hijacking a user session using a cross-site script attack

Answer: C

Explanation

CEH v13 describes Cross-Site Request Forgery (CSRF) as an attack in which an authenticated user's browser is tricked into submitting unauthorized actions to a trusted application without the user's intent. CSRF exploits the fact that browsers automatically include stored session cookies when sending requests to a domain the user is logged into. In this scenario, the attacker creates a malicious form that triggers an unwanted funds transfer. Since the application does not validate request origin, enforce CSRF tokens, or require secondary verification, it processes the attacker's forged request as if it came legitimately from the victim. CEH emphasizes that CSRF differs from XSS because no malicious script executes on the target website; instead, the attacker leverages the victim's authenticated session. This is distinct from session fixation (Option A), replay attacks (Option B), and XSS (Option D). The described behavior aligns precisely with CSRF exploitation.

Question #:365 - [Reconnaissance Techniques]

A financial startup in Chicago hires an ethical hacker to evaluate its exposure on hidden networks. The client is particularly concerned that confidential administrative documents might be circulating on .onion sites. To remain passive, the hacker relies on advanced search filters to look for files with headers suggesting management-related content. Which of the following queries would best meet this objective?

- A. filetype:docx "credentials"
- B. filetype:pdf intitle:"secure login" site:onion
- C. filetype:pdf intitle:"admin access" site:onion
- D. filetype:docx intitle:"user accounts" site:onion

Answer: C**Explanation**

The objective is to conduct passive reconnaissance for potentially exposed administrative documents on .onion sites, using advanced search operators. The query should therefore (1) restrict results to the hidden-network domain space, (2) focus on document formats likely to contain internal material, and (3) use a title/header hint that aligns with management or administration content.

Option C is the best match because it combines:

site:onion to constrain results to .onion resources (the target environment of concern),

filetype:pdf to focus on a common format for internal documents (policies, reports, procedures, administrative exports), and

intitle:"admin access" to search for pages/files whose title/header metadata indicates administrative relevance. Using intitle aligns with the requirement to look for files "with headers suggesting management-related content," because titles are a practical proxy for document headers and indexing metadata.

By comparison, A does not include site:onion, so it is not scoped to hidden services, and it targets "credentials" rather than administrative documents. B includes site:onion and filetype:pdf, but the title focus is "secure login," which is more likely to find authentication pages or generic security guidance rather than administrative document exposure. D is also plausible (docx + user accounts), but "user accounts" tends to point to account lists or HR-style docs rather than broader administrative access documentation, and PDFs are frequently used for formal administrative documentation and may be more commonly indexed.

Thus, C best satisfies the passive, targeted reconnaissance requirement for admin-related documents on .onion sites.

Question #:366 - [Web Application Hacking]

Multiple failed login attempts using expired tokens are followed by successful access with a valid token. What is the most likely attack scenario?

- A. Capturing a valid token before expiry
- B. Token replay attack using expired tokens
- C. Brute-forcing token generation
- D. Exploiting a race condition in token validation

Answer: D

Explanation

This scenario strongly suggests a race condition attack in the application's token validation logic, as described in CEH v13 Web Application Hacking. A race condition occurs when an application processes multiple requests simultaneously and fails to properly synchronize validation checks.

The presence of multiple failed attempts using expired tokens followed by successful access within a short time window indicates the attacker exploited a timing flaw. During this window, the system may have inconsistently validated token expiration, allowing an expired token to be accepted.

Option A is unlikely because the logs specifically reference expired tokens. Option B is incorrect because replaying expired tokens should fail unless a validation flaw exists. Option C is highly improbable due to token entropy.

CEH v13 highlights race conditions as advanced logic flaws that are difficult to detect and often missed during standard testing. They are commonly exploited in authentication, payment processing, and session management systems.

Therefore, Option D is the correct and CEH-aligned answer.

Question #:367 - [Network and Perimeter Hacking]

At Pinnacle Financial Services in Chicago, Illinois, ethical hacker Sarah Thompson is conducting a penetration test to evaluate the security of the company's online banking portal. During her assessment, Sarah positions herself on the internal network and uses a sniffer to capture traffic between a user's browser and the banking server. She quietly collects session data, including user IDs and authentication tokens, without interfering with the ongoing communication. Later, she plans to use this information to impersonate a legitimate user in a controlled test environment to demonstrate potential risk to the bank's IT team.

What type of session hijacking is Sarah performing during this phase of her penetration test?

- A. Session Fixation Attack
- B. Active Session Hijacking
- C. Man-in-the-browser Attack
- D. Passive Session Hijacking

Answer: D

Explanation

The activity described is passive session hijacking because Sarah is only observing and capturing session-related information without altering, injecting, or disrupting the live client server communication. In CEH coverage of session hijacking, the key distinction is whether the attacker merely eavesdrops to obtain session identifiers or actively takes control of the session in real time. Passive hijacking focuses on sniffing traffic to collect authentication material such as session IDs, cookies, bearer tokens, or other credentials transmitted in cleartext or exposed through weak transport protections. The prompt explicitly says she “quietly collects session data” and does so “without interfering,” which is the hallmark of passive hijacking.

This is commonly feasible when applications use unencrypted HTTP, weak TLS configurations, or when tokens are exposed in ways that can be captured on the network. Once obtained, the attacker can replay or reuse the stolen token to impersonate the victim, which matches Sarah’s plan to later use the captured tokens to demonstrate risk in a controlled environment. CEH emphasizes that session tokens effectively become the user’s identity after authentication; if an attacker can steal them, they can often bypass login entirely.

Option B, active session hijacking, would involve manipulating the connection, injecting packets, desynchronizing the client, or taking over the session live. Option A, session fixation, involves forcing a victim to use a session ID chosen by the attacker, not sniffing. Option C, man-in-the-browser, requires malware within the browser to intercept or modify transactions, which is not described. Therefore, Passive Session Hijacking is correct.

Question #:368 - [Network and Perimeter Hacking]

You are performing a security audit for a regional hospital in Dallas, Texas. While monitoring the network, you discover that an unknown actor has been silently capturing clear-text credentials and analyzing unencrypted traffic flowing across the internal Wi-Fi network. No modifications have been made to the data, and the attack remained undetected until your assessment. Based on this activity, what type of attack is most likely being conducted?

- A. Passive attack
- B. Distribution attack
- C. Close-in attack
- D. Insider attack

Answer: A

Explanation

The correct answer is A. Passive attack because the activity described involves monitoring and capturing information without altering data, system resources, or communications. In CEH-aligned information security concepts, passive attacks are defined by the attacker’s goal of eavesdropping—observing traffic to collect intelligence such as usernames/passwords, session identifiers, network patterns, or sensitive content—while making minimal changes that would trigger detection. The scenario explicitly states that the actor is “silently capturing clear-text credentials” and “analyzing unencrypted traffic,” and that “no modifications have been made to the data.” These are signature indicators of passive attacks such as packet sniffing and traffic analysis.

On an internal Wi-Fi network, passive attacks are particularly effective when encryption is weak or absent, or when users access services that transmit credentials in clear text. An attacker can capture packets and reconstruct sensitive information, especially where legacy protocols or misconfigurations exist. Because passive attackers do not need to inject or modify packets, they often avoid generating anomalies such as retransmissions, spoofed responses, or unexpected routing changes—helping them remain undetected, consistent with the prompt.

Why the other options do not fit: Distribution attack is not the standard classification for this behavior and does not specifically describe silent observation of traffic. Close-in attack refers to attacks that depend on physical proximity (e.g., shoulder surfing, physical tapping, local interception near the target). While Wi-Fi sniffing can require proximity, the defining characteristic in the question is the non-invasive observation with no data modification—i.e., passive attack. Insider attack relates to the attacker's identity/role (a trusted internal person), which is not established here; the scenario only describes behavior, not who the actor is.

Therefore, the described credential capture and traffic analysis without modification most clearly indicates a passive attack.

Question #:369 - [Security Operations and Incident Response]

In downtown Chicago, Illinois, security analyst Mia Torres investigates a breach at Windy City Enterprises, a logistics firm running an Apache HTTP Server. The attacker exploited a known vulnerability in an outdated version, gaining unauthorized access to customer shipment data. Mia's analysis reveals the server lacked recent security updates, leaving it susceptible to remote code execution. Determined to prevent future incidents, Mia recommends a strategy to the IT team to address this exposure.

Which approach should Mia recommend to secure Windy City Enterprises' Apache HTTP Server against such vulnerabilities?

- A. Eliminate unnecessary files within the jar files
- B. Block all unnecessary ports, ICMP traffic, and unnecessary protocols such as NetBIOS and SMB
- C. Use a dedicated machine as a web server
- D. Conduct an extensive risk assessment to determine which segments of the network are most vulnerable or at high risk that need to be patched first

Answer: D

Explanation

The correct answer is D because the root cause of the breach was an unpatched, outdated Apache HTTP Server vulnerable to remote code execution. According to CEH principles under Security Operations and Incident Response, vulnerability management and risk assessment are critical components of defensive security strategy. An extensive risk assessment enables the organization to identify vulnerable assets, prioritize patching based on severity and business impact, and implement a structured remediation plan.

Risk assessment is part of the vulnerability management lifecycle, which includes asset identification, vulnerability scanning, risk evaluation, prioritization, patch management, and verification. By determining

which systems are most exposed and critical, the organization can apply patches and security updates systematically, reducing the attack surface. Since the breach occurred due to a known vulnerability, proper patch management and regular security updates would have prevented exploitation.

Options A, B, and C represent hardening or segmentation techniques but do not directly address the core issue of outdated software vulnerabilities. Blocking ports and using dedicated machines are good security practices; however, they do not eliminate the risk of exploitation if the web server software itself remains unpatched. Therefore, implementing a comprehensive risk assessment process followed by prioritized patch management aligns directly with CEH-recommended best practices for preventing similar future incidents.

Question #:370 - [Web Application Hacking]

A tester evaluates a login form that constructs SQL queries using unsanitized user input. By submitting ' C 'll-T; —, the tester gains unauthorized access to the application. What type of SQL injection has occurred?

- A. Tautology-based SQL injection
- B. Error-based SQL injection
- C. Union-based SQL injection
- D. Time-based blind SQL injection

Answer: A

Explanation

This question describes a classic example of Tautology-Based SQL Injection, a subcategory of SQL Injection attacks which fall under Web Application Hacking in the CEH curriculum.

In a tautology-based SQL injection, the attacker injects a SQL fragment that always evaluates to true, thus bypassing the authentication mechanism. The string ' C 'll-T; — is a malformed variant, possibly meant to represent ' OR '1'='1'; --, which is one of the most basic and widely recognized tautology-based injection payloads. When injected into a vulnerable SQL query, this kind of input manipulates the WHERE clause of the query so that it always evaluates to true, regardless of the original conditions.

Here's how it works:

If the SQL query is:

```
SELECT * FROM users WHERE username = '$username' AND password = '$password';
```

And the attacker inputs:

```
' OR '1'='1'; --
```

The query becomes:

```
SELECT * FROM users WHERE username = " OR '1'='1'; --" AND password = ";
```

This results in the execution of:

```
SELECT * FROM users WHERE '1'='1';
```

Which always evaluates to true, thereby bypassing authentication and allowing unauthorized access.

This method does not rely on error messages (Error-Based), timing delays (Time-Based Blind), or UNION statements (Union-Based). Its goal is to exploit logic within the query structure itself using boolean-based manipulation.

According to EC-Council's CEH v13 Module: Web Application Hacking, understanding tautology-based injection is critical because it's one of the most common ways attackers bypass login forms on poorly secured web applications.

Question #:371 - [Web Application Hacking]

A sophisticated injection attack bypassed validation using obfuscation. What is the best future defense?

- A. Continuous code review and penetration testing
- B. Deploy WAF with evasion detection
- C. SIEM monitoring
- D. Enforce 2FA

Answer: B

Explanation

CEH v13 emphasizes that advanced injection attacks often evade input validation through encoding and obfuscation. A Web Application Firewall (WAF) with evasion detection can analyze request patterns, payload behavior, and anomalies in real time.

Code reviews are important but reactive. SIEM correlates logs after attacks. 2FA does not prevent injection.

Thus, Option B provides the most effective immediate protection.

Question #:372 - [Social Engineering]

During a social engineering simulation at BrightPath Consulting in Denver, ethical hacker Liam emails employees a message that appears to come from the company's security team. The email urgently warns that "all systems will shut down within 24 hours" unless staff download a patch from a provided link. The message is deliberately false and contains no actual malware, but it causes confusion and prompts several employees to call IT for clarification.

Which social engineering technique is Liam demonstrating?

- A. Hoax

- B. Baiting
- C. Pretexting
- D. Spam
- E. AThe best answer is A. Hoax because the scenario is built around a false alarm message designed to provoke fear, urgency, and reactive behavior rather than to deliver a real payload. In CEH-aligned social engineering concepts, a hoax typically involves distributing a fabricated warning (for example, claims of imminent system failure, viruses spreading internally, accounts being deleted, or catastrophic outages) to manipulate users into taking unnecessary actions or spreading the message further. The key trait is that the content is intentionally untrue and aims to exploit human psychology—especially urgency and fear—to disrupt normal operations or trigger unsafe decisions. Here, Liam impersonates the security team and claims “all systems will shut down within 24 hours” unless employees act. Even though the email contains no malware, it still achieves a common hoax outcome: confusion, loss of productivity, and increased helpdesk load as employees contact IT. In real-world attacks, hoaxes can be used as a precursor to more damaging steps (e.g., pushing victims toward unsafe links, persuading them to install fake “patches,” or creating noise that distracts defenders), but the defining characteristic remains the false security warning and the behavioral manipulation it causes. Why the other options are less correct: Baiting relies on enticing victims with something appealing (free software, prizes, “exclusive” content) to get them to click or plug in media; this scenario is fear/urgency, not temptation. Pretexting is the creation of a believable fabricated identity/story to obtain information or actions; while impersonation is present, the question’s hallmark is the deliberately false alarm consistent with a hoax. Spam refers to unsolicited bulk messaging and is not defined by deception about imminent shutdowns or security crises. Therefore, Liam is demonstrating a hoax social engineering technique.

Answer: A B C D E

Question #:373 - [Social Engineering]

A senior executive receives a personalized email titled “Annual Performance Review 2024.” The email includes a malicious PDF that installs a backdoor when opened. The message appears to originate from the CEO and uses official company branding. Which phishing technique does this scenario best illustrate?

- A. Email clone attack with altered attachments
- B. Broad phishing sent to all employees
- C. Pharming using DNS poisoning
- D. Whaling attack targeting high-ranking personnel

Answer: D

Explanation

The Certified Ethical Hacker (CEH) Social Engineering module defines whaling as a highly targeted phishing attack aimed specifically at senior executives or high-ranking personnel.

This scenario exhibits all whaling characteristics: personalization, impersonation of leadership, business-themed content, and tailored malware delivery.

Option D is correct.

Option A involves copying legitimate emails, but does not necessarily target executives.

Option B lacks targeting.

Option C is unrelated to email-based attacks.

CEH stresses executive awareness training to counter whaling attacks.

Question #:374 - [Reconnaissance Techniques]

While simulating a reconnaissance phase against a cloud-hosted retail application, your team attempts to gather DNS records to map the infrastructure. You avoid brute-forcing subdomains and instead aim to collect specific details such as the domain's mail server, authoritative name servers, and potential administrative information like serial number and refresh interval.

Given these goals, which DNS record type should you query to extract both administrative and technical metadata about the target zone?

- A. MX
- B. SOA
- C. TXT
- D. NS

Answer: B

Explanation

The correct choice is the SOA record because it uniquely provides authoritative administrative and operational metadata about a DNS zone. In CEH reconnaissance techniques, DNS enumeration is a high-value passive and semi-passive method to learn about an organization's infrastructure without actively attacking hosts. The Start of Authority record defines core parameters of the zone and identifies the primary authoritative name server for that domain. Most importantly for this question, the SOA record contains fields that directly match "serial number and refresh interval," which are classic SOA elements used for zone replication and synchronization behavior between primary and secondary DNS servers.

An SOA record typically includes the primary name server, the responsible party field often formatted like an email address for the zone administrator, the zone serial number, and timing values such as refresh, retry, expire, and minimum TTL. These details can reveal change frequency, operational practices, and sometimes administrative contact clues, all of which are relevant in reconnaissance and reporting.

The other record types do not meet the requirement. MX records identify mail exchangers for the domain but do not include serial or refresh parameters. NS records list authoritative name servers but lack administrative timing metadata. TXT records store arbitrary text such as SPF, DKIM, DMARC, or verification strings and are useful for email security posture analysis, but they do not provide the zone control fields the question

references. Since the question explicitly calls out serial and refresh interval, the SOA record is the only option that fits completely.

Question #:375 - [Mobile Platform and IoT Hacking]

You are Noah Kim, an ethical hacker at Quantum Cyber Solutions, hired to test the mobile device security of TechTrend Innovations, a tech firm in Austin, Texas. During a covert assessment, your objective is to simulate an attacker attempting to gain privileged access to an iPhone 12 running iOS 14.5 used for proprietary app development. You apply a jailbreaking technique that allows the device to fully restart without requiring a computer, maintaining a patched kernel and enabling access to sensitive app data in the file system. Based on this method, which iOS jailbreaking technique are you using?

- A. Semi-tethered jailbreaking
- B. Untethered jailbreaking
- C. Semi-untethered jailbreaking
- D. Tethered jailbreaking

Answer: B

Explanation

Untethered jailbreaking is the only option that matches all key characteristics described: the device can reboot normally without needing a computer, and the jailbreak remains active after the restart with kernel-level modifications still in effect. In CEH-aligned mobile security concepts, the main difference among jailbreak types is what happens after a reboot.

A tethered jailbreak requires a computer to boot the device at all. If the phone restarts without being connected to a computer, it will not complete the boot process. That contradicts the scenario, which explicitly says the device can fully restart without requiring a computer. A semi-tethered jailbreak allows the phone to reboot without a computer, but it boots into a non-jailbroken state, meaning elevated privileges and kernel patching are not active until re-enabled through a tool. A semi-untethered jailbreak is similar in that it can boot normally without a computer, but the jailbreak does not persist automatically; it typically requires re-activating the jailbreak after each reboot to regain kernel patching and privileged access.

The scenario states the restart occurs while still “maintaining a patched kernel” and continuing access to protected filesystem data, which indicates persistence across reboot. That persistence is the defining feature of an untethered jailbreak. From a defensive and assessment perspective, this is considered higher risk because it provides continuous post-reboot privileged access, increasing the window for data access, tampering, and persistence mechanisms compared with reboot-reset jailbreak states.

Question #:376 - [Network and Perimeter Hacking]

A penetration tester is conducting a security assessment for a client and needs to capture sensitive information transmitted across multiple VLANs without being detected by the organization's security monitoring systems. The network employs strict VLAN segmentation and port security measures. Which advanced sniffing technique should the tester use to discreetly intercept and analyze traffic across all VLANs?

- A. Deploy a rogue DHCP server to redirect network traffic
- B. Exploit a VLAN hopping vulnerability to access multiple VLANs
- C. Implement switch port mirroring on all VLANs
- D. Use ARP poisoning to perform a man-in-the-middle attack

Answer: B

Explanation

VLAN hopping is an advanced attack technique described in CEH materials, used to bypass VLAN segmentation by exploiting switch misconfigurations or vulnerabilities. Two primary methods—switch spoofing and double tagging—allow attackers to gain access to traffic from VLANs they are not authorized to view. This technique enables the capture of inter-VLAN traffic without requiring administrative privileges or triggering security tools. Port mirroring requires administrative control and is not an attack method. Rogue DHCP servers target IP assignment, not VLAN segmentation. ARP poisoning is effective only within a single broadcast domain and cannot traverse VLAN boundaries. Because the objective is to silently access multiple VLANs despite enforced segmentation, VLAN hopping is the correct technique as per CEH's network perimeter attack methodology.

Question #:377 - [Web Application Hacking]

A penetration tester discovers that a web application is vulnerable to Local File Inclusion (LFI) due to improper input validation in a URL parameter. Which approach should the tester take to exploit this vulnerability?

- A. Conduct a brute-force attack on the admin login page to gain access
- B. Inject SQL commands into the URL parameter to test for database vulnerabilities
- C. Perform a Cross-Site Scripting (XSS) attack by injecting malicious scripts into the URL
- D. Use directory traversal to access sensitive files on the server, such as /etc/passwd

Answer: D

Explanation

Local File Inclusion vulnerabilities arise when a web application incorporates user-supplied input into file-handling functions without proper sanitization. CEH courseware emphasizes that attackers can leverage directory traversal sequences (such as ../..) to escape the intended directory structure and access sensitive local files. An LFI payload commonly targets system files like /etc/passwd on Linux to extract user information or escalate the attack further.

Question #:378 - [Malware Threats]

Attackers persisted by modifying legitimate system utilities and services. What key step helps prevent similar threats?

- A. Weekly off-site backups
- B. Monitor file hashes of sensitive executables
- C. Update antivirus and firewalls
- D. Disable unused ports

Answer: B

Explanation

This scenario describes Living-off-the-Land (LotL) malware techniques, where attackers modify or abuse legitimate system binaries and services to evade detection. CEH v13 identifies this as a highly stealthy persistence mechanism commonly used in advanced persistent threats (APTs).

The most effective countermeasure is file integrity monitoring (FIM), specifically by tracking cryptographic hashes of critical system executables. CEH v13 emphasizes that monitoring file hashes enables early detection of unauthorized modifications to binaries such as PowerShell, cmd.exe, or Windows services.

Backups (Option A) aid recovery but do not prevent or detect compromise. Antivirus updates (Option C) often fail against modified legitimate tools. Firewall hardening (Option D) reduces attack surface but does not detect tampering of trusted binaries.

CEH v13 explicitly recommends hash-based integrity verification as a core defense against stealthy persistence mechanisms. Therefore, option B is correct.

Question #:379 - [Cryptography]

An organization uses SHA-256 for data integrity checks but still experiences unauthorized data modification. Which cryptographic tool can help resolve this issue?

- A. Asymmetric encryption
- B. SSL/TLS certificates
- C. Symmetric encryption
- D. Digital signatures

Answer: D

Explanation

SHA-256 is a cryptographic hash function, and CEH v13 clearly states that hash functions alone provide data integrity, but not authenticity or non-repudiation. If attackers can modify data and recompute the hash, integrity checks will still pass.

The issue arises because SHA-256 does not prove who created or modified the data. To address this weakness, CEH v13 recommends using digital signatures, which combine hashing with asymmetric cryptography. A digital signature ensures:

Integrity (data has not changed)

Authentication (data was signed by a known entity)

Non-repudiation (the signer cannot deny the action)

Digital signatures work by hashing the data and encrypting the hash with the sender's private key. Any modification to the data invalidates the signature.

Encryption alone (Options A and C) protects confidentiality, not integrity or authenticity. SSL/TLS (Option B) secures data in transit but does not protect stored data from tampering.

CEH v13 explicitly identifies digital signatures as the correct cryptographic control when integrity mechanisms alone are insufficient. Therefore, Option D is correct.

Question #:380 - [Web Application Hacking]

You are a security analyst at Sentinel Cyber Group, monitoring the web portal of Aspen Valley Bank in Salt Lake City, Utah. During log review, you notice repeated attempts by attackers to inject malicious strings into the login fields. However, despite these attempts, the application executes queries safely without altering their logic, since user inputs are kept separate from the SQL statements and bound as fixed values before execution.

Based on the observed defense mechanism, which SQL injection countermeasure is the application employing?

- A. Perform user input validation
- B. Restrict database access
- C. Encoding the single quote
- D. Use parameterized queries or prepared statements

Answer: D

Explanation

The defense described—keeping user inputs separate from the SQL statement and binding them as fixed values before execution—is the defining characteristic of parameterized queries (prepared statements). This is one of the most effective and widely recommended countermeasures against SQL injection because it prevents attacker input from being interpreted as SQL code.

In a vulnerable application, developers often build SQL statements by concatenating strings, such as "SELECT ... WHERE user='" + input + '". In that pattern, malicious payloads can alter the query structure (adding conditions, UNIONs, comments, or stacked queries). With prepared statements, the SQL engine

receives the query structure first (the template), and then receives the parameter values separately. The database treats the parameters strictly as data, not executable SQL. As a result, even if an attacker submits quotes, keywords, or operators, those characters remain part of the parameter value and cannot change the query's logic.

The scenario specifically says inputs are "bound as fixed values," which is direct language associated with parameter binding. That makes option D the best answer.

Why the other options are less accurate:

User input validation (A) is helpful but can be bypassed and is not as robust as parameterization; also the described mechanism is not validation but binding separation.

Restrict database access (B) is a defense-in-depth measure (least privilege) that reduces impact, but it does not inherently stop injection from occurring.

Encoding the single quote (C) is a legacy/insufficient approach; encoding or escaping can be error-prone and DBMS-specific, and it does not match the description of parameters being bound separately.

Therefore, the application is using D. Use parameterized queries or prepared statements.

Question #:381 - [Reconnaissance Techniques]

A penetration tester is tasked with uncovering historical content from a company's website, including previously exposed login portals or sensitive internal pages. Direct interaction with the live site is prohibited due to strict monitoring policies. To stay undetected, the tester decides to explore previously indexed snapshots of the organization's web content saved by external sources. Which approach would most effectively support this passive information-gathering objective?

- A. Search with intext:"login" site:target.com to retrieve login data
- B. Use the link: operator to find backlinks to login portals
- C. Apply the cache: operator to view Google's stored versions of target pages
- D. Use the intitle:login operator to list current login pages

Answer: C

Explanation

Passive reconnaissance is emphasized throughout CEH as an essential method for gathering intelligence without alerting monitoring systems. When the tester cannot interact with the live site, they must rely entirely on third-party archives or cached content stored by search engines or internet archival services. Google's cache function provides previously stored versions of web pages exactly for this purpose. CEH explains that attackers frequently use cached content to retrieve outdated login portals, administrative pages, exposed directories, or other sensitive elements that may no longer appear on the live web server. Unlike operators such as intext or intitle, which query live indexed metadata, the cache operator retrieves historical snapshots

without accessing the target website. The link operator identifies backlinks but does not provide historical page content. Only the cache operator directly supports viewing previous versions of pages passively, aligning perfectly with the requirement to avoid detection while gathering intelligence on legacy web content.

Question #:382 - [Social Engineering]

During a red team engagement at Apex Biotech in Dallas, ethical hacker Rachel calls the company's HR desk pretending to be Mark Stevens, a senior finance manager. She pressures the HR staffer by citing his “upcoming presentation for the CFO” and insists he urgently needs a copy of the updated employee benefits spreadsheet. The staffer feels compelled to help due to Rachel’s convincing manner and authoritative tone.

Which social engineering technique is Rachel demonstrating in this exercise?

- A. Quid Pro Quo
- B. Impersonation
- C. Vishing
- D. Reverse Social Engineering

Answer: B

Explanation

The correct answer is B. Impersonation because Rachel’s primary technique is pretending to be a specific, legitimate employee (“Mark Stevens, a senior finance manager”) to induce the HR staffer to disclose or transmit sensitive information. In CEH-aligned social engineering concepts, impersonation is the act of assuming another person’s identity or role—often someone with authority or a believable business need—to gain trust and persuade the target to perform an action they otherwise should not (such as sharing confidential documents, resetting credentials, or bypassing verification steps).

The scenario includes multiple social engineering influence factors commonly emphasized in CEH: authority (claiming to be a senior finance manager and referencing the CFO), urgency (“upcoming presentation” and “urgently needs”), and pressure to reduce the likelihood the staffer follows standard validation procedures. These elements strengthen the impersonation by making the request feel both legitimate and time-sensitive, increasing compliance. The target’s reaction—feeling compelled due to Rachel’s authoritative tone—matches the expected psychological effect of impersonation attacks.

Why the other options are less correct: Vishing (voice phishing) is a delivery channel—social engineering conducted via phone calls. While this interaction occurs over the phone, the question asks for the technique being demonstrated. The defining technique here is the identity deception (impersonation) rather than merely the medium. Quid pro quo involves offering something in exchange (e.g., “I’ll fix your issue if you give me your password”), which is not present. Reverse social engineering involves the attacker creating a problem and positioning themselves as the helper so the victim contacts them; that is not described because Rachel initiates the call and directly requests the document.

Therefore, the most accurate classification of Rachel’s method is Impersonation.

Question #:383 - [Security Operations and Incident Response]

During a targeted phishing campaign, a malicious HTML attachment reconstructs malware locally using obfuscated JavaScript without making external network calls, bypassing firewalls and IDS inspection. Which evasion technique is being employed?

- A. HTML smuggling
- B. Port forwarding
- C. Cross-site scripting
- D. HTTP header spoofing

Answer: A

Explanation

CEH v13 highlights HTML smuggling as a modern technique used to bypass perimeter defenses by leveraging browser-side execution. Instead of downloading a malware file directly—which firewalls and IDS can detect—an attacker embeds obfuscated JavaScript or HTML within an attachment. When the victim opens the file, the browser reconstructs the payload locally using APIs like Blob or URL.createObjectURL. This method avoids external network transfers during the payload creation stage, allowing it to bypass content filters, sandboxing, and inline inspection tools. CEH emphasizes that HTML smuggling is especially dangerous because it operates within the browser environment, which security appliances implicitly trust. Port forwarding (Option B) relates to tunneling traffic, not file reconstruction. XSS (Option C) requires injecting scripts into web pages, not delivering malware. HTTP header spoofing (Option D) manipulates request metadata, not payload construction. Therefore, HTML smuggling precisely matches the described behavior.

Question #:384 - [Network and Perimeter Hacking]

A web server is overwhelmed by many slow, incomplete HTTP connections. What attack is occurring?

- A. Slowloris attack
- B. ICMP flood
- C. UDP flood
- D. Fragmentation attack

Answer: A

Explanation

This scenario describes a Slowloris attack, a classic application-layer DoS attack covered in CEH v13 Network and Perimeter Hacking. Slowloris works by opening many HTTP connections and sending data very slowly, preventing the server from closing the connections.

Because the connections appear legitimate, the server keeps them open, eventually exhausting its connection pool. This causes legitimate users to experience timeouts and service unavailability—exactly as described.

ICMP and UDP floods consume bandwidth, which was ruled out. Fragmentation attacks target packet handling, not application-layer sessions.

CEH v13 highlights Slowloris as particularly dangerous because it requires minimal bandwidth and bypasses many traditional DoS defenses. Therefore, Option A is correct.

Question #:385 - [Web Application Hacking]

A penetration tester discovers that a web application uses unsanitized user input to dynamically generate file paths. The tester identifies that the application is vulnerable to Remote File Inclusion (RFI). Which action should the tester take to exploit this vulnerability?

- A. Inject a SQL query into the input field to perform SQL injection
- B. Use directory traversal to access sensitive system files on the server
- C. Provide a URL pointing to a remote malicious script to include it in the web application
- D. Upload a malicious shell to the server and execute commands remotely

Answer: C

Explanation

Remote File Inclusion occurs when an application allows external resources to be loaded from user-controlled input. CEH teaches that an attacker can supply a remote URL pointing to a malicious script (for example, a PHP shell). When the vulnerable application includes this external file, the attacker's code executes on the server. This can lead to full system compromise, remote command execution, or lateral movement.

Question #:386 - [Cryptography]

Which algorithm best protects encrypted traffic patterns?

- A. PSA
- B. AES
- C. DES
- D. HMAC

Answer: B

Explanation

AES is the industry-standard symmetric encryption algorithm endorsed by CEH v13. It provides strong confidentiality and resists traffic analysis when used with proper modes (e.g., CBC, GCM).

DES is obsolete, HMAC ensures integrity not encryption, PSA is not a standard encryption algorithm.

Thus, Option B is correct.

Question #:387 - [Web Application Hacking]

During a penetration test at Cascade Financial in Raleigh, ethical hacker Ethan Brooks evaluates the security of the company's authentication system. He observes that the application accepts a high volume of repeated credential submissions without introducing any additional challenge, allowing automated scripts to cycle rapidly through large password lists. Ethan advises the IT team to deploy a control that forces interaction steps designed to disrupt automation.

Which countermeasure should the IT team adopt in this scenario?

- A. Use strong hashing algorithms
- B. Implement 2FA/MFA
- C. Use CAPTCHA challenges on login and registration pages
- D. Force periodic password changes

Answer: C

Explanation

The scenario describes an authentication endpoint that allows a high volume of repeated login attempts with no additional friction, enabling automated scripts to rapidly try large password lists. This is typical of online password guessing and credential stuffing/brute-force style automation. The countermeasure being requested is explicitly one that “forces interaction steps designed to disrupt automation,” which best matches CAPTCHA. CAPTCHA mechanisms introduce a challenge-response test intended to distinguish humans from automated bots, thereby reducing the effectiveness of scripted, high-rate credential attempts.

CAPTCHA is commonly deployed on login and registration pages (and sometimes on password reset flows) to slow down or block automated abuse. When triggered—often after a threshold of failed attempts or suspicious behavior—it forces the requester to complete an interactive step (image selection, puzzle, checkbox with behavioral analysis, etc.). This breaks fully automated attack loops and increases the attacker’s cost, especially when combined with additional controls such as account lockout thresholds, IP reputation, device fingerprinting, and rate limiting.

Why the other options are less aligned to the “disrupt automation” requirement:

Strong hashing algorithms (A) protect stored passwords at rest (e.g., if a database is compromised). They do not directly stop online automated login attempts.

2FA/MFA (B) is excellent for reducing account takeover impact, but it does not inherently prevent high-volume credential submissions; it adds a second factor after correct credentials are provided. Also, the question's wording strongly points to a bot-disruption interaction step.

Forced periodic password changes (D) is not a primary control for stopping automated login attempts and can introduce usability issues; it does not directly add friction to repeated submissions.

Therefore, the most appropriate countermeasure described is C. Use CAPTCHA challenges on login and registration pages.

Question #:388 - [Reconnaissance Techniques]

You must map open ports and services while remaining stealthy and avoiding IDS detection. Which scanning technique is best?

- A. FIN Scan
- B. TCP Connect Scan
- C. ACK Scan
- D. Stealth Scan (SYN Scan)

Answer: D

Explanation

The TCP SYN scan, also known as a Stealth Scan, is emphasized in CEH v13 Network Scanning as the most effective balance between accuracy and stealth. It sends a SYN packet and analyzes the response without completing the TCP handshake.

Because the connection is never fully established, SYN scans are less likely to be logged by applications and are harder for IDS systems to detect compared to TCP Connect scans.

FIN and ACK scans are used for firewall rule mapping and evasion, but they do not reliably enumerate services. TCP Connect scans are noisy and easily detected. Therefore, Stealth (SYN) Scan is the best choice.

Question #:389 - [Social Engineering]

During a red team exercise at Horizon Financial Services in Chicago, ethical hacker Clara crafts an email designed to trick the company's CEO. The message, disguised as an urgent memo from the legal department, warns of a pending lawsuit and includes a link to a fake internal portal requesting the executive's credentials. Unlike generic phishing, this attack is tailored specifically toward a high-ranking individual with decision-making authority.

- A. Whaling
- B. Spear Phishing

- C. Clone Phishing
- D. Consent Phishing

Answer: A

Explanation

Whaling is the correct answer because the scenario describes a highly targeted phishing attempt aimed at a “big fish”—a senior executive (the CEO). In CEH terminology, whaling is a specialized form of phishing that focuses on high-profile, high-authority individuals (e.g., CEOs, CFOs, directors) to maximize impact. These targets often have access to sensitive data, financial approvals, privileged systems, and strategic communications, making their credentials significantly more valuable than those of typical employees.

The attacker (Clara) uses classic social engineering drivers emphasized in CEH training: authority (impersonating the legal department), urgency/fear (a “pending lawsuit”), and trust in internal processes (a link to a supposed internal portal). This combination is designed to short-circuit normal verification behavior and prompt quick compliance. The inclusion of a credential-harvesting link aligns with common phishing goals: capturing usernames/passwords, enabling account takeover, and potentially facilitating broader compromise (e.g., email access for business email compromise, lateral movement, or privileged escalation).

Why the other options are less accurate: Spear phishing is also targeted, but it is a broader category aimed at specific individuals or groups at any level. The defining clue here is the executive-level target, which elevates it to whaling. Clone phishing involves copying a legitimate email previously received and swapping a malicious link or attachment—this detail is not present. Consent phishing typically abuses legitimate OAuth /app consent flows rather than a fake portal requesting credentials.

Question #:390 - [Web Application Hacking]

A penetration tester finds that a web application does not properly validate user input and is vulnerable to reflected Cross-Site Scripting (XSS). What is the most appropriate approach to exploit this vulnerability?

- A. Perform a brute-force attack on the user login form to steal credentials
- B. Embed a malicious script in a URL and trick a user into clicking the link
- C. Inject a SQL query into the search form to attempt SQL injection
- D. Use directory traversal to access sensitive files on the server

Answer: B

Explanation

CEH v13 explains that reflected XSS occurs when malicious input supplied by an attacker is immediately returned in the HTTP response without sanitization. This type of XSS is typically exploited through a crafted URL containing embedded JavaScript payloads. When a victim clicks the link, the vulnerable server reflects the injected script back to the browser, executing it within the user’s session context. CEH emphasizes that reflected XSS relies on social engineering to deliver the payload, often via links sent through email,

messaging platforms, or compromised pages. The goal may include stealing session cookies, redirecting users, or manipulating page content. Brute-forcing credentials (Option A) has no relation to XSS. SQL injection (Option C) targets backend databases, not client-side script execution. Directory traversal (Option D) concerns file path manipulation, not dynamic script injection. Therefore, embedding a malicious script in a URL is the correct method to exploit reflected XSS.

Question #:391 - [Network and Perimeter Hacking]

Which sophisticated DoS technique is hardest to detect and mitigate?

- A. Distributed SQL injection DoS
- B. Coordinated UDP flood on DNS servers
- C. Zero-day exploit causing service crash
- D. Smurf attack using ICMP floods

Answer: A

Explanation

CEH v13 classifies application-layer DoS attacks as the most difficult to detect and mitigate. A distributed SQL injection-based DoS exploits database query processing by overwhelming backend systems with malicious but syntactically valid requests.

Unlike volumetric attacks, this method generates low-bandwidth, high-impact traffic that appears legitimate. Traditional DDoS protections often fail to identify such traffic, especially when it targets authenticated services like online banking.

UDP floods, Smurf attacks, and ICMP-based attacks are well-known and more easily mitigated with rate limiting and filtering. Zero-day exploits cause service disruption but are not primarily DoS techniques.

CEH v13 highlights that application-layer DoS attacks blend seamlessly with normal traffic patterns, making them exceptionally challenging. Thus, option A is correct.

Question #:392 - [Web Application Hacking]

As an Ethical Hacker, you have been asked to test an application's vulnerability to SQL injection. During testing, you discover an entry field that appears susceptible. However, the backend database is unknown, and regular SQL injection techniques have failed to produce useful information. Which advanced SQL injection technique should you apply next?

- A. Content-Based Blind SQL Injection
- B. Time-Based Blind SQL Injection
- C. Union-Based SQL Injection

D. Error-Based SQL Injection

Answer: B

Explanation

This scenario clearly describes the need for Time-Based Blind SQL Injection, an advanced SQL injection technique covered in the CEH v13 Web Application Hacking module. Blind SQL injection is used when an application does not return database errors or visible output, making traditional techniques ineffective.

According to CEH v13, Time-Based Blind SQL Injection is particularly useful when:

The backend database type is unknown

Error messages are suppressed

UNION queries fail

No direct data is returned in responses

In this technique, attackers inject SQL statements that deliberately introduce time delays using database-specific functions such as SLEEP(), WAITFOR DELAY, or BENCHMARK(). The ethical hacker then observes the application's response time to determine whether the injected condition is true or false.

For example:

```
' OR IF(1=1, SLEEP(5), 0) --
```

If the application response is delayed, it confirms that the injected SQL statement was executed successfully. CEH v13 categorizes this method as behavioral-based inference, where the attacker extracts information one bit at a time by analyzing timing differences.

Other options are incorrect because:

Content-Based Blind SQL Injection relies on visible differences in responses, which the question states are unavailable.

Union-Based SQL Injection requires knowing column count and data types.

Error-Based SQL Injection depends on database error messages being displayed.

CEH v13 emphasizes Time-Based Blind SQL Injection as a last-resort yet highly effective technique when dealing with hardened applications that suppress output, making it a frequent exam-tested concept.

Question #:393 - [Cryptography]

An attacker uses many plaintext–ciphertext pairs and applies statistical analysis to XOR combinations of specific bits. Which technique is being used?

A. Brute-force attack

- B. Differential cryptanalysis
- C. Linear cryptanalysis
- D. Side-channel attack

Answer: C

Explanation

This scenario describes Linear Cryptanalysis, a technique detailed in CEH v13 Cryptography. Linear cryptanalysis involves finding linear approximations that relate plaintext bits, ciphertext bits, and key bits using XOR operations. By analyzing a large number of known plaintext–ciphertext pairs, attackers can identify statistical biases that reveal information about the secret key.

CEH v13 explains that linear cryptanalysis differs from differential cryptanalysis in its approach. While differential cryptanalysis studies how differences in plaintext affect differences in ciphertext, linear cryptanalysis focuses on linear relationships and probability distributions.

The mention of XOR combinations and statistical analysis of plaintext–ciphertext pairs directly aligns with linear cryptanalysis. Brute-force attacks attempt all keys without analysis. Differential cryptanalysis focuses on input differences, not linear equations. Side-channel attacks exploit physical characteristics such as power consumption or timing.

Modern block ciphers like AES are designed to resist linear cryptanalysis by ensuring that linear approximations occur with probabilities close to random. CEH v13 highlights linear cryptanalysis as a foundational attack method used to evaluate cipher strength.

Therefore, Option C is correct.

Question #:394 - [Mobile Platform, IoT, and OT Hacking]

Which advanced mobile hacking technique is the hardest to detect and mitigate in a healthcare environment?

- A. Zero-day mobile exploits
- B. App spoofing
- C. Bluejacking
- D. Side-channel attacks

Answer: A

Explanation

Zero-day exploits are considered the most dangerous mobile attack vector in CEH v13 Mobile Platform Hacking. These exploits abuse previously unknown vulnerabilities, meaning no patches, signatures, or defenses exist at the time of attack.

In healthcare environments, mobile devices access sensitive EHR systems and operate under strict compliance requirements. Zero-day exploits can bypass mobile OS security, sandboxing, and antivirus controls entirely.

App spoofing and Bluejacking are easier to detect and mitigate through user awareness and Bluetooth controls. Side-channel attacks are highly specialized and rare in enterprise mobile environments.

CEH v13 stresses that zero-day attacks pose the greatest risk due to lack of detection mechanisms, making Option A correct.

Question #:395 - [Web Application Hacking]

During an ethical hacking exercise, a security analyst is testing a web application that manages confidential information and suspects it may be vulnerable to SQL injection. Which payload would most likely reveal whether the application is vulnerable to time-based blind SQL injection?

- A. UNION SELECT NULL, NULL, NULL--
- B. ' OR '1'='1'--
- C. ' OR IF(1=1,SLEEP(5),0)--
- D. AND UNION ALL SELECT 'admin','admin'--

Answer: C

Explanation

CEH's SQL Injection coverage distinguishes between classic (error-based), union-based, boolean-based blind, and time-based blind SQL injection. Time-based blind SQL injection is used when the application does not return database errors or query results to the attacker (no visible output), but the attacker can infer execution behavior by measuring response delays.

A time-based payload intentionally triggers a database delay function (for example, SLEEP(), WAITFOR DELAY, pg_sleep() depending on DBMS). If the injection is successful, the page response time increases predictably, confirming that attacker-controlled SQL is being executed.

Option C is the correct time-based blind probe because it uses conditional logic (IF(1=1, SLEEP(5), 0)) to cause a measurable delay only when the injected condition evaluates true. CEH teaches that this technique is particularly effective against hardened applications that suppress errors and sanitize outputs, because timing becomes the side-channel for confirmation.

Option A and Option D are UNION-based payload patterns intended to extract data via returned result sets, which time-based blind scenarios typically do not provide. Option B is a classic authentication-bypass /boolean test; it can indicate injection but does not specifically validate time-based blind behavior when output is not observable.

CEH mitigation guidance includes parameterized queries, strict input validation, least-privilege DB accounts, WAF tuning, and centralized logging to detect anomalous query timing patterns.

Question #:396 - [Web Application Hacking]

You are an ethical hacker at SilverRock Security, engaged by BayState Credit Union in Boston, Massachusetts, to evaluate their online loan application portal. While testing the customer dashboard, you inject crafted input into a numeric parameter. Instead of returning only the expected loan details, the response also displays sensitive employee information from another table, merged into the same page results. This behavior indicates that the attacker's input successfully combined multiple datasets into a single output.

Based on the observed behavior, which type of SQL injection attack are you exploiting?

- A. Error-Based SQL Injection
- B. Blind SQL Injection
- C. Second-Order SQL Injection
- D. UNION SQL Injection

Answer: D**Explanation**

The correct answer is D. UNION SQL Injection because the key observation is that the application's response shows data from another table merged into the same page results, meaning the injected payload successfully combined two result sets into a single output. In CEH-aligned SQL injection taxonomy, UNION-based SQL injection occurs when an attacker uses the SQL UNION (or UNION ALL) operator to append the results of a second SELECT query to the original query's results. If the application prints query results to the page, UNION injection is especially powerful because it can directly exfiltrate database contents in-band through the normal web response.

The scenario describes input into a numeric parameter in the customer dashboard (commonly an id value in a query such as selecting loan details). By manipulating this parameter, the attacker causes the back-end query to return not only the intended loan record(s) but also employee information from a different table. That is the hallmark of UNION SQL injection: retrieving unrelated columns/rows by crafting a second SELECT that matches the original query's column count and compatible data types, then unioning it with the legitimate query so both datasets render together. Attackers often enumerate the number of columns (e.g., with ORDER BY tests) and then identify which columns are reflected in the response to place sensitive data where it will be displayed.

Why the other options do not match: Error-based SQL injection relies on database error messages to leak information, rather than cleanly merging results into the page. Blind SQL injection yields no direct data in the response and instead infers information via boolean conditions or time delays. Second-order SQL injection happens when malicious input is stored first and executed later in a different context; the prompt describes immediate, in-response merging of data.

Therefore, the behavior most directly indicates UNION SQL injection.

Question #:397 - [Web Application Hacking]

In the financial hub of Charlotte, North Carolina, ethical hacker Raj Patel is contracted by TrustBank, a regional U.S. bank, to evaluate their online loan application portal. During testing, Raj submits crafted input into the portal's form fields and notices that the server's HTTP responses are unexpectedly altered. His payloads cause additional headers to appear and even inject unintended content into the output, creating opportunities for attackers to manipulate web page behavior and deliver malicious data to users.

Which type of vulnerability is Raj most likely exploiting in TrustBank's online loan application portal?

- A. HTTP Response Splitting
- B. XML Poisoning
- C. XML External Entity (XXE) Injection
- D. Server-Side Request Forgery (SSRF)

Answer: A

Explanation

The described behavior strongly matches HTTP Response Splitting. This vulnerability occurs when an application includes unsanitized user input in HTTP response headers. By injecting carriage return and line feed characters (CRLF), an attacker can “split” the server’s response into multiple parts—causing additional headers to appear or injecting unintended body content. The scenario explicitly says Raj’s payloads cause “additional headers to appear” and “inject unintended content into the output,” which is the classic outcome of response splitting.

Why this matters: response splitting can enable attacks such as web cache poisoning, cookie manipulation, redirection, and cross-site scripting-like impacts through header/body injection. For example, if an attacker can inject a Set-Cookie header, they may set or overwrite cookies in the victim’s browser. If they can inject a Location header, they may force redirects. If they inject content into the body, they may deliver malicious scripts or alter page behavior—especially when combined with caching intermediaries. The vulnerability typically arises in features that reflect user input into headers such as Location, Set-Cookie, Content-Disposition, or custom headers.

The other options do not match the symptoms:

XML Poisoning (B) and XXE (C) relate to XML parsing and entity resolution; they do not directly cause added HTTP headers in responses.

SSRF (D) involves forcing the server to make outbound requests to internal/external resources; it may expose data but does not primarily manifest as injected response headers and altered response structure.

Therefore, Raj is most likely exploiting A. HTTP Response Splitting.

Question #:398 - [Web Application Hacking]

You are an ethical hacker at RedOak Cyber Solutions, contracted to perform a penetration test for MetroHealth Hospital in Cleveland, Ohio. While assessing the hospital's appointment booking portal, you

craft and submit multiple malicious inputs into the patient search field. One of your payloads successfully manipulates the backend query, returning additional appointment data that was not intended to be displayed.

Based on the observed behavior, which step of the SQL injection methodology are you performing?

- A. Identifying Data Entry Paths
- B. Launching SQL Injection Attacks
- C. Database Enumeration
- D. Information Gathering and Vulnerability Detection

Answer: B

Explanation

The correct answer is B. Launching SQL Injection Attacks because the scenario describes moving beyond merely locating inputs or detecting error behavior and into actively sending injection payloads that successfully alter query logic and change returned results. In a typical CEH-aligned SQL injection workflow, testers begin by identifying where user-controlled input enters the application (forms, URL parameters, cookies, headers), then perform basic tests to detect whether inputs affect backend SQL processing. Once a suspected injection point is found, the next step is to launch SQL injection attempts using crafted inputs designed to manipulate the query and demonstrate impact.

In this case, you “craft and submit multiple malicious inputs,” and one payload “successfully manipulates the backend query,” causing the application to return “additional appointment data that was not intended to be displayed.” That outcome is a clear indicator that exploitation is underway: the injection is not hypothetical—it is functioning and changing the application’s behavior in a way that reveals unauthorized data. This is characteristic of executing an SQL injection attack (in-band exploitation), such as using boolean logic manipulation (e.g., conditions that expand result sets) or other query-altering techniques. The emphasis is on the successful manipulation and unauthorized data exposure, which aligns with the attack execution phase.

Why the other options are less correct: Identifying Data Entry Paths would be earlier, when you locate the patient search field as a candidate parameter. Information Gathering and Vulnerability Detection generally refers to discovering and confirming the presence of weaknesses (often via initial probes, errors, or abnormal responses) rather than a confirmed payload that already returns unauthorized data. Database Enumeration is typically the follow-on step once exploitation is confirmed, where the tester extracts metadata such as database names, tables, columns, users, and versions. Here, you are demonstrating the injection’s ability to retrieve extra records, which is the exploitation/attack-launch stage, not full enumeration yet.

Therefore, the step being performed is Launching SQL Injection Attacks.

Question #:399 - [Network and Perimeter Hacking]

A penetration tester observes that traceroutes to various internal devices always show 10.10.10.1 as the second-to-last hop, regardless of the destination subnet. What does this pattern most likely indicate?

- A. DNS poisoning at the local resolver used by the compromised host

- B. Loopback misconfiguration at the destination endpoints
- C. A core router facilitating communication across multiple internal subnets
- D. Presence of a transparent proxy device acting as a forwarder

Answer: C

Explanation

CEH v13 highlights the importance of route tracing during internal reconnaissance to identify key infrastructure devices such as distribution switches, firewalls, and core routers. When a single IP address consistently appears as the penultimate hop across multiple network paths, this typically indicates that the device serves as a core router responsible for inter-VLAN or inter-subnet routing. Core routers aggregate traffic from various segments before forwarding to endpoint subnets, explaining why it appears before diverse destinations. CEH emphasizes recognizing core infrastructure because compromising such devices provides attackers with significant visibility and potential control over network-wide communications. DNS poisoning would affect name resolution, not hop patterns. Loopback misconfigurations would affect single hosts, not multiple segments. A transparent proxy would appear only for traffic routed through application-layer inspection, not all traceroute tests. The consistency across subnets strongly points to a centralized routing device.

Question #:400 - [Mobile Platform and IoT Hacking]

Maya Patel from SecureHorizon Consulting is called to investigate a security breach at Dallas General Hospital in Dallas, Texas, where a lost employee smartphone was used to access sensitive patient records. During her analysis, Maya finds that the hospital's mobile security policy failed to include a contingency to remotely secure compromised devices, allowing continued access to confidential data even after the device was lost. Based on this gap, which mobile security guideline should Maya recommend preventing similar incidents?

- A. Utilize a secure VPN connection while accessing public Wi-Fi networks
- B. Install device tracking software that allows the device to be located remotely
- C. Register devices with a remote locate and wipe facility
- D. Use anti-virus and data loss prevention DLP solutions

Answer: C

Explanation

The central failure in the scenario is that a lost smartphone remained capable of accessing sensitive data, which means the organization lacked an effective lost device response control. In CEH-aligned mobile security guidance, one of the most important protections for lost or stolen devices is the ability to remotely secure the endpoint by locking it and wiping corporate data. This is typically implemented through Mobile Device Management tools and enterprise mobility controls. Registering devices with a remote locate and wipe

facility ensures the security team can immediately take action once a device is reported missing, reducing the window in which an attacker can use stored sessions, cached credentials, saved tokens, or application access to reach protected resources such as patient records.

Option C is the best answer because it addresses both key needs implied by the incident: location capability to aid recovery and remote wipe to eliminate data exposure if recovery is uncertain. In healthcare environments, where protected health information is highly sensitive, CEH documentation emphasizes compensating controls that protect confidentiality when physical control of the device is lost. Remote wipe supports incident containment by preventing further access and limiting data disclosure.

Option B only provides tracking and does not guarantee data protection if the device cannot be recovered quickly. Option A helps protect data in transit on untrusted networks, but it does not solve the risk of a stolen device already authenticated to internal systems. Option D can help overall hygiene, but antivirus and DLP do not reliably stop misuse of a legitimately authenticated, lost device. Remote locate and wipe is the most direct mitigation for this exact gap.

Question #:401 - [Social Engineering]

During a red team assessment at Apex Technologies in Austin, ethical hacker Ryan tests whether employees can be tricked into disclosing sensitive data over the phone. He poses as a vendor requesting payment details and reaches out to several staff members. To evaluate defenses, the security team emphasizes that beyond general training, there is a practical step employees must apply in every interaction to avoid being deceived by such calls.

Which countermeasure should Apex Technologies prioritize to directly prevent this type of social engineering attempt?

- A. Conduct security awareness programs
- B. Employees must verify the identity of individuals requesting information
- C. Establish policies and procedures
- D. Use two-factor authentication

Answer: B

Explanation

This scenario is a classic vishing (voice phishing) attempt: the attacker calls employees, impersonates a vendor, and tries to persuade them to disclose sensitive payment information. The most direct, practical countermeasure that employees can apply in every interaction is verifying the requester's identity before sharing any information. That means using a trusted verification method—such as calling back using an official number from an internal directory/vendor contract, confirming through a known manager or procurement channel, or following an established verification workflow—rather than trusting the caller ID, the caller's confidence, or claimed affiliation.

Option B is the best answer because it directly breaks the social engineering tactic being used: pretexting (posing as a vendor) relies on getting the victim to accept identity and urgency without validation. If employees consistently verify identity through independent channels, the attacker's pretext collapses and the

request is denied or escalated. This is the most immediate control at the human decision point, where the data disclosure risk occurs.

Why the other choices are less direct:

Security awareness programs (A) are important, but the question asks for the practical step employees must apply in each interaction. Training supports the behavior; it is not the specific action that stops the call from succeeding.

Policies and procedures (C) provide governance and guidance, but the direct operational control during a phone call is still identity verification.

Two-factor authentication (D) protects login processes but does not prevent an employee from verbally disclosing payment details over the phone.

Therefore, the prioritized countermeasure is B. Employees must verify the identity of individuals requesting information.

Question #:402 - [Mobile Platform and IoT Hacking]

In Miami, Florida, a luxury resort deploys smart climate control units in guest rooms. During a red team engagement, ethical hacker Sophia Bennett discovers that once a compromised device is restarted, it continues running altered instructions without any integrity check before the operating system loads. This allows tampered firmware to run as if it were legitimate. Which secure development practice would most directly prevent this weakness?

- A. Allow code signing
- B. Secure firmware or software updates
- C. Utilize secure communication protocols
- D. Ensure secure boot

Answer: D

Explanation

The weakness described is that a device can reboot and still execute tampered firmware or pre-boot code “without any integrity check before the operating system loads.” The secure development practice that most directly prevents this is Secure Boot. Secure boot establishes a chain of trust starting at power-on, where each stage of the boot process verifies the integrity and authenticity of the next stage (bootloader, kernel, firmware components) before execution. If the verification fails (because firmware was modified, unsigned, or improperly signed), the device can halt, fall back to a known-good image, or enter a recovery mode—preventing malicious pre-OS code from running as if it were legitimate.

This matters especially for IoT devices such as smart climate control units, where attackers may attempt to persist by modifying firmware so that malware survives reboots. Without pre-boot integrity verification, a compromised device can continually load attacker-controlled instructions, making detection and remediation difficult.

Why the other options are less direct:

Code signing (A) is important, but by itself it does not guarantee the device will verify signatures at boot time. Secure boot is the enforcement mechanism that validates signed boot components before they run.

Secure firmware/software updates (B) reduce the chance of malicious updates being installed (e.g., signed OTA updates, authenticated update channels), but they do not necessarily prevent execution of already-tampered firmware at startup if boot-time verification is missing.

Secure communication protocols (C) protect data in transit and device communications, but they do not address firmware integrity during the boot process.

Therefore, the most direct preventive practice for this pre-OS integrity gap is D. Ensure secure boot.

Question #:403 - [Web Application Hacking]

Which strategy best mitigates session hijacking?

- A. IPsec VPN encryption
- B. Physical security
- C. Network IPS
- D. Security awareness training

Answer: A

Explanation

CEH v13 highlights that encrypting session data in transit is one of the strongest defenses against session hijacking. IPsec VPN encrypts the entire IP packet, preventing attackers from capturing usable session tokens.

IPS helps detection but not prevention. Physical security and awareness do not address technical hijacking.

Therefore, Option A is correct.

Question #:404 - [Mobile Platform and IoT Hacking]

Which attack best demonstrates covert eavesdropping via smartphone sensors?

- A. Malicious APK exploitation
- B. Man-in-the-Disk attack
- C. Spearphone attack
- D. Tap 'n Ghost attack

Answer: C**Explanation**

The Spearphone attack, covered in CEH v13 Mobile Platform Hacking, exploits smartphone accelerometers to infer speech vibrations from loudspeakers—without microphone permissions.

This attack demonstrates how built-in sensors can be abused for covert surveillance, making it ideal for assessing privacy risks.

Other options involve different attack vectors not related to sensor-based eavesdropping.

Thus, Option C is correct.

Question #:405 - [Reconnaissance Techniques]

During a security review for a healthcare provider in Denver, Colorado, Ava examines the header of a suspicious message to map the sender's outbound email infrastructure. Her goal is to identify which specific system on the sender's side processed the message so the team can understand where the transmission originated within that environment. Which detail from the email header should she examine to determine this?

- A. Date and time of message sent
- B. Sender's mail server
- C. Sender's IP address
- D. Authentication system used by sender's mail server

Answer: B**Explanation**

To determine which specific system on the sender's side processed the message, the most relevant email-header detail is the sender's mail server, typically revealed in the chain of Received: headers. Each mail transfer agent (MTA) that handles the message adds a Received line indicating the system that passed the message along and the system that received it. By reviewing these headers from bottom to top (earliest hop upward), analysts can identify the originating outbound infrastructure used by the sender—such as the initial submission server, outbound relay, or gateway that first accepted the email for delivery.

The scenario's goal is to “map the sender's outbound email infrastructure” and identify “which specific system on the sender's side processed the message.” That maps more directly to identifying the mail server hostnames involved (the MTAs), because those are the processing systems that relayed the email. While an IP address can help locate a host, the question emphasizes the “specific system” responsible for processing, which is typically expressed as the mail server identity (hostname/domain) shown in header traces. In practice, investigators correlate the sender mail server information with IPs, TLS details, and authentication results, but the primary header clue for the processing system is the server identified in Received lines.

Why the other options are less suitable:

Date and time (A) helps with timeline analysis, not identification of the processing system.

Sender's IP address (C) can indicate a source network, but the message may traverse NAT, relays, or cloud email services; it doesn't always name the processing system.

Authentication system used (D) (e.g., SPF/DKIM/DMARC results) indicates validation outcomes, not which server processed the message.

Therefore, the correct choice is B. Sender's mail server.

Question #:406 - [Network and Perimeter Hacking]

Under the neon glow of Seattle's skyline, ethical hacker Elena Vasquez slips into her role as a cybersecurity consultant for Cascade Financial's online banking platform. Tasked with probing the web server's defenses, Elena simulates a series of rapid login attempts to the admin portal. She notes that the system allows unlimited tries without locking the account, exposing a gap that could invite relentless password-guessing attacks. Determined to safeguard the bank's assets, Elena drafts a recommendation to fortify the server's authentication process against such threats.

What countermeasure should Elena recommend to strengthen Cascade Financial's web server against the vulnerability identified?

- A. Implement 2FA or MFA
- B. Force users to periodically change passwords
- C. Use CAPTCHA challenges on login and registration pages
- D. Use strong, one-way hashing algorithms such as bcrypt, scrypt, or Argon2

Answer: C

Explanation

The weakness described is a classic online password-guessing condition: the application permits unlimited authentication attempts without any throttling, lockout, or challenge mechanism. In CEH guidance, this exposure enables brute-force attacks and automated credential stuffing, where attackers rapidly test many passwords or reused credential pairs until successful. A practical and commonly recommended control at the web application layer is adding CAPTCHA challenges to the login workflow, especially after a small number of failed attempts or when anomalous behavior is detected. CAPTCHA increases the cost of automation by forcing human interaction, directly disrupting high-speed scripted guessing against the admin portal.

While implementing MFA is an excellent additional safeguard and is strongly encouraged for privileged access, the question asks for the best countermeasure to address the specific issue of unlimited rapid attempts. CAPTCHA is a direct mitigation for automated login abuse, and CEH commonly pairs it with rate limiting, progressive delays, and account lockout policies. Periodic password changes do not prevent an attacker from guessing a password today, and CEH materials note that forced rotation can even reduce security if it drives predictable password patterns. Strong password hashing such as bcrypt, scrypt, or Argon2 is critical for protecting stored passwords if a database is compromised, but it does not stop online guessing against the login form itself. Therefore, the most fitting countermeasure for the identified vulnerability is using

CAPTCHA challenges on login and registration pages, ideally combined with throttling and lockout for stronger defense in depth

Question #:407 - [Wireless Network Hacking]

You are a cybersecurity consultant at FortiSec, advising DesertTech Innovations in Phoenix, Arizona. The company wants to modernize its Wi-Fi so that even if an attacker obtains a captured handshake or a weak passphrase, they cannot perform offline dictionary attacks or recover session keys; management also wants stronger, per-session encryption and protection for IoT devices without relying on a single shared password.

Which wireless security measure should DesertTech implement to meet these goals?

- A. MAC Address Filtering
- B. Use 802.1X Authentication
- C. Upgrade to WPA3
- D. Disable TKIP

Answer: C

Explanation

The requirements map most directly to WPA3, because WPA3-Personal replaces the legacy WPA2-PSK handshake with SAE (Simultaneous Authentication of Equals). SAE is designed to resist offline dictionary attacks: even if an attacker captures the handshake, they cannot simply take it offline and test password guesses at high speed the way they can with WPA2-PSK handshakes. This directly addresses management's concern that a captured handshake plus a weak passphrase could enable offline cracking and eventual session key recovery.

WPA3 also strengthens per-session protection by improving how keys are established and by supporting stronger cryptographic defaults. In enterprise contexts, WPA3 aligns with stronger authentication and encryption suites, and in IoT scenarios it supports modern onboarding and improved security posture compared to older WPA2/TKIP-era configurations. The "per-session encryption" and "stronger protection" goals are consistent with WPA3's modern design focus.

Why the other options are less suitable:

MAC address filtering (A) is not a security control against credential capture or offline attacks; MACs are easily spoofed and do not provide cryptographic protection.

802.1X authentication (B) (WPA2/WPA3-Enterprise) is very strong and removes reliance on a single shared PSK by using per-user/device credentials and dynamic keys. However, the question's key requirement explicitly calls out preventing offline dictionary attacks even if a handshake is captured—this is most directly the hallmark improvement of WPA3-Personal (SAE). (In practice, WPA3-Enterprise with 802.1X is also excellent, but "upgrade to WPA3" is the single best match to the stated offline dictionary concern.)

Disabling TKIP (D) is good hygiene (prefer AES/CCMP), but it does not prevent WPA2-PSK handshake capture and offline cracking if PSK is used.

Therefore, the best measure to meet the stated modernization goals is C. Upgrade to WPA3.

Question #:408 - [Cloud Computing]

Emily, a security engineer at a Chicago-based healthcare provider, is auditing the organization's new cloud environment after a breach where sensitive patient records were exposed. Her investigation reveals that the root cause was the lack of encryption during data transmission between end-user devices and cloud storage. To mitigate this issue and align with HIPAA compliance requirements, Emily must prioritize addressing the correct cloud computing security risk.

Which cloud computing threat should Emily address to mitigate the risk of sensitive data being exposed during transmission?

- A. Multi-Tenancy and Physical Security
- B. Incidence Analysis and Forensic Support
- C. Service and Data Integration
- D. Infrastructure Security

Answer: C

Explanation

In CEH-aligned cloud security discussions, protecting data across its lifecycle is a primary requirement, and a major risk area is how data moves between clients, applications, and cloud services. The scenario states the exposure occurred because there was no encryption during transmission between user devices and cloud storage. That maps directly to the Service and Data Integration risk area because it focuses on the security controls applied when cloud services exchange data with users and with other services, including secure communication channels, API protection, and proper cryptographic enforcement for data in transit.

When data is transmitted without TLS or with weak or misconfigured TLS, it becomes vulnerable to interception and manipulation through man in the middle attacks, traffic sniffing, SSL stripping, or downgrade attacks. In regulated environments such as healthcare, HIPAA expectations strongly align with implementing strong encryption in transit and ensuring secure session establishment, certificate validation, and modern cipher suites. This is not primarily a multi tenancy or physical security issue, which relates to isolation between tenants and the provider's datacenter controls. It is also not primarily an incident analysis and forensic support issue, which concerns detection, logging, evidence collection, and investigative capability after events occur. Infrastructure security is broader and can include network protections, but the question is specifically about preventing exposure during transmission, which is most precisely addressed by service and data integration controls.

Correct remediation typically includes enforcing HTTPS with modern TLS, enabling HSTS, disabling legacy protocols and weak ciphers, ensuring correct certificate management, using mutual TLS where appropriate, and securing cloud storage access through authenticated, encrypted endpoints and properly secured APIs.

Question #:409 - [Network and Perimeter Hacking]

Abnormal DNS resolution behavior is detected on an internal network. Users are redirected to altered login pages. DNS replies come from an unauthorized internal IP and are faster than legitimate responses. ARP spoofing alerts are also detected. What sniffing-based attack is most likely occurring?

- A. Internet DNS spoofing
- B. Intranet DNS poisoning via local spoofed responses
- C. Proxy-based DNS redirection
- D. Upstream DNS cache poisoning

Answer: B

Explanation

This is a textbook case of Intranet DNS Poisoning, often combined with ARP spoofing, as described in CEH v13 Network Sniffing and MITM Attacks. The attacker positions themselves inside the local network, intercepts DNS requests, and responds faster than the legitimate DNS server.

ARP spoofing enables the attacker to perform a Man-in-the-Middle attack, allowing sniffing and modification of DNS traffic. CEH v13 notes that faster rogue responses are a strong indicator of local DNS poisoning.

Question #:410 - [Security Operations and Incident Response]

You are a cybersecurity analyst at a global banking corporation and suspect a backdoor attack due to abnormal outbound traffic during non-working hours, unexplained reboots, and modified system files. Which combination of measures would be most effective to accurately identify and neutralize the backdoor while ensuring system integrity?

- A. Review firewall logs, analyze traffic, and immediately reboot systems
- B. Monitor system and file activity, apply anomaly detection, and use advanced anti-malware tools
- C. Enforce strong passwords, MFA, and regular vulnerability assessments
- D. Apply ACLs, patch systems, and audit user privileges

Answer: B

Explanation

According to CEH v13 Security Operations and Incident Response, backdoors are stealth mechanisms that allow attackers persistent access. Indicators such as unexplained outbound traffic, unauthorized file modifications, and irregular reboots strongly suggest post-compromise persistence mechanisms.

CEH v13 recommends a behavioral and host-based detection approach for backdoor identification. Continuous monitoring of system and file activity helps detect unauthorized binaries, registry changes, and scheduled tasks. Anomaly detection identifies deviations from normal system behavior, which is critical for uncovering hidden backdoors that evade signature-based detection.

Additionally, advanced anti-malware tools with heuristic and memory analysis capabilities are essential to identify sophisticated backdoors that traditional antivirus may miss. These tools can detect rootkits, fileless persistence, and covert communication channels.

The other options are preventative but not investigative. Immediate reboots may destroy volatile evidence, while password policies and ACLs do not detect existing compromises. Therefore, option B provides the most effective and CEH-aligned response.

Question #:411 - [Web Application Hacking]

You are an ethical hacker at Nexus Cybersecurity, contracted to perform a penetration test for BlueRidge Retail, a US-based e-commerce company in Atlanta, Georgia. While testing their online store's product search page, you attempt to inject a malicious query into the URL to extract customer data. The application is protected by a web application firewall WAF that blocks standard SQL injection attempts. To bypass this, you modify your input to split the query into multiple parts, ensuring the malicious instructions are not detected as a single signature. For example, you craft the URL as `products.php?id=1+UNION+SE+LECT+1,2`, which successfully retrieves unauthorized data. Based on the observed behavior, which SQL injection evasion technique are you employing?

- A. Hex Encoding
- B. String Concatenation
- C. In-line Comment
- D. Null Byte

Answer: B

Explanation

String concatenation is the best match because the technique described is breaking a recognizable SQL keyword or payload into separate pieces so a signature-based WAF rule does not see the full malicious token in one continuous pattern. In CEH-aligned web application testing, many WAF detections rely on matching known strings such as `UNION SELECT`, `OR 1=1`, and other classic patterns. If an attacker can cause the database parser to interpret the same meaning while the input appears different at the inspection layer, the WAF may fail to match its rule and the payload can reach the backend.

The prompt explicitly says you “split the query into multiple parts” to avoid detection as “a single signature.” That is the core idea of concatenation-based evasion: represent the same instruction through separated fragments that are recombined or tolerated by the SQL parser, depending on the database and application behavior. This differs from in-line comments, which would typically insert comment markers inside keywords

to break signatures while preserving parsing, and differs from hex encoding, which replaces characters or strings with hexadecimal representations. A null byte technique is usually associated with string-termination tricks in older contexts and does not align with splitting SQL keywords for WAF bypass.

Defensively, CEH guidance emphasizes that relying on WAF signatures alone is insufficient. Strong prevention requires parameterized queries, strict server-side input validation, least-privilege database accounts, and monitoring for anomalous query patterns and error behaviors even when obvious signatures are not present.

Question #:412 - [Malware Threats]

During a red team exercise for a global insurance provider in Chicago, ethical hacker Maria tests the effectiveness of the company's endpoint defenses. She launches an attack by injecting malicious PowerShell commands into a trusted process without dropping any executables to disk. The code executes entirely in memory, generating abnormal spikes in resource usage. After a reboot, Maria notes that the system returns to normal and traditional antivirus logs show no evidence of infection.

Which type of malware technique did Maria most likely use in this test?

- A. Rootkit
- B. Trojan
- C. Fileless Malware
- D. Ransomware

Answer: C

Explanation

Maria most likely used fileless malware, because the scenario explicitly describes malicious activity that does not write a payload executable to disk and instead executes entirely in memory using PowerShell and process injection. In CEH-aligned malware classifications, fileless malware is characterized by leveraging legitimate system tools (often called “living off the land” utilities) such as PowerShell, WMI, cmd.exe, or scripting engines to execute attacker-controlled code without creating traditional malware files on the filesystem. Since many legacy antivirus solutions depend heavily on signature-based scanning of files on disk, purely memory-resident execution can reduce or eliminate typical AV detections and leave minimal artifacts in standard AV logs.

The description also mentions that after a reboot the system returns to normal, which strongly supports fileless behavior: if the attacker did not establish persistence (for example via registry run keys, scheduled tasks, services, or WMI event subscriptions), then the in-memory code and injected instructions would be cleared when memory is reset. The “abnormal spikes in resource usage” are consistent with malicious scripts running inside a trusted process context, where attackers may inject or reflectively load code to blend into normal operating activity and evade straightforward monitoring.

Why the other options are incorrect: a rootkit primarily focuses on stealth through deep system-level hiding (often kernel/driver-level) and is commonly associated with persistent concealment rather than “no disk footprint” PowerShell-only execution. A trojan is typically a malicious program masquerading as legitimate

software and usually involves a delivered executable or application. Ransomware is defined by encrypting data and extorting payment, which is not described here.

Thus, the technique most consistent with the test is fileless malware executed via PowerShell and memory-only injection.

Question #:413 - [Network and Perimeter Hacking]

During a red team assessment at a university in Chicago, Jake, a penetration tester, scans a group of older Windows workstations in the administration department. On several hosts, he notices traffic on UDP ports 137 and 138 as well as an open TCP port 139. Curious, he uses a utility to query the name table and session services. Within moments, he collects information including machine names, logged-in usernames, and available shared folders without authentication.

Which enumeration method is being demonstrated in this scenario?

- A. NFS Enumeration
- B. NetBIOS Enumeration
- C. SMB Enumeration
- D. SNMP Enumeration

Answer: B

Explanation

The correct answer is B. NetBIOS Enumeration because the ports and services described map directly to NetBIOS over TCP/IP (NBT) and the actions align with querying NetBIOS name table and session services. In Windows networking (especially older systems), NetBIOS provides naming and session-layer services that can reveal valuable host and user information. Specifically, UDP 137 is used for the NetBIOS Name Service (NBNS), UDP 138 for NetBIOS Datagram Service, and TCP 139 for NetBIOS Session Service. Observing activity on UDP 137/138 and an open TCP 139 strongly indicates that NetBIOS services are reachable and can be interrogated.

The scenario states Jake “uses a utility to query the name table and session services,” which is a hallmark of NetBIOS enumeration. NetBIOS name table queries can disclose machine names, domain/workgroup names, and sometimes logged-in usernames (depending on configuration and what names are registered). Session /service enumeration can reveal information about active sessions and available resources. The fact that Jake obtains machine names, usernames, and shared folders without authentication is consistent with weakly configured legacy Windows networking where NetBIOS/SMB information disclosure is possible through null /unauthenticated queries.

Why not the other options: NFS enumeration targets UNIX/Linux file sharing and is unrelated to ports 137–139. SNMP enumeration uses UDP 161/162 and relies on SNMP communities, not NetBIOS naming/session queries. SMB enumeration is closely related and often overlaps operationally, but the question emphasizes “query the name table and session services” and explicitly references the classic NetBIOS port set (137/138 /139), making NetBIOS enumeration the most precise classification for this behavior.

In practice, defenders mitigate this exposure by disabling NetBIOS where unnecessary, restricting these ports at network boundaries, enforcing SMB hardening, and limiting anonymous/null session information disclosure.

Question #:414 - [Cloud Computing]

During a routine security audit, administrators found that cloud storage backups were illegally accessed and modified. What countermeasure would most directly mitigate such incidents in the future?

- A. Deploying biometric entry systems
- B. Implementing resource auto-scaling
- C. Regularly conducting SQL injection testing
- D. Adopting the 3-2-1 backup model

Answer: D

Explanation

According to CEH v13 Cloud Computing, backup integrity and resilience are critical components of cloud security. The 3-2-1 backup model is a widely recommended best practice to mitigate unauthorized access, data corruption, and ransomware-related incidents.

The 3-2-1 rule dictates that organizations should maintain:

3 copies of critical data

Stored on 2 different media types

With 1 copy stored offsite or offline

This approach ensures that even if one backup is compromised, altered, or deleted—as described in the scenario—clean and trusted versions of the data remain available for restoration. CEH v13 emphasizes that offline or immutable backups significantly reduce the impact of malicious modification.

Option A focuses on physical security, which does not protect cloud backups. Option B addresses availability, not integrity. Option C is relevant to web application security, not backup protection.

CEH v13 explicitly highlights backup segregation and redundancy as key countermeasures against cloud data compromise. Therefore, Option D is the most direct and effective mitigation strategy.

Question #:415 - [Network and Perimeter Hacking]

You perform a SYN (half-open) scan and receive a SYN/ACK packet in response. How should this result be interpreted?

- A. The target IP is not reachable

- B. The scanned port is open
- C. The scanned port is filtered
- D. The scanned port is closed

Answer: B

Explanation

In CEH v13 Network Scanning, a SYN scan—also known as a half-open scan—is one of the most common and reliable techniques used to identify open TCP ports. This method involves sending a TCP SYN packet to a target port and analyzing the response without completing the full three-way handshake.

When a scanner sends a SYN packet:

SYN/ACK response # The port is OPEN

RST response # The port is CLOSED

No response or ICMP unreachable # The port is FILTERED

In this scenario, the receipt of a SYN/ACK packet clearly indicates that the target system is willing to establish a TCP connection on that port. The scanner typically responds with a RST packet instead of an ACK to avoid completing the connection, thereby remaining stealthy.

Option B is therefore correct and aligns exactly with CEH v13 definitions.

Option A is incorrect because unreachable hosts do not respond with SYN/ACK.

Option C is incorrect because filtered ports usually do not respond or return ICMP errors.

Option D is incorrect because closed ports respond with RST, not SYN/ACK.

CEH v13 emphasizes SYN scanning as a preferred method due to its balance of accuracy and reduced logging. Understanding TCP flag behavior is fundamental for interpreting scan results correctly.

Question #:416 - [Social Engineering]

A senior executive receives a personalized email with the subject line “Annual Performance Review 2024.” The email contains a downloadable PDF that installs a backdoor when opened. The email appears to come from the CEO and includes company branding. Which phishing method does this best illustrate?

- A. Broad phishing sent to all employees
- B. Pharming using DNS poisoning
- C. Whaling attack aimed at high-ranking personnel

D. Email clone attack with altered attachments

Answer: C

Explanation

This scenario is a textbook example of a Whaling Attack, a highly targeted phishing technique described in the CEH v13 Social Engineering module. Whaling specifically targets senior executives or high-ranking individuals, exploiting their authority, access privileges, and decision-making roles.

In the given case, the attacker crafts a personalized email, impersonates the CEO, and uses legitimate corporate branding to build trust. The malicious PDF attachment delivers a backdoor, aligning with CEH v13 descriptions of advanced spear-phishing techniques used against executives.

CEH v13 differentiates whaling from other phishing types:

Broad phishing targets large groups indiscriminately.

Pharming redirects users via DNS manipulation.

Email clone attacks copy legitimate emails but typically target peers, not executives.

Whaling attacks are particularly dangerous because executives often bypass security scrutiny and possess elevated system access. CEH v13 emphasizes executive awareness training as a key mitigation strategy.

Therefore, the correct answer is Whaling attack aimed at high-ranking personnel.

Question #:417 - [Web Application Hacking]

During a penetration test at Windy City Enterprises in Chicago, ethical hacker Mia Torres targets the company's public-facing site. By exploiting an unpatched vulnerability in the web server, she manages to alter visible content on the homepage, replacing it with unauthorized messages. Mia explains to the IT team that this kind of attack can damage the company's reputation and erode customer trust, even if sensitive data is not directly stolen.

Which type of web server attack is Mia most likely demonstrating?

- A. DNS Hijacking
- B. Frontjacking
- C. File Upload Exploits
- D. Website Defacement

Answer: D

Explanation

The attack described is website defacement, which occurs when an attacker gains the ability to modify the content of a website—often the homepage—to display unauthorized messages, propaganda, or vandalism. The scenario explicitly says Mia “alter[s] visible content on the homepage, replacing it with unauthorized messages,” and emphasizes the reputational harm even without data theft. That reputational impact is a hallmark of defacement: it undermines customer trust, signals weak security, and can create regulatory/brand consequences even if no confidential information is exfiltrated.

The stated entry point—“exploiting an unpatched vulnerability in the web server”—is also consistent with defacement. Attackers frequently leverage web server or web application weaknesses (misconfigurations, known CVEs, weak credentials, vulnerable plugins, or insecure file permissions) to gain write access to web content or templates. Once write access is achieved, the attacker can replace HTML pages, alter templates, inject malicious scripts, or modify assets so that visitors see the attacker’s message.

Why the other options are less appropriate:

DNS hijacking (A) redirects users by changing DNS resolution so that the domain points to an attacker-controlled server. That can lead to a fake site, but it’s not the same as modifying the real server’s homepage content.

Frontjacking (B) typically involves UI deception—overlaying or framing content to trick users—rather than server-side modification of the homepage.

File upload exploits (C) are a method that can be used to gain code execution or place malicious files on a server, but the question asks for the type of web server attack being demonstrated. The visible outcome described—unauthorized homepage changes—is best categorized as defacement.

Therefore, Mia is most likely demonstrating D. Website Defacement.

Question #:418 - [Security Operations and Incident Response]

An attacker gained escalated privileges on a critical server. What should be done FIRST to contain the threat with minimal disruption?

- A. Engage a forensic team immediately
- B. Power down the server and isolate it
- C. Monitor, analyze, and then isolate the server
- D. Conduct a vulnerability scan on all servers

Answer: C

Explanation

CEH v13 follows the Incident Response Lifecycle, which prioritizes identification and analysis before containment, unless there is immediate risk of catastrophic damage. In this scenario, the attacker has escalated privileges, but the organization still needs to understand what actions are being taken, what systems are affected, and whether lateral movement is occurring.

Option C aligns with CEH v13 best practices. Real-time monitoring and documentation allow analysts to:

Identify attacker techniques and tools

Preserve volatile evidence

Understand scope and impact

Implement targeted containment

Immediately powering down the server (Option B) may destroy volatile forensic evidence and disrupt services unnecessarily. Engaging forensic teams (Option A) is important but premature without initial analysis. Running vulnerability scans (Option D) does not address the active threat.

CEH v13 stresses that informed containment is more effective than reactive shutdowns. Therefore, Option C is correct.

Question #:419 - [Network and Perimeter Hacking]

On July 25, 2025, during a security assessment at Apex Technologies in Boston, Massachusetts, ethical hacker Sophia Patel conducts a penetration test to evaluate the company's defenses against a simulated DDoS attack targeting their e-commerce platform. The simulated attack floods the platform with traffic from multiple sources, attempting to overwhelm server resources. The IT team activates a specific tool that successfully mitigates this attack by distributing traffic across multiple servers and filtering malicious requests. Sophia's test aims to verify the effectiveness of this tool in maintaining service availability.

Which DoS DDoS protection tool is most likely being utilized by the IT team in this scenario?

- A. Web Application Firewall WAF
- B. Load Balancer
- C. Intrusion Prevention System IPS
- D. Firewall

Answer: B

Explanation

A load balancer is the best match because the key mitigation behavior described is distributing incoming traffic across multiple servers to prevent any single system from being overwhelmed. In CEH coverage of availability attacks, one of the most practical architectural defenses against flooding-based DoS and DDoS is to scale horizontally and place a load-balancing layer in front of a server pool. This allows the organization to absorb spikes by spreading connections and requests across multiple backend nodes, improving resilience and maintaining uptime.

The scenario also mentions filtering malicious requests. Modern load balancers commonly provide health checks, rate limiting, connection limiting, and integration with access control rules, and they are often

deployed alongside DDoS scrubbing or edge protections. Even when the filtering logic is implemented through integrated security policies or upstream services, the defining characteristic in the prompt is traffic distribution across multiple servers, which is a primary function of load balancing and a common CEH-referenced mitigation strategy for volumetric attacks.

A web application firewall focuses on inspecting and blocking malicious HTTP and application-layer payloads such as injection, request anomalies, and known attack patterns, but it is not primarily responsible for distributing traffic across multiple servers. An IPS can block suspicious patterns and exploit attempts, yet it does not typically provide the core traffic distribution function described. A traditional firewall enforces network-level rules and may help with rate limits, but it does not inherently balance traffic across a server farm. Therefore, the most likely tool in use here is a load balancer.

Question #:420 - [Malware Threats]

Self-replicating malware causes redundant traffic, crashes, and spreads autonomously. What malware type is responsible, and how should it be handled?

- A. Worm – isolate systems, scan network, update OS
- B. Ransomware – disconnect, back up data, decrypt
- C. Trojan – scan systems and patch
- D. Rootkit – reboot and deploy scanner

Answer: A

Explanation

This scenario describes a worm infection, as defined in CEH v13 Malware Threats. Worms are self-replicating malware that spread autonomously across networks without user interaction. Their propagation often results in excessive network traffic, system crashes, and resource exhaustion, which aligns with the symptoms described.

CEH v13 differentiates worms from other malware:

Ransomware encrypts data but does not self-propagate aggressively.

Trojans require user execution.

Rootkits focus on stealth and persistence rather than replication.

The appropriate response prioritizes containment and eradication. Quarantining affected systems prevents further spread. A network-wide antivirus sweep with updated signatures removes known worm variants. Updating operating systems closes vulnerabilities that worms exploit for propagation.

CEH v13 stresses rapid isolation and patching as critical measures to control worm outbreaks and restore network stability. Therefore, Option A is correct.

Question #:421 - [Mobile Platform, IoT, and OT Hacking]

You are Sameer Das, an ethical hacker hired by a national utilities provider to assess the resilience of its power grid infrastructure. During your red team operation, you conduct a phishing campaign targeting field engineers and successfully gain access to the internal OT network. From there, you identify unsecured access to the substation's programmable controllers and replace one of the system's firmware components with a custom payload. This payload silently processes your commands while maintaining access across reboots. Based on this action, which type of IoT OT threat are you simulating?

- A. Forged malicious device
- B. Firmware update attack
- C. Remote access using backdoor
- D. Exploit kits

Answer: B**Explanation**

The described activity most directly matches a firmware update attack. In CEH coverage of IoT and OT threats, firmware represents the low-level code that runs on embedded devices and industrial controllers, and compromising it is one of the most impactful persistence methods because it survives reboots and often persists through normal configuration resets. The scenario states that Sameer "replaces one of the system's firmware components with a custom payload" and that the payload "maintains access across reboots." Those are signature characteristics of a firmware-level compromise, typically achieved through insecure firmware update mechanisms, weak signing or verification controls, exposed update interfaces, or inadequate access controls on management ports.

A firmware update attack can occur when devices accept unsigned firmware, use weak integrity checks, allow downgrade to vulnerable versions, or expose update services without strong authentication. Once malicious firmware is installed, it can covertly execute commands, manipulate device behavior, hide its presence from higher-level monitoring, and create a durable foothold in OT environments where patching and reimaging are difficult. CEH emphasizes that OT devices such as programmable controllers and substation automation equipment are especially sensitive because firmware tampering can affect availability and safety, not just confidentiality.

Remote access using a backdoor is a broader concept and could be the payload's function, but the primary technique here is achieving persistence by modifying firmware. Forged malicious device refers to introducing rogue hardware, and exploit kits are typically used for automated exploitation on endpoints, not controller firmware replacement.

Question #:422 - [Network and Perimeter Hacking]

During a penetration test at a financial services company in Denver, ethical hacker Jason demonstrates how employees could be tricked by a rogue DHCP server. To help the client prevent such attacks in the future, Jason shows the administrators how to configure their Cisco switches to reject DHCP responses from untrusted ports. He explains that this global setting must be activated before more granular controls can be applied.

Which switch command should Jason recommend to implement this defense?

- A. Switch(config)# ip dhcp snooping
- B. Switch(config)# ip arp inspection vlan 10
- C. Switch(config)# ip dhcp snooping vlan 10
- D. Switch(config-if)# ip dhcp snooping trust

Answer: A

Explanation

The correct answer is A. Switch(config)# ip dhcp snooping because the question asks for the global setting that must be enabled first, before applying more specific (granular) DHCP Snooping controls. In Cisco switching, DHCP Snooping is the primary Layer 2 security feature used to mitigate rogue DHCP server attacks. Once enabled, the switch can distinguish between trusted ports (where legitimate DHCP server responses are allowed, typically uplinks toward the authorized DHCP server) and untrusted ports (typically access ports to end-user devices), where DHCP server responses (DHCP OFFER/DHCP ACK) are filtered to prevent a rogue server from handing out malicious network configuration (gateway/DNS) to clients.

The scenario's defense goal—"reject DHCP responses from untrusted ports"—is exactly what DHCP Snooping enforces after it is enabled and ports are assigned trust states. Conceptually, the workflow is:

Enable DHCP Snooping globally (feature activation),

Enable it for the relevant VLAN(s), and

Mark the legitimate DHCP-facing interface(s) as trusted so only those ports can send DHCP server responses.

Options C and D are part of the later, granular steps:

C enables DHCP snooping for a specific VLAN, which is necessary but is not the global prerequisite the question highlights.

D is applied under an interface to designate a port as trusted; again, this is granular and only meaningful after DHCP snooping is activated.

Option B is a different feature (Dynamic ARP Inspection) and is used to mitigate ARP spoofing/poisoning rather than rogue DHCP.

Therefore, the global command Jason should recommend first is Switch(config)# ip dhcp snooping.

Question #:423 - [Web Application Hacking]

Which advanced session-hijacking technique is hardest to detect and mitigate?

- A. Covert XSS attack

- B. Man-in-the-Browser (MitB) attack
- C. Passive sniffing on Wi-Fi
- D. Session fixation

Answer: B

Explanation

CEH v13 identifies Man-in-the-Browser (MitB) attacks as one of the most dangerous and difficult-to-detect session hijacking techniques, especially in online banking environments. In MitB attacks, malware operates inside the user's browser, intercepting and manipulating transactions in real time.

Unlike XSS or session fixation attacks, MitB bypasses server-side security controls entirely. Even strong encryption, multi-factor authentication, and secure cookies are ineffective because the attack occurs after authentication, within a trusted session.

Passive sniffing is limited by encryption, and session fixation relies on poor session management. Covert XSS requires injection points and is more easily mitigated.

CEH v13 emphasizes that MitB attacks can modify transaction details without user awareness, making detection extremely difficult. Therefore, Option B is correct.

Question #:424 - [Mobile Platform and IoT Hacking]

At Bayview University in San Francisco, California, ethical hacker Sofia Patel is evaluating security controls on Android 11 tablets used by staff. To simulate an attack, she installs KingoRoot.apk directly on one of the devices. The application leverages system vulnerabilities to elevate privileges without requiring a computer connection. Based on the module, which feature of this rooting approach makes the attack effective?

- A. It uses a tethered jailbreak to restart the device with patched kernel functions
- B. It is an APK that can run directly on the device without a PC
- C. It relies on weak SSL validation to bypass application controls
- D. It exploits Bluetooth pairing flaws to gain device-level privileges

Answer: B

Explanation

This scenario describes an Android rooting approach where the attacker installs a rooting tool directly on the device as an APK and uses it to exploit vulnerabilities to gain elevated privileges. The key feature that makes this approach effective, as stated in the question, is that it works without requiring a computer connection. That aligns directly with option B: "It is an APK that can run directly on the device without a PC."

Rooting tools packaged as APKs are effective in environments where physical access is limited to the device itself (or where connecting to a PC is impractical or would raise suspicion). Once installed, such an app can attempt privilege escalation by leveraging known weaknesses in the OS, drivers, or vendor components, aiming to obtain root-level access. From a security assessment standpoint, this demonstrates that mobile devices may be at risk if users can install untrusted applications, if the device is not fully patched, or if application controls (enterprise MDM policies, app allowlisting, unknown-sources restrictions) are weak.

The other options are inconsistent with Android APK-based rooting as described. “Tethered jailbreak” terminology applies to iOS jailbreaking, not Android rooting, and the scenario explicitly says no computer connection is required. Weak SSL validation relates to application-layer transport security issues rather than privilege escalation to root. Bluetooth pairing flaws are a different attack class and are not indicated here; the described method is an on-device exploit chain initiated by installing a rooting APK.

Therefore, the feature that makes this rooting approach effective in the scenario is B: it runs directly on the device as an APK without needing a PC.

Question #:425 - [Web Application Hacking]

A penetration tester is investigating a web server that allows unrestricted file uploads without validating file types. Which technique should be used to exploit this vulnerability and potentially gain control of the server?

- A. Perform a SQL injection attack to extract sensitive database information
- B. Upload a shell script disguised as an image file to execute commands on the server
- C. Conduct a brute-force attack on the server's FTP service to gain access
- D. Use a Cross-Site Scripting (XSS) attack to steal user session cookies

Answer: B

Explanation

CEH teaches that unrestricted file upload vulnerabilities are among the most dangerous in web applications because they allow attackers to bypass extension checks and upload malicious executable files. When the server fails to validate MIME types, file extensions, or execution permissions, an attacker can upload a web shell disguised as a harmless file, such as “image.php.jpg,” which may pass superficial validation and still be executed by the server’s interpreter. Once executed, the shell provides the attacker with command execution capabilities, allowing full control over the system. CEH emphasizes that web shells can enable privilege escalation, database compromise, lateral movement, or full server takeover. Unlike SQL injection or XSS, file upload exploitation directly affects server-side execution, making it significantly more severe. Unrestricted upload flaws are commonly tested in CEH labs with tools like Burp Suite to alter content-type headers or bypass client-side filters. This is a high-impact vulnerability requiring strict validation and sandboxing controls.

Question #:426 - [Security Operations and Incident Response]

As part of a cybersecurity assessment for a healthcare provider in Denver, Colorado, you are asked to recommend a framework that addresses how organizations should identify, assess, and treat information security risks as part of their ISMS. Which international standard best meets this requirement?

- A. ISO/IEC 27701:2019
- B. ISO/IEC 27002:2022
- C. ISO/IEC 27005:2022
- D. ISO/IEC 27001:2022

Answer: C

Explanation

The requirement is specifically for a framework that explains how to identify, assess, and treat information security risks within the context of an Information Security Management System (ISMS). The ISO standard dedicated to information security risk management is ISO/IEC 27005. It provides guidance on establishing a risk management process aligned with the ISO/IEC 27000 family and supports the ISMS by describing risk context, risk identification, risk analysis, risk evaluation, risk treatment, risk acceptance, and ongoing risk communication and monitoring.

This focus on the “how” of risk management is what distinguishes ISO/IEC 27005 from the other options. ISO/IEC 27001:2022 is the standard that specifies the requirements to establish, implement, maintain, and continually improve an ISMS. It requires that risk assessment and treatment be performed, but it is not primarily a detailed methodology standard for conducting those activities. ISO/IEC 27002:2022 is a code of practice that provides a catalog of security controls (the “what” controls you can select), rather than a risk assessment/treatment methodology. ISO/IEC 27701:2019 extends ISO/IEC 27001/27002 to privacy information management (PIMS) and focuses on privacy controls and requirements—not the general information security risk management lifecycle.

Because the question asks for a standard that addresses identification, assessment, and treatment of information security risks as part of an ISMS, ISO/IEC 27005 is the best match. It complements ISO/IEC 27001 by giving organizations practical guidance for building and running the risk management process that ISO/IEC 27001 requires, ensuring risk decisions are systematic, repeatable, and suitable for governance and continual improvement.

Question #:427 - [Security Operations and Incident Response]

A penetration tester performs a vulnerability scan on a company's network and identifies a critical vulnerability related to an outdated version of a database server. What should the tester prioritize as the next step?

- A. Attempt to exploit the vulnerability using publicly available tools or exploits
- B. Conduct a brute-force attack on the database login page
- C. Ignore the vulnerability and move on to testing other systems

D. Perform a denial-of-service (DoS) attack on the database server

Answer: A

Explanation

CEH v13 details the standard penetration testing workflow, where confirmed critical vulnerabilities—especially those affecting core systems like database servers—should be prioritized for exploitation only after verification and when explicitly permitted by the rules of engagement. Exploiting a known vulnerability using vetted tools (e.g., Metasploit, CVE-specific exploits) provides evidence of real-world risk and validates the severity rating. Brute-forcing logins (Option B) is inefficient and often outside scope. Ignoring a critical vulnerability (Option C) violates CEH's prioritization guidelines. A DoS attack (Option D) is never appropriate unless the engagement explicitly authorizes destructive testing, which is rare. CEH stresses that high-impact vulnerabilities should be exploited to demonstrate business risk, privilege escalation potential, data exposure, or lateral movement possibilities—making Option A fully aligned with CEH methodology.

Question #:428 - [Network and Perimeter Hacking]

During a red team assessment at Alpine Manufacturing Corp., network security consultant Marcus Lee is instructed to evaluate the security of internal communications within their switched LAN environment. Without altering any switch configurations, Marcus manages to intercept credentials being transmitted between a payroll administrator's workstation and the backend authentication server. He subtly reroutes the communication path through his testing machine, though no proxy or VPN was involved. Analysis shows the redirection was achieved by injecting crafted messages that silently altered how the two hosts identified each other on the local network.

Which sniffing technique did Marcus most likely use?

- A. DNS Spoofing
- B. Switch Port Stealing
- C. ARP Spoofing
- D. MAC Flooding

Answer: C

Explanation

The described behavior aligns precisely with ARP spoofing, also known as ARP poisoning, a common man-in-the-middle attack technique covered extensively in CEH materials. ARP operates at Layer 2 of the OSI model and is responsible for mapping IP addresses to MAC addresses within a local network. Because ARP lacks authentication mechanisms, any host can send forged ARP replies to other devices on the LAN.

In this scenario, Marcus injects crafted messages that alter how two hosts identify each other. This strongly indicates forged ARP replies were sent to both the payroll workstation and the authentication server. By

telling each system that his machine's MAC address corresponds to the other party's IP address, Marcus positions himself logically between the two endpoints. As a result, traffic is transparently routed through his system without requiring changes to switch configurations, proxies, or VPN tunnels.

This technique enables interception and potential modification of credentials in transit. DNS spoofing affects domain name resolution rather than direct Layer 2 host identification. MAC flooding overflows the switch CAM table to force broadcast behavior but does not specifically manipulate IP-to-MAC mappings between two targeted hosts. Switch port stealing targets MAC table entries but does not rely on altering host identity mappings in the same way ARP poisoning does.

Therefore, ARP spoofing is the most accurate technique described in this scenario.

Question #:429 - [Malware Threats]

During a red team engagement at a manufacturing company in Dallas, penetration tester Tyler gains access to a Windows workstation. Later in the exercise, he reviews his exfiltrated logs and finds detailed records of employee logins, email drafts, and sensitive data entered into desktop applications. The collection occurred without requiring browser injection or physical device access, and no kernel drivers were installed.

Which type of keylogger did Tyler most likely deploy?

- A. JavaScript Keylogger
- B. Hardware Keylogger
- C. Kernel Keylogger
- D. Application Keylogger

Answer: D

Explanation

The correct answer is D. Application Keylogger because the scenario describes keystroke capture from desktop applications on a Windows workstation without installing kernel drivers and without requiring physical access or browser-level script injection. In CEH-aligned keylogger classifications, an application (user-mode) keylogger operates at the application layer by using user-space techniques such as hooking common Windows APIs (for example, keyboard input functions and message-handling routines) to intercept keystrokes as they are processed by applications. This enables logging of credentials typed into local programs, draft emails written in desktop clients, and sensitive text entered into business tools—exactly the outcome Tyler observed.

The question provides two strong eliminators. First, it states no kernel drivers were installed, which rules out kernel keyloggers that capture input at the kernel level (often requiring driver installation and deeper OS integration). Second, it states the attack did not require browser injection, which rules out a JavaScript keylogger (typically implemented by injecting script into a web page/application to capture form inputs within a browser session). It also explicitly notes that there was no physical device access, which rules out a hardware keylogger (a physical device placed between keyboard and computer or embedded in a keyboard) that requires in-person installation.

Application keyloggers are frequently used in post-exploitation because they can be deployed quickly with standard user-level privileges (though higher privileges may expand coverage), can target a broad range of applications, and can run covertly. From a defense perspective, monitoring for suspicious API hooking behavior, unusual process injection, abnormal input-capture patterns, and endpoint controls that detect credential access techniques are common countermeasures.

Therefore, given the constraints and the observed logging of desktop application input, the most likely keylogger type is an application keylogger.

Question #:430 - [Network and Perimeter Hacking]

Multiple internal workstations and IoT devices are compromised and transmitting large volumes of traffic to numerous external targets under botnet control. Which type of denial-of-service attack best describes this situation?

- A. An attack where compromised internal devices participate in a botnet and flood external targets
- B. An attack relying on spoofed IP addresses to trick external servers
- C. A direct botnet flood without spoofing intermediary services
- D. An internal amplification attack using spoofed DNS responses

Answer: A

Explanation

This scenario represents a Botnet-Based Distributed Denial-of-Service (DDoS) attack, as described in CEH v13 Network Attacks. Compromised internal devices become part of a botnet and are used to launch attacks against external targets.

CEH v13 notes that botnets frequently include IoT devices and employee workstations, making insider-originated DDoS activity a serious concern.

Question #:431 - [Security Operations and Incident Response]

At a federal research agency, cybersecurity officer Nikhil is drafting a vulnerability assessment report. In this section, he documents the scanning methodology used, the information about the targets, the type and scope of scans performed, and the tools involved. He does not yet include specific vulnerabilities or affected assets, as this portion of the report is meant to provide context for how the assessment was conducted.

Which section of the vulnerability assessment report is Nikhil working on?

- A. Supporting Information
- B. Risk Assessment
- C. Assessment Overview

D. Findings

Answer: C

Explanation

The described content matches the Assessment Overview section because it focuses on how the vulnerability assessment was executed rather than what was found. An assessment report typically includes a part that explains the methodology and approach used to perform scanning so stakeholders can understand the process, validate coverage, and interpret results correctly. In this scenario, Nikhil is documenting the scanning methodology, target information, type and scope of scans, and the tools used. These elements provide context and transparency about the assessment process, assumptions, and boundaries—exactly what an overview is meant to capture.

This section is also intentionally not listing specific vulnerabilities or affected assets, which further confirms it is not the Findings section. Findings is where the report enumerates discovered vulnerabilities, affected systems, evidence, severity, and recommendations. Similarly, it is not the Risk Assessment section because that portion generally interprets the findings to determine likelihood and impact, prioritizes risks, and may map issues to business impact or compliance requirements. Since Nikhil is only describing the scanning approach and scope, risk analysis is premature and out of place.

Why not Supporting Information? Supporting information usually contains appendices or reference material that supplements the core report—such as raw scan outputs, detailed configuration data, asset inventories, screenshots, logs, tool configurations, or glossary/definitions. While tool names and technical details can appear there, the narrative about methodology, targets, scope, and scan types is more appropriately part of the main body's overview so readers understand the assessment context before reviewing results.

Therefore, the section Nikhil is working on is C. Assessment Overview, which establishes the assessment context and explains the scanning approach prior to presenting findings and risk conclusions.

Question #:432 - [Network and Perimeter Hacking]

A penetration tester is mapping a Windows-based internal network. The tester notices that TCP port 139 and UDP port 137 are open on multiple systems. File and printer sharing is enabled. To retrieve hostnames, user details, and domain roles without triggering alerts, which tool and method would be most effective?

- A. Perform LDAP enumeration via anonymous bind
- B. Use pspasswd to change remote passwords
- C. Run nbtstat -A to query the NetBIOS name table
- D. Use psloggedon to retrieve remote login sessions

Answer: C

Explanation

CEH v13 teaches that NetBIOS enumeration is a key technique for gathering information in Windows environments without raising alarms. Ports 137 and 139 indicate that NetBIOS Name Service (NBNS) and

SMB services are active. The tool `nbtstat -A <IP>` retrieves valuable information including computer names, logged-in users, domain/workgroup membership, and system roles—all passively and without authentication. CEH emphasizes that querying NetBIOS is often overlooked by defenders and generates minimal noise, making it ideal for stealth enumeration. LDAP enumeration (Option A) requires directory access and tends to trigger logs. `Psloggedon` and `pspasswd` (Options B and D) involve active interaction and authentication attempts, which are far more detectable. `nbtstat` is the CEH-recommended tool for initial reconnaissance on Windows networks using NetBIOS and SMB, especially when quiet enumeration is required.

Question #:433 - [Network and Perimeter Hacking]

During a penetration test at a healthcare provider in Phoenix, ethical hacker Sofia crafts a stream of IP packets with manipulated offset fields and overlapping payload offsets so that the records server's protocol stack repeatedly attempts to reconstruct the original datagrams. The repeated reconstruction attempts consume CPU and memory, causing the system to crash intermittently and disrupt patient portal access, even though overall bandwidth remains normal. Packet analysis shows deliberately malformed offsets that trigger processing errors rather than a simple flood of traffic.

Which type of attack is Sofia most likely simulating?

- A. Fragmentation Attack
- B. ICMP Flood
- C. Teardrop Attack
- D. Ping of Death

Answer: C

Explanation

This scenario matches a Teardrop attack, which exploits IP fragmentation reassembly weaknesses by sending fragments with overlapping or inconsistent offset fields. In a teardrop attack, the attacker crafts IP fragments so that when the target attempts to reassemble them into the original datagram, the fragment offsets and sizes do not align correctly (often overlapping). Vulnerable systems can experience errors in the reassembly process, leading to CPU/memory exhaustion, crashes, or instability in the network stack. The question highlights “manipulated offset fields and overlapping payload offsets,” “repeated attempts to reconstruct,” and “deliberately malformed offsets that trigger processing errors rather than a simple flood,” which are all core teardrop characteristics.

The impact described—system crashes and service disruption without abnormal bandwidth usage—also fits. This is not a volumetric DoS (like ICMP flood); it's a malformed-packet attack that targets protocol stack processing. The key is that the attacker is exploiting how the target handles fragmented packets, causing excessive processing and failure during reassembly.

Why the other options are less accurate:

Fragmentation attack (A) is a broader category and could include many fragmentation-based manipulations, but “overlapping offsets causing reassembly failure” is the classic teardrop pattern.

ICMP flood (B) is bandwidth/packet-rate driven and does not involve IP fragment offset manipulation.

Ping of Death (D) involves oversized ICMP packets (often via fragmentation) exceeding maximum IP size, causing crashes on vulnerable stacks; the scenario instead emphasizes overlapping offsets and reassembly logic errors rather than oversized packet size.

Therefore, Sofia is most likely simulating C. Teardrop Attack.

Question #:434 - [Reconnaissance Techniques]

Which approach should an ethical hacker avoid to maintain passive reconnaissance?

- A. Direct interaction with the threat actor
- B. WHOIS and DNS lookups
- C. Anonymous browsing via Tor
- D. Using the Wayback Machine

Answer: A

Explanation

CEH v13 defines passive reconnaissance as information gathering without interacting directly with the target or alerting them. The goal is to remain undetected while collecting intelligence from publicly available sources.

Directly interacting with a threat actor on forums—even under a pseudonym—constitutes active engagement. CEH v13 warns that such interaction risks exposure, attribution, and legal complications. It can alert the adversary, cause them to alter behavior, or even retaliate.

WHOIS lookups, DNS queries, archived web content, and anonymous browsing are all passive techniques endorsed in CEH v13. These methods do not notify the target and leave minimal trace.

Thus, Option A should be avoided to maintain a low profile.

Question #:435 - [Network and Perimeter Hacking]

An e-commerce platform hosted on a public cloud infrastructure begins to experience significant latency and timeouts. Logs show thousands of HTTP connections sending headers extremely slowly and never completing the full request. What DoS technique is most likely responsible?

- A. Slowloris holding web server connections
- B. Fragmentation flood attack
- C. UDP application-layer flooding

D. SYN flood with spoofed source IPs

Answer: A

Explanation

CEH v13 identifies Slowloris as a low-bandwidth yet highly effective application-layer DoS technique that works by opening many HTTP connections and sending headers very slowly, never completing the request. Because the server must maintain these half-open HTTP sessions, its connection pool becomes saturated, preventing it from servicing legitimate users. Slowloris is particularly dangerous because it does not rely on malformed packets, high traffic volume, or protocol abuses; instead, it mimics legitimate HTTP behavior, making it difficult for firewalls or IDS systems to distinguish malicious traffic. This aligns exactly with the described scenario, where thousands of legitimate-looking HTTP connections are gradually consuming server resources. Fragmentation attacks (Option B) target packet reconstruction, UDP floods (Option C) generate high-bandwidth noise, and SYN floods (Option D) impact the TCP handshake layer, not the HTTP header behavior. Slowloris' unique use of slow HTTP headers directly matches the symptoms described.

Question #:436 - [Cloud Computing]

A company's customer data in a cloud environment has been exposed due to an unknown vulnerability. Which type of issue most likely led to the incident?

- A. Side-channel attack on the hypervisor
- B. Denial-of-Service (DoS) attack on cloud servers
- C. Brute-force attack on user passwords
- D. Exploitation of misconfigured security groups

Answer: D

Explanation

In CEH's Cloud Computing module, one of the most common real-world causes of cloud data exposure is misconfiguration, especially overly permissive network access controls. Cloud platforms commonly use constructs like security groups / firewall rules / network ACLs to define inbound and outbound access. CEH highlights that exposing sensitive services (databases, storage endpoints, admin panels) to the public internet—whether by “0.0.0.0/0” rules, overly broad ports, or unintended administrative access—frequently results in unauthorized access and data leakage even without sophisticated exploit chains.

Option D is therefore the most likely, because misconfigured security groups can directly expose customer data stores or management interfaces, enabling data theft through normal connectivity rather than exploiting a rare hypervisor flaw.

Option A (hypervisor side-channel attack) is advanced and less common; it typically requires high attacker capability and conditions not implied here. Option B (DoS) impacts availability, not confidentiality, so it doesn't best explain data exposure. Option C (brute force passwords) is possible, but the question emphasizes an “unknown vulnerability” in the cloud environment—CEH teaching often frames “unknown vulnerability” in cloud incidents as misconfiguration or uncontrolled exposure rather than authentication guessing alone.

CEH countermeasures include least-privilege security group rules, segmentation, continuous configuration monitoring, cloud security posture management, and auditing publicly exposed resources.

Question #:437 - [Security Operations and Incident Response]

During routine network monitoring, the blue team notices several LLMNR and NBT-NS broadcasts originating from a workstation attempting to resolve an internal hostname. They also observe suspicious responses coming from a non-corporate IP address that claims to be the requested host. Upon further inspection, the security team suspects that an attacker is impersonating network resources to capture authentication attempts. What type of password-cracking setup is likely being staged?

- A. Decrypt login tokens from wireless networks
- B. Use CPU resources to guess passphrases quickly
- C. Exploit name resolution to capture password hashes
- D. Match captured credentials with rainbow tables

Answer: C

Explanation

CEH incident response material explains that LLMNR and NBT-NS poisoning is a common credential-harvesting technique in internal networks. These legacy name-resolution protocols operate via broadcast queries. Attackers can listen for these broadcasts and respond faster than legitimate DNS/hosts entries, impersonating the requested resource. Once the victim system attempts to authenticate, it sends NTLM hashes to the attacker-controlled machine. Tools like Responder and Inveigh automate this process, enabling attackers to collect challenge-response hashes for offline cracking. CEH highlights that this method is passive from the victim's viewpoint and difficult to detect unless monitoring tools watch for anomalous LLMNR/NBT-NS responses. Options A, B, and D refer to other components of password cracking, but none describe the mechanism of capturing hashes via poisoned name resolution. The attacker's technique directly aligns with exploiting the name-resolution protocol to intercept authentication attempts.

Question #:438 - [Security Operations and Incident Response]

A penetration tester is running a vulnerability scan on a company's network. The scan identifies an open port with a high-severity vulnerability linked to outdated software. What is the most appropriate next step for the tester?

- A. Execute a denial-of-service (DoS) attack on the open port
- B. Perform a brute-force attack on the service running on the open port
- C. Research the vulnerability and determine if it has a publicly available exploit
- D. Ignore the vulnerability and focus on finding more vulnerabilities

Answer: C**Explanation**

CEH v13 outlines a structured approach to vulnerability assessment and exploitation. After identifying a high-severity vulnerability, the next critical step is verification and research, not immediate exploitation. This ensures accuracy, reduces false positives, and avoids unnecessary risk. CEH emphasizes that testers must validate vulnerability details, confirm version applicability, assess exploit availability (e.g., Metasploit, Exploit-DB), and evaluate potential impact. Attempting DoS attacks (Option A) is prohibited unless explicitly scoped and does not align with responsible testing. Brute-force attacks (Option B) are unrelated to software version vulnerabilities. Ignoring the issue (Option D) violates CEH methodology. The correct process is to research and verify—ensuring exploitation is safe, relevant, and authorized. This aligns with CEH’s vulnerability management lifecycle: discovery # verification # prioritization # exploitation (when allowed) # reporting.

Question #:439 - [Network and Perimeter Hacking]

During a security assessment in San Francisco, an ethical hacker is tasked with evaluating a network's resilience against stealthy reconnaissance attempts. The hacker needs to employ a scanning technique that leverages TCP flags to evade detection by intrusion detection systems, relying on the target's response behavior to infer port states without completing a full connection. Which approach best aligns with this strategy, ensuring minimal visibility during the assessment?

- A. TCP Connect Scan
- B. Network Scanning
- C. FIN Scan
- D. NULL Scan

Answer: C**Explanation**

A FIN scan is a classic “stealth” TCP scan technique discussed in CEH network scanning methodology. Unlike a TCP Connect scan, which completes the full three-way handshake and is highly visible in logs, a FIN scan sends a TCP packet with only the FIN flag set to a target port. The scan then interprets the target’s response to infer whether the port is open or closed, without establishing a normal TCP session. This matches the scenario’s requirement to “infer port states without completing a full connection” and to keep visibility low.

The logic relies on expected TCP behavior defined for many TCP/IP stacks. For a closed port, the target typically responds with an RST packet, indicating there is no service listening. For an open port, many systems do not respond at all to an unexpected FIN packet (because it does not correspond to an existing connection). That “no response” behavior becomes the signal the tester uses to suspect the port may be open or filtered. CEH emphasizes that because FIN scans do not perform a handshake, they can be less likely to trigger certain basic connection-based logging, and they generate fewer obvious connection events than TCP Connect scans.

Option D, NULL scan, is also a stealth method, but it uses a packet with no flags set. The question specifically highlights leveraging TCP flags and is commonly mapped in CEH-style questions to FIN scanning as the representative “TCP flag stealth scan.” Option B is too generic, and option A is the most detectable. Therefore, FIN scan best aligns with the described stealth reconnaissance strategy.

Question #:440 - [Reconnaissance Techniques]

In a security assessment conducted in New York, Sarah, an ethical hacker, is evaluating a corporate network to enhance its protection against potential threats. She aims to gather essential data about available access points to guide her analysis. Which scanning technique should Sarah apply to meet this objective while adhering to the organization's ethical guidelines?

- A. Vulnerability Scanning
- B. Port Scanning
- C. Topology Mapping
- D. Network Scanning

Answer: B

Explanation

Port scanning is the CEH-aligned technique used to identify available access points into systems, where “access points” refers to open TCP and UDP ports and the services listening on them. In the reconnaissance and scanning phases described in CEH methodology, testers first enumerate live hosts and then perform port scanning to discover which network services are reachable, such as HTTP on 80 or 443, SSH on 22, RDP on 3389, DNS on 53, and many others. This information directly guides the next steps of analysis by revealing the attack surface: what services are exposed, which systems are running them, and which ports may permit remote interaction.

Vulnerability scanning is different because it attempts to identify known weaknesses or misconfigurations and typically requires service detection, versioning, and signature or configuration checks. It is usually performed after ports and services are discovered, not as the first method for finding “available access points.” Topology mapping focuses on understanding how the network is structured, including routing paths, device relationships, and segmentation boundaries. Network scanning is a broader term that can include host discovery and other probes, but it is less precise than port scanning for identifying the specific entry points that an attacker could use to connect.

Under ethical guidelines, port scanning is conducted with proper authorization, scoped targets, controlled timing to avoid disruption, and clear reporting of open ports, detected services, and risk implications so defenders can reduce exposure by closing unnecessary ports and hardening required services.

Question #:441 - [Reconnaissance Techniques]

Why is NTP responding with internal IP addresses and hostnames?

- A. TCP fallback abuse

- B. DNS poisoning
- C. Honeypot redirection
- D. Misconfigured NTP daemon allowing external queries

Answer: D

Explanation

CEH v13 explains that NTP (UDP port 123) can leak sensitive network information if misconfigured. When an NTP daemon allows unrestricted external queries (e.g., monlist or ntpq commands), attackers can enumerate internal IP addresses and hostnames.

This exposure is a known reconnaissance weakness and has been exploited in both information disclosure and amplification attacks. CEH v13 strongly recommends restricting NTP query access using access control lists.

DNS poisoning and honeypots do not explain legitimate NTP enumeration responses. Therefore, option D is correct.

Question #:442 - [Information Security and Ethical Hacking Overview]

During a compliance review at a law firm in Chicago, an ethical hacker tests the firm's secure email gateway. She observes that sensitive legal documents are being transmitted in clear text over the Internet, allowing anyone intercepting the traffic to read the contents. The firm is concerned about unauthorized individuals being able to view these communications. Which principle of information security is being violated?

- A. Confidentiality
- B. Integrity
- C. Non-Repudiation
- D. Availability

Answer: A

Explanation

The correct answer is A. Confidentiality because the scenario describes sensitive information being transmitted in clear text, meaning the contents can be read by any unauthorized party who is able to intercept the traffic. In information security, confidentiality is the principle that ensures information is accessible only to authorized individuals, entities, or processes. When communications are sent without adequate protection—such as encryption—attackers performing network interception (for example, through man-in-the-middle positioning, packet sniffing on compromised routers, malicious Wi-Fi, or upstream monitoring) can directly view the document contents. That is a direct failure of confidentiality controls.

The prompt's key phrase is that "anyone intercepting the traffic can read the contents." This is not describing altered messages or forged emails; it is describing unauthorized disclosure. Confidentiality is typically

protected using mechanisms such as encryption in transit (e.g., TLS for SMTP submission and server-to-server transport where possible, S/MIME, PGP), secure key management, and policy enforcement at email gateways. In legal environments, confidentiality is particularly critical because client communications and legal documents often contain privileged or regulated information. Clear-text transmission exposes the firm to compliance violations, reputational harm, and potential legal consequences.

Why the other options are not correct: Integrity concerns whether the message or document is altered in transit (tampering, modification, insertion). The scenario does not mention changes—only unauthorized reading. Non-repudiation ensures parties cannot deny sending or receiving a message (often supported by digital signatures and logging). The issue here is not proof-of-origin but exposure. Availability relates to whether systems and data remain accessible when needed (uptime, resilience, DoS). Nothing indicates service disruption.

Therefore, transmitting sensitive legal documents in clear text violates the fundamental security principle of confidentiality.

Question #:443 - [System Hacking Phases]

Targeted, logic-based credential guessing using prior intel best describes which technique?

- A. Strategic pattern-based input using known logic
- B. Exhaustive brute-force testing
- C. Shoulder surfing
- D. Rule-less hybrid attack

Answer: A

Explanation

This describes a rule-based or logic-based password attack, which CEH v13 classifies as a smart, targeted guessing technique. Attackers use known patterns—such as naming conventions, dates, or personal interests—to reduce the keyspace and increase success rates.

Option A accurately reflects this methodology. Option B is brute force, which is random and exhaustive. Option C is physical observation. Option D describes hybrid attacks without structured logic.

CEH v13 emphasizes that pattern-based attacks are highly effective when attackers possess prior intelligence. Therefore, Option A is correct.

Question #:444 - [Social Engineering]

A penetration tester targets a company's executive assistants by referencing upcoming board meetings in an email requesting access to confidential agendas. What is the most effective social engineering technique to obtain the necessary credentials without raising suspicion?

- A. Create a personalized email referencing specific meetings and request access

- B. Call posing as a trusted IT support to verify credentials
- C. Send a mass phishing email with a fake meeting link
- D. Develop a fake LinkedIn profile to connect and request information

Answer: A

Explanation

CEH v13 identifies spear-phishing as one of the most effective and targeted social engineering methods. It involves crafting highly personalized messages that reference real events, internal processes, or upcoming activities to build credibility and reduce suspicion. In this scenario, referencing board meetings—an event executive assistants frequently handle—creates a believable and urgent context for the request. CEH emphasizes that personalization significantly increases success rates because recipients perceive the sender as someone with legitimate access to internal information. A phone call impersonating IT support (Option B) is less convincing for retrieving agenda access-specific credentials. Mass phishing (Option C) lacks personalization and is easily flagged. LinkedIn social engineering (Option D) is long-term and less effective for obtaining immediate credentials. Therefore, a tailored spear-phishing email is the most effective approach.

Question #:445 - [System Hacking Phases]

During a post-exploitation phase on a compromised finance department workstation, ethical hacker Anika uses her Meterpreter session to extract sensitive credential data. After running a command, she receives a long list of alphanumeric strings representing LM and NTLM values. These outputs are later transferred to a cracking rig for offline password recovery, allowing the red team to simulate credential theft across multiple systems.

Which Meterpreter command most likely produced these results?

- A. keyscan_start
- B. hashdump
- C. getsystem
- D. screenshot

Answer: B

Explanation

The correct answer is B. hashdump because the output described—“a long list of alphanumeric strings representing LM and NTLM values”—matches the Windows password hash formats typically extracted from the local Security Account Manager (SAM) database (with supporting data from the SYSTEM hive). In CEH-aligned post-exploitation and credential access concepts, attackers frequently target LM/NTLM hashes rather than plaintext passwords. Hashes can be taken offline for password recovery attempts (e.g., dictionary/brute-force and rule-based cracking), which aligns with the scenario where the values are transferred to a cracking rig.

Within a Meterpreter context, hashdump is the command commonly associated with dumping local account password hashes from a compromised Windows host. The hashes are useful for simulating credential compromise across an environment because recovered passwords may be reused on other systems, and even without recovery, hashes can sometimes be leveraged in authentication abuse scenarios depending on controls in place.

Why the other options are incorrect:

keyscan_start initiates keystroke logging in Meterpreter; it would not output LM/NTLM hash strings.

getsystem attempts privilege escalation to SYSTEM-level (or equivalent). While higher privileges may be required before successfully dumping hashes, getsystem itself does not produce a list of hashes; it changes /attempts to change the privilege context.

screenshot captures the user's screen and has no relationship to credential hash extraction.

The "post-exploitation phase" detail is important: credential dumping is a classic activity after gaining a foothold, used to expand access (pivoting/lateral movement) and assess the impact of poor password hygiene. From a defensive perspective, this highlights the need for least privilege, credential protection controls, restricted local admin, strong password policies, and monitoring for suspicious credential-access behaviors.

Question #:446 - [Reconnaissance Techniques]

While analyzing logs, you observe a large number of TCP SYN packets sent to various ports with no corresponding ACKs. What scanning technique was likely used?

- A. SYN scan (half-open scanning)
- B. XMAS scan
- C. SYN/ACK scan
- D. TCP Connect scan

Answer: A

Explanation

This activity clearly indicates a TCP SYN scan, also known as a half-open scan, which is a commonly used stealth scanning technique discussed in CEH v13 Reconnaissance and Network Scanning. In a SYN scan, the attacker sends TCP SYN packets to target ports and observes the responses without completing the TCP three-way handshake.

If the port is open, the target responds with a SYN/ACK packet. The scanner then immediately sends a RST packet instead of the final ACK, leaving the connection half-open. This behavior allows attackers to identify open ports while minimizing log entries and reducing detection by security monitoring tools.

The absence of ACK packets in logs supports this explanation, as the handshake is never completed.

Other options are incorrect because:

XMAS scans send packets with multiple flags set.

SYN/ACK scans are primarily used for firewall rule discovery.

TCP Connect scans complete the full handshake and generate ACKs.

CEH v13 emphasizes that SYN scans are widely used because they balance accuracy and stealth, making them a preferred reconnaissance method for attackers.

Question #:447 - [Information Security and Ethical Hacking Overview]

As the cybersecurity lead for an international news agency, you are alerted by your threat intelligence team that confidential communications between journalists and whistleblowers have been posted to an online activist forum. Further forensic analysis reveals that no financial transactions were tampered with and no ransomware was deployed. However, the agency's internal systems were accessed and selectively leaked emails were published alongside a manifesto accusing the organization of biased reporting. The attackers also posted on social media claiming responsibility and justifying their actions as a fight against misinformation.

Based on this behavior, what category of hacker are you most likely dealing with?

- A. Script Kiddies
- B. Hacktivists
- C. Black Hat hackers
- D. White Hat hackers

Answer: B

Explanation

Hacktivists are the most likely category because the scenario is driven by an ideological or political motive rather than direct financial gain. The attackers selectively accessed internal systems and leaked communications, then paired the leak with a manifesto accusing the agency of biased reporting. They also publicly claimed responsibility on social media and framed the intrusion as a fight against misinformation. In CEH-aligned terminology, hacktivism commonly involves unauthorized access, defacement, doxxing, or data leakage intended to influence public opinion, embarrass a target, or push a political or social agenda. The public messaging and justification are key indicators of hacktivist intent.

The other options do not fit as well. Script kiddies typically use ready-made tools with limited sophistication and usually do not produce coordinated ideological messaging or targeted, narrative-driven leaks. Black hat hackers are defined by malicious intent, but they are most commonly associated with theft for profit, extortion, fraud, or ransomware. This incident explicitly notes there was no ransomware and no financial tampering, reducing the likelihood that profit was the primary objective. White hat hackers operate with authorization and documented scope, and they do not leak sensitive whistleblower communications or publish manifestos.

Therefore, the combination of unauthorized access, selective exposure of sensitive information, and public ideological justification aligns most strongly with hackers.

Question #:448 - [Network and Perimeter Hacking]

During a penetration test at a regional bank in Richmond, ethical hacker Thomas is tasked with identifying weaknesses in how employee credentials are transmitted. He sets up Wireshark on a mirrored port and captures HTTP login sessions from the customer services VLAN. To quickly reconstruct entire conversations between browsers and the server, Thomas uses a feature that reassembles packet data into a readable stream, allowing him to view usernames and passwords directly in plain text.

Which Wireshark feature is Thomas most likely using in this case?

- A. Filtering by IP Address
- B. Display Filtering by Protocol
- C. Monitoring the Specific Ports
- D. Follow TCP Stream

Answer: D

Explanation

Thomas is most likely using Follow TCP Stream. This Wireshark feature reconstructs the bidirectional application data carried over a TCP connection by reassembling packets in sequence into a readable conversation view. When traffic is unencrypted HTTP, the reassembled stream can reveal full request/response content, including URLs, headers, form parameters, and—critically in this scenario—usernames and passwords transmitted in clear text (for example, within POST body parameters).

The scenario's language is a direct match: "reconstruct entire conversations between browsers and the server" and "reassembles packet data into a readable stream." That is exactly what Follow TCP Stream does: it groups packets that belong to the same TCP session and displays the payload as contiguous data, making it far easier than manually inspecting individual packets. This is commonly used during assessments and investigations to understand what data was exchanged, validate whether sensitive data is exposed, and confirm whether protections like TLS are properly applied.

Why the other options are not correct:

Filtering by IP Address (A) helps narrow the packet list to specific hosts but does not reconstruct conversations.

Display Filtering by Protocol (B) can isolate HTTP packets but still leaves the analyst to interpret individual packets without full reassembly.

Monitoring the Specific Ports (C) similarly narrows traffic (e.g., TCP/80 for HTTP) but does not present a reassembled readable session.

Because the goal is quick, readable reconstruction of HTTP login sessions over TCP, the correct answer is D. Follow TCP Stream.

Question #:449 - [Network and Perimeter Hacking]

During a penetration test at Triangle FinTech in Raleigh, North Carolina, ethical hacker Ethan attempts to bypass the company's perimeter firewall. Instead of sending obvious malicious payloads, he encapsulates his traffic inside standard web requests on port 80, blending in with normal browsing activity. This method allows his packets to slip past perimeter defenses that are not performing deep application inspection.

Which firewall evasion technique is Ethan most likely using?

- A. HTTP Tunneling
- B. Source Routing
- C. Tiny Fragments
- D. DNS Tunneling

Answer: A

Explanation

The described technique is HTTP tunneling because Ethan is encapsulating his traffic inside standard web requests on port 80 to blend with normal browsing activity and bypass perimeter defenses that only perform basic port/protocol filtering. HTTP tunneling leverages the fact that many organizations allow outbound (and sometimes inbound) HTTP/HTTPS traffic through firewalls for business needs. If a firewall is not doing deep inspection (such as application-layer proxying, WAF inspection, or strict egress controls), encapsulated traffic can traverse allowed ports while carrying non-HTTP payloads inside the HTTP structure.

The scenario's core clues are: (1) "encapsulates his traffic inside standard web requests," (2) uses port 80, and (3) success depends on the firewall "not performing deep application inspection." These are exactly the conditions where HTTP tunneling is effective: the traffic appears as ordinary HTTP sessions, so the firewall treats it as permitted web traffic even though the content is being used as a carrier for another protocol or command channel.

Why the other options don't fit:

DNS tunneling (D) also encapsulates traffic, but it uses DNS queries/responses (typically UDP/TCP 53), not HTTP requests on port 80.

Tiny fragments (C) is an evasion method that breaks packets into very small fragments to confuse filtering /IDS reassembly; the scenario is about encapsulation in web requests, not fragmentation.

Source routing (B) attempts to influence packet path using IP options; it is not described here and is commonly blocked/ignored in modern networks.

Therefore, the firewall evasion technique is A. HTTP Tunneling.

Question #:450 - [Cloud Computing]

An attacker places a malicious VM on the same physical server as a target VM in a multi-tenant cloud environment. The attacker then extracts cryptographic keys using CPU timing analysis. What type of attack was conducted?

- A. Side-channel attack
- B. Cloud cryptojacking
- C. Cache poisoned denial of service (CPDoS)
- D. Metadata spoofing

Answer: A

Explanation

CEH cloud modules explain that side-channel attacks exploit indirect information leakage based on hardware characteristics—such as CPU timing, power usage, cache access patterns, or electromagnetic emissions. In virtualized cloud environments, multiple tenants share the same physical hardware, creating opportunities for attackers to extract sensitive data from neighboring virtual machines. By placing a malicious VM on the same host as the victim, an attacker can measure minute differences in timing during cryptographic operations, allowing them to infer private keys or sensitive computations. This aligns precisely with CEH's definition of a side-channel attack. Cryptojacking involves unauthorized cryptocurrency mining, CPDoS targets caching layers rather than key extraction, and metadata spoofing manipulates cloud metadata endpoints. Only side-channel analysis matches the described attack behavior.

Question #:451 - [Security Operations and Incident Response]

A vulnerability has a score of 9.8. What does this rating help explain?

- A. It quantifies impact and exploitability to prioritize remediation
- B. It measures authentication errors
- C. It generates exploit payloads
- D. It classifies attacks qualitatively

Answer: A

Explanation

This refers to the CVSS (Common Vulnerability Scoring System), which CEH v13 identifies as the industry standard for vulnerability prioritization. A score of 9.8 indicates critical severity, combining metrics such as exploitability, impact, privileges required, and scope.

CVSS helps organizations prioritize remediation objectively, focusing resources on vulnerabilities with the highest business risk. It also allows consistent communication between technical and management teams.

Options B, C, and D misrepresent CVSS functionality. Therefore, Option A is correct.

Question #:452 - [Cloud Computing]

During a cloud security assessment, it was discovered that a former employee still had access to critical resources months after leaving the organization. Which practice would have most effectively prevented this issue?

- A. Using multi-cloud deployment models
- B. Implementing real-time traffic analysis
- C. Conducting regular penetration tests
- D. Enforcing timely user de-provisioning

Answer: D

Explanation

According to CEH v13 Cloud Computing, improper identity and access management (IAM) is one of the most common causes of cloud security incidents. When former employees retain access to cloud resources, it represents a failure in user lifecycle management, specifically in the de-provisioning phase.

Timely user de-provisioning ensures that when an employee leaves the organization or changes roles, all associated access rights—API keys, IAM roles, credentials, tokens, and permissions—are immediately revoked. CEH v13 emphasizes that cloud environments magnify this risk because access is often centralized and remote, meaning former employees can access systems from anywhere.

Options A, B, and C are supportive security practices but do not directly address the root cause. Multi-cloud models do not prevent unauthorized access. Traffic analysis may detect misuse after the fact but does not prevent it. Penetration testing identifies vulnerabilities but does not manage user access.

CEH v13 explicitly identifies timely de-provisioning as a critical cloud security control to prevent insider threats, privilege abuse, and compliance violations. Therefore, Option D is the correct answer.

Question #:453 - [Reconnaissance Techniques]

During a large-scale network assessment of a telecom provider in Dallas, Texas, a cybersecurity consultant uses Recon-ng and Nmap to enumerate legacy and infrastructure-level services across multiple nodes. The tools uncover open Telnet ports, FTP directories with anonymous login enabled, active TFTP services, and exposed SMB shares. The consultant also detects a service that responds to VRFY, EXPN, and RCPT commands, allowing the enumeration of user identities and delivery addresses due to weak input validation. IPv6 tunneling protocols are also detected. Concerned about information leakage, the consultant flags these services for immediate remediation.

Which classification best describes this set of enumeration activities?

- A. LDAP Enumeration
- B. VoIP Enumeration
- C. SMTP Enumeration
- D. DNS Enumeration

Answer: C

Explanation

SMTP enumeration is the correct classification because the scenario explicitly references the SMTP commands VRFY, EXPN, and RCPT, which are well-known techniques for discovering valid user accounts and email routing information on mail servers. In CEH-aligned enumeration methodology, attackers and testers use these commands to determine whether specific usernames or mailbox addresses exist. VRFY is used to verify a user, EXPN can expand a mailing list or alias into individual recipients, and RCPT TO is commonly tested during an SMTP conversation to see whether a recipient address is accepted or rejected. When a server provides detailed responses, it can leak account validity and internal addressing formats, enabling targeted phishing, password spraying against known usernames, and broader social engineering campaigns.

Although the assessment also identifies Telnet, FTP with anonymous access, TFTP, and SMB shares, those findings represent additional exposed services and misconfigurations rather than the named enumeration classification in the answer choices. LDAP enumeration would focus on directory queries against services such as LDAP or Active Directory to extract users and groups. VoIP enumeration would involve SIP endpoints, extensions, and call infrastructure. DNS enumeration would center on zone transfers, record harvesting, and subdomain discovery. The distinguishing clue here is the use of VRFY, EXPN, and RCPT, which is uniquely tied to SMTP behavior and mail server user enumeration, making SMTP Enumeration the best fit.

Question #:454 - [System Hacking Phases]

During an internal red team engagement at a software company in Boston, ethical hacker Meera gains access to a developer's workstation. To ensure long-term persistence, she plants a lightweight binary in a hidden directory and configures it to automatically launch every time the system is restarted. Days later, even after the host was rebooted during patching, the binary executed again without requiring user interaction, giving Meera continued access.

Which technique most likely enabled this persistence?

- A. Scheduled Tasks
- B. Creating a new service
- C. Startup Folder
- D. Registry run keys

Answer: D**Explanation**

The persistence described—“automatically launch every time the system is restarted” with no user interaction—most commonly aligns with Registry Run keys on Windows. Run keys are a classic persistence mechanism where an attacker adds a value referencing their executable to locations such as HKCU\Software\Microsoft\Windows\CurrentVersion\Run (per-user) or HKLM\Software\Microsoft\Windows\CurrentVersion\Run (system-wide). When Windows starts (and/or when a user logs in, depending on the key), the operating system processes these entries and launches the referenced program automatically. This provides reliable persistence across reboots and is frequently used because it is simple, effective, and blends with legitimate startup entries.

The scenario indicates Meera placed a binary in a hidden directory and configured it to auto-launch after restarts. Registry-based autoruns fit that exact pattern: the binary can reside anywhere (including a hidden folder), while the registry entry points to it. The persistence survives reboot and does not require the attacker to be present.

Why the other options are less likely given the phrasing:

Startup Folder (C) can also auto-launch programs, but it commonly implies a shortcut or executable placed in the user’s startup directory and is generally tied to user logon behavior. The question emphasizes “every time the system is restarted” and is most often tested in CEH contexts as registry autorun persistence.

Scheduled Tasks (A) can run at startup or on triggers and is a valid persistence technique, but the scenario does not mention task scheduling, triggers, or task configuration.

Creating a new service (B) would typically imply installing a Windows service, often requiring elevated privileges and presenting as a managed service; the scenario frames it as a lightweight binary planted and configured to auto-launch, which aligns more naturally with Run keys.

Therefore, the most likely persistence technique is D. Registry run keys.

Question #:455 - [Social Engineering]

An employee finds a USB drive labeled “Employee Salary Info 2024” and plugs it into a company computer, causing erratic behavior. What type of social engineering attack is this?

- A. Tempting the victim to engage with a malicious device using curiosity.
- B. Impersonating a senior staff member to extract login credentials.
- C. Using a discarded document to retrieve sensitive information.
- D. Bypassing physical security by following an authorized employee.

Answer: A**Explanation**

This scenario represents a classic baiting attack, a social engineering technique explicitly described in CEH v13 Social Engineering. In baiting, attackers exploit human curiosity or greed by leaving behind a malicious physical device—most commonly a USB drive—with an enticing label. When the victim plugs the device into a system, malware is automatically executed, leading to compromise.

Option A precisely captures this behavior. The label “Employee Salary Info 2024” is intentionally designed to entice the victim into interacting with the device. CEH v13 highlights USB baiting as particularly dangerous because it bypasses technical controls and relies solely on human behavior.

Option B describes pretexting, which involves impersonation. Option C refers to dumpster diving. Option D describes tailgating, a physical access attack. None of these match the USB-based lure described.

CEH v13 emphasizes that baiting attacks are highly effective in corporate environments and recommends strong security awareness training and disabling USB autorun features as mitigation.

Question #:456 - [Reconnaissance Techniques]

During a black-box security assessment of a large enterprise network, the penetration tester scans the internal environment and identifies that TCP port 389 is open on a domain controller. Upon further investigation, the tester runs the ldapsearch utility without providing any authentication credentials and successfully retrieves a list of usernames, email addresses, and departmental affiliations from the LDAP directory. The tester notes that this sensitive information was disclosed without triggering any access control mechanisms or requiring login credentials. Based on this behavior, what type of LDAP access mechanism is most likely being exploited?

- A. LDAP over SSL (LDAPS)
- B. Authenticated LDAP with Kerberos
- C. Anonymous LDAP binding
- D. LDAP via RADIUS relay

Answer: C

Explanation

CEH reconnaissance and enumeration modules explain that LDAP services often support anonymous binding by default unless explicitly disabled. Anonymous bind allows unauthenticated users to query certain directory attributes, which can lead to disclosure of usernames, organizational hierarchy, and email addresses—critical information for password attacks, phishing campaigns, and privilege escalation planning. In the scenario described, the tester obtained directory data without providing any credentials, demonstrating that anonymous bind permissions were enabled. LDAPS requires TLS encryption and authentication, which contradicts the observed access. Kerberos authentication mandates valid credentials. LDAP via RADIUS is used for authentication integration, not for information disclosure. Since the query was successful with no authentication and no access controls triggered, this aligns exactly with CEH’s description of anonymous LDAP binding.

Question #:457 - [System Hacking Phases]

During a red team engagement at a healthcare organization in Chicago, ethical hacker Devon intercepts Kerberos authentication material from a compromised workstation. Instead of cracking the data, he reuses the stolen tickets to authenticate directly to other systems within the domain. This allows him to access shared resources and servers without needing the users' plaintext credentials. No NTLM hashes or broadcast poisoning were involved.

Which attack technique did Devon most likely perform?

- A. LLMNR/NBT-NS Poisoning
- B. Pass-the-Ticket Attack
- C. Kerberoasting
- D. Pass-the-Hash

Answer: B

Explanation

The scenario describes the reuse of stolen Kerberos tickets to authenticate to other domain systems without cracking anything and without needing the user's plaintext password. That behavior aligns directly with a Pass-the-Ticket (PtT) attack. In Kerberos-based environments (such as Active Directory domains), authentication relies on tickets (for example, Ticket Granting Tickets and service tickets). If an attacker can obtain valid ticket material from a compromised host—commonly from memory, credential caches, or ticket stores—they can present (“pass”) the ticket to access services as that user, as long as the ticket is still valid and accepted by the target service.

The key clues are: (1) Devon “intercepts Kerberos authentication material,” (2) “instead of cracking the data, he reuses the stolen tickets,” and (3) he authenticates “directly to other systems within the domain” to access resources. This is the essential advantage of PtT: it bypasses password guessing or hash cracking by leveraging the fact that possession of a valid ticket can be enough to authenticate to services (file shares, application servers, and other Kerberos-protected resources).

The question also rules out common alternatives:

Kerberoasting (C) involves requesting service tickets for SPNs and then offline cracking the encrypted portion to recover service account passwords. Devon is explicitly not cracking anything.

Pass-the-Hash (D) is an NTLM-based technique that reuses NTLM hashes to authenticate. The scenario explicitly states “No NTLM hashes.”

LLMNR/NBT-NS Poisoning (A) is a name-resolution poisoning technique used to capture/relay credentials on a local network. The scenario states no broadcast poisoning was involved and focuses instead on Kerberos ticket reuse.

Therefore, Devon most likely performed B. Pass-the-Ticket Attack.

Question #:458 - [Web Application Hacking]

You are an ethical hacker at Apex Security Consulting, hired by Riverfront Media, a digital marketing firm in Boston, Massachusetts, to assess the security of their customer relationship management CRM web application. While evaluating the application's search feature, you input a long string of single quote characters into the search bar. The application responds with an error message suggesting that it cannot handle the length or structure of the input in the current SQL context. Based on the observed behavior, which SQL injection vulnerability detection technique are you employing?

- A. Detecting SQL Modification
- B. Fuzz Testing
- C. Function Testing
- D. Error Message Analysis

Answer: D**Explanation**

The technique being used is Error Message Analysis, because the tester is intentionally supplying a special character payload and then interpreting the application's returned database or SQL parsing error to infer the presence of an injection point. In CEH-aligned SQL injection methodology, one of the earliest indicators of SQL injection is when crafted input causes the application to generate a database error, such as syntax errors, unclosed quotation marks, type conversion failures, or context-related messages that reveal how the input is being embedded into a query. A long series of single quotes is a classic trigger: if user input is concatenated into a SQL statement without proper sanitization or parameterization, the quotes can break the query structure and force the database engine or ORM layer to throw an error that exposes the query context.

The scenario explicitly states the response is an error message indicating the application cannot handle the input "in the current SQL context." That means the application is leaking information through error responses, which CEH highlights as both a detection opportunity for testers and a security weakness because detailed errors can guide attackers toward successful payload construction.

This is not primarily "Detecting SQL Modification," which focuses on confirming changes in query logic or results, often using boolean-based techniques. It is not "Function Testing," which validates application functions rather than probing input handling at the SQL layer. While the input resembles fuzzing, fuzz testing is broader and does not specifically depend on interpreting SQL error messages as the detection signal. Here, the decisive evidence is the SQL-context error returned, making Error Message Analysis the correct technique.

Question #:459 - [Cloud Computing]

A critical flaw exists in a cloud provider's API. What is the most likely threat?

- A. Physical security breaches
- B. Unauthorized access to cloud resources
- C. DDoS attacks

D. Compromise of encrypted data at rest

Answer: B

Explanation

In CEH v13 Cloud Computing, APIs are identified as the primary control plane for managing cloud resources. A vulnerability in a cloud API can allow attackers to bypass authentication, escalate privileges, and manipulate resources.

Unauthorized access may lead to:

Data exposure

Resource abuse

Account takeover

Lateral movement within the cloud environment

Physical security (Option A) and encryption at rest (Option D) are unrelated to API flaws. DDoS attacks (Option C) are possible but not the primary risk of API vulnerabilities.

Thus, Option B is correct.

Question #:460 - [Network and Perimeter Hacking]

While auditing legacy network devices at a public hospital in Miami, Jason, a penetration tester, needs to verify what SNMP traffic is leaking across the internal segment. Instead of running structured queries, he decides to capture live network traffic and manually review the protocol fields. This method allows him to see SNMP requests and responses in transit but requires manual parsing of OIDs, community strings, and variable bindings.

Which method should Jason use in this situation?

A. Nmap

B. Wireshark

C. SnmpWalk

D. SoftPerfect Network Scanner

Answer: B

Explanation

Jason's goal is to capture live SNMP traffic on the wire and manually inspect protocol fields such as community strings, OIDs, and variable bindings within requests and responses. The method described is

packet capture and protocol dissection, which is exactly what Wireshark is designed for. Wireshark can capture traffic from an interface (or from a mirrored/SPAN port) and decode SNMP at the protocol level, presenting SNMP PDUs in a human-readable structure. This enables an assessor to view SNMP GET/GETNEXT/GETBULK requests, SET operations (if present), and responses, including the transmitted identifiers and values—useful for verifying whether sensitive SNMP data is exposed in transit.

The scenario explicitly states Jason is not running structured queries and instead wants to observe “SNMP requests and responses in transit,” which rules out tools that actively query devices. SnmpWalk (C) is an active enumeration tool that queries SNMP agents using a community string and walks a subtree of the MIB; that is the opposite of passive traffic inspection. Nmap (A) can scan ports and perform some SNMP-related scripts, but it still operates as an active probing tool rather than a live traffic capture and manual field review platform. SoftPerfect Network Scanner (D) is a network discovery tool for identifying hosts and services; it is not a packet-level sniffer intended for dissecting SNMP messages on the wire.

Additionally, the mention of “manual parsing” is consistent with packet analysis workflows: even though Wireshark decodes SNMP, the analyst still needs to interpret what OIDs and values mean, correlate requests to responses, and assess sensitivity (e.g., community strings in SNMPv1/v2c are not encrypted, and captured traffic may reveal them).

Therefore, the correct method is B. Wireshark.

Question #:461 - [Reconnaissance Techniques]

During an external assessment of a regional retail company's digital infrastructure, security analyst Joe is assigned to map internal services without active intrusion. While testing the behavior of a publicly exposed resolution system, he discovers that a secondary system responds unusually to structured queries. When he issues a specific request format, the server replies with a full list of internal mappings, including subdomains, mail hosts, and system aliases without requiring credentials or triggering alerts.

Which technique was most likely used to obtain this information?

- A. LDAP Enumeration
- B. NTP Enumeration
- C. DNS Zone Transfer Enumeration
- D. NetBIOS Enumeration

Answer: C

Explanation

The described behavior matches DNS Zone Transfer Enumeration. In CEH reconnaissance, DNS enumeration aims to discover hosts and services by querying DNS records. A zone transfer is a special DNS operation intended for legitimate replication between an authoritative primary DNS server and its secondary DNS servers. When misconfigured, a DNS server may allow an unauthorized requester to perform a zone transfer, returning the entire DNS zone database. This can reveal extensive internal naming information such as subdomains, hostnames, mail exchangers, service records, and aliases, exactly like the “full list of internal mappings, including subdomains, mail hosts, and system aliases” described in the question. The clue

“secondary system responds unusually” is especially telling, because secondary DNS servers are commonly the ones configured for replication and may be mistakenly left open to transfers from any host.

The other options do not fit the output. LDAP enumeration targets directory services and would not yield DNS-style mappings unless you already had directory access and queries. NTP enumeration relates to time synchronization services and can reveal time/server details, not comprehensive host/subdomain lists. NetBIOS enumeration focuses on Windows networking (names, shares, workgroups) typically on internal networks and would not produce a DNS zone's record set.

CEH-recommended mitigations include restricting zone transfers to authorized secondary server IPs only, using TSIG keys for authenticated transfers, minimizing publicly exposed DNS data, splitting internal and external DNS (split-horizon), and continuously auditing DNS configurations to prevent inadvertent information leakage.

Question #:462 - [Network and Perimeter Hacking]

Which tool is best for sniffing plaintext HTTP traffic?

- A. Nessus
- B. Nmap
- C. Netcat
- D. Wireshark

Answer: D

Explanation

Wireshark is the primary packet-sniffing tool covered in CEH v13 Network Sniffing. It captures and analyzes live traffic, allowing analysts to view plaintext HTTP packets.

Nessus is a vulnerability scanner, Nmap is for scanning, Netcat is a networking utility. None provide protocol-level inspection like Wireshark.

Thus, Option D is correct.

Question #:463 - [Web Application Hacking]

In the bustling city of Chicago, Illinois, ethical hacker Sophia Nguyen is contracted by TaskFlow Systems, a U.S.-based project management provider, to review the security of its template upload feature. During testing, Sophia discovers that by modifying the input parameters in an upload request, she can trick the application into retrieving sensitive files from the server's local directories. This flaw allows her to view internal configuration files that should never be exposed through the web interface. She records her findings in a report for TaskFlow's security team.

Which vulnerability is this?

- A. Insecure Deserialization
- B. Cookie Poisoning
- C. File Injection
- D. Local File Inclusion

Answer: D

Explanation

The behavior described—manipulating request parameters so the application retrieves and exposes files from the server’s local directories—is characteristic of Local File Inclusion (LFI). LFI occurs when an application uses user-controllable input to construct a file path (often for templates, language files, includes, or uploads) and fails to properly validate or constrain it. An attacker can then supply values such as relative path traversal sequences to force the application to access unintended local resources, leading to disclosure of sensitive files (configuration files, credentials, keys, environment files) and sometimes further impact depending on context.

In the scenario, Sophia is testing a “template upload feature,” then “modifying the input parameters in an upload request” to “trick the application into retrieving sensitive files from the server’s local directories,” allowing her to view internal configuration files. That is a textbook LFI outcome: unauthorized read access to local files through a web interface, caused by improper input validation and insecure file path handling.

Why the other options are less accurate:

Insecure deserialization (A) involves unsafe processing of serialized objects, often leading to remote code execution; it is not about retrieving local files via path manipulation.

Cookie poisoning (B) is tampering with cookie values to escalate privileges or alter application behavior; it does not inherently explain local file retrieval.

File injection (C) is a broader term and can refer to multiple file-related abuses, but the specific pattern of including or reading local files via parameters is most precisely labeled Local File Inclusion.

Therefore, the correct answer is D. Local File Inclusion.

Question #:464 - [Network and Perimeter Hacking]

In Raleigh, North Carolina, ethical hacker Ethan Brooks is conducting a penetration test for Triangle FinTech, a rising financial startup. During his assessment, Ethan aims to bypass the company’s network security to access a restricted internal server. He crafts network packets to disguise his traffic as legitimate, forcing some TCP header information into subsequent packets to evade the firewall’s checks. His aim is to demonstrate how an attacker could slip past the security perimeter undetected, alerting the IT team to potential weaknesses.

Which technique is Ethan employing to bypass Triangle FinTech’s firewall during his penetration test?

- A. Source Routing
- B. Tiny Fragments

- C. HTTP Tunneling
- D. IP Address Spoofing

Answer: B

Explanation

Tiny Fragments is the technique described because it relies on IP fragmentation to evade firewall or packet-filter inspection by splitting critical header and payload information across multiple fragments. In CEH-aligned network evasion concepts, some security devices make allow or deny decisions by inspecting specific fields and patterns in the first fragment of a packet or by performing limited reassembly. If the attacker deliberately crafts fragments that are unusually small, the first fragment may not contain enough of the TCP header or higher-layer data for the firewall to properly evaluate the packet against its rules and signatures. The remaining TCP header bytes or meaningful payload patterns can be pushed into subsequent fragments, which may pass through because the device cannot correlate them correctly or does not fully reassemble traffic before inspection.

The question's key clue is that Ethan is "forcing some TCP header information into subsequent packets" to bypass checks. That phrasing is a direct match to fragmentation-based evasion rather than identity deception or tunneling. IP address spoofing changes the apparent source IP, but it does not specifically move TCP header details into later fragments. Source routing is an old technique to influence packet pathing using IP options and is typically blocked in modern environments; it also does not describe splitting TCP header content. HTTP tunneling encapsulates non-HTTP traffic inside HTTP to pass through proxies or firewalls, which is a different mechanism than fragmentation.

Therefore, the correct firewall bypass technique in this scenario is Tiny Fragments.

Question #:465 - [Mobile Platform and IoT Hacking]

A penetration tester is evaluating the security of a mobile application and discovers that it lacks proper input validation. The tester suspects that the application is vulnerable to a malicious code injection attack. What is the most effective way to confirm and exploit this vulnerability?

- A. Perform a brute-force attack on the application's login page to guess weak credentials
- B. Inject a malicious JavaScript code into the input fields and observe the application's behavior
- C. Use directory traversal to access sensitive files stored in the application's internal storage
- D. Execute a dictionary attack on the mobile app's encryption algorithm

Answer: B

Explanation

CEH teaches that insufficient input validation on mobile applications enables code injection attacks. Injecting JavaScript or crafted payloads into fields validates whether the application improperly processes untrusted data. If executed, it confirms that the app is vulnerable to injection-based attacks.

Question #:466 - [Web Application Hacking]

A penetration tester intercepts HTTP requests between a user and a vulnerable web server. The tester observes that the session ID is embedded in the URL, and the web application does not regenerate the session upon login. Which session hijacking technique is most likely to succeed in this scenario?

- A. Injecting JavaScript to steal session cookies via cross-site scripting
- B. DNS cache poisoning to redirect users to fake sites
- C. Session fixation by pre-setting the token in a URL
- D. Cross-site request forgery exploiting user trust in websites

Answer: C**Explanation**

This scenario demonstrates a classic case of Session Fixation, a session hijacking technique explicitly covered under the CEH v13 Web Application Hacking module. Session fixation occurs when an attacker sets or predicts a valid session identifier and forces a victim to authenticate using that same session ID.

In the given question, two critical vulnerabilities are highlighted:

The session ID is embedded in the URL

The application does not regenerate the session ID after login

According to CEH v13, secure applications must regenerate session identifiers after successful authentication to prevent fixation attacks. If this does not occur, an attacker can craft a URL containing a known session ID and trick the victim into clicking it. Once the victim logs in, the attacker reuses the same session ID to gain unauthorized access.

CEH documentation states that session fixation is particularly effective when:

Session IDs are passed via URL parameters

Sessions persist across authentication

Secure cookie attributes are not enforced

Other options are incorrect because:

XSS-based cookie theft requires client-side script injection.

DNS cache poisoning is unrelated to session management.

CSRF exploits user trust but does not directly hijack sessions.

Thus, Session Fixation by pre-setting the token in a URL is the most effective attack in this case.

Question #:467 - [Mobile Platform, IoT, and OT Hacking]

Fleet vehicles with smart locking systems were compromised after attackers captured unique signals from key fobs. What should the security team prioritize to confirm and prevent this attack?

- A. Secure firmware updates
- B. Increase physical surveillance
- C. Deploy anti-malware on smartphones
- D. Monitor wireless signals for jamming or interference

Answer: D

Explanation

This scenario aligns with a Replay Attack against RF-based smart key systems, covered in CEH v13 IoT and OT Hacking. Attackers capture radio-frequency signals transmitted by key fobs and replay them to unlock vehicles.

CEH v13 emphasizes that detecting and preventing such attacks requires monitoring wireless RF signals for anomalies such as signal replay, interference, or jamming patterns. RF analysis helps confirm unauthorized signal capture and retransmission.

Firmware updates may mitigate future vulnerabilities, but confirmation requires RF monitoring. Physical surveillance and smartphone malware controls are unrelated to RF replay attacks. Therefore, option D is correct.

Question #:468 - [Network and Perimeter Hacking]

During a security assessment of an internal network, a penetration tester discovers that UDP port 123 is open, indicating that the NTP service is active. The tester wants to enumerate NTP peers, check synchronization status, offset, and stratum levels. Which command should the tester use?

- A. ntpdc
- B. ntpq
- C. ntptrace
- D. ntpdate

Answer: B

Explanation

The ntpq utility provides detailed NTP peer information, synchronization states, offsets, delays, and strata. CEH specifically lists ntpq as the tool for querying NTP daemon status and enumerating peer relationships, making it essential for reconnaissance and lateral movement mapping.

Question #:469 - [System Hacking Phases]

During a post-exploitation phase in a network compromise simulation, ethical hacker Devon Hughes gains a Meterpreter session on a manager's Windows 10 workstation. To maintain stealth, he avoids actions that generate obvious signs of tampering such as privilege escalation or file system changes. Instead, he wants to monitor the user's live activity over time without their knowledge, focusing specifically on input patterns and active sessions.

Which Meterpreter command should he use to achieve this objective with minimal visibility?

- A. keyscan_start
- B. hashdump
- C. persistence
- D. getsystem
- E. A This scenario is testing recognition of a post-exploitation objective focused on covertly observing user activity, specifically “input patterns,” which directly aligns with keystroke capture or keylogging behavior. In CEH coverage of System Hacking and Post-Exploitation, attackers who already have interactive access commonly shift to information-gathering actions that reveal credentials and sensitive business data without performing noisy changes such as privilege escalation or writing artifacts to disk. Keystroke monitoring is a classic example because it can capture usernames, passwords, internal system commands, chat messages, and other sensitive inputs as the user works, often with lower visibility than actions that alter system configuration. The remaining options map to different post-exploitation goals and are less consistent with the prompt’s emphasis on stealth and “no obvious signs of tampering.” Dumping password hashes (hashdump) targets stored credential material and is typically associated with higher privilege requirements and higher detection potential due to access to sensitive security databases. Persistence is about maintaining long-term access across reboots and usually introduces artifacts such as registry changes, scheduled tasks, or services—precisely the type of detectable modification the prompt says Devon wants to avoid. Privilege escalation (getsystem) explicitly attempts to elevate rights, increasing operational risk and logging footprint. From a defensive perspective, CEH emphasizes mitigating this class of activity with strong endpoint monitoring and EDR, least-privilege controls, rapid patching, application allowlisting, and credential protections such as MFA and hardened authentication storage. Teams should alert on suspicious input-capture behaviors, abnormal process activity, and unusual remote sessions to detect post-exploitation collection attempts early.

Answer: A B C D E

Question #:470 - [Web Application Hacking]

In the crisp mountain air of Denver, Colorado, ethical hacker Lila Chen investigates the security framework of MedVault, a US-based healthcare platform used by regional clinics to manage patient data. During her assessment, Lila manipulates session parameters while navigating the patient portal’s dashboard. Her tests reveal a critical flaw: the system allows users to access sensitive medical records not associated with their

own account, enabling unauthorized changes to private health data. Upon deeper inspection, Lila determines that the issue stems from the application allowing users to perform actions beyond their assigned roles rather than failures in encryption, unsafe object handling, or server configuration.

Which OWASP Top 10 2021 vulnerability is Lila most likely exploiting in MedVault's web application?

- A. Security Misconfiguration
- B. Insecure Deserialization
- C. Cryptographic Failures
- D. Broken Access Control

Answer: D

Explanation

Broken Access Control is the correct choice because the scenario describes a user being able to access and modify resources that should be restricted to other users or roles. In CEH-aligned web testing, access control flaws occur when an application fails to enforce authorization checks consistently on the server side. Manipulating session parameters and then retrieving "sensitive medical records not associated with their own account" is a classic indicator of an authorization bypass, often seen as insecure direct object references, parameter tampering, or horizontal and vertical privilege escalation. Horizontal escalation is when one user accesses another user's data at the same privilege level, while vertical escalation is when a user performs actions reserved for higher-privileged roles. The prompt explicitly states users can perform actions beyond assigned roles, which is the definition of broken authorization enforcement.

The other options do not align with the described root cause. Cryptographic Failures focuses on weak or missing encryption and does not explain why authenticated users can reach unauthorized records. Insecure Deserialization involves unsafe deserialization leading to remote code execution or data tampering via serialized objects, which is not indicated here. Security Misconfiguration is broader and can contribute to exposure, but the scenario emphasizes role and resource permission bypass rather than mis-set server headers, default accounts, or exposed admin interfaces.

Mitigation in CEH best practices includes enforcing server-side authorization on every request, using deny-by-default policies, validating that the authenticated user is allowed to access the specific record identifier, implementing robust role-based access control, logging access denials, and adding automated tests to prevent IDOR and privilege escalation regressions.

Question #:471 - [System Hacking Phases]

An ethical hacker needs to enumerate user accounts and shared resources within a company's internal network without raising any security alerts. The network consists of Windows servers running default configurations. Which method should the hacker use to gather this information covertly?

- A. Deploy a packet sniffer to capture and analyze network traffic
- B. Perform a DNS zone transfer to obtain internal domain details

- C. Exploit null sessions to connect anonymously to the IPC\$ share
- D. Utilize SNMP queries to extract user information from network devices

Answer: C

Explanation

CEH v13 explains that Windows systems running older or default configurations often allow anonymous or null session connections to IPC\$ shares, enabling attackers to enumerate users, groups, shares, and other system details without authentication. Null session enumeration is highlighted as a classic yet effective technique because it generates minimal detectable activity and does not require credentials, making it ideal for stealth operations. CEH stresses that SMB null sessions are frequently overlooked in legacy or poorly hardened environments, especially when default permissions remain unchanged. Packet sniffing (Option A) may provide some data but requires traffic visibility and may be detected through monitoring tools. DNS zone transfers (Option B) require misconfigurations and usually do not reveal user list details. SNMP queries (Option D) require community strings and often generate alerts. Therefore, exploiting null sessions is the most covert and effective method for enumerating Windows systems under default configurations.

Question #:472 - [Web Application Hacking]

A web application returns generic error messages. The analyst submits AND 1=1 and AND 1=2 and observes different responses. What type of injection is being tested?

- A. UNION-based SQL injection
- B. Error-based SQL injection
- C. Boolean-based blind SQL injection
- D. Time-based blind SQL injection

Answer: C

Explanation

This technique is known as Boolean-Based Blind SQL Injection, as defined in CEH v13 Web Application Hacking. When applications suppress database errors and return generic responses, attackers use conditional statements to infer database behavior.

By comparing responses to true (1=1) and false (1=2) conditions, the attacker deduces whether injected SQL is being executed successfully.

CEH v13 distinguishes this from:

Error-based SQLi (visible DB errors)

UNION-based SQLi (data extraction)

Time-based SQLi (response delays)

Boolean-based blind SQL injection relies solely on content differences, making option C correct.

Question #:473 - [Wireless Network Hacking]

A penetration tester is tasked with compromising a company's wireless network, which uses WPA2-PSK encryption. The tester wants to capture the WPA2 handshake and crack the pre-shared key. What is the most appropriate approach to achieve this?

- A. Execute a Cross-Site Scripting (XSS) attack on the router's admin panel
- B. Use a de-authentication attack to force a client to reconnect, capturing the WPA2 handshake
- C. Perform a brute-force attack directly on the WPA2 encryption
- D. Conduct a Man-in-the-Middle attack by spoofing the router's MAC address

Answer: B

Explanation

CEH training outlines the standard methodology for attacking WPA2-PSK networks: capture the 4-way handshake and then attempt offline cracking of the pre-shared key. The most reliable way to force handshake generation is to perform a de-authentication attack using tools like Aircrack-ng. This attack momentarily disconnects a wireless client, forcing it to reauthenticate with the access point. During this reauthentication, the AP and client exchange the 4-way handshake packets necessary for offline cracking. CEH emphasizes that WPA2 encryption itself cannot be brute-forced directly; attackers must obtain the handshake and then apply dictionary or brute-force attacks offline. Attempting XSS or router spoofing does not capture the handshake and is unrelated to WPA2 key extraction. The deauth attack is also a classic wireless attack vector described extensively in CEH because it is effective, does not require interaction with the encryption algorithm, and works regardless of the strength of the AP's passphrase. Once the handshake is captured, tools such as Hashcat are used to attempt key recovery.

Question #:474 - [Network and Perimeter Hacking]

During a security penetration test at ABC Financial Services in Miami, Florida, on July 9, 2025, ethical hacker Javier Morales targets the company's online banking portal to assess its resilience. Over several hours, the portal's web server begins to falter, with legitimate users reporting inability to log in or complete transactions. The IT team notices the server is struggling to accept new connections, as its maximum connection limit is nearly reached, despite no significant spike in overall network traffic. Javier's controlled test, run from a secure system, logs interactions to simulate a real attack, aiming to evaluate the IT team's ability to identify the threat.

What DoS or DDoS attack technique is Javier's exercise primarily simulating?

- A. Slowloris Attack
- B. UDP Flood Attack

- C. Peer-to-Peer Attack
- D. SYN Flood Attack

Answer: A

Explanation

The symptoms point directly to a Slowloris attack, which CEH materials classify as an application-layer denial-of-service technique that targets web servers by exhausting their available concurrent connection slots rather than saturating bandwidth. In a Slowloris attack, the attacker opens many HTTP or HTTPS connections to the server and then keeps them alive as long as possible by sending partial, incomplete HTTP requests or very slow header transmissions at timed intervals. Because the requests are never fully completed, the server keeps the connections open, waiting for the remainder of the request. Over time, the server's maximum connection limit is consumed, and legitimate users cannot establish new sessions, even though overall network traffic may remain relatively low.

That exact pattern is described in the scenario: the server is "struggling to accept new connections," the "maximum connection limit is nearly reached," and there is "no significant spike in overall network traffic." This is a classic indicator of low-and-slow DoS behavior, which can be harder to detect because it does not resemble a high-volume flood.

A SYN Flood attack can also exhaust connection resources, but it typically creates a large number of half-open TCP connections and is usually more apparent in network-level telemetry and SYN backlog behavior. A UDP Flood generally causes a noticeable traffic spike. "Peer-to-Peer Attack" describes a botnet architecture style, not the specific technique used here. Therefore, the attack being simulated is Slowloris.

Question #:475 - [Cryptography]

Olivia, a cybersecurity architect at a Boston-based fintech company, is tasked with upgrading the organization's cryptographic infrastructure in preparation for future quantum computing threats. A recent internal audit flagged that sensitive customer data stored in the company's cloud environment could be vulnerable if quantum decryption methods become practically viable. To strengthen their post-quantum defense, Olivia must recommend a proactive cryptographic control that ensures long-term confidentiality of stored data, even against advanced quantum attackers.

Which cryptographic defense should Olivia prioritize to mitigate the risk of future quantum-based decryption?

- A. Break data into fragments and distribute it across multiple locations
- B. Encrypt stored data with quantum-resistant algorithms
- C. Use quantum-specific firewalls to protect quantum communication channels
- D. Include quantum-resistance checks in SDLC and code review processes

Answer: B

Explanation

The best choice is encrypting stored data with quantum-resistant algorithms because the scenario's core risk is long-term confidentiality of data at rest in a cloud environment under a future where large-scale quantum computing could break widely used public-key schemes. In CEH cryptography coverage, the most direct way to protect confidentiality is to use strong encryption that remains secure against the expected attacker capabilities. "Harvest now, decrypt later" is a practical concern: adversaries can copy encrypted data today and wait until new capabilities make decryption feasible. Therefore, the control must be cryptographic and future-resistant, not merely procedural or architectural.

Option B aligns with post-quantum readiness by moving encryption and key-establishment mechanisms toward quantum-resistant primitives. This is especially important for protecting stored records over long retention periods. Even if symmetric encryption such as AES is generally more resilient to quantum attacks than classical public-key algorithms, organizations still must ensure appropriate key sizes, robust key management, and quantum-resistant approaches where public-key cryptography is used for key exchange, key wrapping, or digital signatures that support storage encryption workflows.

Option A, distributing fragments, can improve availability and limit exposure in some breach scenarios, but it does not replace encryption and does not guarantee confidentiality if fragments are obtained. Option C is not applicable because the problem is stored cloud data, not quantum communications. Option D is a good governance practice, but it is not itself a cryptographic control that ensures confidentiality. The priority, per CEH-aligned cryptographic defense principles, is quantum-resistant encryption and key management for data at rest.

Question #:476 - [Information Security and Ethical Hacking Overview]

Which best describes the role of a penetration tester?

- A. Unauthorized malicious hacker
- B. Malware distributor
- C. Authorized security professional who exploits vulnerabilities
- D. Malicious code developer

Answer: C

Explanation

In CEH v13 Information Security and Ethical Hacking Overview, a penetration tester is defined as a trusted, authorized security professional hired to simulate real-world attacks in order to identify and exploit vulnerabilities with explicit permission.

The primary objectives of a penetration tester are:

Identify weaknesses in systems, networks, and applications

Demonstrate real-world impact of vulnerabilities

Help organizations improve their security posture

Unlike malicious hackers (Option A) or malware authors (Options B and D), penetration testers operate under strict legal and ethical guidelines, following scopes of engagement and reporting findings responsibly.

CEH v13 emphasizes that penetration testing is proactive defense, not crime. Therefore, Option C accurately defines the role.

Question #:477 - [Social Engineering]

You are Liam Chen, an ethical hacker at CyberGuard Analytics, hired to test the social engineering defenses of Coastal Trends, a retail chain in Los Angeles, California. During a covert assessment, you craft a deceptive message sent to the employees' company phones, claiming a critical account update is needed and directing them to a link that installs monitoring software. Several employees interact with the link, exposing a vulnerability to a specific mobile attack vector. Based on this approach, which mobile attack type are you simulating?

- A. Bluebugging
- B. SMS Phishing
- C. Call Spoofing
- D. OTP Hijacking

Answer: B

Explanation

SMS Phishing, commonly called smishing, is the correct answer because the attack method is a deceptive text message sent to mobile devices that lures recipients into clicking a malicious link. In CEH-aligned social engineering coverage, smishing is a direct extension of phishing that uses SMS as the delivery channel. The attacker typically creates urgency or authority, such as "critical account update needed," to trigger fast compliance. The message then pushes the victim to a malicious URL that can deliver malware, prompt credential entry, or enroll the device into a monitoring or management profile depending on platform and permissions. The key indicators in the question are company phones, a crafted message, and a link that installs monitoring software, which fits smishing exactly.

Bluebugging is a Bluetooth-based attack where the attacker exploits Bluetooth weaknesses to gain unauthorized access to a device, read data, place calls, or send messages, and it does not rely on sending a deceptive SMS link. Call spoofing is manipulating caller ID to impersonate a trusted number during voice calls, not delivering a malicious installation link through text. OTP hijacking focuses on intercepting or tricking users into revealing one-time passwords, often through SIM swapping, malware, or real-time phishing, but the scenario emphasizes installing monitoring software through a link rather than capturing a one-time code.

Defenses highlighted in ethical security training include mobile security awareness, blocking unknown links, using mobile threat defense, restricting app installation from untrusted sources, enforcing MDM controls, and monitoring SMS-based social engineering indicators.

Question #:478 - [Information Security and Ethical Hacking Overview]

A government agency trains a group of cybersecurity experts to carry out covert cyber missions against foreign threats and gather intelligence without being detected. These experts work exclusively for national interests. What classification best describes them?

- A. Organized hackers
- B. State-sponsored hackers
- C. Hacktivists
- D. Gray hat hackers

Answer: B

Explanation

CEH courseware categorizes hackers based on intent, authorization, and affiliation. State-sponsored hackers are defined as individuals or teams who conduct cyber operations on behalf of a government to advance national interests. These operations often include espionage, cyber warfare, intelligence gathering, and covert offensive actions. Unlike organized hackers or cybercriminal groups, whose motivations may include financial gain or ideological activism, state-sponsored units follow strategic directives issued by government agencies. CEH materials explain that such groups operate with access to advanced tools, long-term funding, and classified intelligence, enabling them to execute highly sophisticated and covert operations targeting foreign governments, corporations, or critical infrastructure. Hacktivists pursue political or social causes, while gray-hat hackers operate without explicit permission but without malicious intent. Only state-sponsored hackers match the scenario where cyber experts are formally trained, resourced, and authorized by a national government to conduct operations that remain undetected. Therefore, the correct classification is state-sponsored hackers.

Question #:479 - [Web Application Hacking]

During a security assessment of a cloud-hosted application using SOAP-based web services, a red team operator intercepts a valid SOAP request, duplicates the signed message body, inserts it into the same envelope, and forwards it. Due to improper validation, the server accepts the duplicated body and executes unauthorized code. What type of attack does this represent?

- A. Cloud snooper attack
- B. Cryptanalysis attack
- C. Wrapping attack
- D. IMDS abuse

Answer: C

Explanation

Comprehensive Explanation from CEH v13 Courseware:

CEH v13 identifies XML Signature Wrapping (XSW) attacks, also known simply as Wrapping attacks, as a major threat against SOAP-based web services. These attacks exploit weak XML parsing and insufficient validation of signed message components. SOAP messages often include digitally signed sections, but if the server validates the signature without confirming the correct position or structure of the signed elements, attackers can duplicate, move, or wrap signed content inside a modified XML envelope. This allows an attacker to inject malicious payloads while still presenting a valid signature. CEH details how this can lead to unauthorized execution, privilege escalation, or bypassing authentication controls in SOAP APIs. Cloud snooping, cryptanalysis, and IMDS abuse do not involve message duplication or signature misplacement. The scenario precisely matches CEH's definition of a Wrapping Attack in SOAP/XML security.

Question #:480 - [Web Application Hacking]

In the bustling digital marketplace of Miami's tech corridor, ethical hacker Sofia Alvarez probes the virtual defenses of RetailRush, a US-based online retailer hosting thousands of daily transactions. Tasked with exposing weaknesses in the web server's URL processing, Sofia submits crafted requests to manipulate resource paths. Her tests uncover a severe flaw: the server grants access to restricted system files, exposing sensitive configuration data. Further scrutiny reveals the issue stems from the server's failure to validate input paths, not from header manipulation, cached content tampering, or credential compromise. Committed to hardening the platform, Sofia drafts a precise report to direct the security team toward immediate fixes.

Which web server attack type is Sofia most likely exploiting in RetailRush's web server?

- A. Directory Traversal Attack
- B. Web Cache Poisoning Attack
- C. HTTP Response Splitting Attack
- D. Password Cracking Attack

Answer: A

Explanation

A Directory Traversal attack, also known as path traversal, exploits weaknesses in how a web server or web application processes user-supplied file and directory paths through URLs or parameters. In CEH-aligned terminology, the attacker crafts requests that use traversal sequences such as dot-dot-slash patterns or encoded equivalents to escape the intended web root or permitted directory and reach sensitive locations on the underlying file system. The question states Sofia "manipulates resource paths" and successfully accesses "restricted system files," revealing "sensitive configuration data." This is the defining outcome of directory traversal: unauthorized access to files that should never be directly retrievable via the web interface, including application configuration files, server configuration, environment files, or other OS-level resources.

The prompt also eliminates other options by describing what the issue is not. It is not header manipulation, which would be more consistent with HTTP response splitting or header injection behaviors. It is not cached content tampering, which points to web cache poisoning. It is not credential compromise, which would indicate password cracking. Instead, the root cause is explicitly "failure to validate input paths," matching CEH emphasis on inadequate input validation and improper path normalization or canonicalization before file access. Defensive guidance typically focuses on strict allowlisting of accessible resources, canonicalizing

paths and enforcing a fixed base directory, blocking traversal tokens and their encoded forms, using indirect references instead of raw file paths, and applying least-privilege permissions to reduce impact if traversal is attempted.

Question #:481 - [Network and Perimeter Hacking]

Which advanced evasion technique poses the greatest challenge to detect and mitigate?

- A. Covert channel communication using IP header fields
- B. Honeypot spoofing
- C. Polymorphic malware
- D. Packet fragmentation evasion

Answer: A

Explanation

Covert channel communication is one of the most sophisticated evasion techniques described in CEH v13 Evasion Techniques. By embedding malicious data within unused or rarely inspected protocol fields (such as IP headers), attackers can bypass firewalls, IDS, and IPS systems entirely.

Unlike polymorphic malware (Option C), which can still be detected using behavior analysis, covert channels blend seamlessly into legitimate traffic. Packet fragmentation (Option D) is well-known and often mitigated. Honeypot spoofing (Option B) is rare and defensive in nature.

CEH v13 emphasizes that covert channels are difficult because:

They do not violate protocol specifications

They evade signature-based and stateful inspection

They appear as normal traffic

Detecting covert channels often requires deep protocol analysis and statistical traffic inspection, making them extremely challenging to mitigate.

Thus, Option A is the correct answer.

Question #:482 - [Security Operations and Incident Response]

A cybersecurity consultant suspects attackers are attempting to evade an Intrusion Detection System (IDS). Which technique is most likely being used?

- A. Deploying self-replicating malware
- B. Fragmenting malicious packets into smaller segments

- C. Flooding the IDS with ICMP packets
- D. Sending phishing emails

Answer: B

Explanation

The CEH IDS/IPS Evasion module describes packet fragmentation as a common evasion technique used to bypass signature-based detection.

Option B is correct.

Other options represent different attack categories.

CEH highlights reassembly normalization as a countermeasure.

Question #:483 - [Wireless Network Hacking]

A penetration tester is attacking a wireless network running WPA3 encryption. Since WPA3 handshake protections prevent offline brute-force cracking, what is the most effective approach?

- A. Downgrade the connection to WPA2 and capture the handshake to crack the key
- B. Execute a dictionary attack on the WPA3 handshake using common passwords
- C. Perform a brute-force attack directly on the WPA3 handshake
- D. Perform a SQL injection attack on the router's login page

Answer: A

Explanation

CEH v13 explains that WPA3 introduces SAE (Simultaneous Authentication of Equals), which resists traditional offline dictionary and brute-force attacks by removing crackable handshake material. Because WPA3 prevents attackers from capturing a reusable handshake, the most practical offensive method is to force a downgrade attack, tricking clients into associating using WPA2 instead of WPA3. Once the victim reconnects under WPA2-PSK, the attacker captures the standard 4-way handshake, which can then be cracked offline using dictionary or GPU-accelerated brute-force methods. CEH discusses downgrade attacks as a significant real-world threat when mixed-mode configurations are enabled or when access points fail to enforce strict WPA3-only operation. Options B and C are ineffective because WPA3 handshake materials cannot be brute-forced offline. Option D is unrelated to Wi-Fi encryption. Downgrading to WPA2 is the most effective and widely documented attack path.

Question #:484 - [Network and Perimeter Hacking]

During a red team engagement at a technology startup in Austin, ethical hacker Priya simulates an internal attacker by connecting a laptop to the corporate LAN. Within minutes, nearby workstations begin receiving incorrect network settings such as altered gateways and DNS servers. Employees trying to access the intranet are redirected to fake login portals hosted on Priya's machine. Security tools record temporary IP conflicts, but no alerts are triggered against the altered traffic paths.

Which attack technique did Priya most likely use?

- A. DHCP Starvation Attack
- B. DNS Cache Poisoning
- C. Rogue DHCP Server Attack
- D. Packet Sniffing

Answer: C

Explanation

The correct answer is C. Rogue DHCP Server Attack because the observed impact is that client machines on the LAN begin receiving incorrect network configuration parameters—specifically altered default gateways and DNS server addresses—shortly after Priya connects her laptop. In CEH-aligned LAN attack concepts, a rogue DHCP attack occurs when an attacker introduces an unauthorized DHCP service that responds to DHCP discovery requests faster than the legitimate DHCP server. As a result, endpoints accept the attacker-provided lease options, which can redirect traffic through attacker-controlled infrastructure.

The redirection to “fake login portals hosted on Priya's machine” is consistent with malicious DHCP option abuse. By supplying a rogue DNS server (or altering DNS-related options), the attacker can resolve internal hostnames (like intranet URLs) to the attacker's IP, enabling credential harvesting via spoofed portals. By supplying a rogue default gateway, the attacker can position themselves as the network path for victim traffic, enabling man-in-the-middle style interception, traffic manipulation, and session hijacking. The mention of “temporary IP conflicts” further supports rogue DHCP behavior, because an attacker DHCP server can hand out addresses that overlap with the legitimate scope or cause duplicate assignments, producing conflicts and instability.

Why the other options are less accurate: DHCP starvation involves exhausting the legitimate DHCP pool by flooding requests with spoofed MAC addresses, often as a precursor to then standing up a rogue DHCP server. The scenario emphasizes that clients are actively receiving malicious settings (gateway/DNS), which is the hallmark of the rogue server stage rather than starvation alone. DNS cache poisoning targets DNS resolvers/caches and does not by itself cause clients to suddenly obtain new gateway/DNS configurations. Packet sniffing is passive and does not explain clients being reconfigured or redirected.

Therefore, Priya most likely performed a rogue DHCP server attack to reconfigure endpoints and redirect users to phishing portals.

Question #:485 - [Mobile Platform and IoT Hacking]

An attacker has partial root access to a mobile application. What control best prevents further exploitation?

- A. Secure coding and automated reviews
- B. Certificate pinning
- C. Regular penetration testing
- D. Mobile Application Management (MAM)

Answer: D

Explanation

When partial root access exists, preventing further privilege abuse is the immediate priority. CEH v13 explains that Mobile Application Management (MAM) enforces granular access control, application isolation, and permission enforcement—even on compromised devices.

Secure coding (Option A) and testing (Option C) are preventative measures but do not contain an active compromise. Certificate pinning (Option B) protects communications, not application control.

MAM solutions allow administrators to revoke access, enforce policies, and isolate apps, limiting attacker capabilities post-compromise. Therefore, Option D is correct.

Question #:486 - [Reconnaissance Techniques]

A security researcher reviewing an organization's website source code finds references to Amazon S3 file locations. What is the most effective way to identify additional publicly accessible S3 bucket URLs used by the target?

- A. Exploit XSS to force the page to reveal the S3 links
- B. Use Google advanced search operators to enumerate S3 bucket URLs
- C. Use SQL injection to extract internal file paths from the database
- D. Perform packet sniffing to intercept internal S3 bucket names

Answer: B

Explanation

OSINT-based reconnaissance includes using search engines to identify publicly exposed cloud assets. CEH highlights Google dorking as a passive method to reveal S3 buckets indexed in search engines through patterns such as `site:s3.amazonaws.com` or keyword-based queries.

Question #:487 - [Network and Perimeter Hacking]

On 10th of July this year, during a security penetration test at IntelliCore Systems in Raleigh, North Carolina, the ethical hacking team evaluates the stability of the company's file-sharing server. Sofia crafts and transmits

a sequence of oversized, malformed packets designed to test how the server handles unexpected input. Shortly after, the system begins crashing intermittently due to processing failures triggered by these anomalous network requests. The security team onsite is tasked with identifying the root cause behind the packet-induced instability and attributing it to a known DoS tactic.

Which of the following best explains the technique Sofia used to trigger the server crashes?

- A. ICMP Flood Attack
- B. Ping of Death PoD
- C. Smurf Attack
- D. ACK Flood Attack

Answer: B

Explanation

Ping of Death is a classic Denial-of-Service technique in which an attacker sends oversized or malformed IP packets that exceed the maximum allowed size when reassembled. In IP networks, the maximum packet size is 65,535 bytes. Historically, attackers exploited fragmentation by sending a series of IP fragments that, when reassembled by the target, resulted in a packet larger than the permitted limit or produced an invalid buffer condition. Vulnerable systems could crash, reboot, or become unstable because the network stack mishandled the reassembly process or failed to properly validate packet length and structure.

The scenario matches this behavior precisely: Sofia transmits “oversized, malformed packets” and the server “crashes intermittently due to processing failures.” That symptom is more consistent with a malformed-packet handling flaw than with pure traffic volume. An ICMP flood and an ACK flood are volumetric or resource-exhaustion attacks that overwhelm bandwidth or connection-handling capacity, typically degrading performance rather than directly causing crashes from malformed packet parsing. A Smurf attack is an amplification-based ICMP attack using broadcast addresses to multiply traffic toward a victim; again, it is about volume, not crafted malformed packets that trigger parsing failures.

CEH guidance highlights that PoD-style attacks exploit improper packet validation and reassembly logic. Modern systems are generally patched, but poorly maintained devices, legacy OS stacks, and some embedded implementations can still exhibit instability when exposed to malformed fragmentation and reassembly edge cases.

Question #:488 - [Malware Threats]

During a red team exercise at a technology consulting firm in San Francisco, analyst Evelyn deploys a malicious payload disguised within a software update installer. When the target runs the installer, the main application functions normally, but behind the scenes, additional malware components are silently placed on the system without the user's knowledge. These hidden components later activate to establish remote access for the red team.

Which technique was most likely used to deliver the hidden malware?

- A. Downloader

- B. Wrapper
- C. Injector
- D. Dropper

Answer: D

Explanation

The scenario describes a program that appears legitimate (a software update installer that “functions normally”) while secretly placing additional malicious components onto the system, which later execute to establish remote access. That is the defining behavior of a dropper. A dropper’s primary role is to deliver (drop) malware payloads onto a host—writing files to disk or unpacking embedded components—often while disguising itself as a benign application. The malicious components may then be executed immediately or staged for later activation to reduce suspicion and increase persistence.

This differs from a downloader, which typically contains minimal payload and focuses on contacting a remote server to fetch malware after initial execution. In this case, the description emphasizes that “additional malware components are silently placed on the system,” implying the payload is being installed/deposited locally by the initial program rather than primarily downloaded. An injector focuses on injecting code into another running process (process injection) to evade detection or run under another process context; it does not inherently describe the act of placing additional components as separate hidden files. A wrapper is a technique where a malicious program is bound or “wrapped” with a legitimate one so that both run; while wrappers can be used in trojanized installers, the question emphasizes the behind-the-scenes placement of additional components for later activation, which is the classic dropper behavior.

The key indicators are: (1) user executes an installer that appears normal, (2) hidden malware components are deposited without the user’s knowledge, and (3) those components later activate for remote access. That chain matches a dropper’s purpose: stealthy malware delivery and staging.

Therefore, the correct answer is D. Dropper.

Question #:489 - [Wireless Network Hacking]

You are Ethan Brooks, an ethical hacker at Vanguard Security Solutions, hired to perform a wireless penetration test for Pacific Logistics, a shipping company in Seattle, Washington. Your task is to identify all Wi-Fi networks in range without alerting the network administrators. Using a laptop with a Wi-Fi card, you monitor radio channels to detect access points and their BSSIDs without sending any probe requests or injecting data packets.

Based on the described method, which Wi-Fi discovery technique are you employing?

- A. Network Discovery Software
- B. Passive Footprinting
- C. Wash Command

D. Active Footprinting

Answer: B

Explanation

The scenario describes a wireless discovery method where the tester only listens to the airwaves and does not transmit probe requests or inject frames. In CEH terms, this is passive reconnaissance, commonly referred to as passive footprinting in the wireless context. Passive footprinting relies on capturing and analyzing existing 802.11 management traffic such as beacon frames (periodically broadcast by access points) and probe responses sent to other clients, allowing the tester to identify SSIDs, BSSIDs (MAC addresses of access points), channel numbers, supported data rates, and sometimes security capabilities, all without generating traffic that could alert administrators or trigger wireless intrusion detection systems.

Active footprinting, by contrast, involves transmitting frames—most notably probe requests—to solicit probe responses from access points, which increases detectability. The question explicitly says Ethan does not send probe requests and does not inject data packets, which rules out active methods. “Network Discovery Software” is too generic; tools can be used for either passive or active discovery, but the technique in use is defined by behavior on the wireless medium, not the presence of software. “Wash” is a specific tool/command associated with enumerating WPS-enabled access points; while it can be used during reconnaissance, the question is testing the broader technique rather than a specific utility, and the defining characteristic here is silent listening.

CEH defensive guidance notes that passive discovery is stealthier because it leverages normal beaconing behavior. Organizations mitigate reconnaissance by using wireless monitoring, rogue AP detection, strong encryption configurations, disabling unnecessary broadcasts where feasible, and maintaining continuous wireless security assessments.

Question #:490 - [Network and Perimeter Hacking]

During a red team engagement at a law firm in Dallas, ethical hacker Sarah connects a compromised workstation to a core switch. Within minutes, the switch begins experiencing instability, and multiple VLANs report traffic leakage across isolated departments. Sarah observes that her machine is now receiving packets not originally destined for it, giving her visibility into multiple active sessions. Logs show the switch's CAM table was overwhelmed during the attack.

Which sniffing technique did Sarah most likely use?

- A. DNS Poisoning
- B. VLAN Hopping
- C. ARP Poisoning
- D. MAC Flooding

Answer: D

Explanation

The key indicator is that the switch's CAM table was overwhelmed and the attacker's machine started receiving traffic not originally destined for it. That is the hallmark of MAC flooding. Switches maintain a CAM (Content Addressable Memory) table mapping MAC addresses to switch ports. Under normal conditions, this allows a switch to forward frames only to the correct destination port (unicast switching). In a MAC flooding attack, the attacker sends a large volume of frames with many spoofed source MAC addresses, rapidly filling the CAM table. Once the table is full, the switch may fail open for unknown unicast traffic and begin broadcasting (flooding) frames out multiple ports, similar to a hub-like behavior. This causes unintended packet exposure and allows the attacker to capture traffic from other hosts, enabling sniffing of multiple sessions.

The scenario explicitly mentions switch instability, traffic leakage, receiving packets not destined for the attacker, and CAM table exhaustion—these are directly aligned with MAC flooding mechanics.

Why the other options don't match as well:

ARP poisoning (C) is a man-in-the-middle technique that manipulates ARP caches to redirect traffic through the attacker. It does not typically overwhelm the switch's CAM table, and the symptom is traffic redirection rather than CAM exhaustion.

VLAN hopping (B) is a VLAN segmentation bypass (e.g., switch spoofing or double-tagging) and is about crossing VLAN boundaries, not causing CAM table overflow and switch-wide flooding behavior. The mention of multiple VLANs seeing leakage could be a downstream consequence of flooding /misconfiguration, but the decisive clue is CAM table overload.

DNS poisoning (A) targets name resolution and would not produce CAM table exhaustion or switch instability.

Therefore, Sarah most likely used D. MAC Flooding.

Question #:491 - [Mobile Platform, IoT, and OT Hacking]

An attacker plans to compromise IoT devices to pivot into OT systems. What should be the immediate action?

- A. Perform penetration testing
- B. Secure IoT-OT communications with encryption and authentication
- C. Deploy ML-based threat prediction
- D. Deploy an IPS

Answer: B

Explanation

CEH v13 stresses that IoT-to-OT convergence is one of the most dangerous architectures in critical infrastructure environments. IoT devices often lack strong security controls and become ideal entry points for lateral movement into OT systems controlling physical processes.

The immediate priority is to secure the communication boundary between IoT and OT systems. Implementing strong encryption, authentication, and access control ensures that even if an IoT device is compromised, it cannot be used as a pivot point. CEH v13 explicitly recommends network segmentation and secure communication channels as first-response containment measures.

Penetration testing (Option A) is valuable but time-consuming and not an immediate mitigation. ML-based tools (Option C) require training time and are not instant safeguards. IPS deployment (Option D) helps detect attacks but does not prevent credential abuse or trusted-path exploitation between IoT and OT layers.

By enforcing secure protocols, certificates, and authentication mechanisms, the organization reduces attack surface immediately. Thus, Option B is correct.

Question #:492 - [Network and Perimeter Hacking]

You suspect a Man-in-the-Middle (MitM) attack inside the network. Which network activity would help confirm this?

- A. Sudden increase in traffic
- B. Multiple login attempts from one IP
- C. IP addresses resolving to multiple MAC addresses
- D. Abnormal DNS request volumes

Answer: C

Explanation

CEH v13 identifies ARP spoofing/poisoning as a primary MitM technique in local networks. In such attacks, a single IP address maps to multiple MAC addresses, indicating ARP table manipulation.

This anomaly allows attackers to intercept traffic between victims and gateways. Increased traffic or DNS activity may occur but are not definitive indicators. Thus, IP-to-MAC inconsistencies are the most reliable confirmation of MitM activity.

Question #:493 - [Cryptography]

You are Jordan, a cryptographic assessor at Cascade Data in Portland, Oregon, reviewing the protection applied to telemetry logs. Your review finds an algorithm that operates on 128-bit blocks, accepts keys up to 256 bits, and the documentation notes it was one of the finalists in the AES selection process that aimed to replace legacy DES. Which symmetric encryption algorithm should you identify as being used?

- A. RC4
- B. AES
- C. Blowfish

D. Twofish

Answer: D

Explanation

The correct answer is D. Twofish because the question explicitly describes a symmetric cipher that: (1) works on 128-bit blocks, (2) supports keys up to 256 bits, and (3) was a finalist in the AES selection process intended to replace DES. Twofish matches all of these characteristics. It is a symmetric block cipher designed by Bruce Schneier and colleagues, and it was one of the five AES finalists (along with Rijndael, Serpent, RC6, and MARS). Twofish uses a 128-bit block size and allows key sizes of 128, 192, or 256 bits, aligning precisely with the “up to 256-bit keys” clue.

Why the other choices do not fit: RC4 is a stream cipher, not a 128-bit block cipher, and it is not an AES finalist. AES itself (Rijndael) is the algorithm that ultimately won the AES competition; the prompt says the algorithm was a finalist, not necessarily the winner, and the description is intended to distinguish a finalist option from AES itself. Blowfish supports variable key lengths up to 448 bits but uses a 64-bit block size, not 128-bit blocks, and it was not an AES finalist (Twofish was designed as Blowfish’s successor with a larger block size to address modern requirements).

In practical terms, the block size and key size characteristics matter for security and performance: 128-bit blocks are standard for modern symmetric encryption, and 256-bit keys provide a high security margin for long-term protection of sensitive logs. The mention of AES finalization also signals that this algorithm belongs to the same generation of modern block ciphers designed with strong resistance to cryptanalysis and efficient software/hardware implementation.

Therefore, based on the stated properties and its AES finalist status, the symmetric encryption algorithm is Twofish.

Question #:494 - [Web Application Hacking]

In Atlanta, Georgia, ethical hacker James Patel is hired by Southern Retail, a major e-commerce chain, to test the security of their online shopping platform. During his penetration test, James aims to simulate a session hijacking attack by setting up a proxy to intercept HTTP traffic between customers and the platform, log the requests, and perform advanced searches on the captured data to identify session tokens. He needs a lightweight tool specifically designed for security research that can handle these tasks in a controlled environment to demonstrate vulnerabilities to the company's security team.

Which tool should James use to perform this session hijacking simulation?

- A. Caido
- B. Hetty
- C. Bettercap
- D. Wireshark

Answer: A

Explanation

The best choice is Caido because the scenario describes a web-focused interception proxy workflow: intercepting HTTP traffic, logging requests, and performing advanced searches to identify session tokens. In CEH-aligned web application testing methodology, session hijacking simulations commonly rely on an intercepting proxy to observe and manipulate application-layer requests and responses, extract session identifiers from cookies or headers, and demonstrate how weak session management can lead to account compromise. A lightweight security research proxy that captures traffic and supports fast filtering and searching across requests fits this exact need. Caido is designed as a modern web security toolkit centered around an interception proxy, allowing testers to capture browser-to-server traffic, inspect headers and cookies, and quickly search through recorded traffic for patterns such as session IDs, authentication cookies, bearer tokens, or predictable parameters.

The other tools are less aligned with the described requirements. Wireshark is a powerful packet analyzer, but it operates primarily at the packet level and is not optimized for web-app testing workflows such as organized request history, token-focused searching, and convenient HTTP manipulation. Bettercap is primarily a network MITM and exploitation framework; while it can intercept traffic, it is not the typical choice for controlled web proxy testing and detailed HTTP request analysis in the way described. Hetty is an HTTP toolkit, but the question's emphasis on a lightweight, security-research proxy with strong captured-data searching and request logging aligns more closely with Caido's purpose-built approach for web application assessments and session token discovery.

Question #:495 - [Cryptography]

An organization uses SHA-256 for data integrity verification but still experiences unauthorized data modification. Which cryptographic tool would best resolve this issue?

- A. Asymmetric encryption
- B. Symmetric encryption
- C. SSL/TLS certificates
- D. Digital signatures

Answer: D

Explanation

CEH explains that hash functions alone, such as SHA-256, only provide integrity checks and do not verify authenticity or non-repudiation. Attackers can modify data and recompute the hash.

Digital signatures combine hashing with asymmetric cryptography, ensuring:

Integrity

Authentication

Non-repudiation

Option D is correct.

Options A and B provide confidentiality, not integrity assurance.

Option C secures communication channels, not standalone data integrity.

CEH explicitly recommends digital signatures for protecting data integrity against tampering.

Question #:496 - [Social Engineering]

While conducting a red team exercise at a corporate office in San Diego, California, you observe employees working in an open-plan area. By discreetly watching their screens and hand movements as they log into internal systems, you are able to capture several usernames and partial passwords without touching any devices or interacting with the staff. Which social engineering technique does this scenario best illustrate?

- A. Shoulder Surfing
- B. Dumpster Diving
- C. Impersonation
- D. Tailgating

Answer: A

Explanation

This scenario most clearly illustrates shoulder surfing, a social engineering technique where an attacker obtains sensitive information by observing a victim's screen, keystrokes, or written notes—often from a nearby position—without directly interacting with the victim or their device. The key indicators are that the tester is “discreetly watching their screens and hand movements” during login and is able to capture “usernames and partial passwords” without touching anything. That is the defining pattern of shoulder surfing: passive observation to harvest credentials or other confidential information.

Shoulder surfing is particularly effective in open-plan offices, shared workspaces, airports, cafés, or any environment where people can be observed entering credentials. Attackers may watch directly, use reflections (e.g., glass surfaces), or position themselves to see the keyboard and screen. Even partial password capture can be valuable when combined with other information (usernames, password patterns, reset questions, or subsequent observation), and it can help an attacker craft more convincing follow-on social engineering attempts.

Why the other options do not fit:

Dumpster diving (B) involves retrieving sensitive information from trash (printed documents, media, badges, notes), not observing logins in real time.

Impersonation (C) requires actively posing as a trusted person (IT staff, vendor, employee) to persuade someone to disclose information or grant access; the scenario explicitly avoids interaction with staff.

Tailgating (D) is physically following someone through a secure door to gain unauthorized entry; it's about bypassing physical access controls rather than capturing credentials.

Because the technique relies on visual observation of screens and keystrokes to obtain login details, the correct answer is A. Shoulder Surfing.

Question #:497 - [Wireless Network Hacking]

You are Michael Rivera, a cybersecurity consultant at FortiSec Solutions, hired to strengthen the wireless network of DesertTech Innovations, a startup in Phoenix, Arizona. After a recent penetration test revealed vulnerabilities, the IT manager, Lisa Nguyen, asks you to recommend a defense mechanism to prevent unauthorized devices from connecting to the corporate Wi-Fi. You suggest a method that requires each connecting device to authenticate through a centralized server using a unique username and password. Based on the described approach, which wireless security countermeasure should DesertTech implement?

- A. Use 802.1X Authentication
- B. Disable TKIP
- C. MAC Address Filtering
- D. Upgrade to WPA3

Answer: A

Explanation

The requirement that each device authenticate through a centralized server using unique usernames and passwords aligns directly with 802.1X authentication, which CEH materials describe as port-based Network Access Control used in enterprise wired and wireless environments. In Wi-Fi, 802.1X is typically implemented as WPA2-Enterprise or WPA3-Enterprise and relies on EAP methods with a backend AAA server, most commonly RADIUS. The access point acts as the authenticator, forwarding the client's authentication exchange to the RADIUS server, which validates the user or device identity and returns an accept or reject decision along with session keys and policy attributes. This provides strong control and auditing because access can be tied to individual identities, supports account disablement, and can enforce different access levels.

The other options do not match the "centralized server with unique credentials" description. Disabling TKIP improves security by removing an outdated encryption protocol, but it does not provide per-user authentication. MAC address filtering is weak because MAC addresses are easily discovered and spoofed, and it does not use centralized identity validation. Upgrading to WPA3 improves cryptographic strength, and WPA3-Enterprise can work with 802.1X, but WPA3 alone does not guarantee centralized username and password authentication unless the enterprise mode with 802.1X is specifically deployed. Therefore, the correct countermeasure that fits the described design is to use 802.1X authentication with a centralized authentication server, enabling strong access control, accountability, and improved resistance to unauthorized device connections.

Question #:498 - [Mobile Platform and IoT Hacking]

Noah Kim, an ethical hacker at Quantum Cyber Solutions in Austin, Texas, is assessing iPhones used for proprietary development. On one device, he demonstrates a technique that allows it to boot normally without a computer, but the elevated access is temporarily lost after restart until the user launches a special on-device app to reapply the modifications. Which jailbreaking method is this?

- A. Tethered Jailbreaking
- B. Untethered Jailbreaking
- C. Semi-untethered Jailbreaking
- D. Semi-tethered Jailbreaking

Answer: C

Explanation

The scenario describes a jailbreak that boots normally without requiring a computer, but after a reboot the device loses the jailbroken (elevated) state until the user runs an on-device app to re-enable jailbreak features. That behavior matches semi-untethered jailbreaking.

In iOS jailbreaking terminology, the key differentiator is what happens after a restart and whether a computer is required to regain jailbroken functionality. With a semi-untethered jailbreak, the device can reboot on its own into a normal, usable iOS state (so it is not “bricked” or stuck at boot), but jailbreak features such as elevated privileges, unsigned code execution, and tweaks are not active immediately after reboot. To reapply the jailbreak, the user launches a jailbreak app installed on the device, which triggers the exploit chain again and re-enables the modified state until the next reboot. This aligns exactly with “temporarily lost after restart until the user launches a special on-device app.”

Why the other choices don't match:

Tethered jailbreaking (A) requires the device to be connected to a computer to boot; without tethering, the device cannot boot properly or remains unusable. The scenario explicitly says it can “boot normally without a computer,” so it is not tethered.

Untethered jailbreaking (B) persists across reboots; the device remains jailbroken after restarting with no extra steps. That contradicts the described need to reapply modifications after restart.

Semi-tethered jailbreaking (D) is similar in that the device can boot without a computer, but typically the device boots into a non-jailbroken mode and may require a computer or additional steps to return to a jailbroken state depending on the method; the scenario specifically highlights re-enabling via an on-device app, which is the hallmark most commonly associated with semi-untethered jailbreaks.

Therefore, the jailbreaking method shown is C. Semi-untethered Jailbreaking.

Question #:499 - [Reconnaissance Techniques]

As part of a passive reconnaissance engagement for a university research network, you are tasked with mapping potential administrative exposure points across .edu domains. Your objective is to identify web

pages that might allow privileged backend access, such as misconfigured administrative interfaces, using only publicly indexed information. To ensure efficiency and compliance, you decide to use advanced Google search operators to refine your search results. Your goal is to locate URLs across educational domains that may contain restricted backend functionality.

Which of the following search strings would most effectively support this goal?

- A. `site:.edu filetype:pdf intitle:"admin"`
- B. `intitle:"admin login" site:.edu`
- C. `site:.edu inurl:admin`
- D. `inanchor:"backend access" site:.edu`

Answer: C

Explanation

The question focuses on passive reconnaissance using Google advanced search operators, a technique commonly referred to in CEH materials as Google hacking or Google dorking. This method leverages publicly indexed data without directly interacting with the target systems, making it a non-intrusive reconnaissance approach. The goal here is to locate potentially exposed administrative interfaces within .edu domains.

Option C, `site:.edu inurl:admin`, is the most effective query for this purpose. The `site` operator restricts results to the .edu top-level domain, ensuring that only educational institutions are searched. The `inurl` operator filters results to pages where the term “admin” appears in the URL itself. Administrative panels and backend management interfaces frequently include terms such as `admin`, `administrator`, or `adminpanel` directly in the URL path. Therefore, this search string increases the likelihood of discovering exposed login portals or backend directories.

Option A focuses on PDF files with “admin” in the title, which is unlikely to reveal active administrative interfaces. Option B searches for pages with “admin login” in the title, which may find login pages but is less precise than filtering by URL structure. Option D searches anchor text references, which does not directly identify actual admin pages.

In CEH methodology, properly constructed Google dorks such as `inurl:admin` combined with site-specific filtering are effective in identifying exposed resources while maintaining passive reconnaissance discipline.

Question #:500 - [Network and Perimeter Hacking]

In Boston, Massachusetts, network administrator Daniel Carter is monitoring the IT infrastructure of New England Insurance, a prominent firm, after receiving alerts about sluggish system performance. While reviewing traffic patterns, Daniel observes an unusual volume of concurrent requests overwhelming critical servers. To validate his suspicion of a session hijacking attempt, he begins capturing and reviewing live network traffic to identify unauthorized session behaviors before escalating to the security team.

What detection method should Daniel use to confirm the session hijacking attack in this scenario?

- A. Use an intrusion detection system (IDS)
- B. Check for predictable session tokens
- C. Monitor for ACK storms
- D. Perform manual packet analysis using packet sniffing tools

Answer: D

Explanation

The scenario emphasizes that Daniel “begins capturing and reviewing live network traffic” to identify unauthorized session behaviors. In CEH-aligned network analysis practice, the most direct method to confirm session hijacking when you already have a packet capture is manual packet analysis using packet sniffing tools. By inspecting live traffic, Daniel can correlate sessions, verify whether multiple sources are reusing the same session identifiers, identify abnormal TCP sequence and acknowledgment behavior, and detect patterns such as duplicated cookies/tokens, replayed requests, inconsistent client IP or user-agent shifts, or sudden session reuse across hosts. This approach provides evidentiary detail beyond an alert and allows validation before escalation.

An IDS can be helpful, but it is a detection system that generates alerts based on signatures or anomalies; it does not inherently “confirm” the issue unless it provides clear supporting evidence, and the question specifically frames Daniel’s action as hands-on traffic review. Checking for predictable session tokens is a preventive and diagnostic step for weak session management design, but it does not directly confirm an in-progress hijacking event from observed network behavior. Monitoring for ACK storms can indicate certain TCP-level hijacking/desynchronization conditions, but it is narrower and may not apply to application-layer session hijacking, which is far more common in enterprise environments and would be validated by inspecting session identifiers and request flows in the capture.

Therefore, given the described workflow and the need to confirm unauthorized session activity from live traffic, CEH methodology aligns best with manual packet analysis using sniffing tools.

Question #:501 - [Reconnaissance Techniques]

A penetration tester is assessing a company’s vulnerability to advanced social engineering attacks targeting its legal department. Using detailed knowledge of mergers and legal proceedings, the tester crafts a highly credible pretext to deceive legal employees into sharing confidential case documents. What is the most effective technique?

- A. Send a spear-phishing email referencing specific merger details and requesting document access
- B. Create a fake LinkedIn profile to connect with legal employees and request document sharing
- C. Visit the office in person posing as a new legal intern to request document access
- D. Conduct a mass phishing campaign with generic legal templates attached

Answer: A

Explanation

CEH identifies spear-phishing as a targeted, context-rich social engineering method tailored to specific individuals or departments. By incorporating accurate insider details, attackers significantly increase trust and likelihood of disclosure.

Question #:502 - [Network and Perimeter Hacking]

In Austin, Texas, ethical hacker Liam Carter is hired by Lone Star Healthcare to probe the defenses of their patient data network. During his penetration test, Liam aims to bypass the hospital's firewall protecting a medical records server. To do so, he uses a tool to craft custom network packets, carefully designing their headers to slip past the firewall's filtering rules. His goal is to demonstrate how an attacker could infiltrate the system, exposing vulnerabilities for the security team to address.

Which tool is Liam using to bypass Lone Star Healthcare's firewall during his penetration test?

- A. Metasploit
- B. Colasoft Packet Builder
- C. Nmap
- D. Traffic IQ Professional

Answer: B

Explanation

Colasoft Packet Builder is specifically designed for creating and editing custom packets, making it the best match for a scenario where the tester "crafts custom network packets" and "carefully designs their headers" to test or evade firewall filtering. In CEH methodology, packet crafting is a common technique used to validate how filtering devices respond to unusual or borderline traffic patterns, including altered TCP flags, manipulated fragmentation behavior, spoofed fields, and protocol edge cases. A packet builder tool enables precise control over Layer 2 through Layer 4 fields and, in many cases, supports building application payloads as well. This supports testing for weaknesses such as overly permissive rules, inconsistent state handling, improper reassembly, and inadequate normalization that could allow malicious traffic to pass.

Metasploit is primarily an exploitation framework used to deliver payloads and run modules after targets and weaknesses are identified. While it can generate traffic, it is not the most direct tool for low-level, manual header crafting as described. Nmap is mainly used for host discovery, port scanning, service detection, and scripting-based enumeration; it can manipulate some packet characteristics, but its core purpose is not interactive custom packet construction. Traffic IQ Professional is typically associated with network analysis and traffic monitoring rather than crafting bespoke packets to probe firewall rule behavior.

Therefore, the tool most aligned with CEH-style custom packet creation for firewall evasion testing is Colasoft Packet Builder.

Question #:503 - [Malware Threats]

Malware adapts behavior, changes code dynamically, and exfiltrates data stealthily. What is it?

- A. AI-powered malware
- B. Worm
- C. Rootkit
- D. Polymorphic virus

Answer: A

Explanation

CEH v13 identifies AI-powered malware as an emerging advanced threat that adapts its execution based on environmental cues and user behavior. Unlike traditional polymorphic malware, AI-driven malware can dynamically decide when and how to execute actions to avoid detection.

The described traits—behavioral adaptation, idle-time exfiltration, encrypted communication—are hallmarks of AI-assisted malware.

Polymorphic viruses change signatures but do not adapt behavior intelligently. Rootkits focus on hiding presence. Worms propagate aggressively.

Therefore, Option A is correct.

Question #:504 - [Network and Perimeter Hacking]

You are instructed to perform a TCP NULL scan. In the context of TCP NULL scanning, which response indicates that a port on the target system is closed?

- A. ICMP error message
- B. TCP SYN/ACK packet
- C. No response
- D. TCP RST packet

Answer: D

Explanation

TCP NULL scanning is a stealth scanning technique covered in CEH v13 Reconnaissance and Network Scanning. In a NULL scan, all TCP flags are set to zero. According to RFC 793 and CEH documentation, closed ports must respond with a TCP RST (Reset) packet.

If the port is open, the target typically does not respond, making this technique useful for firewall evasion. Therefore:

RST response = Closed port

No response = Open or filtered port

Other options do not apply to NULL scans:

SYN/ACK is associated with SYN scans.

ICMP errors may indicate filtering, not port state.

Question #:505 - [Information Security and Ethical Hacking Overview]

Who are “script kiddies” in the context of ethical hacking?

- A. Highly skilled hackers who write custom scripts
- B. Novices who use scripts developed by others
- C. Ethical hackers using scripts for penetration testing
- D. Hackers specializing in scripting languages

Answer: B

Explanation

In CEH v13 Information Security and Ethical Hacking Overview, script kiddies are defined as individuals with limited technical knowledge who rely on pre-written tools, scripts, and exploits created by others to carry out attacks. They typically lack a deep understanding of how the underlying exploits work.

CEH v13 categorizes attackers based on skill level and intent. Script kiddies sit at the lower end of the skill spectrum. They often download exploit kits, automated scanners, or attack frameworks and run them with minimal customization. While their attacks may be unsophisticated, they can still cause damage due to the availability of powerful tools.

Option B accurately reflects this definition. Options A and D describe skilled attackers or programmers, which contradicts the CEH classification. Option C is incorrect because ethical hackers use tools responsibly with authorization and possess a strong understanding of security principles.

CEH v13 emphasizes that although script kiddies are less skilled, they pose a risk because automation allows them to exploit known vulnerabilities at scale. This is why organizations must patch systems promptly and implement baseline security controls.

Thus, Option B is the correct answer.

Question #:506 - [Mobile Platform and IoT Hacking]

During a red team engagement, an ethical hacker discovers that a thermostat accepts older firmware versions without verifying their authenticity. By loading a deprecated version containing known vulnerabilities, the

tester gains unauthorized access to the broader network. Which IoT security issue is most accurately demonstrated in this scenario?

- A. Lack of secure update mechanisms
- B. Denial-of-service through physical tampering
- C. Insecure network service exposure
- D. Use of insecure third-party components

Answer: A

Explanation

CEH v13 emphasizes that IoT devices must implement secure firmware update mechanisms that enforce authenticity, integrity, and version control. A critical lapse occurs when devices allow rollback to older firmware versions or accept updates without cryptographic validation. This opens the door to “firmware downgrade attacks,” where attackers intentionally install outdated but vulnerable firmware to reintroduce exploitable weaknesses. CEH identifies this as part of insecure update design, one of the most dangerous IoT vulnerabilities because firmware governs device behavior, network communication, and trust boundaries. Without signature verification, integrity checking, and anti-rollback enforcement, attackers can load malicious or deprecated firmware to escalate privileges or pivot deeper into a network. Options B and C represent different categories of IoT weaknesses, and D refers to supply-chain issues, none of which match the described rollback exploitation. Therefore, the vulnerability demonstrated is the absence of secure update mechanisms.

Question #:507 - [Reconnaissance Techniques]

While reviewing exposed infrastructure for a logistics company in Denver, Joe, a security analyst, identifies that one host is synchronizing time using UDP port 123. Probing further, he issues queries to extract details about peers, offsets, and delays. This allows him to gather internal hostnames and client IP addresses connected to the time server. Such information leakage could provide insight into the company's internal network structure.

Which technique was most likely used to obtain this information?

- A. DNS Zone Transfer Enumeration
- B. NTP Enumeration
- C. VoIP Enumeration
- D. NetBIOS Enumeration

Answer: B

Explanation

The correct answer is B. NTP Enumeration because the indicators and the data obtained match enumeration of the Network Time Protocol (NTP) service, which commonly runs on UDP port 123. In CEH-aligned reconnaissance and enumeration concepts, attackers often enumerate exposed services to learn configuration and internal details that can assist with follow-on attacks. When NTP is reachable from untrusted networks and is misconfigured (or supports certain query modes), it can leak information about the time server's peers, synchronization status, and operational metrics such as offset and delay—exactly the attributes described in the scenario.

The prompt also notes that Joe can gather internal hostnames and client IP addresses connected to the time server. This aligns with how NTP can reveal associated systems and relationships: time servers often have multiple internal clients, upstream peers, or configured associations. Queries that expose peer/association information can unintentionally disclose internal naming conventions, IP address ranges, and network structure—valuable intelligence for an attacker conducting mapping and target selection. In addition, time infrastructure is frequently centralized, so enumerating it can provide a hub-like view of the environment.

Why the other options are incorrect: DNS zone transfer enumeration is associated with DNS AXFR and typically yields DNS records such as subdomains and MX/CNAME entries—not NTP peers/offsets/delays and not UDP 123. VoIP enumeration targets telephony protocols and services (e.g., SIP) on different ports and would not center on time synchronization metrics. NetBIOS enumeration involves ports 137–139 and returns NetBIOS name and session information, not NTP operational data.

Therefore, the technique used to obtain peer, offset, delay, and connected client details from a UDP/123 time server is NTP enumeration.

Question #:508 - [Social Engineering]

During a physical penetration test at Sterling Electronics in Cleveland, ethical hacker Priya waits near the employee entrance during a shift change. When a group of staff enters the building using their access cards, Priya closely follows behind without swiping her own badge. None of the employees confront her, assuming she belongs there. Once inside, Priya proceeds to the break area where she documents the success of the exercise.

Which social engineering technique is Priya demonstrating?

- A. Shoulder Surfing
- B. Dumpster Diving
- C. Tailgating
- D. Piggybacking

Answer: C

Explanation

This scenario demonstrates tailgating, which is gaining unauthorized physical access to a secure area by following an authorized person through an access-controlled entry point. Priya does not present credentials, swipe a badge, or otherwise authenticate; instead, she leverages normal human behavior and social

assumptions during a busy shift change. Because employees assume she belongs there and do not challenge her, she successfully bypasses the physical access control.

Tailgating is common in workplaces with high traffic, open-plan culture, or weak enforcement of “no badge, no entry” rules. Attackers may exploit politeness, distraction, or the desire to hold doors open. It is especially effective during shift changes, deliveries, or when people are carrying items and appreciate someone holding the door. The security weakness being tested here is not the badge technology itself but the human factor: lack of challenge culture and inconsistent adherence to access policies.

Tailgating versus piggybacking: in many security references, piggybacking implies the authorized person knowingly allows the other to enter (e.g., holds the door intentionally after being asked). Tailgating typically implies the intruder enters without explicit permission, often by slipping in behind a group. In this scenario, no one confronts her and they “assume she belongs there,” indicating she is following them in without asking or being granted explicit permission—tailgating.

The other options are unrelated: shoulder surfing is visual observation of sensitive input; dumpster diving is retrieving information from trash. Therefore, the correct answer is C. Tailgating.

Question #:509 - [Web Application Hacking]

During a penetration test at Pinnacle Bank in Chicago, ethical hacker Sarah injects crafted TCP packets into an active communication between a customer's browser and the online banking server. The victim's connection becomes unstable, allowing Sarah's system to maintain communication with the server in place of the legitimate client. She later demonstrates to the IT team how attackers could forcibly take control of live sessions through this approach.

Which type of session hijacking is Sarah performing in this scenario?

- A. Passive Session Hijacking
- B. Blind Hijacking
- C. Man-in-the-Browser Attack
- D. Active Session Hijacking

Answer: B

Explanation

The correct answer is B. Blind Hijacking because the scenario describes injecting crafted TCP packets into an active client-server session to disrupt the legitimate client and take over the connection, without requiring the attacker to see (or fully rely on seeing) the server's responses. In CEH-aligned session hijacking classifications, blind hijacking is an active takeover technique at the TCP/session layer where the attacker forges packets (often with predicted or inferred TCP sequence numbers) to insert data into an existing session and potentially desynchronize the legitimate endpoints. By injecting traffic that causes instability (for example, triggering retransmissions, resets, or sequence/ack mismatch), the attacker can effectively push the victim out of sync or off the session while continuing to communicate with the server as if they were the client.

The key clue is that Sarah “injects crafted TCP packets” into an “active communication,” and then the “victim’s connection becomes unstable,” after which Sarah’s system “maintain[s] communication with the server in place of the legitimate client.” This aligns with blind hijacking concepts where the attacker does not simply observe (passive) but actively manipulates the TCP stream to seize control. The attacker’s goal is forced takeover of a live session, which often involves sequence prediction and packet injection to become the effective participant while the real client experiences disruption.

Why the other options are incorrect: Passive session hijacking is eavesdropping/monitoring traffic to capture session identifiers without altering the session; it does not involve injecting packets or destabilizing a connection. Man-in-the-Browser is a client-side attack (typically via malware in the browser) that manipulates transactions within the browser context; it is not a TCP packet injection technique. Active session hijacking is a broad category and is true at a high level, but the question asks for the type—and the specific technique described (TCP injection causing takeover) maps most directly to blind hijacking in CEH-style terminology.

Therefore, Sarah is demonstrating blind session hijacking.

Question #:510 - [Mobile Platform, IoT, and OT Hacking]

An IoT traffic light shows anomalous traffic to an external IP and has an open port. What should be your next step?

- A. Attempt reverse connections
- B. Isolate the device and investigate firmware
- C. Modify firewall rules only
- D. Conduct full network penetration testing

Answer: B

Explanation

CEH v13 emphasizes that IoT and smart city environments are highly sensitive and safety-critical. When an IoT device shows anomalous outbound traffic and unauthorized open ports, this strongly indicates device compromise.

The correct immediate response is to isolate the affected device to prevent lateral movement and protect public safety. CEH v13 further stresses the importance of firmware analysis, as IoT malware often resides at the firmware level to maintain persistence.

Attempting reverse connections (Option A) is risky and may violate operational safety. Firewall changes alone (Option C) do not address an already compromised device. A full penetration test (Option D) is appropriate later but not as an immediate containment step.

Therefore, Option B aligns with CEH v13 incident handling best practices for IoT and OT environments.

Question #:511 - [Wireless Network Hacking]

A penetration tester targets a WPA2-PSK wireless network. The tester captures the handshake and wants to speed up cracking the pre-shared key. Which approach is most effective?

- A. Conduct a Cross-Site Scripting (XSS) attack on the router's login page
- B. Use a brute-force attack to crack the pre-shared key manually
- C. Use a dictionary attack with a large wordlist to crack the WPA2 key
- D. Perform a SQL injection attack to bypass the WPA2 authentication

Answer: C

Explanation

CEH v13 explains that WPA2-PSK security relies on the strength of the pre-shared key. Once the 4-way handshake is captured, the attacker must attempt offline cracking. CEH emphasizes that the dictionary attack is the most efficient and commonly used cracking method because it tests structured wordlists, human-derived passwords, and hybrid permutations, dramatically reducing time compared to full brute force. Brute forcing (Option B) is computationally heavy and often impractical unless the password is extremely short. XSS (Option A) and SQL injection (Option D) have no relevance to WPA2 authentication, which occurs at the wireless protocol level, not the router's web interface. The dictionary attack is highlighted in CEH as the principal technique used with tools like aircrack-ng, hashcat, and pyrit, allowing rapid key testing using optimized GPU or CPU cracking. Thus, Option C is the most effective and CEH-aligned method.

Question #:512 - [Mobile Platform, IoT, and OT Hacking]

A city's power management system relies on SCADA infrastructure. Recent anomalies include inconsistent sensor readings and intermittent outages. Security analysts suspect a side-channel attack designed to extract sensitive information covertly from SCADA devices. Which investigative technique would best confirm this type of attack?

- A. Measuring unusual physical or electrical fluctuations during device operation at the hardware level.
- B. Identifying weak cryptographic configurations in device communications.
- C. Assessing SCADA user interfaces for unauthorized access or misuse.

Answer: A

Explanation

According to the Certified Ethical Hacker (CEH) IoT, OT, and SCADA Security module, side-channel attacks exploit indirect information leaks such as power consumption, electromagnetic emissions, timing variations, or thermal output rather than software vulnerabilities.

Option A is correct because monitoring hardware-level anomalies is the primary method for detecting side-channel exploitation. CEH materials emphasize that these attacks bypass traditional security controls.

Option B relates to cryptographic weaknesses, not side-channel analysis.

Option C addresses interface misuse, not covert data leakage.

CEH highlights that SCADA systems are especially vulnerable due to legacy hardware and limited monitoring capabilities.

Question #:513 - [Reconnaissance Techniques]

During a penetration test, you perform extensive DNS interrogation to gather intelligence about a target organization. Considering the inherent limitations of DNS-based reconnaissance, which of the following pieces of information cannot be directly obtained through DNS interrogation?

- A. The specific usernames and passwords used by the organization's employees.
- B. The estimated geographical location of the organization's servers derived from IP addresses.
- C. The subdomains associated with the organization's primary internet domain.
- D. The IP addresses associated with the organization's mail servers.

Answer: A

Explanation

The CEH Footprinting and Reconnaissance module describes DNS interrogation as a valuable technique for extracting publicly available infrastructure information such as A records, MX records, NS records, and subdomains.

DNS can reveal:

Subdomains (via zone transfers, brute forcing, or enumeration)

Mail server IP addresses (MX records)

Server locations inferred from IP geolocation

However, DNS does not store authentication credentials. Usernames and passwords are protected within authentication systems and directories, not DNS records.

Therefore, option A is correct.

CEH clearly states that DNS reconnaissance is limited to infrastructure metadata, not sensitive user credentials.

Question #:514 - [Web Application Hacking]

During a penetration test at Sunshine Media's streaming platform in Miami, ethical hacker Sofia Alvarez examines whether the company's web server exposes sensitive resources through poor configuration. She finds that a crawler directive at the server's root allows unintended indexing of restricted areas. This oversight reveals internal paths that may expose hidden links, confidential files, or other sensitive information.

Which technique is Sofia most likely using in this assessment?

- A. Vulnerability Scanning
- B. Information Gathering from robots.txt File
- C. Web Server Footprinting/Banner Grabbing
- D. Directory Brute Forcing

Answer: B

Explanation

The scenario points directly to information gathering from the robots.txt file. A robots.txt file is typically located at the root of a website (e.g., <https://example.com/robots.txt>) and is intended to instruct search engine crawlers which paths should or should not be indexed. During web reconnaissance, testers often review robots.txt because it can unintentionally disclose sensitive directories, administrative panels, staging paths, backup locations, or restricted areas that the organization hoped would remain obscure. The scenario explicitly says Sofia found “a crawler directive at the server’s root” that “allows unintended indexing of restricted areas,” and that this “reveals internal paths.” That is exactly the kind of leakage that can come from misconfigured or overly revealing crawler directives.

This is considered an early-stage reconnaissance / information gathering technique because it does not require exploitation. It leverages publicly accessible configuration hints to map the application’s hidden structure. Even when robots.txt is used correctly, the listed disallowed entries can still serve as a roadmap of interesting targets; if configured incorrectly (for example, allowing indexing or exposing sensitive paths), it can increase exposure by helping those paths surface in search results or be discovered faster by attackers.

Why the other options are less accurate:

Vulnerability Scanning (A) implies using scanners to identify known flaws; here, the tester is manually /strategically inspecting a crawler directive for exposed paths.

Web Server Footprinting/Banner Grabbing (C) focuses on identifying server type/version and technologies via headers or responses, not discovering hidden paths from crawler directives.

Directory Brute Forcing (D) uses wordlists to guess directories; Sofia’s discovery comes from a disclosed list of paths, not brute-force guessing.

Therefore, the technique is B. Information Gathering from robots.txt File.

Question #:515 - [Web Application Hacking]

A penetration tester suspects that a web application's login form is vulnerable to SQL injection due to improper sanitization of user input. What is the most appropriate approach to test for SQL injection in the login form?

- A. Inject JavaScript into the input fields to test for Cross-Site Scripting (XSS)
- B. Enter ' OR '1'='1 in the username and password fields to bypass authentication
- C. Perform a directory traversal attack to access sensitive files
- D. Use a brute-force attack on the login page to guess valid credentials

Answer: B

Explanation

CEH v13 explains that SQL injection typically occurs when user inputs are concatenated into SQL queries without proper validation or parameterization. The login form is one of the most common injection targets, and testers use specific test payloads designed to manipulate the authentication query. A classic test string such as ' OR '1'='1 exploits conditional logic to force the SQL statement to evaluate as true, effectively bypassing authentication if the application is vulnerable. CEH notes that this technique is a standard initial test because it is low-risk, easily detectable if vulnerable, and directly confirms improper sanitization. JavaScript injection (Option A) tests for XSS, not SQLi. Directory traversal (Option C) targets file path vulnerabilities rather than SQL queries. Brute-force attacks (Option D) rely on guessing credentials and do not test input sanitization. Therefore, using a logical SQL injection payload is the most appropriate and CEH-aligned method.

Question #:516 - [Information Security and Ethical Hacking Overview]

You are part of a red team hired to assess the cybersecurity posture of a large retail chain headquartered in New York. The client wants to know whether their defenses can anticipate future attack patterns before they occur. To meet this objective, your team deploys an AI-enabled platform that analyzes previous breaches and anomaly data to forecast potential attack vectors. Which benefit of AI-driven ethical hacking is most critical in this case?

- A. Scalability
- B. Predictive analysis
- C. Enhanced reporting
- D. Simulation and testing

Answer: B

Explanation

The correct answer is B. Predictive analysis because the client's primary objective is to anticipate future attack patterns before they occur, and the described AI-enabled platform is explicitly being used to forecast potential attack vectors based on historical breaches and anomaly data. In CEH-aligned coverage of modern

security capabilities, AI-driven approaches add value by learning from large datasets (logs, alerts, incidents, threat intelligence, and observed attacker behaviors) to identify trends, detect weak signals, and predict the most likely next steps an adversary may take. This directly supports proactive defense planning rather than purely reactive response.

In this scenario, the platform ingests “previous breaches and anomaly data” and produces forward-looking insights. That is the essence of predictive analysis: applying machine learning/analytics to estimate where attacks may emerge (for example, which assets are most at risk, which tactics are trending, what misconfigurations correlate with compromise, or which sequences of events often precede an intrusion). This helps defenders prioritize controls, patching, monitoring, and hardening to disrupt the projected attack paths ahead of time. It also aligns with the retail client’s desire to know whether their defenses can “anticipate” attacks, not merely document them after the fact.

Why the other options are less correct: Scalability is a benefit of AI (automating large-scale analysis), but it does not specifically address forecasting future attack vectors. Enhanced reporting improves how findings are communicated, but it is not the key capability described. Simulation and testing refers to running scenarios or automated testing in environments to measure resilience; that can be AI-assisted, but the prompt focuses on analyzing historical and anomaly data to predict likely attacks, which maps most directly to predictive analysis.

Therefore, the most critical benefit of AI-driven ethical hacking in this case is predictive analysis.

Question #:517 - [Reconnaissance Techniques]

In Seattle, Washington, ethical hacker Mia Chen is hired by Pacific Trust Bank to test the security of their corporate network, which stores sensitive customer financial data. During her penetration test, Mia conducts a thorough reconnaissance, targeting a server that appears to host a critical database of transaction records. As she interacts with the server, she notices it responds promptly to her queries but occasionally returns error messages that seem inconsistent with a production system’s behavior, such as unexpected protocol responses. Suspicious that this server might be a decoy designed to monitor her actions, Mia applies a technique to detect inconsistencies that may reveal the system as a honeypot.

Which technique is Mia most likely using to determine if the server at Pacific Trust Bank is a honeypot?

- A. Analyzing Response Time
- B. Analyzing MAC Address
- C. Fingerprinting the Running Service
- D. Analyzing System Configuration and Metadata

Answer: C

Explanation

Fingerprinting the running service is the most appropriate technique because the strongest indicator in the scenario is inconsistent protocol behavior and error responses that do not match a legitimate production database service. In CEH reconnaissance guidance, honeypots and decoy systems often emulate common services but may implement only partial protocol stacks or simplified responses. This can lead to anomalies

such as incorrect banner strings, malformed or generic error messages, unsupported command handling, unusual protocol negotiation, or responses that do not align with the claimed software version. By fingerprinting, Mia compares observed behavior against expected behavior for the genuine service, including version-specific quirks, command sets, response codes, and timing patterns for particular requests.

In practice, service fingerprinting involves interacting with the service using legitimate and edge-case requests, validating banners and headers, and correlating results with known signatures from real implementations. If the server claims to be a specific database or application service but reacts in ways that real deployments would not, it suggests emulation, instrumentation, or deception typical of honeypots designed to log attacker activity.

Analyzing response time can help, because some honeypots respond too quickly or with uniform timing, but timing alone is less definitive than protocol inconsistencies. MAC address analysis is not reliable for identifying honeypots and is often not visible beyond the local segment. Analyzing system configuration and metadata usually requires deeper access than reconnaissance and is not the primary method when the clue is protocol-level mismatch. Therefore, fingerprinting the running service best fits the observed symptoms.

QUBB ESTION NO: 25 [Mobile Platform and IoT Hacking]

Javier Ruiz from CyberFortress Solutions is tasked with auditing the mobile security practices of Apex Financial Services, a financial firm in Houston, Texas. During a covert penetration test, Javier targets employees' personal smartphones used to access corporate financial systems. He exploits a vulnerability by installing a malicious app that bypasses access controls, granting him unauthorized entry to sensitive financial data because the devices lack a specific security measure to restrict app access. Based on this vulnerability, which BYOD security guideline is most likely missing in Apex Financial Services' policy?

- A. Review permissions requested by apps before installing them
- B. Set passwords for apps to restrict others from accessing them
- C. Enforce automatic device locking or implement biometric authentication
- D. Use encryption mechanisms to store data

Answer: A

The most likely missing BYOD guideline is reviewing application permissions before installation. In CEH mobile security guidance, a major risk in BYOD environments is the introduction of untrusted or malicious applications that abuse the mobile permission model to access corporate data, intercept authentication tokens, read storage, capture keystrokes via accessibility services, or communicate externally. When users install apps without scrutinizing requested permissions, they may unknowingly grant excessive privileges that enable data theft or access-control bypass, especially if the app leverages OS weaknesses or misconfigurations.

The scenario states Javier “installs a malicious app that bypasses access controls” and gains access to sensitive financial data because devices “lack a specific security measure to restrict app access.” This maps directly to a policy gap around controlling and validating apps and their permission requests. CEH emphasizes that organizations should reduce attack surface by limiting app privileges, avoiding sideloading from untrusted sources, and enforcing least privilege through user awareness and enterprise controls such as MDM application allowlisting and permission governance. Reviewing permissions is the user-facing guideline that prevents employees from granting dangerous access (for example, SMS, storage, contacts, accessibility, device admin, or VPN configuration permissions) that can enable credential theft or unauthorized data access.

Option B adds an extra layer for local access but does not stop a malicious app with granted permissions from accessing corporate data. Option C helps if a device is physically stolen, but it does not prevent malicious apps already running under the user context. Option D protects data at rest, yet a malicious app can still exfiltrate data once it is decrypted and accessed by the user session. Therefore, permission review is the most directly relevant missing BYOD guideline.

Question #:518 - [Information Security and Ethical Hacking Overview]

A financial institution in San Francisco suffers a breach where attackers install malware that captures customer account credentials. The stolen data is then sold on underground forums for profit. No political or social statements are made, and the attackers remain anonymous while continuing to target similar organizations for financial gain. Based on this activity, what category of hacker is most likely responsible?

- A. Black Hat hackers
- B. Hacktivists
- C. Script Kiddies
- D. White Hat hackers

Answer: A

Explanation

The attackers described are most consistent with black hat hackers because their actions are clearly unauthorized, intentionally harmful, and motivated by financial gain. They compromise a financial institution, deploy credential-stealing malware, exfiltrate customer account data, and then sell the stolen information on underground forums. This aligns with criminal hacking behavior: monetizing access and stolen data through illicit marketplaces, fraud, and repeated targeting of similar victims.

The scenario explicitly rules out ideologically motivated activity: “no political or social statements are made.” That makes hacktivists unlikely, since hacktivism typically involves a political, social, or ideological motive and often seeks publicity for a cause (defacements, leaks, DDoS protests). It also rules out ethical categories: white hat hackers operate with authorization and report findings to improve security rather than steal and sell credentials. Script kiddies are generally low-skill attackers who rely on existing tools and scripts; while they can cause harm, the scenario highlights sustained targeting, credential theft, and underground monetization—behavior more strongly associated with organized cybercriminals/black hats.

Black hats typically pursue objectives like theft of credentials, financial fraud, ransomware deployment, and sale of access or data. Their operations often emphasize anonymity, operational security, and repeatability across many similar targets—consistent with “continuing to target similar organizations for financial gain.”

Therefore, the most likely category is A. Black Hat hackers.

Question #:519 - [Reconnaissance Techniques]

Which technique is least useful during passive reconnaissance?

- A. WHOIS lookup
- B. Search engines
- C. Social media monitoring
- D. Nmap scanning

Answer: D

Explanation

Passive reconnaissance involves gathering information without directly interacting with the target. WHOIS, search engines, and social media are all passive techniques highlighted in CEH v13 Reconnaissance.

Nmap scanning, however, actively probes target systems and generates traffic that can be logged and detected. This makes it an active reconnaissance technique.

Therefore, Option D is least useful in a passive phase.

Question #:520 - [Mobile Platform, IoT, and OT Hacking]

In the humid air of Houston, Texas, a chemical plant is preparing to deploy a new production automation module. As part of a red team engagement, you, Ethan Brooks, a cybersecurity specialist are tasked with identifying industrial control devices that communicate with SCADA systems. To proactively uncover devices that may expose critical functions, you launch a focused Nmap sweep targeting TCP port 102, known to be associated with industrial controllers used in critical infrastructure. Your scan detects specific PLC models used in the automation process. What OT reconnaissance step are you performing?

- A. Scanning Omron PLC devices
- B. Scanning Modbus devices
- C. Capturing Modbus TCP traffic using Wireshark
- D. Scanning Siemens SIMATIC S7 PLCs

Answer: D

Explanation

TCP port 102 is strongly associated with Siemens S7 communications, commonly referred to as S7comm, which is used by Siemens SIMATIC S7 PLC families and related engineering and HMI components in OT environments. In CEH coverage of ICS and SCADA reconnaissance, identifying industrial protocols by their well-known ports is a standard first step because it quickly narrows down device type, vendor ecosystem, and likely attack surface. When Ethan targets TCP 102 and the scan reveals PLC models used in the automation process, that aligns directly with enumerating Siemens SIMATIC S7 PLCs, since S7comm typically operates over ISO-on-TCP on port 102.

The other options do not match the port-protocol pairing described. Modbus TCP most commonly uses TCP port 502, so “scanning Modbus devices” would be associated with 502 rather than 102. “Capturing Modbus TCP traffic using Wireshark” is passive sniffing and also would focus on Modbus traffic patterns on 502, not an active Nmap sweep on 102. Omron PLCs may use different protocols and ports depending on model and configuration, but TCP 102 is the canonical indicator for Siemens S7 in most defensive and offensive playbooks taught for OT discovery.

From a defensive perspective, CEH-aligned best practices emphasize segmenting OT networks, restricting access to engineering ports like 102, monitoring for scanning behavior, and enforcing allowlisted communications between SCADA, HMIs, and PLCs to reduce the risk of unauthorized enumeration and follow-on manipulation.

Question #:521 - [Mobile Platform and IoT Hacking]

An Android device has an unpatched permission-handling flaw and updated antivirus. What is the most effective undetected exploitation approach?

- A. SMS phishing
- B. Rootkit installation
- C. Custom exploit with obfuscation
- D. Metasploit payload

Answer: C

Explanation

CEH v13 explains that mobile antivirus solutions rely heavily on signatures and known exploit patterns. A custom exploit using obfuscation is far more likely to evade detection.

Metasploit payloads and rootkits are commonly flagged, and SMS phishing relies on user interaction. Therefore, custom obfuscated exploit code is the most stealthy and effective method.

Question #:522 - [Network and Perimeter Hacking]

During a UDP service enumeration scan, the tester sees that some ports respond with ICMP Type 3 Code 3 (Port Unreachable), while most remain silent. No firewall or IDS is interfering. What can the tester conclude about the non-responsive ports?

- A. The ports are likely closed because no ICMP response was received.
- B. The system blocked all probes after rate-limiting was detected.
- C. They may be open or filtered, requiring retransmission.
- D. They may correspond to some services requiring three-way handshakes.

Answer: C**Explanation**

UDP scanning produces reliable "closed" results only when an ICMP Port Unreachable is returned. Silent responses indicate either open ports (no reply expected) or filtered ports (blocks dropping packets). CEH emphasizes that non-responses require retransmission or alternate verification techniques.

Question #:523 - [Network and Perimeter Hacking]

An Nmap SMTP enumeration script returns valid usernames. What misconfiguration is being exploited?

- A. SMTP VRFY/EXPN/RCPT commands exposed
- B. SMTP authentication bypass
- C. Misconfigured MX records
- D. STARTTLS disabled

Answer: A**Explanation**

This scenario demonstrates SMTP Enumeration, a classic enumeration technique described in CEH v13 Network Enumeration. SMTP servers may expose commands such as VRFY, EXPN, and RCPT TO, which can be abused to validate user accounts.

When these commands are enabled without restriction, attackers can enumerate valid usernames without authentication. The Nmap script used explicitly leverages these commands, confirming the misconfiguration.

Option B is incorrect because authentication is not bypassed. Option C concerns DNS routing, not user enumeration. Option D relates to encryption, not enumeration capability.

CEH v13 strongly recommends disabling or restricting SMTP user verification commands. Thus, Option A is correct.

Question #:524 - [Security Operations and Incident Response]

A zero-day vulnerability is actively exploited in a critical web server, but no vendor patch is available. What should be the FIRST step to manage this risk?

- A. Shut down the server
- B. Apply a virtual patch using a WAF
- C. Perform regular backups and prepare IR plans
- D. Monitor for suspicious activity

Answer: B**Explanation**

According to CEH v13 Security Operations and Incident Response, zero-day vulnerabilities pose one of the highest operational risks because exploits exist before official remediation is available. When active exploitation is observed and no vendor patch exists, immediate compensating controls must be deployed.

The first and most effective action is implementing virtual patching, typically through a Web Application Firewall (WAF) or Intrusion Prevention System (IPS). CEH v13 defines virtual patching as a security measure that blocks exploitation attempts at the network or application layer without modifying the vulnerable software. This approach allows organizations to maintain service availability while reducing exposure.

Shutting down the server (Option A) may prevent exploitation but introduces unacceptable business disruption and is not recommended as a first response. Backups and incident response planning (Option C) are critical but do not actively prevent exploitation. Passive monitoring (Option D) allows attackers to continue exploiting the vulnerability unchecked.

CEH v13 emphasizes that virtual patching is the preferred first response for zero-day threats, especially when systems are mission-critical. It provides immediate risk reduction while allowing time for vendor patch development and controlled deployment.

Question #:525 - [Social Engineering]

You are conducting a security audit at a government agency. During your walkthrough, you observe a temporary contractor sitting in the staff lounge using their smartphone to discretely record employees as they enter passwords into their systems. Upon further investigation, you find discarded documents in a nearby trash bin containing sensitive project information. What type of attack is most likely being performed?

- A. Cisco-in attack
- B. Insider attack
- C. Distribution attack
- D. Passive attack

Answer: B**Explanation**

The behavior described most closely matches an insider attack, because the actor is a temporary contractor who has physical proximity and implicit access to internal areas where employees work and handle sensitive information. In CEH guidance, an “insider” is not limited to permanent employees; it includes contractors, vendors, interns, and any trusted or semi-trusted individuals who can enter facilities or access internal environments. The attack combines two common insider-facilitated techniques: shoulder surfing and dumpster diving. Recording employees entering passwords is a form of shoulder surfing, where credentials are harvested by observing or capturing authentication entry through direct viewing or recording devices.

Finding sensitive documents in a trash bin indicates dumpster diving, where attackers recover confidential information from improperly disposed materials.

These actions are typically feasible because the attacker is already inside the perimeter and can exploit weak operational security practices, such as lack of clean-desk enforcement, inadequate shredding policies, and insufficient physical monitoring of visitor or contractor activity. CEH materials emphasize that insider threats are particularly dangerous because they bypass many external perimeter controls and can blend into normal workplace behavior.

The other options do not fit. A distribution attack generally refers to compromise introduced through supply chain or third-party distribution channels, not on-site observation and trash retrieval. A passive attack is too generic and does not capture the key element of an authorized or trusted presence enabling the compromise. “Cisco-in attack” is not a standard CEH attack category for this scenario. Therefore, the most accurate classification is an insider attack.

Question #:526 - [System Hacking Phases]

A red team operator wants to obtain credentials from a Windows machine without touching LSASS memory due to security controls and Credential Guard. They use SSPI to generate NetNTLM responses in the logged-in user context and collect those responses for offline cracking. Which attack technique is being used?

- A. Internal Monologue attack technique executed through OS authentication protocol manipulations
- B. Replay attack attempt by reusing captured authentication traffic sequences
- C. Hash injection approach using credential hashes for authentication purposes
- D. Pass-the-ticket attack method involving forged tickets for network access

Answer: A

Explanation

CEH v13 discusses various credential extraction and authentication abuse techniques, including approaches that avoid LSASS memory due to modern protections like Credential Guard. The Internal Monologue technique is a specialized credential-harvesting approach that leverages the Windows SSPI authentication stack to coerce the local system into generating NetNTLM challenge-response hashes without requiring direct access to LSASS. This allows attackers to obtain legitimate NTLM responses entirely within the user’s security context. These captured responses can then be cracked offline using tools such as Hashcat. Unlike replay attacks (Option B), Internal Monologue is not about reusing captured traffic. Hash injection (Option C) requires possession of NT hashes and modifies authentication tokens, which does not occur here. Pass-the-ticket (Option D) targets Kerberos, not NTLM. Therefore, the correct technique is the Internal Monologue attack.

Question #:527 - [Reconnaissance Techniques]

During a penetration test for a U.S.-based retail company, John gains access to a secondary server that responds unusually to structured queries. By sending a specially crafted request, he receives a full list of subdomains, MX records, and aliases belonging to the target organization. The response exposes sensitive internal mappings that could be leveraged for further attacks.

Which tool was MOST likely used to perform this enumeration?

- A. `smtp-user-enum.pl -u user -t host`
- B. `ldapsearch -h -x`
- C. `nbtstat -A`
- D. `dig @server axfr`

Answer: D

Explanation

The most likely tool/command is `dig @server axfr`, which attempts a DNS zone transfer (AXFR) from a specified DNS server. In CEH-aligned reconnaissance and enumeration methodology, DNS is a high-value target because it reveals how an organization's names map to systems. A successful zone transfer can expose an entire DNS zone database, often including hostnames (subdomains), mail exchanger (MX) records, canonical name (CNAME) aliases, and sometimes internal-facing entries if the zone is misconfigured. The scenario's outcome—receiving “a full list of subdomains, MX records, and aliases”—matches exactly what an AXFR zone transfer can disclose when a DNS server is improperly configured to allow transfers to unauthorized hosts.

The clue about a “secondary server” is also significant. In DNS architecture, organizations frequently deploy primary (master) and secondary (slave) DNS servers. Secondary servers legitimately request zone transfers from the master to stay synchronized. If the secondary server is misconfigured (for example, allowing AXFR to any requester or to a broader range than intended), an attacker can exploit this and retrieve the zone file. This results in detailed visibility into the organization's naming scheme and infrastructure layout—information that can be used to identify high-value targets (mail servers, VPN portals, admin hosts), locate staging points, and plan follow-on attacks such as credential harvesting, targeted exploitation, or social engineering.

Why the other options do not fit: `smtp-user-enum.pl` is used for enumerating valid users on SMTP servers, not DNS records. `ldapsearch` enumerates directory information from LDAP services, not DNS zones. `nbtstat -A` queries NetBIOS name tables for Windows hosts, which may reveal local names and shares but not DNS-wide subdomains and MX/CNAME records. Therefore, the enumeration described is most consistent with a DNS zone transfer using `dig` with AXFR.

Question #:528 - [Network and Perimeter Hacking]

During a penetration test at a logistics company in Atlanta, Georgia, you examine the configuration of network devices and discover that they rely on legacy communication mechanisms lacking encryption and

integrity checks. These mechanisms allow neighboring systems to exchange operational data without verification, exposing the infrastructure to potential manipulation. What type of vulnerability is most clearly present?

- A. Firewall vulnerabilities
- B. Lack of password protection
- C. Lack of authentication
- D. Insecure routing protocols

Answer: D

Explanation

The best answer is D. Insecure routing protocols because the scenario describes legacy neighbor-to-neighbor device communications that lack encryption and integrity validation, allowing operational routing data to be exchanged without verification. In CEH-aligned network hacking concepts, this is a classic weakness of older or improperly secured routing protocols (and related network control-plane exchanges) where routers trust updates from neighbors and do not cryptographically validate the authenticity and integrity of routing information.

When routing updates are accepted without strong verification, an attacker who can position themselves on the same segment (or spoof a trusted neighbor) may inject or manipulate routing information. This can enable attacks such as route injection, route poisoning, man-in-the-middle (MITM) traffic redirection, blackholing traffic, or causing instability/denial of service by continuously advertising bad routes. The mention of “neighboring systems” and “operational data” strongly maps to routing adjacencies where devices exchange reachability and topology information. The absence of integrity checks makes it feasible to alter routing messages in transit or forge them, and the absence of encryption can expose routing details that further assists reconnaissance and targeted manipulation.

Why the other options are less accurate:

Firewall vulnerabilities relate to filtering and policy enforcement, but the core issue here is the trust model and protection of routing/control messages, not firewall rule flaws.

Lack of password protection is too generic and typically refers to weak/no credentials on management access, not unauthenticated routing exchanges.

Lack of authentication is conceptually related, but the question asks for the type of vulnerability most clearly present given “legacy communication mechanisms” between neighbors carrying operational data—this is most specifically categorized in CEH terms as insecure routing protocols (i.e., routing updates lacking authentication/integrity and sometimes encryption).

In practice, organizations mitigate this by enabling routing protocol authentication (where supported), using cryptographic integrity protections, restricting routing adjacencies, and segmenting or filtering routing/control-plane traffic to trusted peers only.

You are an ethical hacker at Vanguard Cyber Defense, hired by Sunrise Logistics, a freight management company in Houston, Texas, to evaluate the security of their shipment tracking portal. During your engagement, you analyze how the application handles user-submitted data. You observe the behavior of the shipment search feature and monitor the HTTP GET requests being sent to the server. Your objective is to determine how user input is processed by the backend system and whether those parameters can be used to manipulate SQL queries. Based on this activity, which step of the SQL injection methodology are you performing?

- A. Advanced SQL Injection
- B. Launching SQL Injection Attacks
- C. Database Enumeration
- D. Identifying Data Entry Paths

Answer: D

Explanation

In the CEH SQL injection methodology, the initial stages focus on understanding where and how user-controlled input enters the application and reaches backend components such as database queries. The activity described is reconnaissance and mapping of input vectors: Rachel is observing the shipment search function, watching HTTP GET parameters, and determining whether those parameters are processed in a way that could influence SQL logic. This directly corresponds to the phase commonly described as identifying data entry paths, where the tester locates all possible points of injection such as URL query strings, form fields, cookies, HTTP headers, and API parameters.

At this stage, the ethical hacker is not yet executing payloads to exploit the database. Instead, they are profiling the request structure, parameter names, values, and server responses to understand how the application behaves when supplied with different inputs. CEH guidance emphasizes that effective SQL injection testing begins by enumerating input sources and determining which of them appear to be reflected in server-side operations. Monitoring HTTP GET requests is a typical technique because query string parameters often map to backend search queries, filters, or record lookups, making them frequent injection candidates if server-side validation and query construction are weak.

The other options occur later. Launching SQL injection attacks involves actively injecting test characters and payloads to confirm injection. Database enumeration happens after a vulnerability is confirmed, to extract schema information and data. Advanced SQL injection refers to more specialized techniques such as out-of-band, time-based blind, or WAF evasion. Since the task here is identifying and assessing potential injection points, the correct step is identifying data entry paths.

Question #:530 - [Social Engineering]

During a cybersecurity awareness drill at Quantum Analytics in San Francisco, California, the ethical hacking team tests the company's defenses against social media-based threats. Nadia creates a fake LinkedIn profile posing as a senior HR manager from Quantum Analytics, using a stolen company logo and publicly available

employee details. Nadia sends connection requests to several employees, including data analyst Priya Sharma, inviting them to join a private group called Quantum Analytics Innovation Hub. The group's page prompts members to share their work email and department role for exclusive project updates.

What social engineering threat to corporate networks is Nadia's exercise primarily simulating?

- A. Loss of Productivity
- B. Involuntary Data Leakage
- C. Spam and Phishing
- D. Network Vulnerability Exploitation

Answer: C

Explanation

This scenario most closely matches spam and phishing delivered through social networking platforms, a technique emphasized in CEH social engineering coverage as social media phishing or spear phishing via professional networks. Nadia impersonates a trusted internal authority figure, a senior HR manager, and uses believable branding elements such as a stolen logo and accurate employee details to establish credibility. She then initiates contact through connection requests and funnels targets into a controlled space, a private group, where she requests sensitive information. Collecting a work email address and department role may appear harmless, but CEH guidance notes that attackers often start with small, plausible requests to build trust and assemble data for deeper compromise. Work emails and roles enable targeted spear phishing, business email compromise preparation, password reset targeting, and crafting convincing pretexts aligned to the victim's function.

The core mechanics align with phishing: deception, impersonation, and a call to action designed to extract information. The "exclusive project updates" hook is a classic lure used to increase compliance. While the exercise could lead to involuntary data leakage as a downstream effect, the primary simulated threat is the phishing process itself, using social media as the delivery channel. Loss of productivity is not the intent here, and network vulnerability exploitation refers to technical system flaws rather than manipulating human trust. Therefore, the most accurate classification of Nadia's drill is spam and phishing conducted through a social media pretext.

Question #:531 - [Cloud Computing]

At a Miami-based cryptocurrency exchange, investigator Jake uncovers that attackers exploited exposed API keys to issue unauthorized cloud commands, leading to resource abuse and lateral movement inside the cloud environment. Which cloud hacking technique is most directly demonstrated in this incident?

- A. Cryptojacking
- B. Enumerating S3 buckets
- C. Wrapping attack
- D. Compromising secrets

Answer: D**Explanation**

The most direct technique demonstrated is D. Compromising secrets, because the attackers abused exposed API keys to authenticate to the cloud provider and execute unauthorized cloud commands. In CEH-aligned cloud attack paths, “secrets” commonly include API keys, access tokens, secret keys, passwords, certificates, and service account credentials. When these secrets are exposed (for example, hard-coded in source code, leaked in public repositories, stored insecurely in endpoints, or logged accidentally), an attacker can use them to gain the same privileges as the legitimate account or service identity.

Once valid API keys are obtained, attackers typically perform actions consistent with the compromised identity’s permissions: spinning up compute, modifying IAM policies, accessing storage, disabling logging, creating new credentials, and pivoting across services. The incident description mentions both resource abuse and lateral movement. Resource abuse is a frequent consequence of stolen cloud credentials because attackers can provision infrastructure on the victim’s account (often for botnets, staging, or other activities). Lateral movement inside the cloud environment can happen when the compromised keys grant access to additional services or when the attacker uses the initial foothold to discover and access other roles, instances, or secrets (for example, by querying metadata services, reading configuration stores, or enumerating IAM privileges).

Why the other options are less accurate: Cryptojacking specifically refers to illicit cryptocurrency mining using hijacked resources; while “resource abuse” could include mining, the key distinguishing factor in the question is the use of exposed API keys to issue commands, which is fundamentally credential/secret compromise. Enumerating S3 buckets is a reconnaissance activity focused on object storage discovery and misconfigurations, not the central mechanism here. A wrapping attack relates to specific cloud/identity token wrapping scenarios and is not indicated by exposed API keys.

Therefore, the incident most clearly demonstrates compromising secrets (exposed API keys).

Question #:532 - [Social Engineering]

During a security compliance audit at Nexus Tech Solutions in Boston, Massachusetts, the ethical hacking team launches a controlled social engineering exercise to assess help desk vulnerabilities. Ethical hacker Rachel Kim calls the company's help desk, posing as a stressed employee named Laura Bennett from the marketing department. Rachel claims her laptop is running slowly and offers to share her login credentials if the help desk can provide a quick fix to meet a tight project deadline. The call is designed to test whether help desk staff follow proper verification protocols or fall for the offer of credentials in exchange for assistance.

What social engineering technique is Rachel employing in this exercise?

- A. Shoulder Surfing
- B. Vishing
- C. Impersonation
- D. Quid Pro Quo

Answer: C

Explanation

This scenario best illustrates impersonation. In CEH-aligned social engineering concepts, impersonation occurs when an attacker assumes the identity of a legitimate person, such as an employee, contractor, executive, or vendor, to exploit trust and bypass established procedures. Rachel explicitly “poses as a stressed employee named Laura Bennett” and uses a believable workplace pretext such as a slow laptop and a tight deadline. This is a classic pressure-and-urgency tactic used to lower skepticism and push the target into breaking policy, such as skipping identity verification or accepting unsafe troubleshooting steps.

Although the interaction happens over the phone, the defining technique being tested is not merely the communication channel but the identity deception. Vishing is phone-based phishing, and while the call could be described as vishing in a broad sense, the prompt emphasizes the assumed identity and the help desk’s verification controls, which is the hallmark of impersonation. Quid pro quo typically involves offering a benefit or service in exchange for information; here, the core mechanic is Rachel’s false identity and her attempt to get the help desk to accept credential sharing as part of support. Shoulder surfing is unrelated because it involves physically observing someone’s screen or keystrokes.

CEH best practices to mitigate impersonation include strict caller verification, callback procedures to known numbers, ticket validation, prohibiting password sharing, requiring multi-factor authentication resets via approved workflows, and training help desk staff to recognize urgency-based manipulation and escalate suspicious requests.

Question #:533 - [Mobile Platform and IoT Hacking]

You are Emma Rodriguez, an ethical hacker at SecurePath Solutions, hired to test the mobile application security of Sterling & Associates, a law firm in New York City. During a covert assessment, your objective is to simulate an attacker attempting to exploit vulnerabilities in the firm’s client case management app. You discover that the app stores user credentials in plain text on the device, enabling you to extract sensitive client login information using a rooted device. Based on this finding, which OWASP Top 10 Mobile Risk are you identifying in the app?

- A. Insecure Communication
- B. Improper Credential Usage
- C. Inadequate Privacy Controls
- D. Insecure Data Storage

Answer: D

Explanation

The finding described maps directly to Insecure Data Storage. In CEH-aligned mobile security guidance and OWASP Mobile risk discussions, insecure data storage occurs when a mobile application saves sensitive information locally in a way that can be easily recovered by an attacker, especially on a rooted or jailbroken device where sandbox protections can be bypassed. Storing usernames and passwords in plain text is a high-severity example because it allows immediate account takeover and enables access to protected client records, case notes, and other confidential material.

Mobile devices routinely store app data in local file systems, shared preferences, databases, logs, or cached content. If sensitive data is stored without proper protections, an attacker with physical access, malware, backup extraction capability, or root access can read it directly. CEH materials emphasize that rooting dramatically increases attacker capability by permitting access to app directories and system areas that would otherwise be restricted. That is exactly what the scenario shows: credentials are recovered from the device once root access is available.

The best practice mitigation is to never store credentials in plain text. Use secure, OS-provided storage such as Android Keystore or iOS Keychain, apply strong encryption with keys protected by hardware-backed mechanisms when available, minimize what is stored locally, and ensure secrets are not written to logs or debug artifacts. Insecure Communication would involve weak transport protections, and Improper Credential Usage can include hardcoded credentials or poor authentication handling, but the specific issue here is plainly unsafe local storage of credentials, so Insecure Data Storage is the correct choice.

Question #:534 - [Network and Perimeter Hacking]

During a red team operation for XYZ Financial Services, security analyst Lily Jensen is assigned to scan a critical subnet that is protected by an IDS. Her initial scan attempt is immediately flagged and blocked. To evade detection while continuing reconnaissance, she adjusts the scanning configuration to include multiple spoofed IP addresses alongside her own. This makes it difficult for network defenses to isolate her real scanning activity, while still allowing her to receive accurate results.

Which scanning technique is Lily using?

- A. SYN FIN Scanning
- B. Source Routing
- C. IP Spoofing
- D. Decoy Scanning

Answer: D

Explanation

The technique described is decoy scanning. In CEH network scanning methodology, decoy scanning is used to make IDS and logging systems attribute scan traffic to multiple apparent sources instead of the attacker's true IP address. The attacker configures the scanner to generate additional probe packets that appear to originate from several spoofed decoy IP addresses, mixed with the real attacker's probes. This creates ambiguity for defenders because IDS alerts and firewall logs show many potential "scanners," complicating attribution and response actions such as blocking a single source.

A key detail in the prompt is that Lily "includes multiple spoofed IP addresses alongside her own" and still "receives accurate results." That matches how decoy scanning works in tools like Nmap: the attacker's real IP must remain in the mix so that replies from the target return to the attacker, enabling accurate interpretation of port states. The decoys mainly exist to confuse monitoring and incident response teams by polluting the log trail.

Option C, IP spoofing, is too general and, by itself, typically prevents the attacker from receiving responses because return traffic goes to the spoofed address. Decoy scanning is a specific, structured use of spoofing combined with the real source to preserve results. Option A refers to stealth flag scans, which reduce handshake visibility but do not involve multiple spoofed sources. Option B, source routing, attempts to control packet paths and is not the described behavior. Therefore, the correct answer is Decoy Scanning.

Question #:535 - [Information Security and Ethical Hacking Overview]

A company hires a hacker to test its network security by simulating real-world attacks. The hacker has permission and operates within legal boundaries. What is this type of hacker called?

- A. Script Kiddie
- B. Black Hat Hacker
- C. Grey Hat Hacker
- D. White Hat Hacker

Answer: D

Explanation

CEH v13 defines a white hat hacker as a security professional who performs authorized assessments to identify vulnerabilities and strengthen an organization's defenses. The defining characteristic of white hat activity is the presence of formal permission—typically through a signed rules-of-engagement, scope of work, and explicit authorization from the organization. CEH emphasizes that white hats adhere to legal boundaries, follow ethical guidelines, and document findings to support remediation. They may use the same tools and methodologies as malicious hackers, but the intent and authorization distinguish them. In contrast, black hats operate without permission and with malicious intent. Grey hats act without authorization but may not have malicious motivations, making them inappropriate in a formal penetration testing engagement. Script kiddies lack professional skill and rely on pre-made tools without understanding the underlying techniques. Therefore, the hacker described is a white hat—an ethical professional performing sanctioned testing.

Question #:536 - [Reconnaissance Techniques]

A penetration tester is conducting an external assessment of a corporate web server. They start by accessing <https://www.targetcorp.com/robots.txt> and observe multiple Disallow entries that reference directories such as /admin-panel/, /backup/, and /confidentialdocs/. When the tester directly visits these paths via a browser, they find that access is not restricted by authentication and gain access to sensitive files, including server configuration and unprotected credentials. Which stage of the web server attack methodology is demonstrated in this scenario?

- A. Injecting malicious SQL queries to access sensitive database records
- B. Performing a cross-site request forgery (CSRF) attack to manipulate user actions
- C. Gathering information through exposed indexing instructions

D. Leveraging the directory traversal flaw to access critical server files

Answer: C

Explanation

The CEH web server attack methodology describes reconnaissance as a key phase, where testers gather publicly available information before attempting exploitation. Robots.txt is commonly used by administrators to instruct web crawlers about which directories should not be indexed. CEH emphasizes that attackers regularly review robots.txt because it often exposes sensitive directories unintentionally, providing valuable intelligence about internal structure, configuration paths, administrative pages, and potential weak points. In this scenario, the tester observes “Disallow” entries and then discovers the directories are not protected by authentication, allowing direct access to sensitive files. This falls under information gathering through exposed indexing instructions rather than directory traversal, which involves path-manipulation exploits. The tester is not altering file paths or inserting traversal sequences; instead, they are reviewing publicly available indexing instructions and discovering misconfigured access controls. This perfectly aligns with the reconnaissance phase of the CEH methodology, where attackers learn about server architecture using passive or minimally intrusive techniques.

Question #:537 - [Network and Perimeter Hacking]

Which indicator most strongly confirms a MAC flooding attack?

- A. Multiple IPs to one MAC
- B. Multiple MACs to one IP
- C. Numerous MAC addresses on a single switch port
- D. Increased ARP requests

Answer: C

Explanation

MAC flooding is a Layer 2 attack described in CEH v13 Network and Perimeter Hacking, where attackers overwhelm a switch's CAM table with fake MAC addresses. Once the table is full, the switch behaves like a hub, forwarding traffic to all ports.

The most definitive indicator of MAC flooding is numerous MAC addresses learned on a single switch port, which is abnormal behavior in a properly segmented network. CEH v13 identifies this condition as a key forensic indicator of CAM table exhaustion.

ARP anomalies may occur, but they are more commonly associated with ARP spoofing attacks. IP-to-MAC inconsistencies indicate MITM attacks, not MAC flooding.

Thus, option C is the clearest confirmation.

Question #:538 - [Cryptography]

A future-focused security audit discusses risks where attackers collect encrypted data now, anticipating that they can decrypt it later with quantum computers. What is this threat known as?

- A. Saving data today for future quantum decryption
- B. Replaying intercepted quantum messages
- C. Breaking RSA using quantum algorithms
- D. Flipping qubit values to corrupt the output

Answer: A

Explanation

In CEH v13 Cryptography, this threat is formally referred to as “Harvest Now, Decrypt Later” (HNDL). It describes a long-term cryptographic risk where adversaries intercept and store encrypted communications today, even though they cannot decrypt them with current computational capabilities. The expectation is that future quantum computers will be powerful enough to break widely used public-key cryptographic algorithms.

CEH v13 emphasizes that quantum algorithms such as Shor’s Algorithm can theoretically break RSA, DSA, and ECC by efficiently solving integer factorization and discrete logarithm problems. However, the defining feature of this threat is not the act of breaking encryption itself, but rather the strategic collection and storage of encrypted data in advance.

Option C is incomplete because it focuses only on the cryptographic mechanism rather than the threat model. Options B and D are unrelated to the scenario described and refer to quantum communication integrity issues, not long-term cryptographic exposure.

CEH v13 highlights that sensitive data with long confidentiality lifetimes—such as government records, financial data, healthcare information, and intellectual property—is especially vulnerable to this threat. As a result, organizations are encouraged to adopt quantum-resistant (post-quantum) cryptographic algorithms proactively.

Thus, Option A accurately describes the threat model and aligns with CEH v13’s treatment of future cryptographic risks.

Question #:539 - [Information Security and Ethical Hacking Overview]

In ethical hacking, what is black box testing?

- A. Testing using only publicly available information
- B. Testing without any prior knowledge of the system
- C. Testing with full system knowledge
- D. Testing knowing only inputs and outputs

Answer: B**Explanation**

According to CEH v13, black box testing refers to a testing approach where the ethical hacker has no prior knowledge of the internal structure, source code, or configuration of the system.

The attacker simulates a real-world external attacker, relying solely on discovery and exploitation techniques.

White box testing = full knowledge

Gray box testing = partial knowledge

Question #:540 - [Network and Perimeter Hacking]

As an IT security analyst, you perform network scanning using ICMP Echo Requests. During the scan, several IP addresses do not return Echo Replies, yet other network services remain operational. How should this situation be interpreted?

- A. The non-responsive IP addresses indicate severe network congestion.
- B. A firewall or security control is likely blocking ICMP Echo Requests.
- C. The lack of Echo Replies indicates an active security breach.
- D. The IP addresses are unused and available for reassignment.

Answer: B**Explanation**

The CEH Network Scanning module explains that ICMP Echo Requests are often filtered or blocked by firewalls, routers, or host-based security controls as a defensive measure to reduce reconnaissance exposure.

When systems fail to respond to ICMP Echo Requests but continue to function normally for other services, CEH indicates that this behavior typically means ICMP traffic is being blocked, not that the host is offline or compromised.

Option B is correct.

Option A would affect all services.

Option C lacks supporting indicators.

Option D is speculative and unreliable.

CEH emphasizes that ICMP filtering is common in hardened networks.

Question #:541 - [Information Security and Ethical Hacking Overview]

In a bustling tech firm in Seattle, Michael, an ethical hacker, is conducting a security assessment to identify potential risks. During his evaluation, he notices that sensitive employee details and system configurations have been exposed through public forums, likely due to careless online behavior. His manager suspects this could lead to unauthorized access or data theft. As part of his testing, what type of threat should Michael focus on to simulate the adversary's method of gathering this exposed information?

- A. Corporate Espionage
- B. Social Engineering
- C. System and Network Attacks
- D. Information Leakage

Answer: D**Explanation**

Information Leakage is the most accurate threat category because the scenario centers on sensitive data becoming publicly accessible through unintended disclosure. In CEH coverage, information leakage refers to the exposure of confidential or internal details to unauthorized parties through oversharing, misconfiguration, poor operational security, or improper handling of information. Here, the data is already visible on public forums, meaning an attacker does not need to exploit a vulnerability in a system directly at first; they can simply collect and correlate exposed details such as employee names, email formats, internal hostnames, software versions, configuration snippets, IP ranges, or screenshots.

This aligns strongly with reconnaissance and OSINT techniques emphasized in CEH: adversaries routinely harvest publicly available information to build an attack plan, identify privileged targets, guess usernames, craft phishing lures, locate externally exposed services, or tailor further exploitation using revealed versions and settings. While social engineering can be a follow-on step, the core issue described is not persuading users to reveal information interactively. Instead, the organization's risk stems from information already leaked due to careless online behavior.

Corporate espionage is a motive rather than a specific technique category, and system and network attacks describe active exploitation and intrusion attempts, which come after the intelligence-gathering stage. Therefore, to simulate the adversary's method of gathering what has been exposed, Michael should focus on information leakage: identifying what is publicly disclosed, how it can be aggregated, and what attack paths it enables, then recommending containment and policy and awareness controls.

Question #:542 - [Cloud Computing]

As a Certified Ethical Hacker, you are assessing a corporation's serverless cloud architecture. The organization experienced an attack where a user manipulated a function-as-a-service (FaaS) component to execute malicious commands. The root cause was traced to an insecure third-party API used within a serverless function. What is the most effective countermeasure to strengthen the security posture?

- A. Regularly updating serverless functions to reduce vulnerabilities.

- B. Using a Cloud Access Security Broker (CASB) to enforce third-party policies.
- C. Deploying a Cloud-Native Security Platform (CNSP) for full cloud protection.
- D. Implementing function-level permissions and enforcing the principle of least privilege.

Answer: D

Explanation

The Certified Ethical Hacker (CEH) Cloud Computing module emphasizes that serverless environments rely heavily on granular permission models. Attacks involving compromised APIs often succeed because functions are granted excessive privileges.

Option D is correct because enforcing function-level permissions and the principle of least privilege directly limits what a compromised function can execute. CEH documentation states this is the primary defense against serverless abuse.

Option A is beneficial but reactive.

Option B focuses on SaaS governance rather than FaaS execution control.

Option C provides visibility but does not directly prevent privilege misuse.

CEH highlights identity and access management (IAM) as critical in serverless security.